KẾ HOẠCH TÍCH HỢP TÍNH NĂNG

Ứng dụng mạng xã hội trên di động (Mobile Social)

Ngày lập: 31/10/2026 · Bản kế hoạch: chưa có dòng code nào được viết cho các tính năng trong tài liệu này

MỤC LỤC

I. Mục tiêu và cách đọc tài liệu

II. Thế nào là "hoàn hảo"

III. Hiện trạng và khoảng trống so với Facebook

IV. Danh sách tính năng và lộ trình

V. Đặc tả chi tiết từng tính năng

Nhóm A. Bảo mật tài khoản

A1. Xác thực hai lớp (2FA)

A2. Phiên đăng nhập và thiết bị

A3. Cảnh báo đăng nhập lạ ("Không phải tôi")

A4. Chống dò mật khẩu

A5. Xác thực số điện thoại (OTP qua SMS)

A6. Đăng nhập bằng Apple

Nhóm B. An toàn – điểm khác biệt của sản phẩm

B1. Tin nhắn chờ và quyền ai được nhắn tin (nâng cấp)

B2. Nhắn ẩn danh có giới hạn (nâng cấp)

B3. Cảnh báo lừa đảo (tin nhắn, đường link, hồ sơ giả mạo)

B4. Giới hạn tạm thời khi bị quấy rối hàng loạt

B5. Làm mờ nội dung nhạy cảm toàn app

B6. Bảo vệ 18+ và xác minh tuổi

B7. Bộ lọc bình luận và từ ngữ ẩn; giới hạn ai được bình luận

B8. Hạn chế (Restrict) và tắt tiếng (Mute)

Nhóm C. Kiểm duyệt và quản trị

C1. Hàng đợi kiểm duyệt (tự động quét + người duyệt)

C2. Cảnh cáo, xử phạt theo bậc và kháng nghị

C3. Phân quyền quản trị (admin / kiểm duyệt viên) và nhật ký thao tác

Nhóm D. Mạng xã hội

D1. Nhắn tin nhóm

D2. Tin nhắn nâng cao: thu hồi, sửa, trả lời trích dẫn, cảm xúc, đang soạn, gửi video, ghi âm

D3. Nhóm cộng đồng (Groups)

D4. Gọi thoại và gọi video 1-1

D5. Xếp hạng bảng tin và Reels theo tương tác

D6. Bài viết nâng cao: trích dẫn bài, bình chọn, gắn thẻ người, lịch sử chỉnh sửa, ghim bài

D7. Bạn thân và tin nổi bật (story)

D8. Thông báo đẩy hoàn chỉnh và cài đặt thông báo theo loại, giờ yên lặng

D9. Tìm kiếm nâng cao: lịch sử tìm kiếm, gợi ý khi gõ @, tìm trong tin nhắn

Nhóm E. Quyền riêng tư và tuân thủ

E1. Tải xuống dữ liệu của bạn

E2. Xóa tài khoản có thời gian chờ 30 ngày và trang web yêu cầu xóa

E3. Kiểm tra quyền riêng tư

E4. Xác minh tài khoản (dấu tick)

VI. Rủi ro, pháp lý và chi phí

VII. Câu hỏi cần chủ dự án quyết

I. MỤC TIÊU VÀ CÁCH ĐỌC TÀI LIỆU

Mục tiêu. Đưa sản phẩm lên mức khoảng 60% những gì Facebook và các mạng xã hội nhỏ đang có, đủ để người dùng thật dùng hằng ngày. Sản phẩm không cạnh tranh bằng số lượng tính năng mà bằng **sự an toàn**: tin nhắn chờ, nhắn ẩn danh có giới hạn, tự làm mờ ảnh nhạy cảm, cảnh báo lừa đảo và giới hạn 18+. Vì vậy nhóm an toàn được đặc tả kỹ nhất, và bảo mật tài khoản (trong đó có xác thực hai lớp) được đưa lên sớm.

Tài liệu gồm: định nghĩa thế nào là "hoàn hảo" (mục II), so sánh hiện trạng với Facebook (mục III), danh sách 30 tính năng chia bốn giai đoạn (mục IV), đặc tả chi tiết từng tính năng (mục V), rồi rủi ro, pháp lý, chi phí và các câu hỏi cần chủ dự án quyết (mục VI, VII).

Mỗi tính năng ở mục V có chín phần cố định: a) Mục đích · b) Hiện trạng trong code · c) Cách hoạt động, từng bước · d) Flowchart · e) Quy tắc, giới hạn và trường hợp đặc biệt · f) Dữ liệu và API đề xuất · g) Android, iOS và web · h) Tiêu chí hoàn thành · i) Ước lượng và phụ thuộc.

Cách đọc flowchart. Mỗi cột (làn) là một bên tham gia: người dùng, ứng dụng trên điện thoại, máy chủ, người nhận, quản trị viên hoặc dịch vụ bên ngoài. Thời gian đi từ trên xuống. Mũi tên đi từ cột này sang cột khác là lúc việc được chuyển cho bên kia.

Hình	Ý nghĩa
Hình bầu dục viền đậm	Điểm bắt đầu của luồng (nền trắng) hoặc điểm kết thúc (nền xám).
Hình chữ nhật	Một bước xử lý: ai đó làm một việc.
Hình thoi	Một câu hỏi; mỗi nhánh đi ra có nhãn trả lời (Có, Không hoặc điều kiện).
Hình bình hành	Màn hình ứng dụng hiện ra, hoặc người dùng nhập thông tin.
Hình trụ	Đọc hoặc ghi cơ sở dữ liệu (đường nét đứt: chỉ tra cứu).
Hình chữ nhật hai vạch dọc	Gọi sang một luồng khác đã vẽ riêng.

Về các con số. Giới hạn (số lần, số phút, số ngày) và ước lượng công sức trong tài liệu là **đề xuất**, dùng để bàn và chốt. Ước lượng tính theo ngày công của một lập trình viên đã quen code dự án. Mọi endpoint và bảng dữ liệu mới cũng là đề xuất: theo RULE.md, phải ghi vào *docs/api-contract.md* và được thống nhất trước khi code.

II. THẾ NÀO LÀ "HOÀN HẢO"

1. Phạm vi "60% Facebook"

Facebook có hàng trăm tính năng, nhưng phần người dùng chạm tới mỗi ngày gồm: tài khoản an toàn, đăng và xem nội dung, tương tác, kết nối với người khác, nhắn tin, cộng đồng, thông báo, tìm kiếm, và một hệ thống an toàn và kiểm duyệt đứng sau. "60%" trong kế hoạch này nghĩa là **có đủ các vòng sử dụng đó ở mức người dùng không thấy thiếu**, chứ không phải đếm đủ 60% số tính năng.

Không nằm trong kế hoạch (chủ ý bỏ ra vì tốn công mà không phục vụ mục tiêu): Marketplace, Trang (Pages) cho doanh nghiệp, quảng cáo, phát trực tiếp (livestream), hẹn hò, trò chơi, sự kiện, gây quỹ, video dài.

2. Tiêu chí hoàn thành chung

Một tính năng chỉ được tính là "xong" khi đạt **tất cả** các điều sau. Đây là định nghĩa "hoàn hảo" dùng xuyên suốt tài liệu; phần h) của mỗi tính năng chỉ ghi thêm các tiêu chí riêng.

1. **Đủ luồng:** có luồng chính, luồng lỗi, trạng thái đang tải, danh sách trống và mất mạng giữa chừng; người dùng luôn biết chuyện gì đang xảy ra và làm gì tiếp.
2. **Chạy trên Android và iPhone** (và trên web khi bản web được bật), đã chạy thử trên máy thật hoặc máy ảo của từng nền tảng, và ghi rõ đã chạy ở đâu.
3. **Tôn trọng an toàn:** người bị chặn, bị hạn chế, tài khoản bị khóa và tài khoản riêng tư được xử lý đúng ở cả API, socket và thông báo đẩy; có giới hạn tần suất để chống lạm dụng.
4. **Quản trị được:** nếu tính năng tạo ra nội dung của người dùng thì nội dung đó báo cáo được, và quản trị viên xem và xử lý được.
5. **Có kiểm thử tự động:** backend có phép thử trên API thật (theo kiểu các script *-*smoke.cjs* hiện có), mobile có test Jest cho phần logic.
6. **Tiếng Việt thống nhất** và đọc được bằng trình đọc màn hình (nút có nhãn, chữ đủ tương phản).
7. **Đo được:** có số liệu tối thiểu (bao nhiêu người dùng, bao nhiêu lỗi) để biết tính năng có được dùng và có chạy đúng không.
8. **Có tài liệu:** cập nhật *docs/api-contract.md*, *docs/change.md*, và *docs/decisions.md* nếu có quyết định ảnh hưởng tới người khác.

III. HIỆN TRẠNG VÀ KHOẢNG TRỐNG SO VỚI FACEBOOK

Mảng	**Facebook và các app nhỏ có**	**Sản phẩm đang có**	**Kế hoạch bổ sung**
Tài khoản và bảo mật	Đăng nhập email hoặc số điện thoại, 2FA, cảnh báo đăng nhập lạ, quản lý thiết bị, chống dò mật khẩu	Email và mã xác thực, quên và đổi mật khẩu, Google (có code, chưa cấu hình), giới hạn 18+, phiên 30 ngày	A1–A6
Hồ sơ	Ảnh đại diện, ảnh bìa, tiểu sử, tài khoản riêng tư, dấu tick xác minh	Có đủ, trừ dấu tick	E4
Bài viết	Chữ, ảnh, video, quyền riêng tư, gắn thẻ, bình chọn, chia sẻ kèm lời bình, lịch sử sửa, ghim bài	Chữ, ảnh, video, quyền riêng tư, đăng lại, lưu, ẩn, hashtag, nhắc tên	D6
Bảng tin và Reels	Sắp xếp theo mức quan tâm, "vì sao tôi thấy bài này"	Bài của mình và người đang theo dõi; Reels đã ghi nhận tương tác nhưng chưa dùng để sắp xếp	D5
Tương tác	Cảm xúc, bình luận nhiều tầng, thích bình luận, lọc bình luận	Sáu cảm xúc, bình luận, trả lời, thích bình luận	B7
Story	Story 24 giờ, bạn thân, tin nổi bật, lưu trữ	Story ảnh và video, cảm xúc, trả lời (có thể ẩn danh)	D7
Kết nối	Theo dõi hoặc kết bạn, gợi ý, hạn chế, tắt tiếng	Theo dõi, yêu cầu theo dõi, gợi ý, chặn	B8
Nhắn tin	1-1 và nhóm, thu hồi, sửa, cảm xúc, ghi âm, video, gọi thoại và video	1-1 bằng chữ và ảnh, "Đã xem", tin nhắn chờ, nhắn ẩn danh có giới hạn	D1, D2, D4
Cộng đồng	Nhóm công khai, riêng tư, duyệt thành viên và bài	Chưa có	D3
Thông báo	Trong app, thông báo đẩy, cài đặt theo loại	Trong app và thời gian thực; thông báo đẩy có code nhưng chưa từng chạy thử	D8

Tìm kiếm	Người, bài, hashtag, lịch sử, tìm trong tin nhắn	Người, bài, hashtag thịnh hành	D9
An toàn	Báo cáo, chặn, hạn chế, lọc từ ngữ, cảnh báo lừa đảo, làm mờ, giới hạn tạm thời	Báo cáo, chặn, tin nhắn chờ, nhắn ẩn danh có giới hạn, làm mờ ảnh trong tin nhắn, cảnh báo lừa đảo cơ bản, 18+	B1–B8
Kiểm duyệt	Hàng đợi kiểm duyệt, xử phạt theo bậc, kháng nghị, phân quyền nhân viên	Trang quản trị xử lý báo cáo bằng ba cách (bỏ qua, gỡ, khóa), khóa và mở khóa tài khoản	C1–C3
Quyền riêng tư và tuân thủ	Tải dữ liệu, xóa tài khoản có thời gian chờ, kiểm tra quyền riêng tư	Xóa tài khoản ngay lập tức trong app	E1–E3

IV. DANH SÁCH TÍNH NĂNG VÀ LỘ TRÌNH

1. Danh sách tính năng

Mã	Tính năng	GĐ	Ngày công (BE / MB / KT)	Phụ thuộc
A1	Xác thực hai lớp (2FA): TOTP, mã dự phòng, OTP email dự phòng	2	10 (5 / 3 / 2)	A2, A4, A3, C3
A2	Phiên đăng nhập và thiết bị: refresh token xoay vòng, danh sách thiết bị, đăng xuất từ xa	1	9 (4 / 3 / 2)	–
A3	Cảnh báo đăng nhập lạ (Không phải tôi)	2	6 (3 / 2 / 1)	A2
A4	Chống dò mật khẩu: chậm dần, khóa tạm, thông báo	1	4 (2 / 1 / 1)	–
A5	Xác thực số điện thoại (OTP SMS)	1	6 (3 / 2 / 1)	–
A6	Đăng nhập bằng Apple	1	5 (2 / 2 / 1)	–
B1	Tin nhắn chờ và quyền ai được nhắn tin (nâng cấp)	2	9 (4 / 3 / 2)	B3, D8
B2	Nhắn ẩn danh có giới hạn (nâng cấp)	2	10 (5 / 3 / 2)	B1, B3, C1, C2, C3
B3	Cảnh báo lừa đảo (tin nhắn, đường link, hồ sơ giả mạo)	2	13 (7 / 4 / 2)	B1, C1, C2
B4	Giới hạn tạm thời khi bị quấy rối hàng loạt	2	9 (4 / 3 / 2)	B1, B2, B7, B8, D8
B5	Làm mờ nội dung nhạy cảm toàn app	2	14 (7 / 5 / 2)	C1, C2
B6	Bảo vệ 18+ và xác minh tuổi (báo cáo dưới 18, khóa, kháng nghị)	2	11 (5 / 4 / 2)	C1, C2, C3, E2
B7	Bộ lọc bình luận, từ ngữ ẩn và giới hạn ai được bình luận	2	10 (4 / 4 / 2)	B8
B8	Hạn chế (Restrict) và tắt tiếng (Mute)	1	9 (4 / 3 / 2)	–
C1	Hàng đợi kiểm duyệt (tự động quét + người duyệt)	1	15 (10 / 3 / 2)	B5, B7, B3, D8, C3
C2	Cảnh cáo, xử phạt theo bậc và kháng nghị	2	12 (6 / 4 / 2)	C1, C3, A2, D8

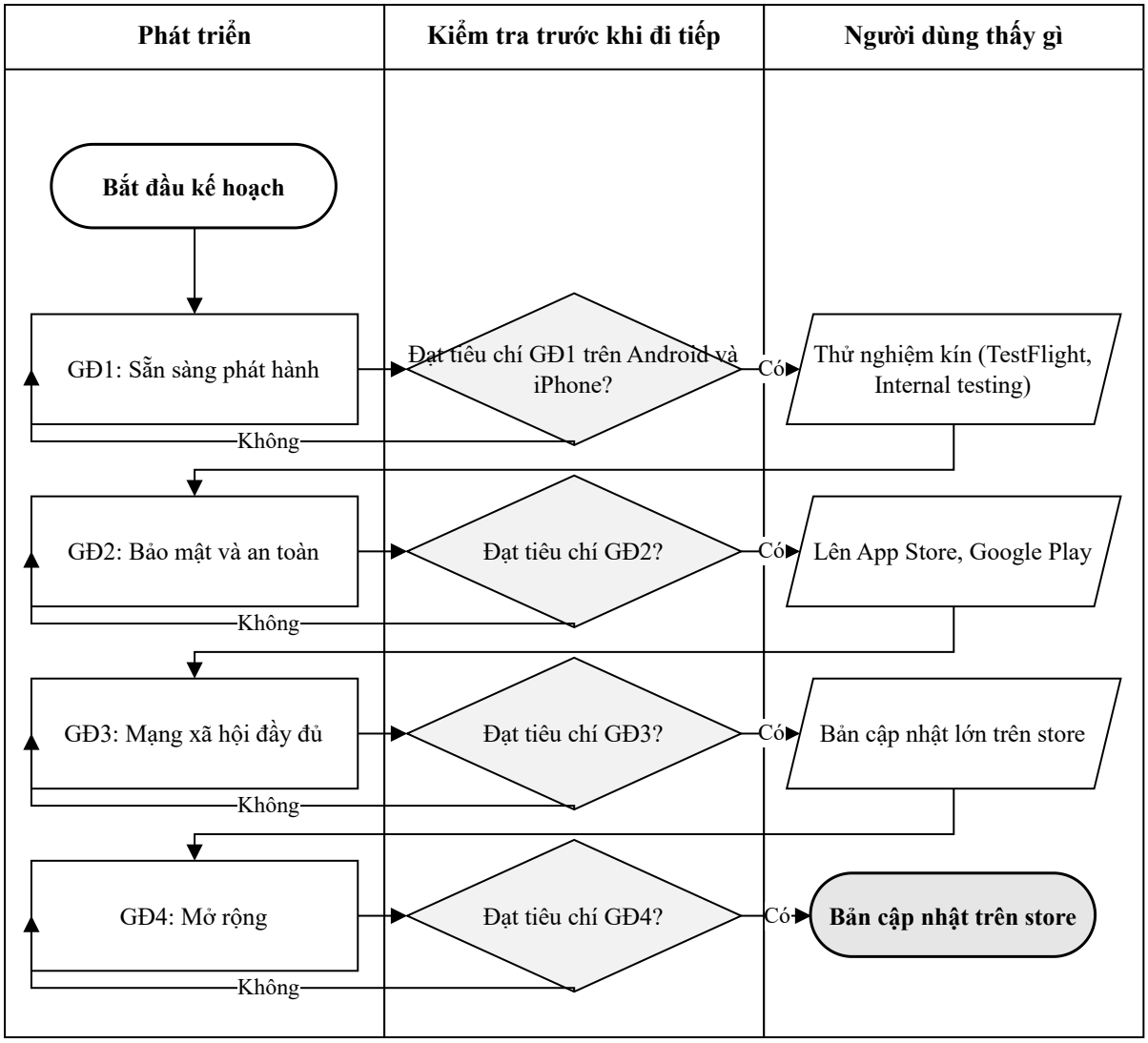
C3	Phân quyền quản trị (admin / kiểm duyệt viên) và nhật ký thao tác	3	8.5 (7 / 0 / 1.5)	A1, A2, A4
D1	Nhắn tin nhóm	3	20 (9 / 8 / 3)	B1, D8, E2
D2	Tin nhắn nâng cao: thu hồi, sửa, trả lời trích dẫn, cảm xúc, đang soạn, gửi video, ghi âm	3	23 (7.5 / 12.5 / 3)	D1, D8, C1, B1, B2
D3	Nhóm cộng đồng (Groups)	4	34 (15 / 14 / 5)	C1, C2, C3, B6, B7, D8
D4	Gọi thoại và gọi video 1-1	4	30 (8 / 16 / 6)	B1, B4, D8, D1, A2
D5	Xếp hạng bảng tin và Reels theo tương tác	3	11 (6 / 3 / 2)	B5, C1, B8
D6	Bài viết nâng cao: trích dẫn, bình chọn, gắn thẻ, lịch sử chỉnh sửa, ghim bài	3	19 (8 / 8 / 3)	D8, D9, B8, C1
D7	Bạn thân và tin nổi bật (story)	3	10 (3 / 5 / 2)	C1, B5, E2, E1
D8	Thông báo đẩy hoàn chỉnh và cài đặt thông báo theo loại, giờ yên lặng	1	12 (4 / 4 / 4)	A2, A3, B8, D6
D9	Tìm kiếm nâng cao: lịch sử tìm kiếm, gợi ý khi gõ @, tìm trong tin nhắn	3	11 (4 / 5 / 2)	D6, D2, D1
E1	Tải xuống dữ liệu của bạn	3	8.5 (5 / 2 / 1.5)	–
E2	Xóa tài khoản có thời gian chờ 30 ngày + trang web yêu cầu xóa	1	11.5 (7 / 2 / 2.5)	A2, A6, C3, E1
E3	Kiểm tra quyền riêng tư	3	5.5 (1.5 / 3 / 1)	A1, A2, B1, B7, B8, D6, E1, D8
E4	Xác minh tài khoản (dấu tick)	4	8 (4 / 2.5 / 1.5)	A1, C2, C3

BE: backend · MB: mobile · KT: kiểm thử. Ngày công của một lập trình viên đã quen code; đề xuất để bàn, chưa phải cam kết.

2. Lộ trình bốn giai đoạn

Các giai đoạn được xếp theo nguyên tắc: **thứ chặn việc phát hành làm trước, điểm khác biệt làm ngay sau, phần mở rộng làm sau cùng**. Mỗi giai đoạn kết thúc bằng một điểm kiểm tra: chỉ đi tiếp khi mọi tính năng của giai đoạn đạt tiêu chí hoàn thành trên cả Android và iPhone.

- **GĐ1 – Sẵn sàng phát hành:** những thứ thiếu thì không lên được store hoặc sẽ hỏng khi có người dùng thật: phiên đăng nhập an toàn, chống dò mật khẩu, Đăng nhập bằng Apple, thông báo đẩy, xóa tài khoản đúng quy định, hàng đợi kiểm duyệt, hạn chế và tắt tiếng. Kết thúc bằng thử nghiệm kín trên TestFlight và Google Play Internal testing.
- **GĐ2 – Bảo mật và an toàn:** làm sâu điểm khác biệt (B1–B7), thêm 2FA, cảnh báo đăng nhập lạ, xử phạt theo bậc và kháng nghị. Kết thúc bằng việc mở đăng ký công khai trên store.
- **GĐ3 – Mạng xã hội đầy đủ:** nhắn tin nhóm và tin nhắn nâng cao, xếp hạng bảng tin, bài viết nâng cao, bạn thân và tin nổi bật, tìm kiếm nâng cao, tải dữ liệu, kiểm tra quyền riêng tư, phân quyền quản trị.
- **GĐ4 – Mở rộng:** nhóm cộng đồng, gọi thoại và video, dấu tick xác minh, và xác thực số điện thoại nếu luật không bắt buộc sớm hơn.



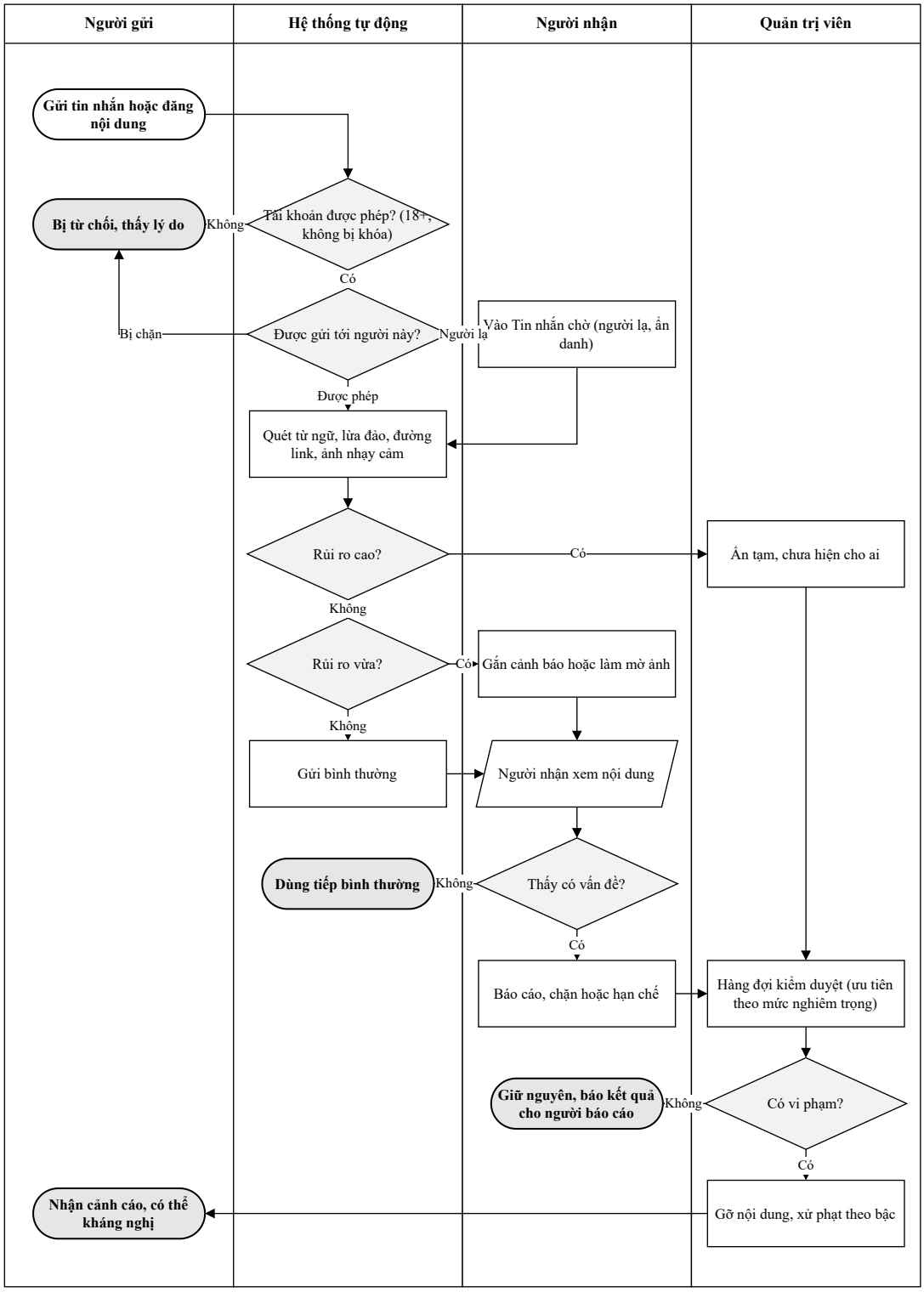
Hình 1. Lộ trình bốn giai đoạn và điểm kiểm tra giữa các giai đoạn

Giai đoạn	**Tính năng**	**Ngày công**
GĐ1 – Sẵn sàng phát hành	A2, A4, A5, A6, B8, C1, D8, E2	71.5
GĐ2 – Bảo mật và an toàn	A1, A3, B1, B2, B3, B4, B5, B6, B7, C2	104
GĐ3 – Mạng xã hội đầy đủ	C3, D1, D2, D5, D6, D7, D9, E1, E3	116.5
GĐ4 – Mở rộng	D3, D4, E4	72
Tổng		**364**

Với một lập trình viên làm toàn thời gian (khoảng 21 ngày công một tháng), toàn bộ kế hoạch mất khoảng **17 tháng**; hai người làm song song backend và mobile rút còn khoảng 9–12 tháng, vì có những phần phải làm tuần tự.

3. Hệ thống an toàn nhiều lớp

Các tính năng an toàn không đứng riêng lẻ mà xếp thành nhiều lớp. Một tin nhắn hay một bài đăng phải đi qua từng lớp; lớp sau bắt những gì lớp trước bỏ sót. Hình dưới là bức tranh chung, các tính năng ở mục V là chi tiết của từng lớp.



Hình 2. Hệ thống an toàn nhiều lớp: đường đi của một tin nhắn hoặc nội dung

Lớp	Việc của lớp	Tính năng

1. Tài khoản	Chỉ người đủ 18 tuổi, đăng nhập an toàn, không bị khóa mới được tương tác.	A1–A6, B6, C2
2. Quyền liên lạc	Ai được nhắn, bình luận, gắn thẻ mình; người lạ vào tin nhắn chờ; chặn, hạn chế, tắt tiếng; giới hạn tạm thời khi bị quấy rối.	B1, B2, B4, B7, B8
3. Quét tự động	Quét chữ, đường link và ảnh; rủi ro vừa thì cảnh báo hoặc làm mờ, rủi ro cao thì ẩn tạm chờ người duyệt.	B3, B5, B7, C1
4. Người dùng tự bảo vệ	Báo cáo, chặn, hạn chế ngay tại chỗ; xem ảnh mờ hay không là do người nhận chọn.	B1, B5, B8
5. Con người kiểm duyệt	Hàng đợi ưu tiên theo mức nghiêm trọng, xử phạt theo bậc, kháng nghị, nhật ký mọi thao tác nhạy cảm.	C1, C2, C3

V. ĐẶC TẢ CHI TIẾT TỪNG TÍNH NĂNG

NHÓM A. BẢO MẬT TÀI KHOẢN

A1. Xác thực hai lớp (2FA)

Nhóm: Bảo mật tài khoản · Giai đoạn: GĐ2 · Ước lượng: 10 ngày công

a) Mục đích

Hiện nay ai biết mật khẩu (hoặc chiếm được tài khoản Google) là vào được tài khoản. Xác thực hai lớp (2FA) bắt thêm một bước: sau mật khẩu phải nhập mã 6 số lấy từ điện thoại của chủ tài khoản. Kẻ gian có mật khẩu bị lộ vẫn không vào được. Người được lợi: mọi người dùng muốn bảo vệ tài khoản, nhất là tài khoản có nhiều người theo dõi; chủ dự án cũng có thêm điểm khác biệt về an toàn.

Cách chính là **TOTP** (mã 6 số tự đổi mỗi 30 giây trong ứng dụng xác thực như Google Authenticator, Microsoft Authenticator, 1Password). Kèm theo là **10 mã dự phòng** (dùng mỗi mã một lần khi mất điện thoại) và **mã qua email** làm đường dự phòng thứ hai. Không dùng SMS làm 2FA vì dễ bị chiếm SIM (xem A5).

b) Hiện trạng

- Chưa có 2FA. Không có trường, bảng hay endpoint nào liên quan trong *apps/api/prisma/schema.prisma* và *apps/api/src/modules/auth*.
- Đăng nhập (*auth.service.ts*, hàm login và loginWithGoogle) kiểm tra mật khẩu hoặc token Google, rồi kiểm tra email đã xác minh, tài khoản bị khóa (bannedAt), khóa vì tuổi (ageLockedAt), sau đó cấp ngay một JWT (token đăng nhập) sống 30 ngày. Không có bước trung gian nào để chen bước thứ hai.
- Đã có sẵn cơ chế mã 6 số dùng lại được: bảng *AuthToken* (trường tokenHash, purpose, attemptCount, expiresAt, usedAt) với hai mục đích EMAIL_VERIFICATION và PASSWORD_RESET. Mã được băm bằng HMAC-SHA256 với khóa *OTP_HASH_SECRET*, hạn 5 phút, sai tối đa 5 lần, gửi tối đa 3 lần mỗi giờ, so sánh bằng timingSafeEqual. Mã OTP email cho 2FA nên đi theo đúng khuôn này.
- Gửi email qua *apps/api/src/modules/mail/mail.service.ts* (nodemailer, SMTP), đã có mẫu thư mã xác minh và mã đặt lại mật khẩu kèm câu cảnh báo không chia sẻ mã.
- Mobile: các màn đăng nhập ở *apps/mobile/src/features/auth/screens* (LoginScreen, VerifyCodeScreen…), token lưu bằng expo-secure-store trong *services/authTokenStorage.ts*. Màn Cài đặt

(*features/settings/screens/SettingsScreen.tsx*) có nhóm Tài khoản, Quyền riêng tư, Giới thiệu, Phiên đăng nhập; chưa có mục Bảo mật.

- Trang quản trị (*apps/api/src/modules/admin*) có khóa/mở khóa tài khoản, chưa có xử lý yêu cầu khôi phục 2FA.

c) Cách hoạt động

Luồng 1. Bật 2FA

1. Người dùng vào Cài đặt, mục mới **Bảo mật**, bấm **Bật xác thực hai lớp**.
2. App hỏi lại mật khẩu. Tài khoản chỉ có Google/Apple (không có mật khẩu) thì máy chủ yêu cầu phiên đăng nhập tạo trong vòng 10 phút; nếu cũ hơn, app bảo đăng nhập lại bằng Google/Apple.
3. Máy chủ kiểm tra mật khẩu (lần sai được tính vào bộ đếm chống dò mật khẩu A4). Đúng thì tạo một khóa bí mật ngẫu nhiên 20 byte, mã hóa (AES-256-GCM) rồi lưu ở trạng thái "chờ xác nhận". Chưa bật 2FA ở bước này.
4. App hiện ba thứ: nút **Mở ứng dụng xác thực** (mở đường link otpauth:// để ứng dụng xác thực trên cùng điện thoại tự thêm tài khoản), **mã QR** (khi ứng dụng xác thực nằm trên máy khác) và **khóa dạng chữ** có nút sao chép (nhập tay).
5. Người dùng thêm tài khoản vào ứng dụng xác thực, nhập mã 6 số đang hiện.
6. Máy chủ kiểm tra mã (cho phép lệch một bước 30 giây trước/sau để bù đồng hồ lệch). Sai thì báo, cho nhập lại; sai 5 lần thì hủy khóa chờ, người dùng phải bắt đầu lại.
7. Đúng: máy chủ ghi thời điểm bật 2FA, tạo 10 mã dự phòng (dạng xxxx-xxxx), chỉ lưu bản băm, gửi email "Bạn vừa bật xác thực hai lớp".
8. App hiện 10 mã dự phòng **một lần duy nhất**, có nút sao chép và nút lưu ra tệp/chia sẻ. Người dùng phải bấm "Tôi đã lưu mã" mới đóng được màn.
9. App hỏi "Đăng xuất khỏi các thiết bị khác?". Chọn Có thì máy chủ thu hồi mọi phiên khác (A2).

Luồng 2. Đăng nhập khi đã bật 2FA

1. Người dùng đăng nhập như thường: email + mật khẩu, Google hoặc Apple (A6).
2. Máy chủ kiểm tra bước 1 như hiện nay (và chống dò mật khẩu A4). Nếu tài khoản chưa bật 2FA thì cấp phiên ngay như cũ.
3. Nếu đã bật 2FA: máy chủ **không** cấp token mà tạo một **phiếu thử thách** (chuỗi ngẫu nhiên, hạn 10 phút, lưu bản băm) và trả về cho app kèm danh sách cách xác minh được phép (ứng dụng xác thực, mã dự phòng, email) và email đã che bớt (ví dụ n***@gmail.com).

4. App hiện màn "Nhập mã 6 số từ ứng dụng xác thực", có liên kết "Dùng cách khác".
5. Người dùng nhập mã. Máy chủ kiểm tra phiếu còn hạn và mã đúng. Mã đã dùng trong cùng khung 30 giây bị từ chối (chống dùng lại mã vừa bị nhìn trộm).
6. Sai: báo sai, cho nhập lại. Sai 5 lần trên một phiếu thì hủy phiếu, người dùng đăng nhập lại từ đầu (và lần sai được tính vào A4).
7. Đúng: máy chủ ghi bước mã đã dùng, xóa phiếu, tạo phiên (A2), xét thiết bị lạ để cảnh báo (A3). App lưu token và vào bảng tin.

Luồng 3. Mất điện thoại: dùng mã dự phòng hoặc mã email

1. Ở màn nhập mã, người dùng bấm "Dùng cách khác". App hiện ba lựa chọn: mã dự phòng, gửi mã qua email, "Tôi mất cả hai".
2. **Mã dự phòng**: nhập một mã trong 10 mã đã lưu. Máy chủ so bản băm, mã đúng thì đánh dấu đã dùng (không dùng lại được) và cho đăng nhập.
3. **Mã email**: app gọi máy chủ gửi mã 6 số tới email tài khoản (hạn 5 phút, tối đa 3 lần mỗi giờ, sai tối đa 5 lần — giống mã xác minh email hiện có). Người dùng nhập mã, đúng thì cho đăng nhập.
4. Sau khi vào bằng cách dự phòng, máy chủ gửi email "Bạn vừa đăng nhập bằng mã dự phòng / mã email" (có nút "Không phải tôi", A3). App hiện lời nhắc: "Bạn còn N mã dự phòng. Hãy cài lại xác thực hai lớp trên điện thoại mới".
5. Người dùng vào Bảo mật, bấm **Đặt lại ứng dụng xác thực**: làm lại luồng 1 với khóa mới; khóa cũ và 10 mã dự phòng cũ hết hiệu lực ngay khi khóa mới được xác nhận.

Luồng 4. Mất cả ứng dụng, mã dự phòng và email: khôi phục qua hỗ trợ

1. Người dùng chọn "Tôi mất cả hai", điền form: email tài khoản, mô tả, cách liên hệ khác. Máy chủ luôn trả cùng một câu "Đã nhận yêu cầu" dù email có tồn tại hay không.
2. Máy chủ lưu yêu cầu và gửi email + thông báo đẩy tới mọi thiết bị đang đăng nhập của tài khoản: "Có người yêu cầu gỡ xác thực hai lớp. Nếu không phải bạn, bấm Hủy".
3. Quản trị viên xem yêu cầu trong trang quản trị, đối chiếu thông tin (cách xác minh do chủ dự án quyết, xem câu hỏi mở). Không xác minh được thì từ chối, gửi email lý do.
4. Duyệt thì bắt đầu **thời gian chờ 7 ngày**. Trong 7 ngày đó, chủ tài khoản thật (nếu còn đăng nhập ở đâu đó hoặc còn đọc được email) bấm Hủy là yêu cầu bị đóng.

5. Hết 7 ngày không ai hủy: máy chủ gỡ 2FA, xóa mã dự phòng, thu hồi mọi phiên, ghi nhật ký quản trị (C3) và gửi email thông báo. Người dùng đăng nhập bằng mật khẩu rồi bật lại 2FA.

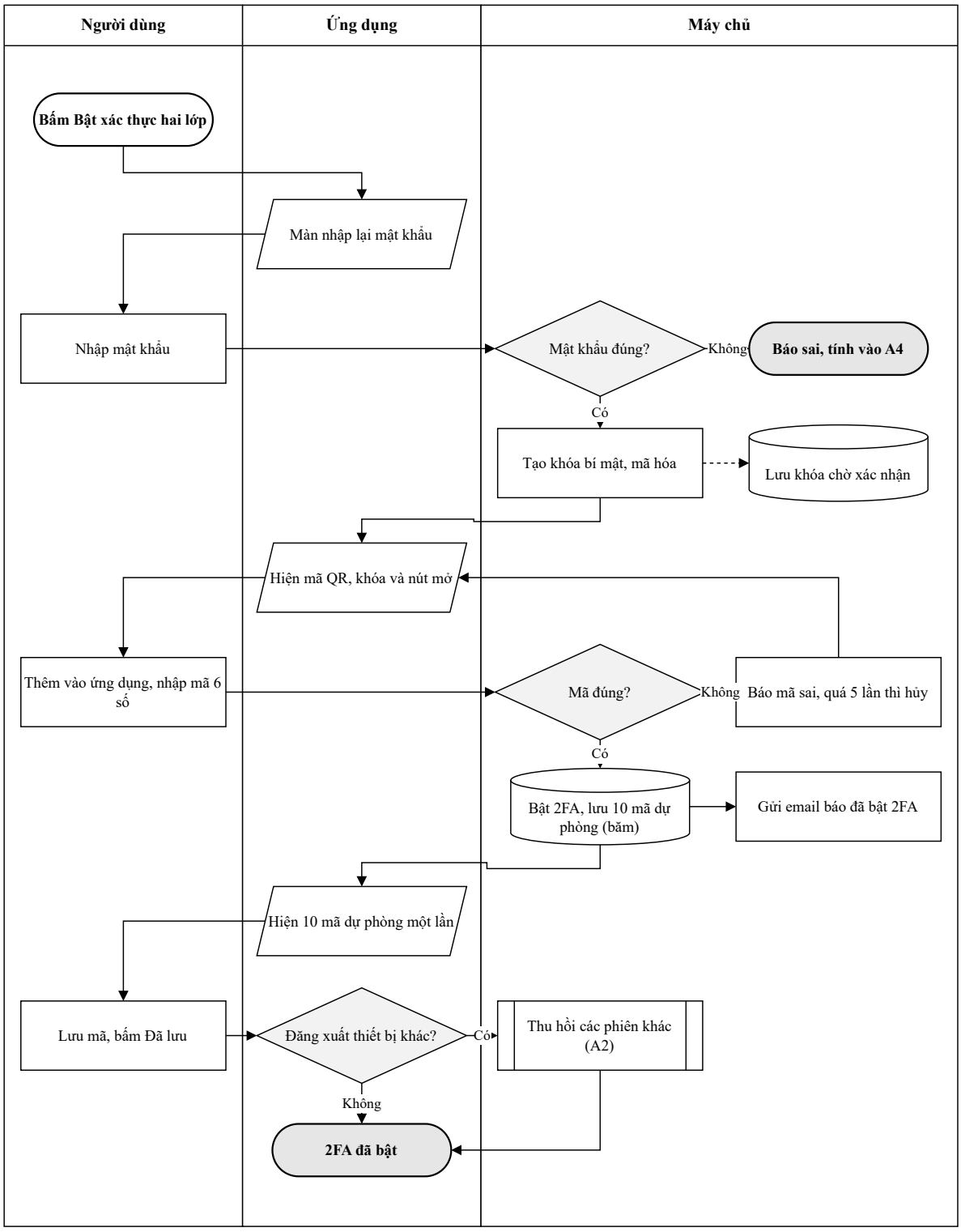
Luồng 5. Tắt 2FA

1. Người dùng vào Bảo mật, bấm **Tắt xác thực hai lớp**.
2. App hỏi mật khẩu (nếu tài khoản có mật khẩu) và mã 6 số hiện tại hoặc một mã dự phòng.
3. Máy chủ kiểm tra cả hai. Sai mật khẩu tính vào A4; sai mã 5 lần trong 15 phút thì phải chờ 15 phút.
4. Đúng: xóa khóa bí mật và mã dự phòng, gửi email + thông báo đẩy "Xác thực hai lớp đã bị tắt" kèm nút "Không phải tôi". App hiện "Đã tắt".

Luồng phụ. Tạo lại mã dự phòng: trong Bảo mật có nút "Tạo mã dự phòng mới" (hỏi mã 6 số). 10 mã cũ hết hiệu lực, 10 mã mới hiện một lần.

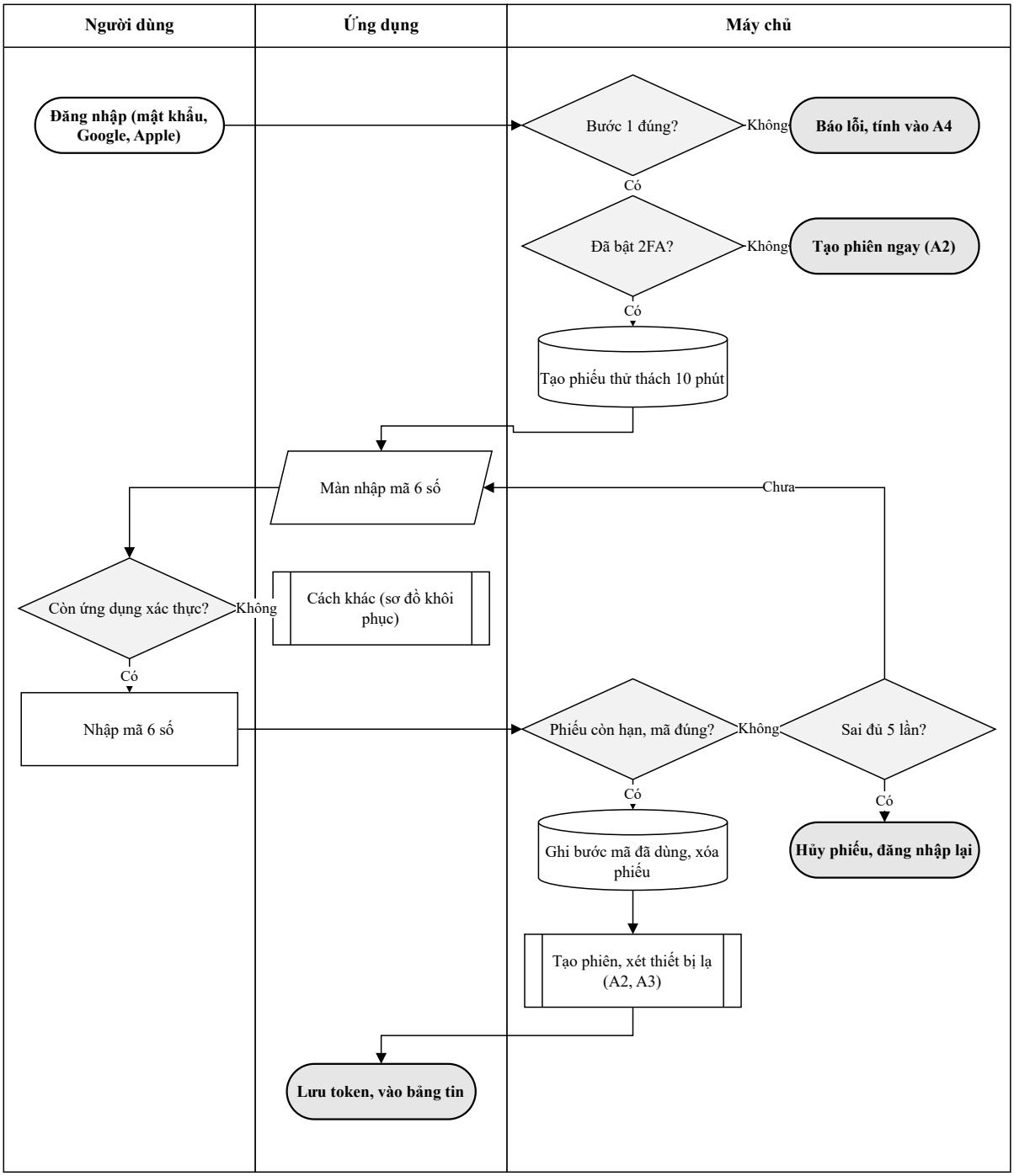
d) Flowchart

Bật 2FA:



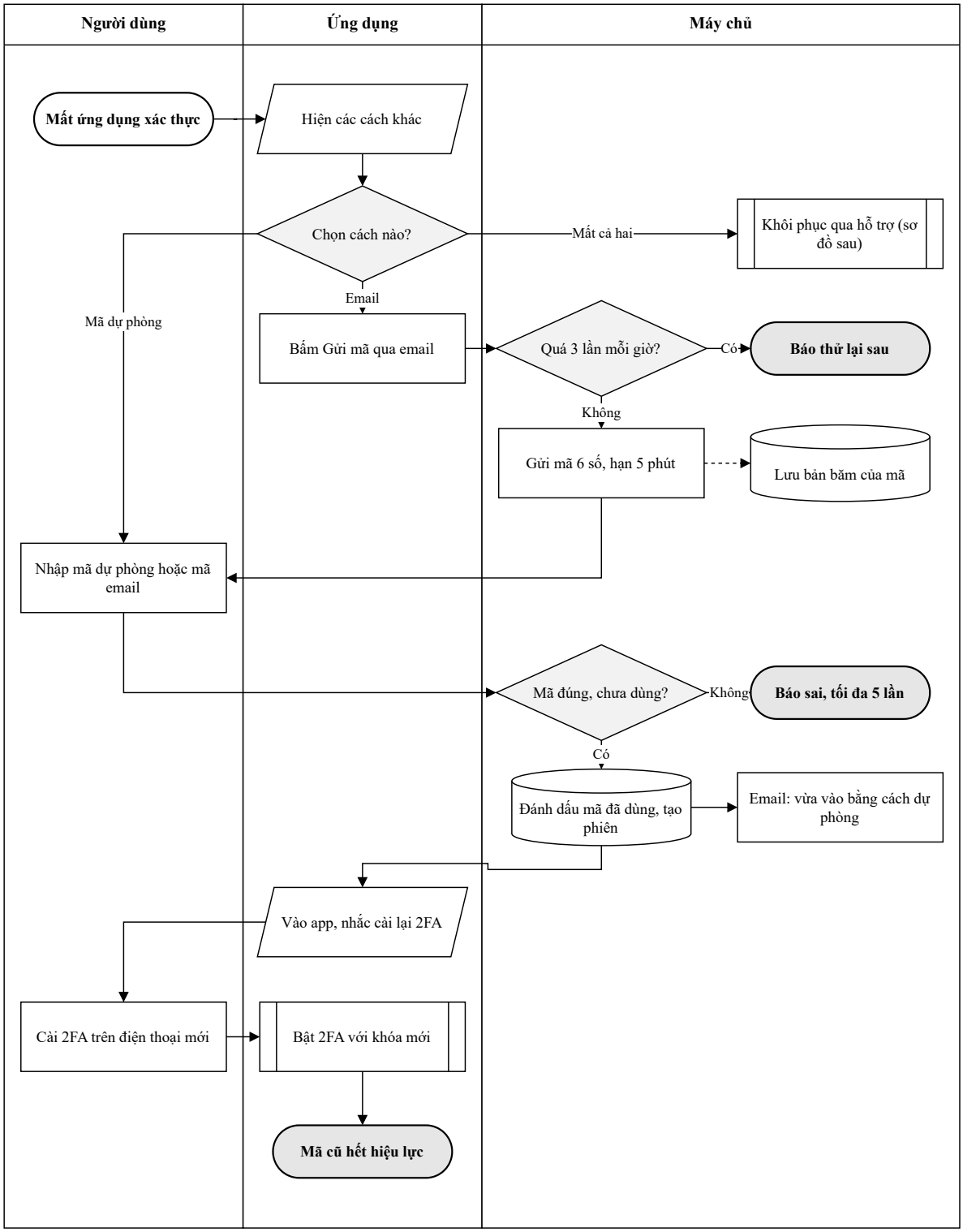
Hình 3. Bật xác thực hai lớp bằng ứng dụng xác thực

Đăng nhập khi đã bật 2FA:



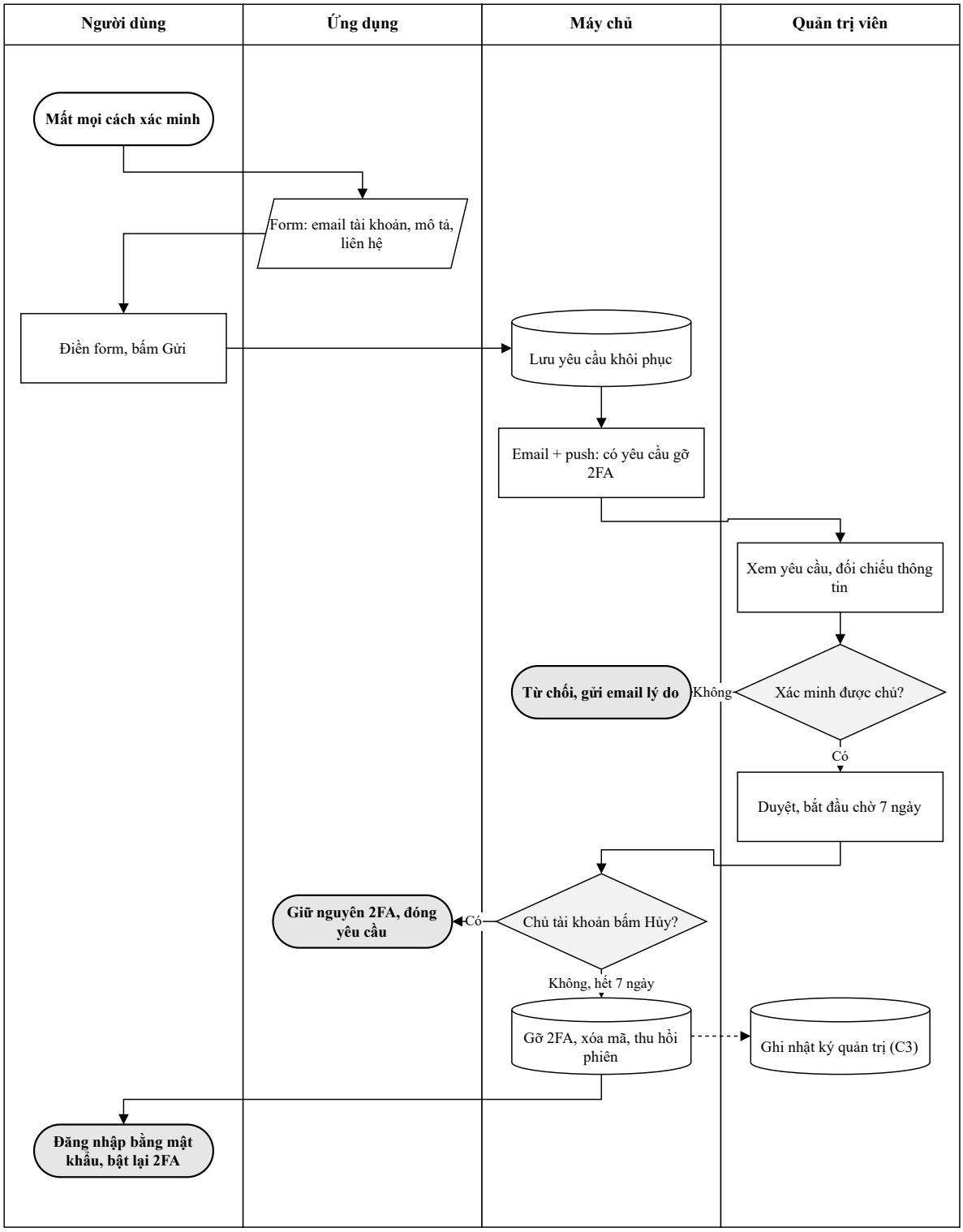
Hình 4. Đăng nhập khi đã bật xác thực hai lớp

Mất điện thoại, vào bằng mã dự phòng hoặc mã email:



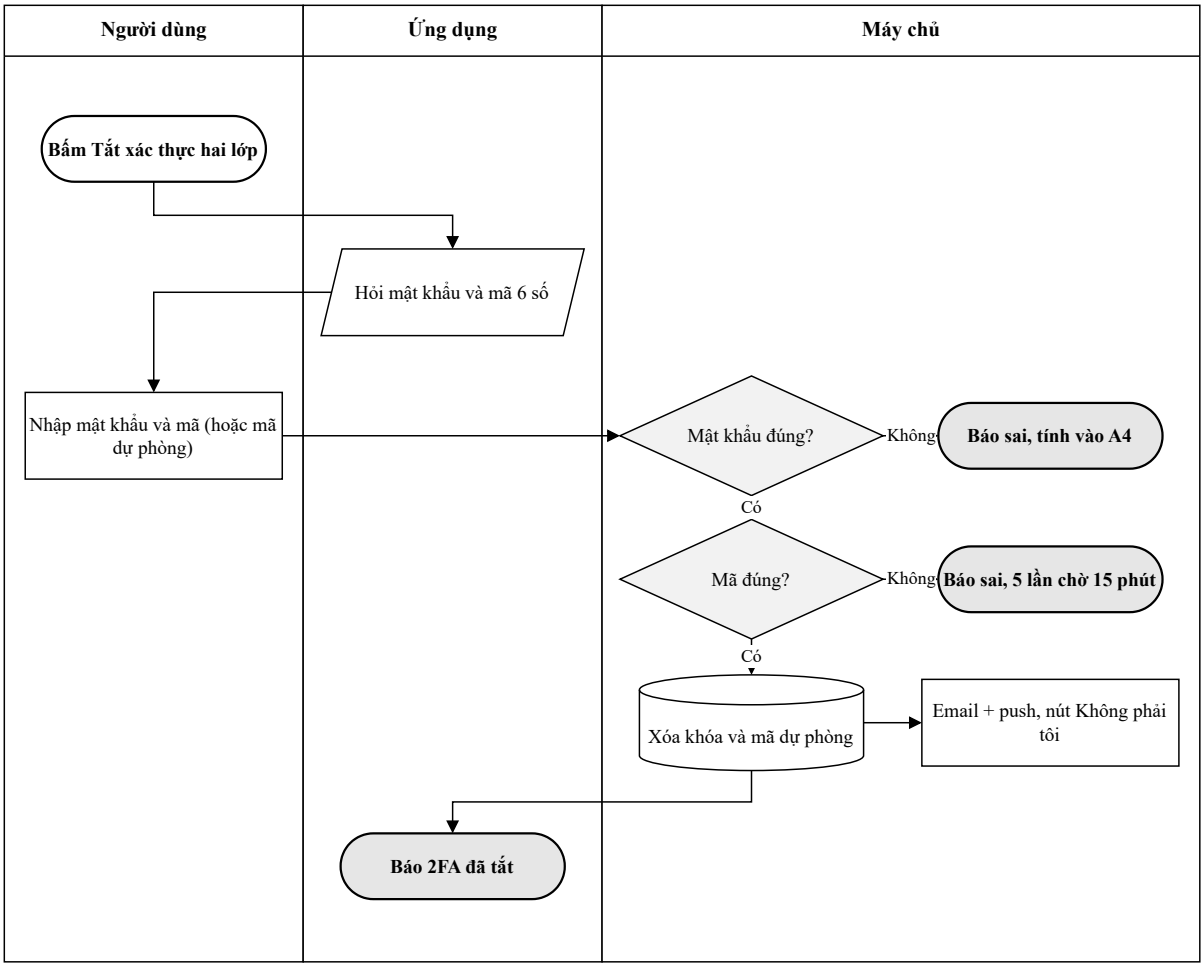
Hình 5. Mất điện thoại: đăng nhập bằng mã dự phòng hoặc mã email

Mất mọi cách xác minh, khôi phục qua quản trị viên:



Hình 6. Mất cả ứng dụng xác thực, mã dự phòng và email: khôi phục qua hỗ trợ

Tắt 2FA:



Hình 7. Tắt xác thực hai lớp

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Mã TOTP** (đề xuất): 6 số, bước 30 giây, thuật toán SHA-1 (mặc định mà mọi ứng dụng xác thực hiểu), chấp nhận lệch ±1 bước. Mỗi bước chỉ dùng được một lần.
- **Phiếu thử thách**: hạn 10 phút, sai tối đa 5 lần. Ngoài ra mỗi tài khoản sai mã 2FA quá 10 lần trong 1 giờ (cộng mọi phiếu) thì khóa bước 2FA 1 giờ và gửi email cảnh báo, vì kẻ gian đã biết mật khẩu.
- **Mã dự phòng**: 10 mã, 8 ký tự chữ thường và số (bỏ các ký tự dễ nhầm như 0/o, 1/l), mỗi mã dùng một lần. Còn dưới 3 mã thì app nhắc tạo mã mới.
- **Mã email**: 6 số, hạn 5 phút, sai tối đa 5 lần, gửi tối đa 3 lần/giờ — dùng lại đúng cách làm của mã xác minh email hiện có. Nút "Gửi lại" chỉ bấm được sau 60 giây.
- **Khóa bí mật** lưu mã hóa bằng khóa riêng trong biến môi trường (đề xuất *TWO_FACTOR_ENC_KEY*), không lưu dạng gốc, không bao giờ trả lại cho app sau bước bật.
- **Đặt lại mật khẩu qua "Quên mật khẩu" không gỡ 2FA**: sau khi đặt mật khẩu mới vẫn phải qua bước 2 khi đăng nhập.

- **Đăng nhập Google/Apple** cũng phải qua bước 2 nếu tài khoản đã bật 2FA.
- **Tài khoản bị khóa / khóa vì tuổi**: kiểm tra khóa trước khi tạo phiếu thử thách; tài khoản bị khóa không nhận phiếu và không nhận mã email.
- **Lỗi mạng**: nếu app gửi mã xong mà mất mạng, người dùng nhập lại mã mới ở bước 30 giây kế tiếp; phiếu vẫn còn hạn 10 phút. Màn nhập mã giữ phiếu trong bộ nhớ, không lưu xuống máy.
- **Email dự phòng làm yếu 2FA**: ai chiếm được cả mật khẩu và email thì vẫn vào được. Đây là đánh đổi để người dùng ít bị khóa ngoài; mỗi lần dùng mã email đều gửi cảnh báo. Chủ dự án có thể cho người dùng tự tắt đường email trong Bảo mật (xem câu hỏi mở).
- **Lạm dụng khôi phục qua hỗ trợ**: thời gian chờ 7 ngày, thông báo tới mọi thiết bị, nhật ký quản trị. Mỗi tài khoản chỉ có 1 yêu cầu đang mở; mỗi IP tối đa 3 yêu cầu/ngày.
- **Người bị chặn** không liên quan tới tính năng này.

f) Dữ liệu và API (đề xuất)

Toàn bộ phần dưới là **đề xuất**, phải ghi vào *docs/api-contract.md* và thống nhất với người làm backend trước khi code (RULE.md: không tự đặt API contract).

Thay đổi dữ liệu (Prisma)	**Nội dung**
User: thêm trường	twoFactorSecretEnc (String?, khóa đã mã hóa), twoFactorEnabledAt (DateTime?, null = chưa bật; có khóa mà chưa có ngày = đang chờ xác nhận), twoFactorLastStep (Int?, bước 30 giây đã dùng gần nhất), twoFactorEmailFallback (Boolean, mặc định true).
Bảng mới TwoFactorBackupCode	id, userId, codeHash (unique), usedAt?, createdAt. Xóa theo User (onDelete: Cascade).
AuthTokenPurpose: thêm giá trị	TWO_FACTOR_CHALLENGE (phiếu thử thách, hạn 10 phút, attemptCount đếm lần sai) và TWO_FACTOR_EMAIL (mã email 6 số).
Bảng mới TwoFactorRecoveryRequest	id, userId, contact, note, status (PENDING, APPROVED, REJECTED, CANCELLED, DONE), reviewedById?, executeAfter?, createdAt.

Endpoint (đề xuất)	**Việc làm**
POST /auth/2fa/setup { currentPassword? }	Tạo khóa chờ xác nhận, trả { secret, otpauthUrl }.
POST /auth/2fa/enable { code }	Xác nhận mã, bật 2FA, trả { backupCodes: [10 mã] }.

POST /auth/2fa/disable { currentPassword?, code }	Tắt 2FA (code là mã 6 số hoặc mã dự phòng).
POST /auth/2fa/backup-codes { code }	Tạo 10 mã mới, hủy mã cũ.
POST /auth/login, /auth/google, /auth/apple	Khi đã bật 2FA trả 200 { data: { twoFactorRequired: true, challengeToken, methods: ["totp","backup","email"], emailHint } } thay cho accessToken. App cũ không hiểu trường này nên cần bắt cập nhật app trước khi bật tính năng (xem g).
POST /auth/2fa/verify { challengeToken, method, code }	Kiểm tra mã; đúng thì trả giống đăng nhập thành công (access + refresh token theo A2).
POST /auth/2fa/email { challengeToken }	Gửi mã 6 số qua email.
POST /auth/2fa/recovery-request { email, note, contact }	Tạo yêu cầu khôi phục, luôn trả cùng một thông báo.
POST /auth/2fa/recovery-request/cancel { token }	Chủ tài khoản hủy yêu cầu (từ link trong email hoặc trong app).
GET /admin/2fa-recovery, POST /admin/2fa-recovery/:id/approve | reject	Quản trị viên xử lý; ghi nhật ký (C3).
GET /users/me	Thêm twoFactorEnabled (boolean) và backupCodesLeft (số).

Mã lỗi đề xuất: 401 { code: "TWO_FACTOR_INVALID" }, 401 { code: "TWO_FACTOR_CHALLENGE_EXPIRED" }, 429 { code: "TWO_FACTOR_LOCKED", retryAfterSeconds }. Lưu ý: sai mã khi đang đăng nhập dùng 401 được (chưa có phiên), nhưng sai mã khi bật/tắt 2FA trong app phải trả **400**, vì app hiện coi mọi 401 là hết phiên và tự đăng xuất (giống quy ước của PATCH /auth/password).

Cách tính TOTP: dùng node:crypto (HMAC-SHA1) có sẵn, cộng một hàm mã hóa base32 nhỏ; không bắt buộc thêm thư viện. Nếu muốn dùng thư viện thì otplib (chỉ ở backend), cần chủ dự án đồng ý.

g) Android, iOS và web

- **Không cần quyền thiết bị nào**, không cần sửa app.json.

- **Mở ứng dụng xác thực**: dùng Linking.openURL với đường link otpauth:// — có trên cả Android và iOS. Nếu máy chưa cài ứng dụng xác thực, lệnh mở báo lỗi; app bắt lỗi và hiện hướng dẫn cài (Google Authenticator có trên cả Google Play và App Store).
- **Mã QR**: cần một thư viện vẽ QR chạy được trên cả hai nền tảng. Dự án đã có react-native-svg; ví dụ react-native-qrcode-svg (JavaScript thuần, dùng react-native-svg) — phải kiểm tra tương thích Expo SDK 57 và cài bằng expo install. Nếu chủ dự án không muốn thêm thư viện, có thể bỏ QR, chỉ giữ nút mở ứng dụng và khóa dạng chữ (đa số người dùng cài ứng dụng xác thực trên chính điện thoại đó).
- **Sao chép khóa và mã dự phòng**: expo-clipboard đã có trong dự án. Lưu mã dự phòng ra tệp/chia sẻ: dùng Share của React Native (có trên cả hai nền tảng).
- **Ô nhập mã**: keyboardType="number-pad", textContentType="oneTimeCode" (iOS gợi ý mã) và autoComplete="one-time-code" (Android) — đều là thuộc tính có sẵn của TextInput.
- **Bàn phím và vùng an toàn**: màn nhập mã dùng AuthScreenContainer hiện có (cần kiểm tra đã có KeyboardAvoidingView đúng cho từng nền tảng).
- **Bản app cũ**: app đang chạy không hiểu twoFactorRequired. Phải phát hành bản app mới có màn nhập mã trước, rồi mới mở cho người dùng bật 2FA; hoặc máy chủ trả lỗi rõ ràng "Hãy cập nhật ứng dụng" cho app cũ khi tài khoản đã bật 2FA.
- **Web**: dự án chưa có web client; trang quản trị là trang HTML do API phục vụ (admin.html). Không ảnh hưởng.
- **Chi phí**: không phát sinh dịch vụ trả phí; email dùng SMTP hiện có.

h) Tiêu chí hoàn thành

- Bật 2FA bằng Google Authenticator thành công trên Android và trên iPhone (cả trường hợp ứng dụng xác thực trên cùng máy và trên máy khác qua QR/khóa chữ).
- Đăng nhập bằng mật khẩu, Google (và Apple khi có A6) đều bị hỏi mã khi đã bật 2FA; mã sai 5 lần thì phiếu bị hủy.
- Mã đã dùng không dùng lại được trong cùng khung 30 giây; mã dự phòng đã dùng bị từ chối.
- Mã email đến được hộp thư, hết hạn sau 5 phút, gửi lần thứ 4 trong 1 giờ bị từ chối.
- Tắt 2FA cần đúng cả mật khẩu và mã; email + thông báo đẩy được gửi.
- Quản trị viên duyệt yêu cầu khôi phục, chủ tài khoản hủy được trong 7 ngày, hết 7 ngày thì 2FA bị gỡ và có nhật ký.

- Khóa bí mật trong cơ sở dữ liệu là dạng đã mã hóa; mã dự phòng chỉ có bản băm.
- Test tự động ở backend: tính TOTP theo bộ số mẫu của RFC 6238, chống dùng lại bước, hết hạn phiếu, đếm lần sai, mã dự phòng dùng một lần.
- Báo cáo ghi rõ đã chạy trên nền tảng nào (ví dụ "Android emulator: có, iPhone: chưa chạy").

i) Ước lượng và phụ thuộc

- Backend 5 ngày (TOTP, mã hóa khóa, mã dự phòng, phiếu thử thách trong 3 đường đăng nhập, mã email, tắt 2FA, yêu cầu khôi phục + trang quản trị). Mobile 3 ngày (mục Bảo mật, màn bật 2FA, màn mã dự phòng, màn nhập mã khi đăng nhập, màn "Dùng cách khác", màn tắt 2FA). Kiểm thử 2 ngày.
- Phụ thuộc: **A2** (phiên và refresh token — để "đăng xuất thiết bị khác" và thu hồi phiên khi gỡ 2FA), **A4** (đếm lần sai chung), **A3** (nút "Không phải tôi" trong email), **C3** (nhật ký quản trị cho luồng khôi phục). Có thể làm A1 trước A3/C3 rồi bổ sung sau.
- Rủi ro: người dùng mất cả mã dự phòng lẫn email gây tải cho bộ phận hỗ trợ; xác minh danh tính qua hỗ trợ dễ bị lừa (social engineering) nếu quy trình lỏng; app cũ không hiểu phản hồi mới.

A2. Phiên đăng nhập và thiết bị

Nhóm: Bảo mật tài khoản · Giai đoạn: GĐ1 · Ước lượng: 9 ngày công

a) Mục đích

Hiện nay một lần đăng nhập cho một "vé" dùng được 30 ngày và máy chủ không có cách nào thu hồi vé đó: bấm Đăng xuất chỉ xóa vé trên điện thoại, đổi mật khẩu cũng không đá được kẻ gian đang dùng tài khoản. Tính năng này cho người dùng xem danh sách thiết bị đang đăng nhập, đăng xuất từ xa từng máy hoặc tất cả, và tự đăng xuất các máy khác khi đổi mật khẩu. Đây cũng là nền cho 2FA (A1) và cảnh báo đăng nhập lạ (A3).

b) Hiện trạng

- *apps/api/src/modules/auth/auth.module.ts*: JWT ký bằng *JWT_SECRET*, hạn **30 ngày**; có ghi chú "shortcut: chưa có refresh token… làm refresh token xoay vòng khi cần thu hồi phiên". Nội dung token chỉ có sub (mã người dùng) — xem *types/jwt-payload.type.ts*.
- *auth.controller.ts*: POST /auth/logout trả 204 và **không làm gì** ở máy chủ. *docs/api-contract.md* cũng ghi rõ chưa có refresh token và chưa thu hồi token phía máy chủ.
- *strategies/jwt.strategy.ts*: mỗi yêu cầu chỉ kiểm tra chữ ký, hạn, và hai danh sách trong bộ nhớ *bannedUserIds*, *ageLockedUserIds* (*ban-list.ts*, có ghi chú chỉ đúng khi chạy một tiến trình API).
- *auth.service.ts*: changePassword và resetPassword chỉ đổi passwordHash; không thu hồi phiên nào, không gửi email báo đổi mật khẩu.
- *notifications.gateway.ts* (Socket.IO): chỉ kiểm tra JWT lúc kết nối, sau đó giữ kết nối; không có cách ngắt kết nối của một phiên cụ thể.
- Bảng *DeviceToken* (token push, userId, platform) không gắn với phiên. Khi đăng xuất, app gọi DELETE /notifications/devices trước (*pushService.unregister*), nhưng đăng xuất từ xa sẽ không có bước này.
- Mobile: *services/authTokenStorage.ts* lưu đúng một access token trong expo-secure-store. *services/httpClient.ts* gặp 401 là gọi handler để xóa phiên và đưa về màn Đăng nhập; không có bước làm mới token. *authSession.tsx* khôi phục phiên lúc mở app bằng cách gọi /users/me.
- Cài đặt: *SettingsScreen.tsx* có nhóm "Phiên đăng nhập" gồm Đăng xuất và Xóa tài khoản; chưa có danh sách thiết bị. *ChangePasswordScreen.tsx* đổi mật khẩu (hoặc đặt mật khẩu đầu tiên cho tài khoản chỉ có Google).

- Quyết định DEC-008 trong *docs/decisions.md* ghi: muốn có refresh token hoặc thu hồi phía máy chủ thì phải cập nhật quyết định này. Vì vậy A2 cần một mục mới trong *docs/decisions.md*.

c) Cách hoạt động

Ý tưởng: mỗi lần đăng nhập tạo một **phiên** (session) lưu trong cơ sở dữ liệu. App nhận hai thứ: **access token** (vé ngắn hạn 15 phút, gửi kèm mọi yêu cầu như hiện nay) và **refresh token** (vé dài hạn chỉ dùng để xin access token mới). Mỗi lần dùng, refresh token bị đổi sang cái mới (**xoay vòng**). Thu hồi phiên = máy đó không xin được vé mới nữa và mọi yêu cầu sau bị từ chối.

Luồng 1. Đăng nhập tạo phiên

1. App gửi thông tin đăng nhập như hiện nay, kèm thông tin máy: mã thiết bị (chuỗi ngẫu nhiên app tự tạo lần đầu và lưu trong SecureStore), tên máy (ví dụ "iPhone 15", "Samsung Galaxy S23"), nền tảng (ios/android), phiên bản app.
2. Máy chủ tạo bản ghi Session (thiết bị, IP, thành phố/quốc gia suy từ IP, thời điểm), tạo refresh token ngẫu nhiên 32 byte và chỉ lưu bản băm SHA-256.
3. Máy chủ trả access token (có thêm mã phiên sid) + refresh token. App lưu cả hai trong SecureStore.

Luồng 2. Làm mới phiên (refresh token xoay vòng)

1. App gọi API, máy chủ trả 401 vì access token hết hạn.
2. App gửi refresh token tới /auth/refresh. Nếu nhiều yêu cầu cùng gặp 401 một lúc, app chỉ gửi **một** lượt làm mới, các yêu cầu khác chờ kết quả.
3. Máy chủ tìm token theo bản băm, kiểm tra phiên chưa bị thu hồi, chưa hết hạn, tài khoản không bị khóa. Không đạt: trả 401, app xóa token và về màn Đăng nhập.
4. Máy chủ kiểm tra token này đã từng được dùng chưa. Nếu đã dùng (tức có người khác đang giữ bản sao token) thì đây là dấu hiệu bị đánh cắp: **thu hồi cả phiên**, gửi email + thông báo đẩy cảnh báo (A3), trả 401. Ngoại lệ: dùng lại trong vòng 30 giây và token mới chưa từng được dùng — thường là app gửi lại do rớt mạng — thì coi là hợp lệ.
5. Hợp lệ: máy chủ đánh dấu token cũ đã dùng, lưu token mới, cập nhật lần dùng cuối và IP của phiên, trả access token 15 phút + refresh token mới.
6. App lưu token mới rồi gửi lại các yêu cầu đang chờ. Người dùng không thấy gì.

Luồng 3. Xem thiết bị và đăng xuất từ xa

1. Người dùng vào Cài đặt, mục mới **Thiết bị đăng nhập** (trong nhóm Phiên đăng nhập).

2. App hiện danh sách phiên đang hoạt động: tên máy, nền tảng, thành phố/quốc gia, lần dùng cuối; phiên hiện tại ghi "Thiết bị này" và đứng đầu.
3. Người dùng bấm một máy, chọn **Đăng xuất**. Máy chủ kiểm tra phiên đó thuộc người này, ghi thời điểm và lý do thu hồi, ngắt kết nối socket của phiên đó, xóa token push của phiên đó.
4. Hoặc bấm **Đăng xuất tất cả thiết bị khác**: app hỏi lại mật khẩu (hoặc mã 2FA nếu tài khoản không có mật khẩu mà đã bật 2FA). Máy chủ thu hồi mọi phiên trừ phiên hiện tại.
5. Máy bị đăng xuất: yêu cầu kế tiếp nhận 401, app về màn Đăng nhập với thông báo "Bạn đã bị đăng xuất khỏi thiết bị này".

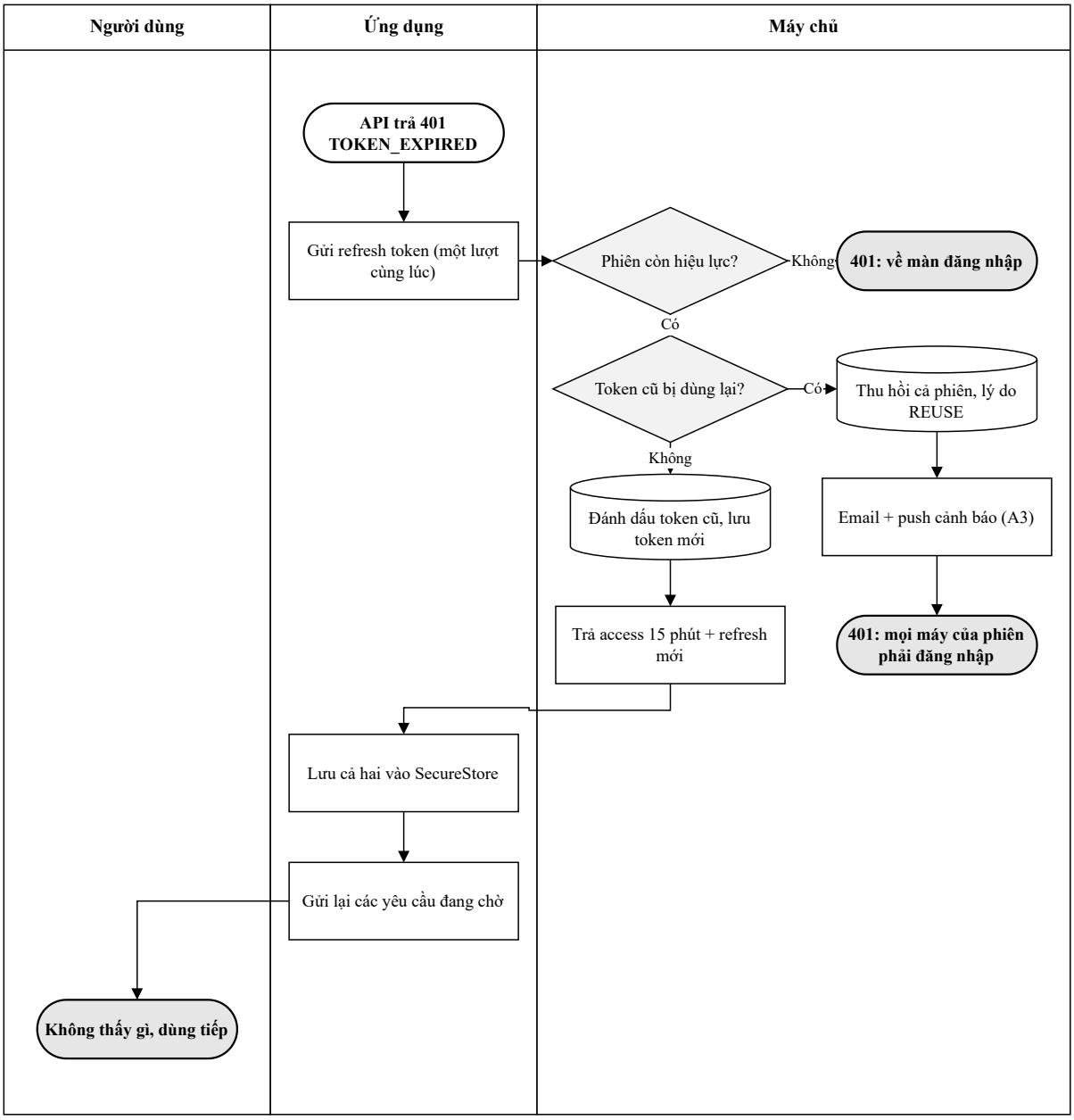
Luồng 4. Đổi hoặc đặt lại mật khẩu

1. Đổi mật khẩu trong app (ChangePasswordScreen): sau khi lưu mật khẩu mới, máy chủ thu hồi mọi phiên **khác**, giữ phiên đang dùng. App báo "Đã đăng xuất N thiết bị khác".
2. Đặt lại mật khẩu qua "Quên mật khẩu": máy chủ thu hồi **tất cả** phiên (kể cả máy đang dùng), người dùng đăng nhập lại bằng mật khẩu mới.
3. Cả hai trường hợp đều gửi email "Mật khẩu của bạn vừa được đổi" kèm nút "Không phải tôi" (A3).

Các trường hợp khác cũng thu hồi phiên: quản trị viên khóa tài khoản (thu hồi tất cả), người dùng xóa tài khoản, gỡ 2FA qua hỗ trợ (A1), bấm "Không phải tôi" (A3), phát hiện refresh token bị dùng lại.

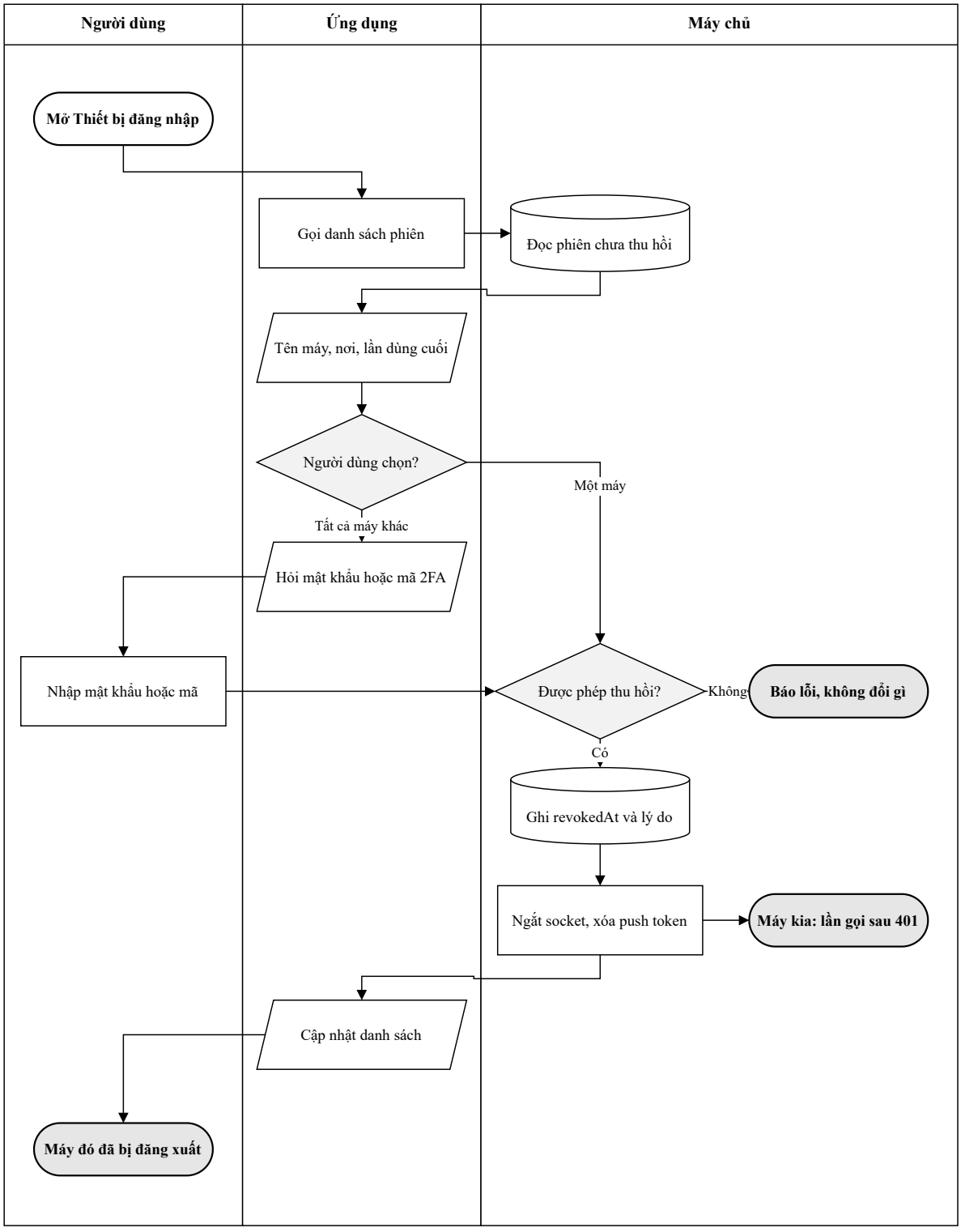
d) Flowchart

Làm mới phiên và phát hiện token bị dùng lại:



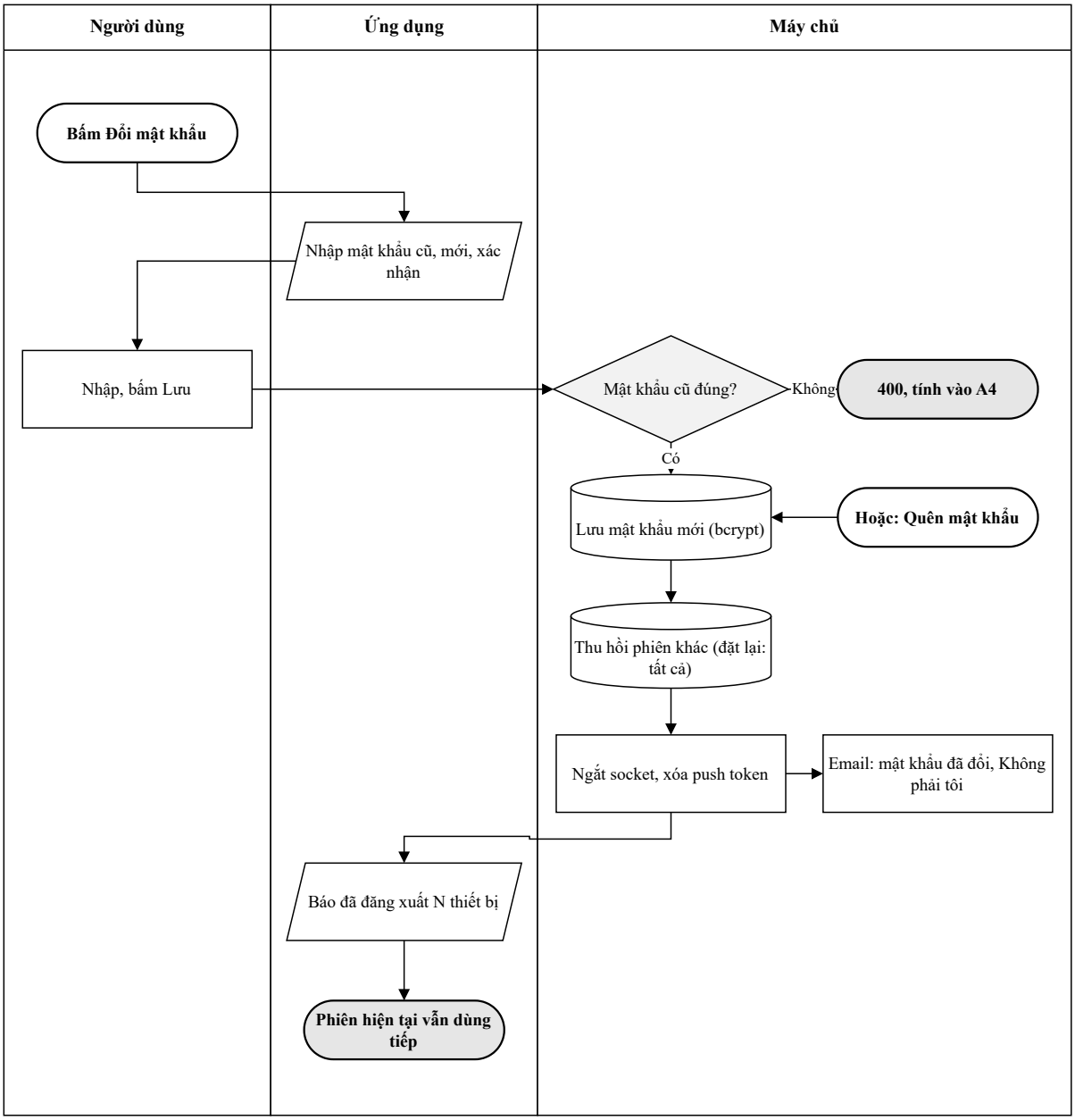
Hình 8. Làm mới phiên bằng refresh token xoay vòng, phát hiện token bị dùng lại

Danh sách thiết bị và đăng xuất từ xa:



Hình 9. Xem thiết bị đang đăng nhập và đăng xuất từ xa

Đổi hoặc đặt lại mật khẩu:



Hình 10. Đổi hoặc đặt lại mật khẩu: đăng xuất các thiết bị khác

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Thời hạn** (đề xuất): access token 15 phút; phiên hết hạn nếu 60 ngày không mở app (mỗi lần làm mới lùi hạn thêm 60 ngày); tối đa 1 năm phải đăng nhập lại.
- **Số phiên**: tối đa 20 phiên đang hoạt động mỗi tài khoản; vượt thì phiên lâu không dùng nhất bị thu hồi.
- **Ân hạn 30 giây** cho refresh token bị gửi lại do rớt mạng (xem luồng 2). Ngoài 30 giây hoặc token mới đã được dùng thì coi là bị đánh cắp.
- **Kiểm tra thu hồi ngay lập tức**: JwtStrategy đọc Session theo sid (một truy vấn theo khóa chính) ở mỗi yêu cầu, để đăng xuất từ xa có hiệu lực ngay chứ không

đợi 15 phút. Khi tải cao thì thêm bộ nhớ đệm hoặc Redis. Cách này cũng thay được danh sách khóa trong bộ nhớ (ban-list.ts) vốn chỉ đúng với một tiến trình API.

- **Socket**: lưu sid vào client.data khi kết nối; thu hồi phiên thì ngắt các socket của sid đó. Socket chỉ kiểm tra token lúc kết nối nên phải làm bước này.
- **Chống kẻ gian vừa vào đá chủ thật**: phiên mới tạo dưới 24 giờ không được đăng xuất phiên cũ hơn nó, trừ khi nhập lại mật khẩu (đề xuất, chủ dự án quyết).
- **Lỗi mạng khi làm mới**: nếu không gửi được (mất mạng) thì giữ nguyên token, không đăng xuất; chỉ đăng xuất khi máy chủ trả 401 rõ ràng.
- **Chuyển đổi từ token 30 ngày**: token cũ không có sid. Đề xuất: vẫn chấp nhận token cũ đến khi hết hạn tự nhiên (tối đa 30 ngày), nhưng nếu người dùng đổi mật khẩu hoặc "đăng xuất tất cả" thì token cũ có thời điểm phát hành trước mốc đó bị từ chối (trường sessionsValidAfter). Bản app cũ không biết làm mới token, nên máy chủ chỉ cấp access token 15 phút cho app có gửi thông tin thiết bị (bản mới); app cũ tiếp tục nhận token 30 ngày cho tới khi buộc cập nhật.
- **Tài khoản bị khóa**: không làm mới được, mọi phiên bị thu hồi lý do BANNED; mở khóa không tự khôi phục phiên.
- **Dọn dẹp**: định kỳ (mỗi ngày) xóa refresh token đã dùng quá 30 ngày và phiên đã thu hồi quá 90 ngày.

f) Dữ liệu và API (đề xuất)

Toàn bộ là **đề xuất**, cần ghi vào *docs/api-contract.md* và cập nhật DEC-008 trong *docs/decisions.md* trước khi code.

Thay đổi dữ liệu (Prisma)	**Nội dung**
Bảng mới Session	id, userId, deviceId?, deviceName?, platform, appVersion?, ip?, city?, country?, createdAt, lastUsedAt, expiresAt, revokedAt?, revokeReason? (LOGOUT, REMOTE, PASSWORD_CHANGED, PASSWORD_RESET, REUSE_DETECTED, NOT_ME, BANNED, ACCOUNT_DELETED, TWO_FACTOR_RESET). Chỉ mục (userId, revokedAt).
Bảng mới RefreshToken	id, sessionId, tokenHash (unique, SHA-256), createdAt, usedAt? (lúc bị đổi sang token mới). Xóa theo Session.
DeviceToken: thêm trường	sessionId? — để xóa đúng token push của phiên bị thu hồi.
User: thêm trường	sessionsValidAfter (DateTime?) — từ chối token cũ không có sid phát hành trước mốc này.

Nội dung JWT	{ sub, sid }, hạn 15 phút.

Endpoint (đề xuất)	**Việc làm**
POST /auth/login, /auth/google, /auth/apple, /auth/2fa/verify	Nhận thêm device { deviceId, deviceName, platform, appVersion }; trả thêm refreshToken, accessTokenExpiresIn.
POST /auth/refresh { refreshToken }	Trả { accessToken, refreshToken }. Lỗi 401 { code: "SESSION_EXPIRED" | "SESSION_REVOKED" | "REFRESH_REUSED" }.
POST /auth/logout	Thu hồi phiên hiện tại (lý do LOGOUT) — thay cho hành vi "không làm gì" hiện nay.
GET /auth/sessions	Danh sách { id, deviceName, platform, city, country, lastUsedAt, createdAt, current }.
DELETE /auth/sessions/:id	Thu hồi một phiên của chính mình.
POST /auth/sessions/revoke-others { currentPassword?, code? }	Thu hồi mọi phiên trừ phiên hiện tại; trả số phiên đã thu hồi.
PATCH /auth/password	Giữ nguyên đầu vào; trả thêm revokedSessions (số).

g) Android, iOS và web

- **Lưu token**: expo-secure-store đã có (Keychain trên iOS, Keystore trên Android). Lưu ý: trên iOS dữ liệu Keychain có thể còn sau khi gỡ app; app nên xóa token cũ ở lần mở đầu tiên sau khi cài lại (đánh dấu bằng một cờ trong bộ nhớ thường).
- **Mã thiết bị**: chuỗi ngẫu nhiên lưu SecureStore. Tạo bằng expo-crypto (randomUUID) — gói Expo chính thức, cần kiểm tra bản cho SDK 57 và cài bằng expo install; gói này cũng dùng cho A6.
- **Tên máy**: expo-device (modelName) cho tên dễ đọc trên cả hai nền tảng — thư viện mới, cài bằng expo install. Nếu không muốn thêm, dùng Platform.OS + Platform.Version (hiện "iOS 18", "Android 14") — kém thân thiện hơn.
- **Làm mới token trong httpClient**: viết bằng fetch có sẵn, không cần thư viện. Socket.IO phải kết nối lại bằng access token mới sau mỗi lần làm mới (hoặc gửi token mới qua handshake khi kết nối lại).
- **Thông báo đẩy**: máy chủ đang gửi qua dịch vụ Expo Push (exp.host), dịch vụ này đi qua APNs cho iOS và FCM cho Android; cần cả hai bộ thông tin (cần kiểm tra đã cấu hình trên EAS cho cả hai).
- **Vị trí theo IP**: dùng cơ sở dữ liệu IP offline (ví dụ GeoLite2 của MaxMind, miễn phí, phải đăng ký tài khoản và cập nhật định kỳ) và một thư viện đọc ở backend —

là phụ thuộc mới, cần chủ dự án đồng ý. Không đòi quyền vị trí trên điện thoại.

- **Proxy**: *main.ts* đặt trust proxy = 1, nghĩa là IP thật lấy đúng khi có đúng một lớp proxy phía trước. Cần kiểm tra lại khi triển khai thật (ví dụ có Cloudflare + load balancer là hai lớp).
- **Web**: chưa có web client. Nếu sau này có, refresh token trên web nên nằm trong cookie HttpOnly, không trong localStorage.
- **Chi phí**: không phát sinh dịch vụ trả phí; thêm một truy vấn nhỏ cho mỗi yêu cầu API.

h) Tiêu chí hoàn thành

- Đăng nhập trên hai máy (một Android, một iPhone), cả hai hiện trong danh sách thiết bị với đúng tên máy và nền tảng.
- Đăng xuất máy kia từ xa: máy kia về màn Đăng nhập ở yêu cầu kế tiếp, socket bị ngắt, không nhận push nữa.
- Đổi mật khẩu: mọi máy khác bị đăng xuất, máy đang dùng vẫn dùng tiếp, email báo đổi mật khẩu được gửi.
- Để app chạy qua 15 phút: token được làm mới tự động, người dùng không bị đăng xuất; nhiều yêu cầu cùng lúc chỉ tạo một lượt làm mới.
- Gửi lại một refresh token cũ sau 30 giây: cả phiên bị thu hồi, có email cảnh báo.
- Bật chế độ máy bay giữa lúc làm mới: không bị đăng xuất oan.
- Bản app cũ (token 30 ngày) vẫn dùng được trong thời gian chuyển đổi.
- Test tự động ở backend: xoay vòng, phát hiện dùng lại, ân hạn 30 giây, thu hồi khi đổi mật khẩu, JwtStrategy từ chối phiên đã thu hồi.
- Báo cáo ghi rõ đã chạy trên Android và iPhone hay chưa.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (2 bảng mới, phát hành/xoay vòng token, JwtStrategy, socket, push token, thu hồi khi đổi/đặt lại mật khẩu và khi khóa tài khoản, email, dọn dẹp, chuyển đổi token cũ). Mobile 3 ngày (lưu 2 token, làm mới trong httpClient, gửi thông tin thiết bị, màn Thiết bị đăng nhập, thông báo bị đăng xuất). Kiểm thử 2 ngày.
- Phụ thuộc: không phụ thuộc mã nào; là nền cho A1, A3, A6 và E2 (xóa tài khoản thu hồi phiên).
- Rủi ro: lỗi ở bước làm mới làm hàng loạt người dùng bị đăng xuất — cần kiểm thử kỹ và phát hành dần; chuyển đổi bản app cũ; cần cập nhật quyết định DEC-008.

A3. Cảnh báo đăng nhập lạ ("Không phải tôi")

Nhóm: Bảo mật tài khoản · Giai đoạn: GĐ2 · Ước lượng: 6 ngày công

a) Mục đích

Khi tài khoản được đăng nhập từ một thiết bị mới hoặc một nơi lạ, chủ tài khoản phải biết ngay và có một nút để chặn kẻ gian chỉ bằng một lần bấm: **"Không phải tôi"**. Người dùng bị lộ mật khẩu phát hiện sớm, trước khi kẻ gian kịp đổi mật khẩu, nhắn tin lừa bạn bè hay xóa dữ liệu.

b) Hiện trạng

- Chưa có cảnh báo đăng nhập nào. Máy chủ không lưu thiết bị, IP hay vị trí của lần đăng nhập (không có trường nào như vậy trong *apps/api/prisma/schema.prisma*).
- Đã có kênh gửi: email qua *apps/api/src/modules/mail/mail.service.ts*; thông báo trong app + Socket.IO + push qua *notifications.service.ts* (hàm notify lưu thông báo, đẩy realtime và gửi push; hàm pushToUser gửi qua dịch vụ Expo Push tới mọi thiết bị của người dùng).
- Bảng *Notification* có trường type dạng chuỗi tự do (thêm loại mới không cần đổi enum) nhưng **actorId bắt buộc**; thông báo bảo mật không có "người gây ra", nên phải dùng chính người dùng làm actor hoặc cho actorId được để trống (cần thống nhất).
- Không có trang web công khai nào ngoài trang quản trị *admin.html* do API phục vụ; link trong email hiện chỉ chứa mã OTP, chưa có link hành động.
- Phụ thuộc vào A2: thông tin thiết bị và khả năng thu hồi một phiên chỉ có sau A2.

c) Cách hoạt động

Luồng 1. Phát hiện và gửi cảnh báo

1. Một lần đăng nhập thành công (sau cả bước 2FA nếu có) tạo phiên mới (A2) kèm mã thiết bị, tên máy, IP, thành phố/quốc gia.
2. Máy chủ xét **thiết bị đã quen chưa**: mã thiết bị này từng có phiên hợp lệ của tài khoản trong 180 ngày qua (không tính phiên bị thu hồi vì "Không phải tôi" hoặc vì token bị đánh cắp). Quen thì không cảnh báo.
3. Thiết bị mới thì xét **nơi đăng nhập**: cùng quốc gia với các phiên trong 90 ngày qua là **mức thường**; quốc gia khác (hoặc không xác định được vị trí) là **mức cao**.
4. Mức thường: thông báo trong app và push tới các thiết bị khác của tài khoản: "Tài khoản vừa đăng nhập trên Samsung Galaxy S23 ở Hà Nội lúc 21:04".

5. Mức cao: như trên, cộng thêm email có nút **"Không phải tôi"** và nút "Đúng là tôi".
6. Máy chủ ghi sự kiện bảo mật, tạo link hành động dùng một lần, hạn 7 ngày.
7. Chủ tài khoản bấm "Đúng là tôi": máy chủ ghi xác nhận, thiết bị đó được coi là quen. Không bấm gì: không có gì xảy ra.

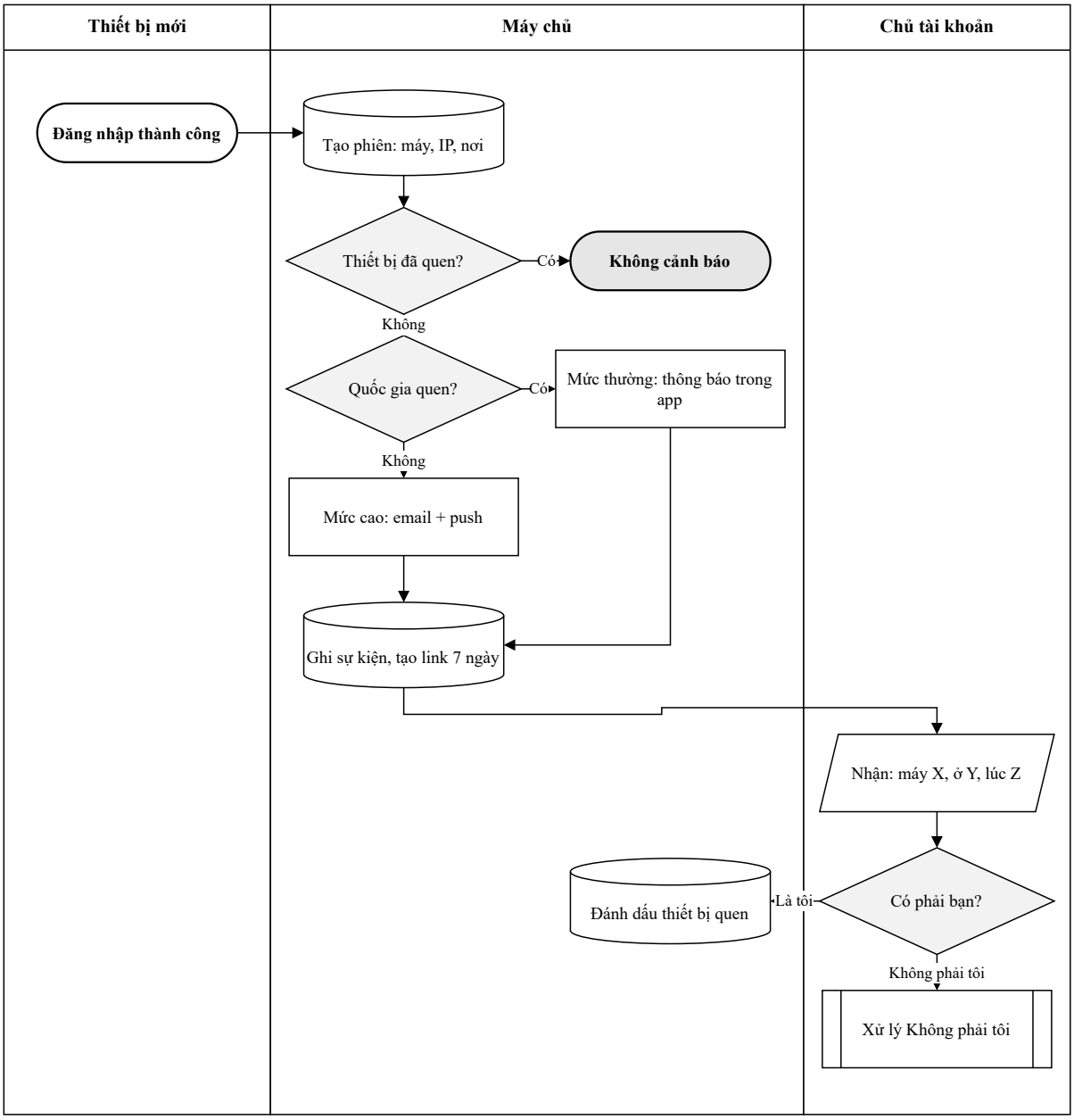
Luồng 2. Bấm "Không phải tôi"

1. Chủ tài khoản bấm "Không phải tôi" trong email hoặc trong thông báo của app.
2. Mở trang xác nhận (trang web do API phục vụ nếu từ email; hộp xác nhận trong app nếu từ app). Trang chỉ hiển thị, **chưa làm gì** — để các trình quét link của dịch vụ email không tự kích hoạt. Người dùng phải bấm "Xác nhận".
3. Máy chủ kiểm tra yêu cầu hợp lệ: link còn hạn và chưa dùng (từ email); hoặc phiên lạ được tạo **sau** phiên đang bấm (từ app — để kẻ gian đang giữ một phiên không dùng nút này đá chủ thật ra).
4. **Từ email** (người bấm có thể không còn vào được app): thu hồi **mọi** phiên, đánh dấu tài khoản "phải đặt lại mật khẩu" (đăng nhập bằng mật khẩu cũ bị từ chối), gửi mã đặt lại mật khẩu qua email như luồng Quên mật khẩu hiện có.
5. **Từ app**: thu hồi phiên lạ (và các phiên tạo sau nó), mở màn Đổi mật khẩu, gợi ý bật 2FA.
6. Máy chủ ghi sự kiện. Nếu nhiều tài khoản bấm "Không phải tôi" với phiên đến từ cùng một IP trong 24 giờ (đề xuất: từ 3 tài khoản), báo cho quản trị viên vì có thể là một đợt dò mật khẩu hàng loạt.
7. Người dùng đặt mật khẩu mới, bật 2FA (A1).

Các sự kiện khác cũng gửi cảnh báo (cùng mẫu thư, cùng nút "Không phải tôi"): đổi mật khẩu (A2), tắt 2FA hoặc đăng nhập bằng mã dự phòng/mã email (A1), refresh token bị dùng lại (A2), tài khoản bị khóa tạm vì sai mật khẩu nhiều lần (A4).

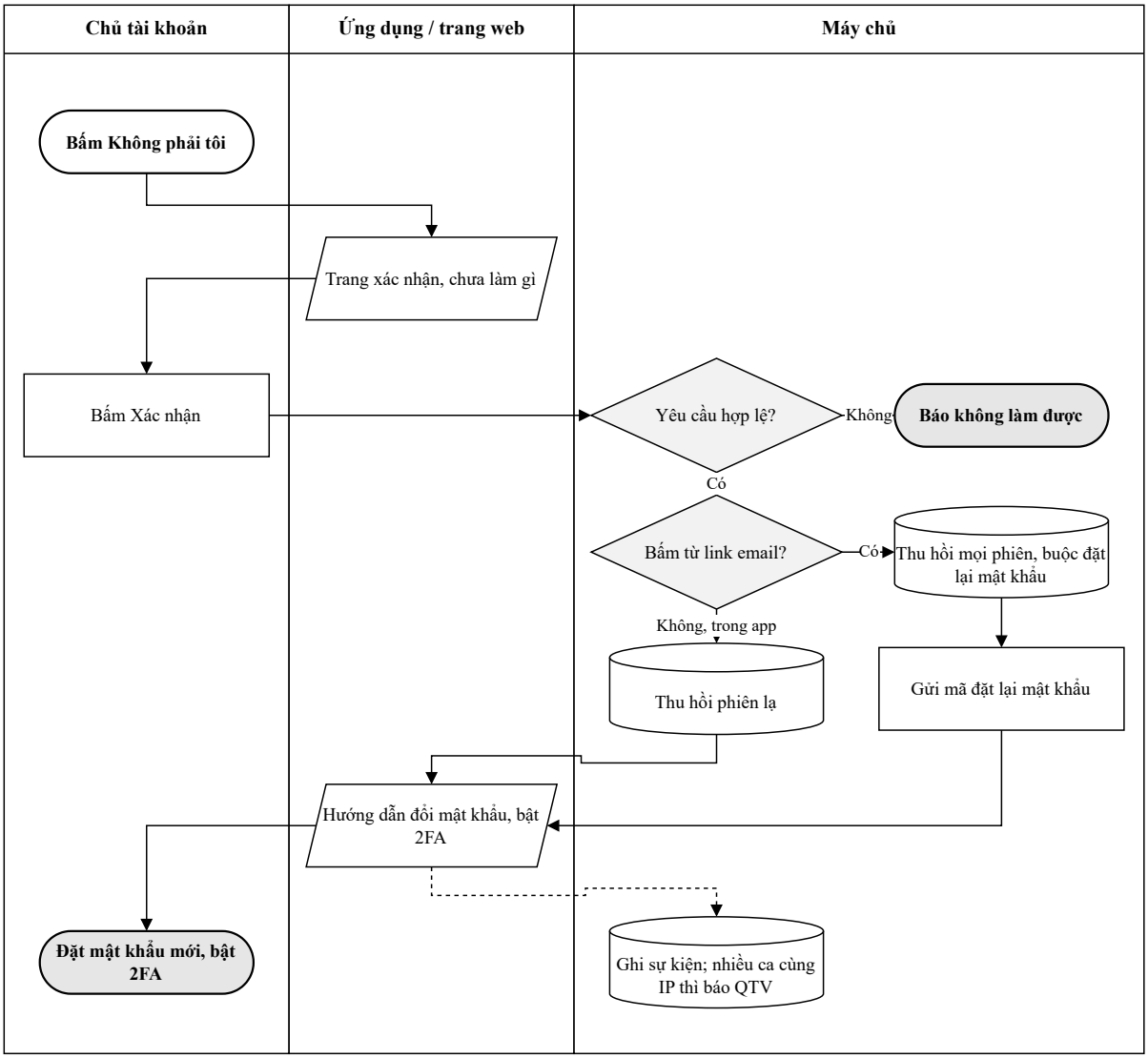
d) Flowchart

Phát hiện đăng nhập lạ:



Hình 11. Phát hiện đăng nhập lạ và gửi cảnh báo

Xử lý "Không phải tôi":



Hình 12. Bấm "Không phải tôi" từ email hoặc trong app

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Con số đề xuất**: thiết bị quen = có phiên hợp lệ trong 180 ngày; nơi quen = quốc gia xuất hiện trong 90 ngày; link hành động hạn 7 ngày, dùng một lần.
- **Chống spam cảnh báo**: tối đa 1 email cảnh báo đăng nhập mỗi thiết bị mới; tối đa 5 email cảnh báo mỗi tài khoản mỗi ngày (các lần sau chỉ thông báo trong app).
- **Lần đăng nhập đầu tiên** của tài khoản (mới đăng ký) không cảnh báo.
- **Vị trí theo IP không chính xác**: mạng di động Việt Nam hay hiện sai thành phố, VPN hiện quốc gia khác. Vì vậy chỉ dùng **quốc gia** để nâng mức cảnh báo, còn thành phố chỉ để hiển thị và ghi "khoảng".
- **Cài lại app**: Android tạo mã thiết bị mới sau khi gỡ app, nên người dùng có thể nhận cảnh báo "thiết bị mới" cho chính máy mình. Chấp nhận được; nội dung cảnh báo nói rõ tên máy để người dùng nhận ra.

- **Tài khoản đang bị khóa**: không gửi cảnh báo đăng nhập (không đăng nhập được), nhưng nút "Không phải tôi" trong email cũ vẫn dùng được để thu hồi phiên và buộc đặt lại mật khẩu.
- **Link hết hạn hoặc đã dùng**: trang báo "Link không còn hiệu lực" và hướng dẫn vào app hoặc dùng Quên mật khẩu.
- **Lạm dụng**: endpoint xác nhận giới hạn 10 lần/giờ/IP; link chứa chuỗi ngẫu nhiên 32 byte, máy chủ chỉ lưu bản băm.
- Nội dung email có câu cảnh báo chống lừa đảo giống thư OTP hiện có ("không bao giờ yêu cầu bạn cung cấp mã").

f) Dữ liệu và API (đề xuất)

Toàn bộ là **đề xuất**, cần đưa vào *docs/api-contract.md* trước khi code.

Thay đổi dữ liệu (Prisma)	**Nội dung**
Bảng mới SecurityEvent	id, userId, type (NEW_DEVICE_LOGIN, PASSWORD_CHANGED, TWO_FACTOR_DISABLED, TWO_FACTOR_FALLBACK_USED, REFRESH_REUSED, LOGIN_LOCKED), level (LOW, HIGH), sessionId?, ip?, city?, country?, deviceName?, actionTokenHash? (unique), actionExpiresAt?, resolvedAt?, resolution? (CONFIRMED, NOT_ME), createdAt. Chỉ mục (userId, createdAt).
User: thêm trường	passwordResetRequiredAt (DateTime?) — đăng nhập bằng mật khẩu trả 401 { code: "PASSWORD_RESET_REQUIRED" } cho tới khi đặt lại.
Session (từ A2)	Dùng các trường deviceId, deviceName, ip, city, country.
Notification	Loại mới type = "SECURITY_ALERT", kèm mã SecurityEvent (thêm trường securityEventId? hoặc dùng bảng riêng — cần thống nhất vì actorId đang bắt buộc).

Endpoint (đề xuất)	**Việc làm**
GET /auth/security-events	Lịch sử sự kiện bảo mật 30 ngày của chính mình (hiện trong mục Bảo mật).
POST /auth/security-events/:id/confirm	"Đúng là tôi".
POST /auth/security-events/:id/not-me	"Không phải tôi" từ trong app; thu hồi phiên lạ nếu nó mới hơn phiên đang bấm.
GET /security/not-me?token=…	Trang HTML xác nhận (không thay đổi gì).

POST /security/not-me { token }	Thực hiện: thu hồi mọi phiên, buộc đặt lại mật khẩu, gửi mã đặt lại.
POST /auth/login	Thêm lỗi 401 { code: "PASSWORD_RESET_REQUIRED" }; app chuyển sang màn Quên mật khẩu.

g) Android, iOS và web

- **Không cần quyền vị trí**: vị trí suy từ IP ở máy chủ (cơ sở dữ liệu IP offline như GeoLite2, xem A2).
- **Thông báo đẩy**: dùng pushToUser hiện có qua Expo Push (APNs cho iOS, FCM cho Android). Nếu người dùng tắt quyền thông báo, vẫn còn email và thông báo trong app. Bấm vào push mở thẳng màn chi tiết cảnh báo (deep link scheme mobilesocial:// đã khai trong app.json; cần kiểm tra xử lý mở từ push trên cả hai nền tảng).
- **Trang "Không phải tôi"** là trang web do API phục vụ (giống admin.html), mở được trong mọi trình duyệt trên điện thoại hay máy tính; phải chạy qua HTTPS ở bản thật.
- **Hộp xác nhận trong app** dùng ConfirmModal sẵn có trong Cài đặt — chạy trên cả hai nền tảng.
- **Chi phí**: không có dịch vụ trả phí bắt buộc. Nếu chọn dịch vụ tra IP trực tuyến thay vì cơ sở dữ liệu offline thì có phí theo lượt (không khuyến nghị).

h) Tiêu chí hoàn thành

- Đăng nhập trên một máy mới (Android) khi đang có phiên trên iPhone: iPhone nhận push và thông báo trong app có đúng tên máy, nơi, giờ. Đổi chiều lại (iPhone mới, Android cũ) cũng đúng.
- Giả lập IP nước ngoài: email cảnh báo mức cao được gửi, nút "Không phải tôi" mở trang xác nhận; chỉ mở link (không bấm Xác nhận) không làm thay đổi gì.
- Bấm Xác nhận: mọi phiên bị thu hồi, đăng nhập bằng mật khẩu cũ bị từ chối với PASSWORD_RESET_REQUIRED, đặt lại mật khẩu xong thì đăng nhập được.
- Từ app: phiên lạ mới hơn bị thu hồi; phiên cũ hơn không thu hồi được bằng nút này.
- Link dùng lần hai hoặc quá 7 ngày bị từ chối.
- Thiết bị quen đăng nhập lại không sinh cảnh báo.
- Test tự động: quy tắc thiết bị quen/nơi quen, giới hạn email mỗi ngày, link dùng một lần.
- Báo cáo ghi rõ nền tảng đã chạy.

i) Ước lượng và phụ thuộc

- Backend 3 ngày (quy tắc phát hiện, SecurityEvent, mẫu email, trang xác nhận, thu hồi + buộc đặt lại mật khẩu, báo quản trị viên). Mobile 2 ngày (loại thông báo mới, màn chi tiết cảnh báo với hai nút, xử lý PASSWORD_RESET_REQUIRED, lịch sử bảo mật). Kiểm thử 1 ngày.
- Phụ thuộc: **A2** (bắt buộc — phiên, thiết bị, thu hồi). Liên quan A1, A4 (dùng chung mẫu cảnh báo), D8 (thông báo đẩy hoàn chỉnh, cài đặt thông báo — cảnh báo bảo mật không được để người dùng tắt hẳn).
- Rủi ro: cảnh báo sai (vị trí IP lệch) làm người dùng hoảng; email bị vào thư rác (cần SPF/DKIM cho tên miền gửi thư — cần kiểm tra cấu hình SMTP hiện tại).

A4. Chống dò mật khẩu

Nhóm: Bảo mật tài khoản · Giai đoạn: GĐ1 · Ước lượng: 4 ngày công

a) Mục đích

Kẻ gian thường thử hàng loạt mật khẩu cho một tài khoản, hoặc thử các cặp email/mật khẩu bị lộ từ trang khác trên rất nhiều tài khoản. Tính năng này làm việc thử chậm dần, khóa tạm khi sai quá nhiều, và báo cho chủ tài khoản qua email. Người dùng bình thường gõ nhầm vài lần không bị ảnh hưởng.

b) Hiện trạng

- Đã có **@nestjs/throttler** (*apps/api/src/app.module.ts*): mặc định 300 yêu cầu/phút cho mỗi IP trên toàn API. Trong *auth.controller.ts*: đăng nhập 10 lần/phút/IP, đăng ký 10 lần/giờ, xác minh email 10 lần/phút, gửi lại mã 10 lần/giờ, quên mật khẩu 10 lần/giờ, đặt lại mật khẩu 10 lần/phút. Đăng nhập Google không có giới hạn riêng (chỉ có mức chung 300/phút).
- Throttler đang đếm **theo IP** và lưu **trong bộ nhớ** của tiến trình API (không cấu hình nơi lưu khác) — chạy nhiều bản API thì mỗi bản đếm riêng. Kẻ gian đổi IP (mạng botnet) là vượt qua.
- **Không có đếm sai theo tài khoản**, không khóa tạm, không email báo. Có 10 lần/phút/IP thì một IP vẫn thử được 14.400 mật khẩu mỗi ngày cho một tài khoản.
- Hàm login trong *auth.service.ts*: nếu email không tồn tại thì trả lỗi **ngay**, còn email có thật thì chạy bcrypt (chậm hơn rõ rệt). Đo thời gian phản hồi là biết email nào đã đăng ký. Cần sửa cùng tính năng này.
- Các mã OTP email (xác minh, đặt lại mật khẩu) đã có giới hạn tốt: sai tối đa 5 lần mỗi mã, gửi tối đa 3 mã mỗi giờ (bảng *AuthToken*, trường attemptCount).
- PATCH /auth/password trả 400 khi mật khẩu cũ sai và chỉ có giới hạn chung 300/phút — có thể bị dùng để dò mật khẩu nếu kẻ gian cầm được một phiên.
- *main.ts* đặt trust proxy = 1 nên IP được lấy từ header của một lớp proxy (cần kiểm tra khi triển khai thật).

c) Cách hoạt động

Luồng chính. Đăng nhập bằng mật khẩu

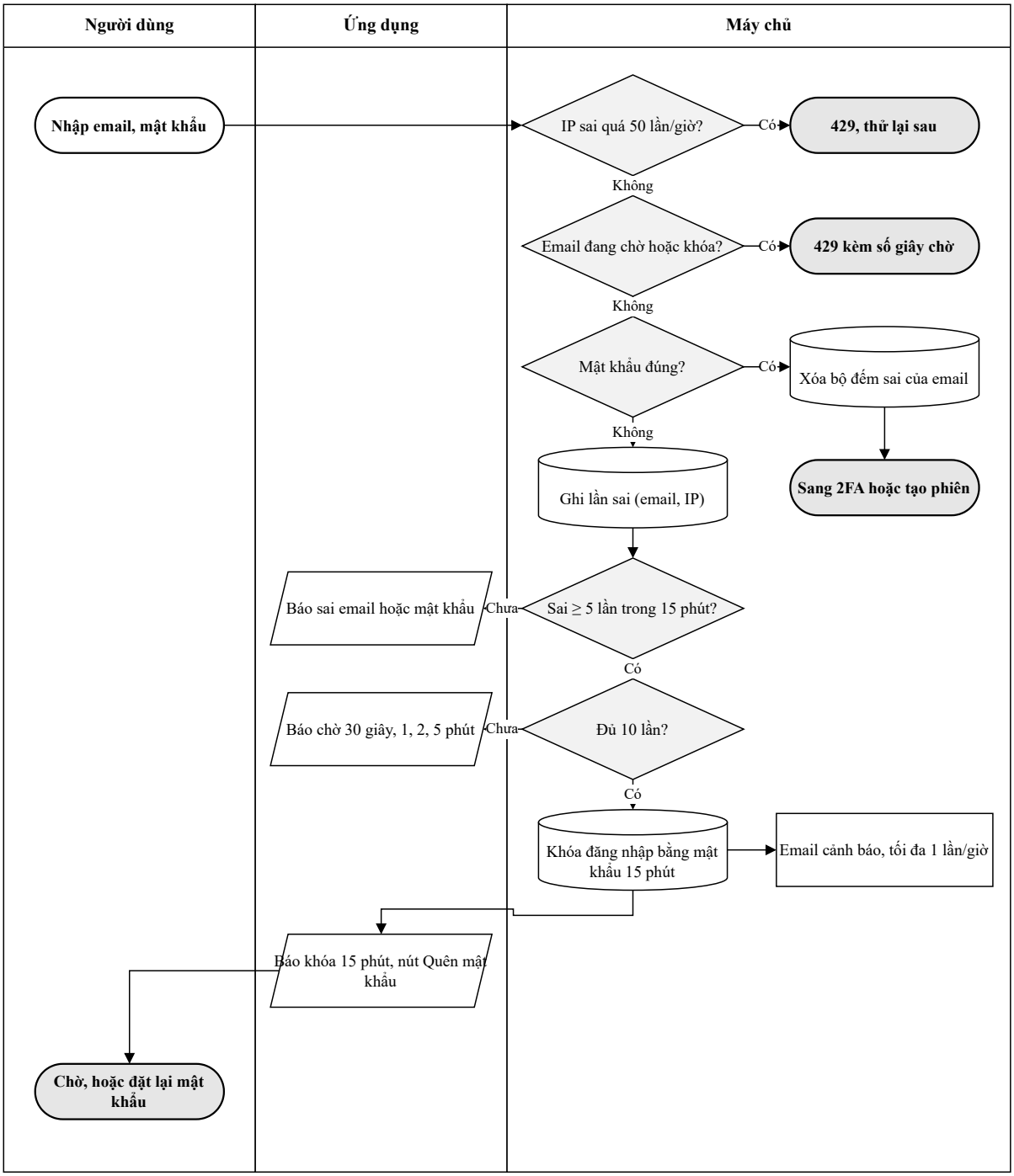
1. Người dùng nhập email và mật khẩu.
2. Máy chủ kiểm tra **IP**: IP này đã sai quá 50 lần trong 1 giờ (cộng mọi email) thì trả 429 "Thử lại sau" trong 1 giờ. Mục đích: chặn một máy thử hàng loạt tài khoản.

3. Máy chủ kiểm tra **email**: email này đang trong thời gian phải chờ hoặc đang bị khóa thì trả 429 kèm số giây còn phải chờ. Kiểm tra theo email chuẩn hóa, kể cả email không tồn tại, để không lộ email nào có đăng ký.
4. Máy chủ so mật khẩu bằng bcrypt. Email không tồn tại thì vẫn so với một bản băm giả để thời gian trả lời như nhau.
5. Đúng: xóa bộ đếm sai của email đó, đi tiếp sang 2FA (A1) hoặc tạo phiên (A2).
6. Sai: ghi một lần sai (email đã băm, IP, thời điểm) rồi đếm số lần sai của email trong 15 phút:
    - Dưới 5 lần: báo "Sai email hoặc mật khẩu" như hiện nay.
    - Từ lần thứ 5 đến thứ 9: **chậm dần** — phải chờ 30 giây, rồi 1 phút, 2 phút, 5 phút, 5 phút mới được thử tiếp. App hiện đếm ngược và nút "Quên mật khẩu".
    - Lần thứ 10: **khóa đăng nhập bằng mật khẩu 15 phút** và gửi email cho chủ tài khoản (nếu email có thật): "Có người đã nhập sai mật khẩu nhiều lần. Nếu không phải bạn, hãy đổi mật khẩu và bật xác thực hai lớp" kèm nút "Không phải tôi" (A3).
7. Người dùng chờ hết thời gian, hoặc dùng "Quên mật khẩu": đặt lại mật khẩu thành công thì xóa luôn bộ đếm và mở khóa.

Các chỗ khác cũng đếm sai (cùng bảng, cùng quy tắc nhưng con số riêng):

- Mật khẩu cũ khi đổi mật khẩu, hỏi lại mật khẩu khi bật/tắt 2FA hoặc đăng xuất tất cả: sai 5 lần trong 15 phút thì phải chờ 15 phút (trả 429, không trả 401 để app không tự đăng xuất).
- Mã 2FA: theo quy tắc trong A1 (5 lần mỗi phiếu, 10 lần mỗi giờ mỗi tài khoản).
- Đăng nhập Google/Apple không dùng mật khẩu nên không bị khóa bởi tính năng này; chỉ giữ giới hạn theo IP (đề xuất thêm 20 lần/phút/IP cho /auth/google và /auth/apple).

d) Flowchart



Hình 13. Chống dò mật khẩu: chậm dần, khóa tạm, báo qua email

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Con số đề xuất**: cửa sổ 15 phút theo email; chờ 30 giây / 1 / 2 / 5 / 5 phút cho lần sai 5–9; khóa 15 phút ở lần 10; IP sai quá 50 lần/giờ thì chặn IP 1 giờ; email cảnh báo tối đa 1 lần/giờ/tài khoản.
- **Vì sao chặn IP ở mức 50 chứ không thấp hơn**: ở Việt Nam nhiều thuê bao di động và mạng trường học dùng chung một IP (CGNAT). Đặt thấp sẽ chặn oan cả nghìn người. Chỉ đếm lần **sai**, không đếm lần đúng.

- **Khóa không phải là khóa tài khoản**: chỉ khóa đăng nhập bằng mật khẩu. Các phiên đang mở vẫn dùng bình thường; đăng nhập Google/Apple vẫn được; "Quên mật khẩu" vẫn được. Như vậy kẻ gian không thể cố tình khóa người khác ra ngoài lâu dài.
- **Không lộ email**: thông báo lỗi, mã lỗi và thời gian phản hồi giống nhau dù email có tồn tại hay không. Email cảnh báo chỉ gửi khi tài khoản có thật.
- **Tài khoản bị quản trị viên khóa** (bannedAt) và khóa vì tuổi: giữ nguyên lỗi hiện có (ACCOUNT_BANNED, AGE_RESTRICTED), nhưng chỉ trả sau khi mật khẩu đúng, như code hiện nay.
- **Nhiều bản API**: bộ đếm nằm trong cơ sở dữ liệu nên đúng cả khi chạy nhiều bản. Riêng throttler hiện có vẫn lưu trong bộ nhớ; khi chạy nhiều bản cần chuyển sang nơi lưu chung (Redis) — ghi nhận, chưa cần làm ngay.
- **Dọn dẹp**: xóa bản ghi lần sai quá 24 giờ (chạy định kỳ mỗi giờ).
- **CAPTCHA**: chưa đề xuất ở giai đoạn này (cần dịch vụ ngoài và giao diện riêng cho mỗi nền tảng). Có thể xem lại nếu số lần thử hàng loạt tăng.

f) Dữ liệu và API (đề xuất)

Toàn bộ là **đề xuất**, cần đưa vào *docs/api-contract.md* trước khi code.

Thay đổi dữ liệu (Prisma)	**Nội dung**
Bảng mới LoginFailure	id, kind (PASSWORD_LOGIN, PASSWORD_CONFIRM), emailHash (HMAC của email chuẩn hóa, không lưu email gốc), userId?, ip, createdAt. Chỉ mục (emailHash, createdAt) và (ip, createdAt).
User: thêm trường	lastLockEmailAt (DateTime?) — để giới hạn 1 email cảnh báo mỗi giờ. Khi đã có A3 thì có thể thay bằng SecurityEvent loại LOGIN_LOCKED.

Thay đổi API (đề xuất)	**Nội dung**
POST /auth/login	Thêm phản hồi 429 { code: "LOGIN_THROTTLED", retryAfterSeconds } và header Retry-After. Lỗi sai mật khẩu giữ nguyên 401 như hiện nay.
PATCH /auth/password và các chỗ hỏi lại mật khẩu	Thêm 429 { code: "PASSWORD_CONFIRM_THROTTLED", retryAfterSeconds }.
POST /auth/reset-password	Thành công thì xóa LoginFailure của email đó.

POST /auth/google (và /auth/apple)	Thêm @Throttle riêng 20 lần/phút/IP.

g) Android, iOS và web

- Chỉ thay đổi ở máy chủ và cách app hiển thị lỗi 429: hiện đếm ngược "Thử lại sau 1:45" và nút "Quên mật khẩu" trên LoginScreen. Không cần thư viện, không cần quyền thiết bị, giống nhau trên Android và iOS.
- Cần kiểm tra httpClient của app đã đọc được nội dung lỗi 429 (hiện nó phân loại lỗi theo mã trạng thái; 401 là "unauthorized").
- Màn đăng nhập hiện vẫn hiển thị tiếng Anh (theo báo cáo tính năng); thông báo mới nên viết tiếng Việt.
- Chi phí: không có. Email dùng SMTP hiện có.

h) Tiêu chí hoàn thành

- Sai mật khẩu 4 lần: vẫn thử ngay được. Lần 5: phải chờ 30 giây, app hiện đếm ngược. Lần 10: khóa 15 phút, email cảnh báo đến hộp thư.
- Trong lúc khóa: đăng nhập Google vẫn được; "Quên mật khẩu" đặt lại xong đăng nhập được ngay.
- Email không tồn tại: thông báo, mã lỗi và thời gian phản hồi giống email có thật (đo trung bình 20 lần, chênh lệch dưới 50 ms).
- 51 lần sai từ một IP với nhiều email khác nhau: IP bị chặn 1 giờ.
- Sai mật khẩu cũ 5 lần ở màn Đổi mật khẩu: app hiện chờ, không bị đăng xuất.
- Chạy trên Android và iPhone (màn đăng nhập hiển thị đúng đếm ngược và nút).
- Test tự động ở backend cho từng ngưỡng và cho việc xóa bộ đếm.

i) Ước lượng và phụ thuộc

- Backend 2 ngày, mobile 1 ngày, kiểm thử 1 ngày.
- Phụ thuộc: không phụ thuộc mã nào. Nút "Không phải tôi" trong email cần A3 (làm A4 trước thì email chỉ có hướng dẫn đổi mật khẩu).
- Rủi ro: đặt ngưỡng IP quá thấp chặn oan người dùng dùng chung mạng; IP lấy sai nếu cấu hình proxy khi triển khai khác với trust proxy = 1.

A5. Xác thực số điện thoại (OTP qua SMS)

Nhóm: Bảo mật tài khoản · Giai đoạn: GĐ1 nếu luật bắt buộc, nếu không thì GĐ4 · Ước lượng: 6 ngày công (chưa tính thời gian đăng ký với nhà mạng)

a) Mục đích

Người dùng nhập số điện thoại, nhận mã 6 số qua SMS và nhập lại để chứng minh số đó là của mình. Lý do chính là **pháp lý**: theo hiểu biết hiện có, Nghị định 147/2024/NĐ-CP (về quản lý, cung cấp, sử dụng dịch vụ Internet và thông tin trên mạng, có hiệu lực từ 25/12/2024) yêu cầu mạng xã hội hoạt động tại Việt Nam xác thực tài khoản người dùng bằng số điện thoại di động Việt Nam (hoặc cách khác với người không có số). **Luật sư phải xác nhận**: Nghị định có áp dụng cho sản phẩm này không (quy mô, có cần giấy phép mạng xã hội không), thời điểm phải áp dụng với tài khoản cũ, cách xử lý người dùng nước ngoài, và yêu cầu lưu trữ dữ liệu. Lợi ích phụ: khó tạo tài khoản ảo hàng loạt hơn.

b) Hiện trạng

- Chưa có gì về số điện thoại: bảng *User* trong *apps/api/prisma/schema.prisma* không có trường số điện thoại; không có dịch vụ SMS; không có biến môi trường cho nhà cung cấp SMS trong *apps/api/.env.example* (cần kiểm tra lại khi làm).
- Khuôn mã OTP đã có và dùng lại được: bảng *AuthToken*, mã 6 số tạo bằng randomInt, băm HMAC-SHA256 với *OTP_HASH_SECRET*, hạn 5 phút, sai tối đa 5 lần, gửi tối đa 3 lần/giờ (*auth.service.ts*, hàm issueVerificationOtp và verifyEmail).
- Đăng ký hiện bắt email, tên người dùng, mật khẩu, ngày sinh (*dto/register.dto.ts*); tài khoản Google tạo mới chưa có ngày sinh và được hỏi sau (BirthDateScreen). Số điện thoại có thể đi theo cùng cách "hỏi sau khi đăng nhập".

c) Cách hoạt động

Luồng 1. Thêm và xác minh số

1. Người dùng vào Cài đặt, Tài khoản, **Số điện thoại** (hoặc bị app đưa tới màn này nếu luật bắt buộc và tài khoản chưa có số).
2. App hiện ô nhập số, mặc định đầu số +84. Người dùng nhập số, bấm Gửi mã.
3. Máy chủ chuẩn hóa số về dạng quốc tế (ví dụ 0912 345 678 thành +84912345678), kiểm tra đúng đầu số di động Việt Nam và số chưa được tài khoản khác xác minh. Sai: báo lỗi.
4. Máy chủ kiểm tra giới hạn gửi (xem mục e). Vượt: trả 429 "Thử lại sau".

5. Máy chủ tạo mã 6 số, lưu bản băm (gắn với cả tài khoản và số điện thoại), hạn 5 phút, rồi gọi nhà cung cấp SMS gửi tin: "Ma xac minh cua ban la 123456. Khong chia se ma nay voi bat ky ai." (SMS thương hiệu thường gửi không dấu).
6. App hiện ô nhập mã và nút "Gửi lại" sau 60 giây.
7. Người dùng nhập mã. Máy chủ kiểm tra; sai thì báo, sai 5 lần thì hủy mã, phải gửi mã mới.
8. Đúng: lưu số điện thoại và thời điểm xác minh. App báo "Đã xác minh số điện thoại".

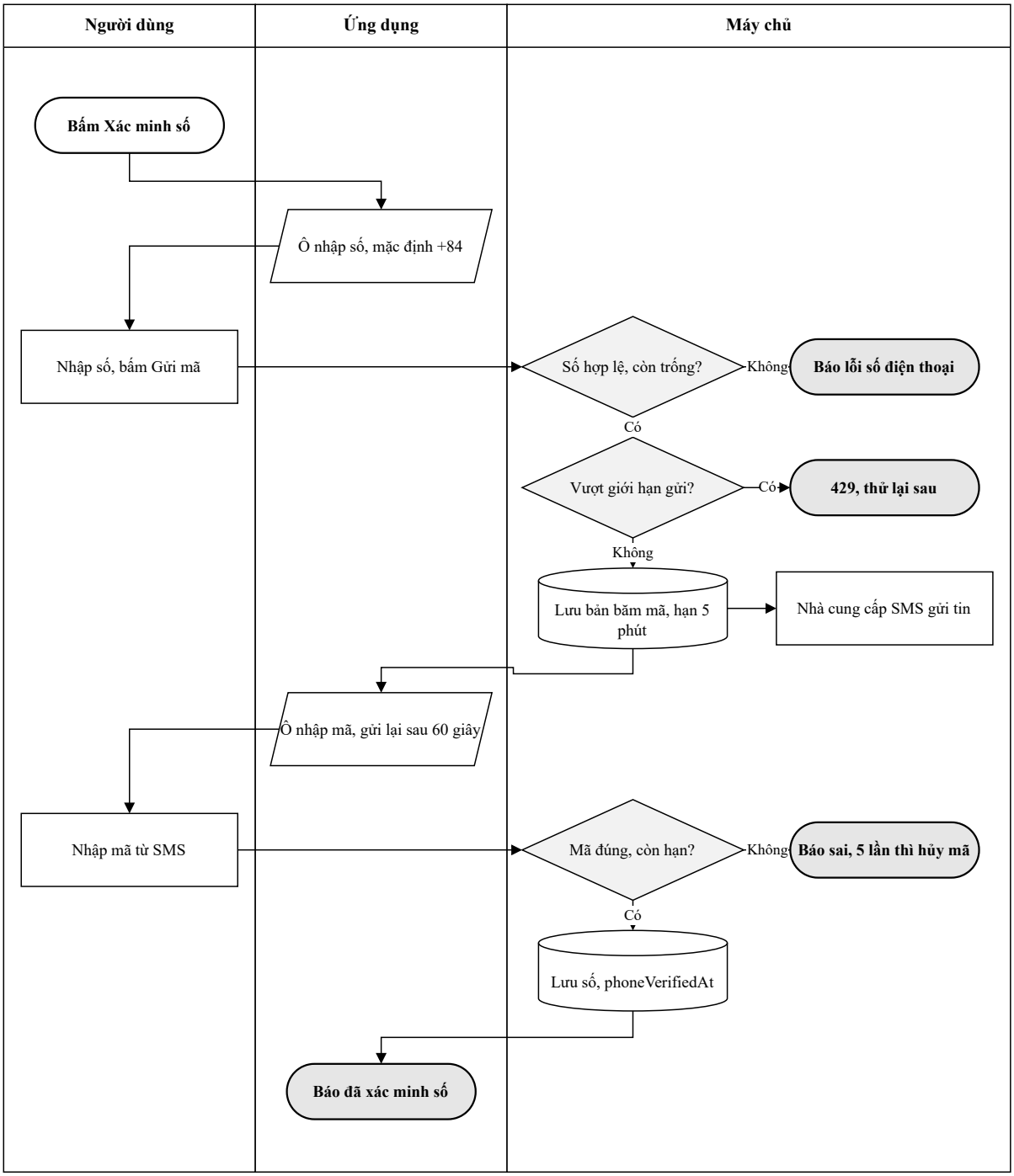
Luồng 2. Đổi số

1. Người dùng bấm "Đổi số", nhập lại mật khẩu (hoặc mã 2FA), rồi làm lại luồng 1 với số mới.
2. Số cũ chỉ bị thay khi số mới đã xác minh xong. Máy chủ gửi email "Số điện thoại của bạn vừa được đổi" kèm nút "Không phải tôi" (A3).

Luồng 3 (chỉ khi luật bắt buộc). Tài khoản chưa xác minh số

1. Tài khoản mới: sau khi xác minh email (và khai ngày sinh), app đưa tới màn xác minh số trước khi vào bảng tin.
2. Tài khoản cũ: có thời gian ân hạn (đề xuất 30 ngày, có banner nhắc). Hết ân hạn: vẫn xem được nội dung nhưng không đăng bài, bình luận, nhắn tin cho đến khi xác minh — máy chủ trả 403 { code: "PHONE_VERIFICATION_REQUIRED" }, app đưa tới màn xác minh.

d) Flowchart



Hình 14. Xác thực số điện thoại bằng mã OTP qua SMS

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Giới hạn gửi SMS** (đề xuất): 1 tin mỗi 60 giây; 3 tin mỗi giờ cho một số; 5 tin mỗi ngày cho một tài khoản; 20 tin mỗi giờ cho một IP; tổng cả hệ thống quá ngân sách ngày (ví dụ 2.000 tin) thì dừng gửi và báo quản trị viên. Lý do: kẻ gian hay lợi dụng chức năng gửi SMS để gửi tin hàng loạt (lừa đảo "SMS pumping"), chủ app phải trả tiền.

- **Chỉ nhận số di động Việt Nam** ở giai đoạn đầu (+84, đầu số 03, 05, 07, 08, 09). Số nước ngoài: chờ luật sư hướng dẫn.
- **Một số chỉ xác minh cho một tài khoản** (đề xuất; chủ dự án quyết). Số đã thuộc tài khoản khác thì báo "Số này đã được dùng"; nếu người dùng nói số là của mình (nhà mạng cấp lại số cũ của người khác), cho xác minh và gỡ số khỏi tài khoản cũ, gửi email báo tài khoản cũ.
- **Không dùng SMS để đăng nhập hay làm 2FA**: SIM có thể bị chiếm (kẻ gian làm lại SIM). Số điện thoại chỉ để xác thực danh tính theo luật.
- **Riêng tư**: số điện thoại không hiện trên hồ sơ công khai, không dùng để gợi ý kết bạn nếu chưa hỏi ý người dùng. Trong app chỉ hiện dạng che (+84 91* *** 678). Đây là dữ liệu cá nhân theo quy định bảo vệ dữ liệu cá nhân (Nghị định 13/2023/NĐ-CP và văn bản mới hơn nếu có) — luật sư xác nhận cách lưu và thời gian lưu.
- **SMS không tới**: nhà mạng chặn, máy hết sóng. Nút "Gửi lại" sau 60 giây; sau 3 lần vẫn không tới thì hiện hướng dẫn liên hệ hỗ trợ. Máy chủ ghi trạng thái nhà cung cấp trả về để tra lỗi.
- **Tài khoản bị khóa**: không gửi SMS.
- **Xóa tài khoản** (E2): xóa số điện thoại, nhật ký gửi SMS giữ ở dạng đã băm số (để chống lạm dụng) trong thời gian luật cho phép.

f) Dữ liệu và API (đề xuất)

Toàn bộ là **đề xuất**, cần đưa vào *docs/api-contract.md* trước khi code.

Thay đổi dữ liệu (Prisma)	**Nội dung**
User: thêm trường	phoneNumber (String?, unique, dạng +84…), phoneVerifiedAt (DateTime?).
AuthTokenPurpose: thêm giá trị	PHONE_VERIFICATION. AuthToken thêm trường target (String?) chứa số đang xác minh; bản băm mã gồm cả số điện thoại để mã không dùng được cho số khác.
Bảng mới SmsLog	id, phoneHash, userId?, ip, provider, providerMessageId?, status (SENT, FAILED, DELIVERED), costVnd?, createdAt. Dùng để đếm giới hạn theo số/IP, đối soát chi phí và tra lỗi.

Endpoint (đề xuất)	**Việc làm**
POST /users/me/phone { phoneNumber, currentPassword? }	Kiểm tra, gửi mã SMS. Trả { resendAfterSeconds: 60 }. currentPassword bắt buộc khi đổi số đã xác minh.

POST /users/me/phone/verify { phoneNumber, code }	Xác minh mã, lưu số.
GET /users/me	Thêm phoneNumberMasked và phoneVerified.
Các endpoint đăng bài, bình luận, nhắn tin (chỉ khi luật bắt buộc)	Trả 403 { code: "PHONE_VERIFICATION_REQUIRED" } khi tài khoản chưa xác minh số và đã hết ân hạn.

Biến môi trường mới (tùy nhà cung cấp): SMS_PROVIDER, SMS_API_KEY, SMS_BRANDNAME, SMS_DAILY_BUDGET.

g) Android, iOS và web

- **Không xin quyền đọc SMS**. Google Play hạn chế quyền READ_SMS và hầu như không duyệt cho mục đích này. Thay vào đó dùng tự điền mã có sẵn của hệ điều hành: ô nhập mã đặt textContentType="oneTimeCode" (iOS gợi ý mã ngay trên bàn phím) và autoComplete="sms-otp" (Android gợi ý mã) — đều là thuộc tính có sẵn của TextInput, không cần thư viện, không cần sửa app.json.
- Ô nhập số: keyboardType="phone-pad", textContentType="telephoneNumber", autoComplete="tel".
- Không cần thư viện mobile mới. Ở backend gọi API nhà cung cấp bằng fetch có sẵn; chỉ thêm SDK của nhà cung cấp nếu thật cần.
- **Dịch vụ ngoài và chi phí**:
  - Nhà cung cấp SMS trong nước (ví dụ eSMS, SpeedSMS, Stringee, VNPT, Viettel qua đại lý): phải đăng ký **tên thương hiệu** (brandname) với từng nhà mạng, cần giấy tờ doanh nghiệp và mẫu nội dung tin; thường mất 1–4 tuần. Giá thường từ vài trăm đến khoảng 1.000 đồng một tin tùy nhà mạng và gói — **cần lấy báo giá**.
  - Nhà cung cấp quốc tế (ví dụ Twilio Verify): tích hợp nhanh hơn nhưng giá gửi về Việt Nam thường cao hơn nhiều và tin có thể bị nhà mạng lọc nếu không có brandname — cần báo giá và thử thực tế.
  - Phương án rẻ hơn cần luật sư xem: gửi mã qua Zalo (Zalo ZNS) — người dùng nhận mã trong Zalo gắn với số điện thoại; cần tài khoản Zalo OA đã xác thực. Chưa chắc phương án này đáp ứng yêu cầu "xác thực bằng số điện thoại" của Nghị định.
  - Ước tính ví dụ (đề xuất, để lập ngân sách): 10.000 người dùng mới × khoảng 1,3 tin mỗi người (tính cả gửi lại) × 800 đồng ≈ 10,4 triệu đồng.
- **Web**: chưa có web client; không ảnh hưởng.

h) Tiêu chí hoàn thành

- Nhận được SMS thật trên số Viettel, Vinaphone, Mobifone (ít nhất 3 nhà mạng lớn); nhập mã thành công.
- iPhone gợi ý mã từ SMS trên bàn phím; Android gợi ý mã (trên máy có dịch vụ Google). Báo cáo ghi rõ đã thử trên máy nào.
- Gửi lần 4 trong 1 giờ cho cùng số bị từ chối; vượt ngân sách ngày thì dừng gửi và quản trị viên được báo.
- Số đã thuộc tài khoản khác bị từ chối; mã sai 5 lần bị hủy; mã hết hạn sau 5 phút.
- Đổi số cần mật khẩu, có email báo.
- Nếu bắt buộc: tài khoản chưa xác minh không đăng bài/bình luận/nhắn tin được sau ân hạn, app dẫn tới màn xác minh.
- Test tự động: chuẩn hóa số, giới hạn gửi, ràng buộc mã với số; nhà cung cấp SMS được thay bằng bản giả trong test.

i) Ước lượng và phụ thuộc

- Backend 3 ngày (chuẩn hóa số, gửi/kiểm mã, tích hợp một nhà cung cấp, giới hạn và ngân sách, chặn hành động khi bắt buộc). Mobile 2 ngày (màn nhập số, màn nhập mã, mục trong Cài đặt, xử lý PHONE_VERIFICATION_REQUIRED). Kiểm thử 1 ngày (cần SIM thật của nhiều nhà mạng).
- Thời gian chờ ngoài code: đăng ký brandname 1–4 tuần; ý kiến luật sư.
- Phụ thuộc: không phụ thuộc mã nào. Liên quan A3 (email báo đổi số), E2 (xóa tài khoản).
- Rủi ro: chi phí SMS tăng do lạm dụng; tin bị chậm hoặc bị chặn; yêu cầu pháp lý thay đổi; người dùng ngại cho số điện thoại làm giảm số đăng ký.

A6. Đăng nhập bằng Apple

Nhóm: Bảo mật tài khoản · Giai đoạn: GĐ1 · Ước lượng: 5 ngày công

a) Mục đích

App có nút Đăng nhập bằng Google. Quy định App Store (mục 4.8 "Login Services") yêu cầu app dùng đăng nhập qua bên thứ ba phải có thêm một lựa chọn đăng nhập tương đương bảo vệ riêng tư (chỉ lấy tên và email, cho ẩn email, không theo dõi quảng cáo). Đăng nhập bằng Apple đáp ứng điều này và là cách phổ biến nhất. Thiếu nó, bản iOS có thể bị từ chối khi nộp lên App Store. Người dùng iPhone cũng được lợi: đăng nhập bằng Face ID, có thể giấu email thật.

b) Hiện trạng

- Chưa có Đăng nhập bằng Apple ở cả backend và mobile. Báo cáo tính năng (*docs/report/bao-cao-tinh-nang.template.html*) cũng ghi "Nếu bật [Google] trên iOS thì App Store yêu cầu thêm Đăng nhập bằng Apple, phần này chưa có".
- Đăng nhập Google đã có: backend *auth.service.ts* (loginWithGoogle) và *google-verifier.service.ts* kiểm tra idToken với *GOOGLE_WEB_CLIENT_ID*; tìm người dùng theo googleId, nếu không có thì theo email và tự gắn vào tài khoản cũ, nếu vẫn không có thì tạo tài khoản mới (không có mật khẩu, chưa có ngày sinh). Kiểm tra bannedAt và ageLockedAt rồi cấp JWT 30 ngày. Đăng nhập Apple nên đi theo đúng khuôn này.
- Mobile: *services/googleSignIn.ts* dùng @react-native-google-signin/google-signin; nút Google chỉ hiện khi có *EXPO_PUBLIC_GOOGLE_WEB_CLIENT_ID* (*config/google.ts*) và hiện như nhau trên Android và iOS (*LoginScreen.tsx*).
- *app.json*: ios.bundleIdentifier và android.package đều là com.mobilesocial.app; plugin Google được khai **không kèm tùy chọn** (không thấy iosUrlScheme) — cần kiểm tra đăng nhập Google trên iOS đã thật sự được cấu hình chưa. Chưa có ios.usesAppleSignIn.
- Tài khoản không có mật khẩu đã đặt được mật khẩu đầu tiên trong Cài đặt (*ChangePasswordScreen.tsx*, user.hasPassword) — dùng được cho người dùng Apple chuyển sang Android.
- Xóa tài khoản đã có (DELETE /users/me trong *users.controller.ts*); khi có Apple thì phải thêm bước thu hồi quyền với Apple (xem mục e).
- Màn ngày sinh (*BirthDateScreen.tsx*) đã hỏi ngày sinh cho tài khoản thiếu — dùng lại cho tài khoản Apple mới.

c) Cách hoạt động

Luồng chính. Đăng nhập bằng Apple trên iPhone

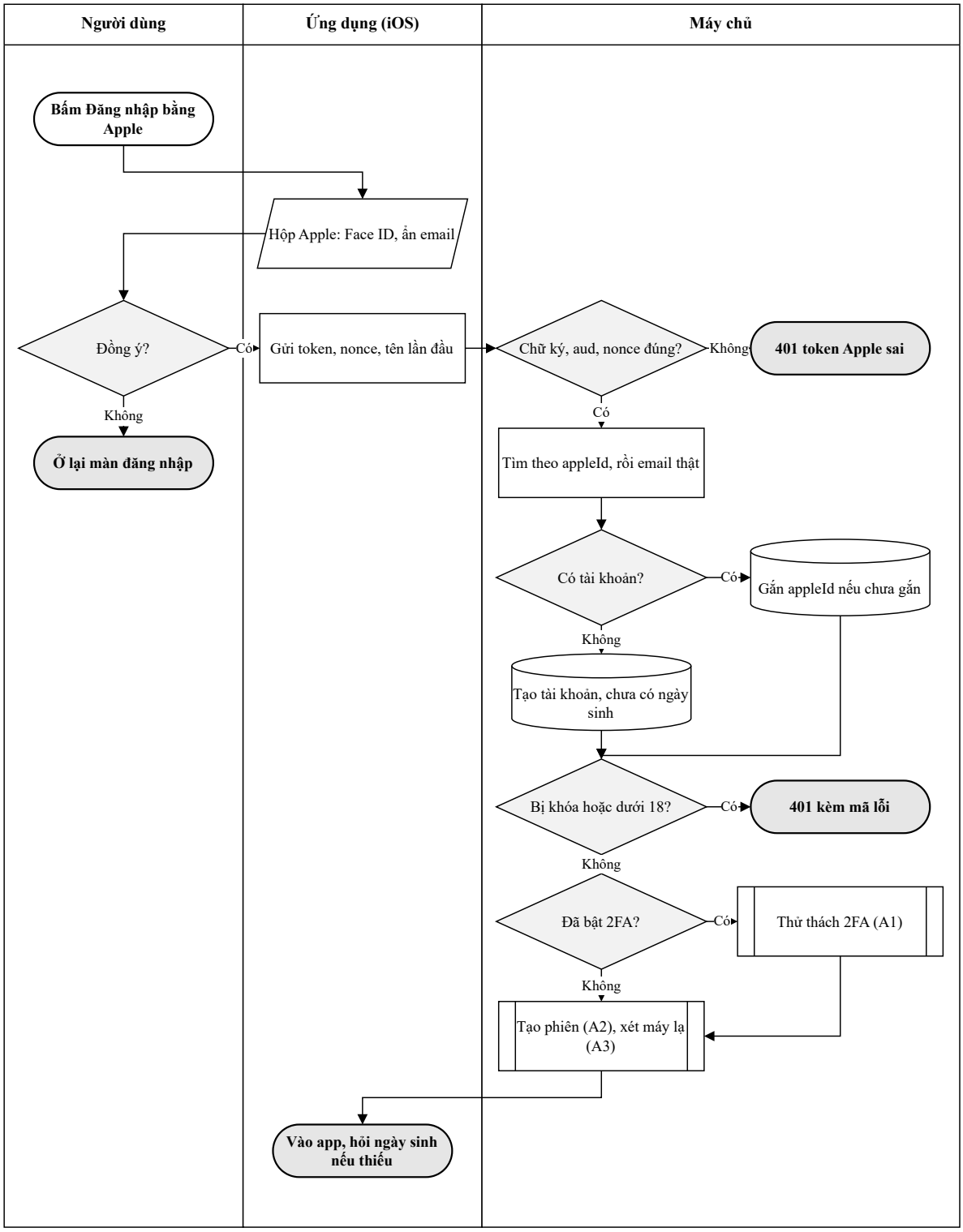
1. Trên màn Đăng nhập (chỉ trên iPhone/iPad), người dùng bấm nút **Đăng nhập bằng Apple** (nút chuẩn của Apple, kích thước không nhỏ hơn nút Google).
2. App tạo một chuỗi ngẫu nhiên dùng một lần (nonce), gửi bản băm SHA-256 của nó cho Apple, rồi mở hộp đăng nhập của Apple: người dùng xác nhận bằng Face ID/mật khẩu Apple và chọn "Chia sẻ email" hoặc "Ẩn email" (Apple tạo một địa chỉ chuyển tiếp dạng …@privaterelay.appleid.com).
3. Người dùng bấm Hủy: đóng hộp, ở lại màn Đăng nhập, không báo lỗi.
4. Đồng ý: Apple trả cho app identityToken (giấy tờ có chữ ký của Apple), authorizationCode và — **chỉ ở lần đầu tiên** — họ tên. App gửi tất cả lên máy chủ cùng nonce gốc.
5. Máy chủ kiểm tra identityToken: chữ ký bằng khóa công khai của Apple (tải từ appleid.apple.com, lưu đệm 24 giờ), người phát hành là Apple, dành cho đúng app (bundle id com.mobilesocial.app), còn hạn, và nonce khớp. Sai: 401.
6. Máy chủ tìm tài khoản theo appleId (mã người dùng Apple, cố định cho app). Không có thì tìm theo email nếu là email thật đã xác minh (không phải địa chỉ chuyển tiếp) và gắn appleId vào tài khoản đó — giống cách Google đang làm. Vẫn không có thì tạo tài khoản mới: tên người dùng sinh từ email, tên hiển thị từ họ tên Apple gửi lần đầu, chưa có mật khẩu, chưa có ngày sinh.
7. Máy chủ đổi authorizationCode lấy refresh token của Apple và lưu dạng mã hóa (để thu hồi khi xóa tài khoản).
8. Kiểm tra khóa tài khoản và khóa vì tuổi như Google. Tài khoản đã bật 2FA thì sang bước thử thách 2FA (A1).
9. Tạo phiên (A2), xét thiết bị lạ (A3). App lưu token; thiếu ngày sinh thì hiện màn khai ngày sinh như tài khoản Google hiện nay.

Luồng phụ. Người dùng Apple dùng điện thoại Android

1. Sau khi tạo tài khoản bằng Apple, app gợi ý một lần: "Đặt mật khẩu để đăng nhập được trên Android và máy khác".
2. Người dùng đặt mật khẩu trong Cài đặt (chức năng Đặt mật khẩu đã có). Trên Android, đăng nhập bằng email (kể cả địa chỉ chuyển tiếp của Apple) và mật khẩu đó.

Luồng phụ. Xóa tài khoản: khi người dùng xóa tài khoản có gắn Apple, máy chủ gọi API thu hồi của Apple bằng refresh token đã lưu, rồi mới xóa dữ liệu.

d) Flowchart



Hình 15. Đăng nhập bằng Apple trên iPhone

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Họ tên chỉ có ở lần đầu**: nếu lần đầu lỗi mạng sau khi Apple trả về, lần sau Apple không gửi tên nữa. Máy chủ phải lưu tên ngay ở lần gọi đầu; thiếu tên thì dùng tên người dùng, người dùng tự sửa trong hồ sơ.

- **Email chuyển tiếp**: thư gửi tới …@privaterelay.appleid.com chỉ tới được người dùng nếu tên miền gửi thư đã được đăng ký trong Apple Developer (mục Sign in with Apple for Email Communication) và có SPF/DKIM. Không làm bước này thì mã OTP, email cảnh báo (A3, A4) và mã đặt lại mật khẩu sẽ không tới người dùng Apple ẩn email.
- **Không tự gắn theo email chuyển tiếp**: địa chỉ chuyển tiếp không trùng với email nào có sẵn, nên người đã có tài khoản email/Google mà chọn "Ẩn email" sẽ có tài khoản **mới**. App nên nói rõ điều này; gắn Apple vào tài khoản có sẵn từ Cài đặt là việc làm sau (chưa đề xuất ở đây).
- **Thu hồi khi xóa tài khoản**: Apple yêu cầu app có Đăng nhập bằng Apple phải gọi API thu hồi token khi người dùng xóa tài khoản. Cần khóa riêng .p8 từ Apple Developer (Team ID, Key ID) để ký yêu cầu.
- **Người dùng gỡ quyền app trong cài đặt Apple ID**: lần đăng nhập Apple sau sẽ như lần đầu (nhưng appleId không đổi nên vẫn vào đúng tài khoản). Nhận thông báo từ máy chủ Apple (server-to-server notifications) là việc làm sau.
- **Tài khoản bị khóa / dưới 18 tuổi**: xử lý như Google (401 ACCOUNT_BANNED, AGE_RESTRICTED); tài khoản mới phải khai ngày sinh, dưới 18 bị khóa theo quy tắc hiện có.
- **Chống dùng lại token**: nonce dùng một lần, identityToken chỉ nhận khi còn hạn.
- **Giới hạn**: endpoint /auth/apple có @Throttle riêng 20 lần/phút/IP (cùng A4).
- **Phương án tránh làm A6**: ẩn nút Google trên iOS (chỉ hiện trên Android). Khi đó App Store không đòi Apple. Đổi lại người dùng iPhone mất đăng nhập nhanh. Chủ dự án quyết.

f) Dữ liệu và API (đề xuất)

Toàn bộ là **đề xuất**, cần đưa vào *docs/api-contract.md* trước khi code.

Thay đổi dữ liệu (Prisma)	**Nội dung**
User: thêm trường	appleId (String?, unique), appleRefreshTokenEnc (String?, mã hóa như khóa 2FA).

Endpoint (đề xuất)	**Việc làm**
POST /auth/apple { identityToken, authorizationCode, nonce, fullName?: { givenName, familyName }, device? }	Trả giống POST /auth/google: { data: { accessToken, user } } (thêm refreshToken khi có A2; trả twoFactorRequired khi có A1).
DELETE /users/me	Thêm bước gọi API thu hồi của Apple nếu tài khoản có appleId.

Biến môi trường mới: APPLE_BUNDLE_ID (com.mobilesocial.app), APPLE_TEAM_ID, APPLE_KEY_ID, APPLE_PRIVATE_KEY. Kiểm tra chữ ký dùng node:crypto + @nestjs/jwt sẵn có (đổi khóa JWK của Apple sang khóa công khai), không bắt buộc thêm thư viện backend.

g) Android, iOS và web

- **iOS**: dùng expo-apple-authentication (gói Expo chính thức; kiểm tra bản cho SDK 57, cài bằng expo install). Thêm vào app.json: "ios": { "usesAppleSignIn": true } và plugin "expo-apple-authentication". Bật Sign in with Apple cho App ID trong Apple Developer (EAS Build có thể tự bật). Tạo nonce và SHA-256 bằng expo-crypto (dùng chung với A2). Không cần quyền thiết bị.
- **Android**: Apple không có thư viện gốc cho Android. Nút Apple **không hiện** trên Android (kiểm tra Platform.OS === "ios" và AppleAuthentication.isAvailableAsync(), ghi chú lý do bằng một dòng comment như RULE.md yêu cầu). Người dùng Apple dùng Android bằng cách đặt mật khẩu (luồng phụ ở mục c). Phương án đầy đủ hơn: đăng nhập Apple trên Android qua trang web của Apple (cần Services ID, đường dẫn trả về HTTPS, mở trình duyệt trong app) — thêm khoảng 2–3 ngày, đề xuất làm sau nếu có nhiều người dùng chuyển máy.
- Đây là khác biệt nền tảng được RULE.md cho phép vì Android có đường thay thế (mật khẩu, Google). Cần ghi quyết định vào *docs/decisions.md*.
- **Nút Google trên iOS**: cần kiểm tra cấu hình iOS của @react-native-google-signin (iosUrlScheme, iOS client ID) — nếu nút Google chưa chạy được trên iPhone thì cần làm cùng lúc.
- **Web**: chưa có web client. Nếu có, dùng Sign in with Apple JS với Services ID.
- **Chi phí**: không có phí riêng; cần tài khoản Apple Developer (99 USD/năm, vốn đã cần để phát hành iOS).

h) Tiêu chí hoàn thành

- Trên iPhone thật (bản dev build hoặc TestFlight, không chạy được trong Expo Go): đăng nhập Apple lần đầu với "Chia sẻ email" tạo tài khoản đúng tên và email; lần sau vào lại đúng tài khoản.
- Đăng nhập Apple với "Ẩn email": tạo tài khoản với địa chỉ chuyển tiếp; email OTP/cảnh báo gửi tới địa chỉ đó đến được hộp thư thật.
- Email thật trùng tài khoản có sẵn: appleId được gắn vào tài khoản đó, không tạo tài khoản trùng.
- Bấm Hủy trong hộp Apple: không có thông báo lỗi.

- Tài khoản mới phải khai ngày sinh; dưới 18 bị khóa như quy tắc hiện có.
- Trên Android: nút Apple không hiện; người dùng Apple đặt mật khẩu rồi đăng nhập được trên Android.
- Xóa tài khoản Apple: Apple ID không còn liệt kê app trong danh sách "Đăng nhập bằng Apple".
- Test tự động ở backend: token sai chữ ký, sai aud, hết hạn, nonce sai đều bị từ chối (dùng khóa giả trong test).
- Báo cáo ghi rõ: iPhone đã chạy hay chưa; Android chỉ kiểm tra việc ẩn nút và đăng nhập bằng mật khẩu.

i) Ước lượng và phụ thuộc

- Backend 2 ngày (kiểm tra token Apple, tìm/gắn/tạo tài khoản, đổi mã lấy refresh token, thu hồi khi xóa tài khoản). Mobile 2 ngày (nút Apple chỉ trên iOS, gọi API, gợi ý đặt mật khẩu, cấu hình app.json và Apple Developer). Kiểm thử 1 ngày trên iPhone thật.
- Phụ thuộc: không bắt buộc mã nào (làm được với cách cấp token hiện nay). Khi có A2/A1 thì thêm refresh token và bước 2FA. Liên quan E2 (xóa tài khoản).
- Rủi ro: không có iPhone thật để thử; quên đăng ký tên miền gửi thư với Apple làm người dùng ẩn email không nhận được OTP; bị từ chối trên App Store nếu nút Apple không đúng hướng dẫn giao diện của Apple.

NHÓM B. AN TOÀN – ĐIỂM KHÁC BIỆT CỦA SẢN PHẨM

B1. Tin nhắn chờ và quyền ai được nhắn tin (nâng cấp)

Nhóm: An toàn tin nhắn · Giai đoạn: GĐ2 · Ước lượng: 9 ngày công

a) Mục đích

Người dùng tự quyết ai được bắt đầu cuộc trò chuyện với mình, và tin của người lạ không chen vào hộp thư chính. Tin rác và tin có dấu hiệu lừa đảo được lọc vào một thư mục riêng, không rung chuông. Người nhận đọc được tin chờ mà người gửi không biết đã bị đọc, rồi chấp nhận, xóa, báo cáo hoặc chặn. Người được lợi nhất là người dùng nữ, người có nhiều người theo dõi và người hay bị lừa qua tin nhắn.

b) Hiện trạng

Đã có trong code (*apps/api/src/modules/messages/messages.service.ts*, *apps/mobile/src/features/messages*):

- Hội thoại thường (*kind = DIRECT*) mở bởi người mà người nhận **chưa theo dõi** có trạng thái *PENDING* (tin nhắn chờ). Người nhận đã theo dõi người mở thì hội thoại là *ACCEPTED* ngay.
- Khi đang chờ, người mở chỉ gửi được chữ, tối đa **3 tin** (*PENDING_MESSAGE_LIMIT*), không gửi được link, số điện thoại, số tài khoản (*findBlockedContact* trong *moderation/text-safety.ts*), lỗi trả về có mã (*REQUEST_LIMIT*, *CONTACT_INFO_BLOCKED*, *IMAGES_NOT_ALLOWED*).
- Đọc mà không lộ "Đã xem": máy chủ vẫn ghi giờ đọc của người nhận nhưng không gửi sự kiện socket *message:read* và trả *peerReadAt = null* cho người mở khi hội thoại chưa được chấp nhận.
- Người nhận có: **Chấp nhận** (*POST /conversations/:id/accept*), **Xóa** (*/decline*, đặt *DECLINED*, người mở vẫn thấy "đang chờ"), **Báo cáo** (lý do *SCAM* đứng đầu, lưu bản chụp 50 tin), **Chặn** (trong menu "..." của màn chat). Trả lời coi như chấp nhận.
- App: hộp thư có hai thư mục "Tin nhắn" và "Tin nhắn chờ" (*ConversationsScreen.tsx*), xem trước tin chờ chỉ ghi "Muốn gửi tin nhắn cho bạn"; màn chat có thanh Xóa / Báo cáo / Chấp nhận (*ChatScreen.tsx*). Huy hiệu tab không tính tin chờ (*GET /conversations/unread-count* trả *count* và *requests* riêng).
- Chặn người dùng có sẵn (*Block*, hàm *blockedUserIds* xét cả hai chiều); người bị chặn nhận 404 khi mở hội thoại.

Còn thiếu hoặc chưa đúng (đọc từ code):

- Không có cài đặt "ai được nhắn tin cho tôi". Mọi tài khoản không bị chặn đều mở được tin chờ, kể cả với tài khoản riêng tư (*open()* không xét *isPrivate*).
- Không giới hạn số tin chờ mới một người được mở mỗi ngày. Chỉ có trần chung 300 request/phút theo IP (*ThrottlerModule* trong *app.module.ts*). Một tài khoản rác có thể nhắn cho hàng nghìn người.
- Không có thư mục lọc rác. Tin chờ có dấu hiệu lừa đảo vẫn nằm chung với tin chờ bình thường và vẫn đẩy thông báo.
- Thông báo đẩy của tin chờ **có nội dung tin** ("[Tin nhắn chờ] ..."), trong khi hộp thư cố ý giấu nội dung. Tin lừa đảo vì vậy hiện thẳng trên màn hình khóa.
- Sau khi người nhận bấm Xóa (*DECLINED*), nếu người mở còn lượt (dưới 3 tin) thì tin mới **vẫn đẩy thông báo và vẫn phát socket** tới người nhận: *send()* không xét trạng thái *DECLINED* trước khi gọi *pushToUser*.
- Báo cáo một tin chờ thường (không ẩn danh) không làm nó rời thư mục: *reportConversation* chỉ đóng hội thoại ẩn danh.
- Thanh tin chờ không có nút Chặn (phải mở menu "..."); không có "Xóa tất cả".

c) Cách hoạt động

Luồng 1: Cài đặt "Ai được nhắn tin cho bạn"

1. Người dùng vào Cài đặt → Quyền riêng tư → "Tin nhắn". Có 3 lựa chọn: **Mọi người** (mặc định, giữ đúng hành vi hiện nay), **Người tôi theo dõi**, **Không ai**.
2. Bên dưới có công tắc "Lọc tin nhắn chờ đáng ngờ" (mặc định bật) và dòng giải thích: tin bị lọc nằm trong "Đã lọc", không có thông báo.
3. App gửi *PATCH /users/me*. Máy chủ lưu và áp dụng ngay cho các hội thoại **mới**. Hội thoại đã được chấp nhận không bị ảnh hưởng.
4. Trang cá nhân của người khác: máy chủ trả thêm *canMessage*. Nếu *false*, app ẩn nút "Nhắn tin" và ô trả lời story, thay bằng dòng "Người này chỉ nhận tin nhắn từ người họ theo dõi" (hoặc "không nhận tin nhắn mới").

Luồng 2: Gửi tin đầu tiên cho người lạ (sơ đồ 1)

1. Người gửi bấm "Nhắn tin" trên trang cá nhân (hoặc trả lời story). App gọi *POST /conversations*.
2. Máy chủ kiểm tra theo thứ tự: có chặn nhau không (có → 404 như hiện nay, không lộ lý do); người nhận có cho phép không (*Người tôi theo dõi* mà người nhận chưa theo dõi người gửi, hoặc *Không ai* → 403 *MESSAGE_NOT_ALLOWED*); người nhận đã theo dõi người gửi chưa (rồi → hội thoại thường, vào hộp thư chính như hiện nay).

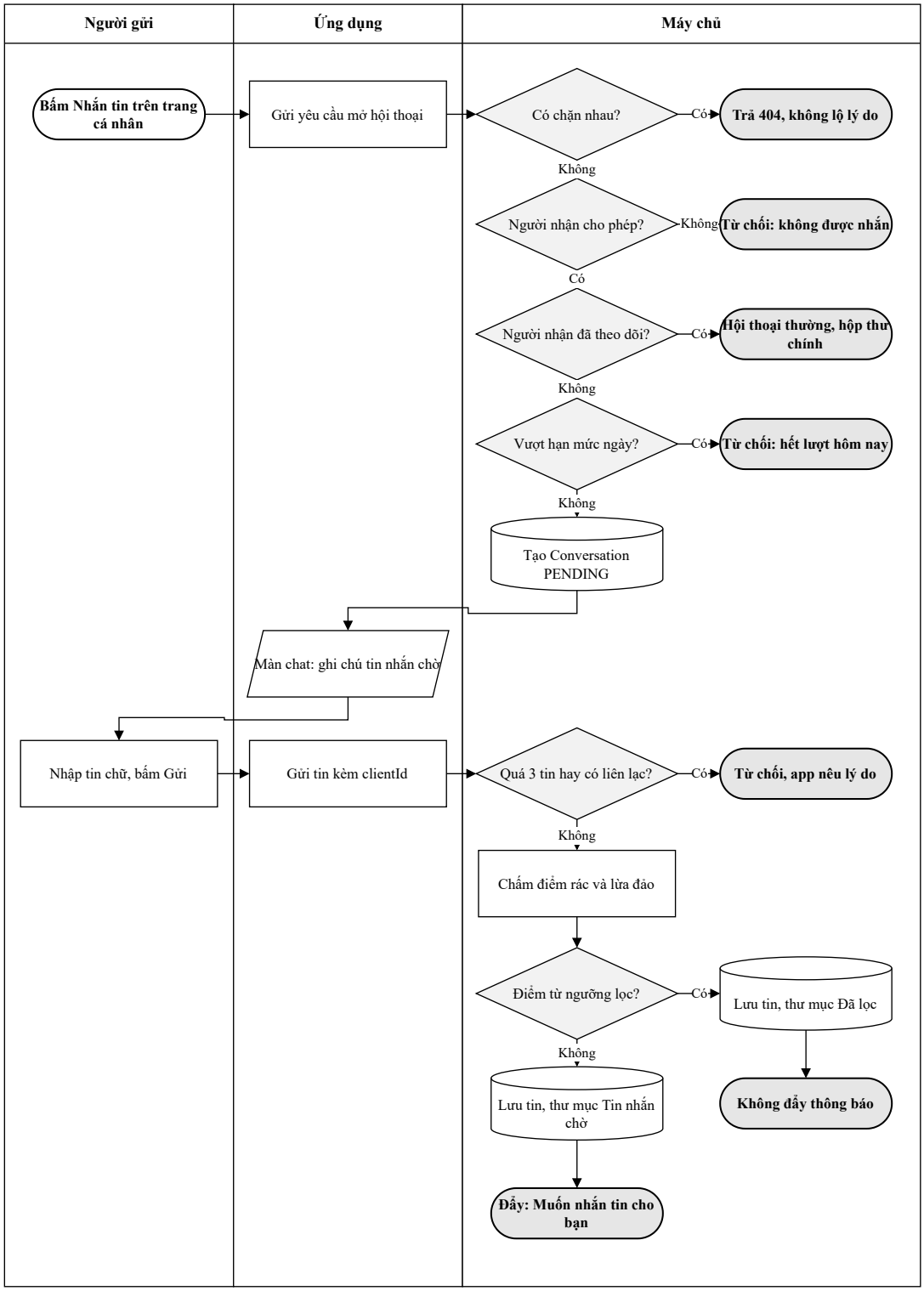
3. Nếu là người lạ: máy chủ đếm số tin chờ mới người gửi đã mở trong 24 giờ. Vượt hạn mức → 429 *REQUEST_DAILY_LIMIT*, app hiện "Hôm nay bạn đã nhắn cho quá nhiều người lạ. Thử lại sau."
4. Tạo hội thoại *PENDING* (như hiện nay). App mở màn chat với ghi chú "Tin nhắn của bạn sẽ nằm trong mục Tin nhắn chờ. Bạn gửi được tối đa 3 tin cho tới khi người kia trả lời."
5. Người gửi gửi tin. Máy chủ giữ nguyên các kiểm tra hiện có (3 tin, chỉ chữ, không liên lạc), rồi **chấm điểm rác** (mục e, dùng bộ chấm lừa đảo của B3).
6. Điểm từ ngưỡng lọc → hội thoại chuyển vào thư mục **Đã lọc** của người nhận: không thông báo đẩy, không socket, không tính vào số tin chờ. Người gửi không biết (vẫn thấy "đã gửi").
7. Dưới ngưỡng → nằm trong **Tin nhắn chờ**. Thông báo đẩy tới người nhận chỉ ghi "*Tên người gửi*: Muốn gửi tin nhắn cho bạn", **không có nội dung**.

Luồng 3: Người nhận xử lý tin nhắn chờ (sơ đồ 2)

1. Người nhận mở Tin nhắn → "Tin nhắn chờ" (có số đếm) hoặc "Đã lọc" (không đếm, nằm cuối thư mục Tin nhắn chờ). Danh sách hiện tên, ảnh, thời gian, nhãn cảnh báo nếu có (giả mạo, lừa đảo), không hiện nội dung tin.
2. Chạm một yêu cầu: app tải tin và gọi đánh dấu đã đọc. Máy chủ ghi giờ đọc nhưng không báo người gửi (như hiện nay). Máy chủ gắn cảnh báo lừa đảo, giả mạo (B3) vào dữ liệu trả về.
3. Màn chat hiện thanh 4 nút: **Chấp nhận**, **Xóa**, **Báo cáo**, **Chặn**. Tin bị B3 đánh mức cao thì bị che sẵn, chạm mới xem.
4. **Chấp nhận hoặc trả lời**: hội thoại thành *ACCEPTED*, chuyển vào hộp thư chính. Từ lúc này người gửi mới thấy "Đã xem", mới gửi được ảnh và link.
5. **Xóa**: *DECLINED*, biến khỏi thư mục. Người gửi không được báo. Mọi tin sau đó của người gửi (nếu còn lượt) được lưu nhưng không thông báo, không socket, không hiện lại.
6. **Báo cáo**: chọn lý do, máy chủ lưu báo cáo kèm bản chụp 50 tin (như hiện nay) và **tự xóa yêu cầu** (*DECLINED*). App hỏi tiếp "Chặn luôn người này?".
7. **Chặn**: hỏi xác nhận, lưu *Block* và xóa yêu cầu. Người gửi không mở lại được (404).
8. Thư mục "Đã lọc" có thêm nút **"Không phải rác"** để chuyển một yêu cầu về Tin nhắn chờ, và **"Xóa tất cả"** (xác nhận một lần).

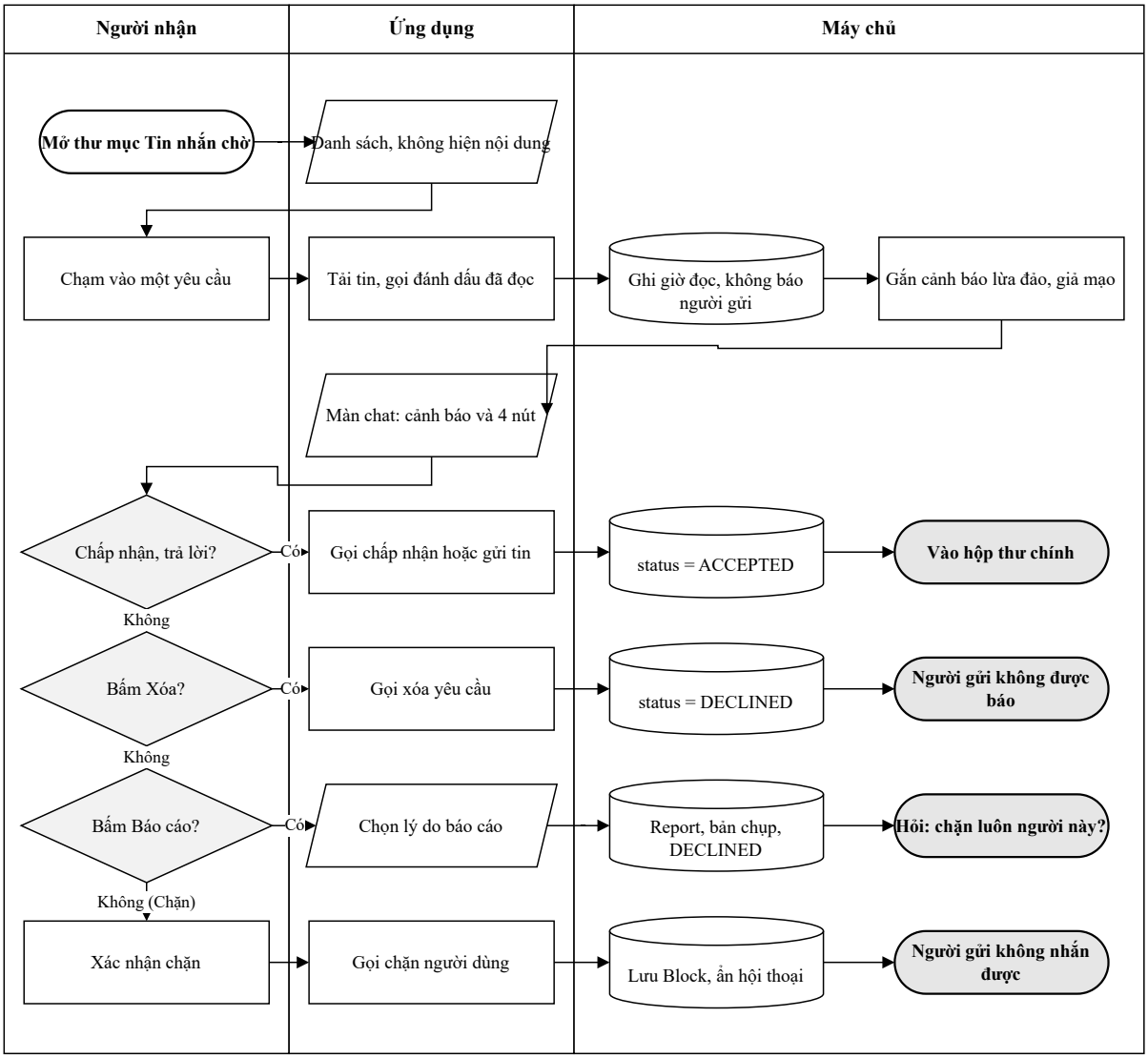
d) Flowchart

Sơ đồ 1 mô tả đường đi của tin đầu tiên từ người lạ, từ lúc bấm "Nhắn tin" tới lúc vào đúng thư mục.



Hình 16. Gửi tin nhắn đầu tiên cho người lạ

Sơ đồ 2 mô tả những gì người nhận làm được với một tin nhắn chờ.



Hình 17. Người nhận xử lý một tin nhắn chờ

e) Quy tắc, giới hạn và trường hợp đặc biệt

Quy tắc	**Giá trị đề xuất**
Tin chờ mới mỗi người gửi / 24 giờ	20; tài khoản dưới 7 ngày tuổi hoặc chưa xác thực email: 5; điểm lạm dụng từ 30 (xem B2): 2
Số tin trước khi được trả lời	3 (giữ như hiện nay), chỉ chữ, không link / SĐT / số tài khoản
Vào "Đã lọc" khi có một trong các điều kiện	(1) điểm rủi ro B3 của tin từ 3; (2) người gửi dưới 7 ngày tuổi và không ai mà người nhận theo dõi đang theo dõi người gửi; (3) điểm lạm dụng của người gửi từ 30; (4) người nhận đang bật Giới hạn (B4) và người gửi thuộc nhóm bị giới hạn
Đã vào "Đã lọc"	Chỉ người nhận chuyển ra được ("Không phải rác"). Máy chủ không tự chuyển ngược.

Tin chờ quá cũ	Ẩn khỏi danh sách sau 30 ngày không có tin mới (dữ liệu vẫn giữ để phục vụ báo cáo)
Điểm lạm dụng cộng thêm cho người gửi	Bị xóa: +3; bị báo cáo: +25 (bảng SafetyEvent, mục f)

- **Đổi cài đặt sau khi đã có tin chờ:** tin chờ cũ vẫn nằm đó; người gửi không gửi thêm được nếu cài đặt mới không cho phép (403 *MESSAGE_NOT_ALLOWED*).
- **"Người tôi theo dõi"** và tài khoản riêng tư: không đổi gì, vì người được nhắn là người mình đã theo dõi.
- **"Không ai"**: không ai mở được hội thoại mới, kể cả người mình theo dõi; hội thoại cũ đã chấp nhận vẫn nhắn bình thường. Nhắn ẩn danh do cài đặt riêng (B2) quyết định.
- **Người nhận theo dõi người gửi sau đó:** tin chờ cũ không tự thành *ACCEPTED*; người nhận chấp nhận hoặc trả lời như thường.
- **Mất mạng khi gửi:** giữ cơ chế *clientId* hiện có, gửi lại không tạo tin trùng và không bị tính thêm lượt.
- **Tài khoản bị khóa:** hội thoại của họ ẩn khỏi hộp thư của người khác (giữ như hiện nay); điểm lạm dụng giữ nguyên để admin xem.
- **Lạm dụng "Xóa" để gây áp lực:** không có; người gửi không bao giờ biết bị xóa, không biết bị lọc.
- **Gửi lặp lại nội dung giống nhau** cho nhiều người (từ 5 người trong 1 giờ, cùng nội dung sau chuẩn hóa) được tính là dấu hiệu rác, cộng 10 điểm lạm dụng (đề xuất).

f) Dữ liệu và API (đề xuất)

Đây là đề xuất. Phải ghi vào docs/api-contract.md và docs/decisions.md trước khi code.

Thay đổi	**Chi tiết**
User.messagePermission	String, mặc định *EVERYONE*; giá trị *EVERYONE* | *FOLLOWING* | *NOBODY*
User.filterRequests	Boolean, mặc định *true*
Conversation.requestFolder	String?, *null* hoặc *FILTERED*; chỉ có nghĩa khi *PENDING*
Conversation.filterReason	String?, ví dụ *SCAM_TEXT* | *NEW_ACCOUNT* | *LOW_REPUTATION* | *LIMITS*, để admin và người dùng thấy lý do

Bảng mới *SafetyEvent* (dùng chung B1–B4)	*id, userId* (người bị chấm điểm), *type, weight* (Int), *actorId?*, *conversationId?*, *createdAt*; chỉ mục *(userId, createdAt)*. Điểm lạm dụng = tổng *weight* trong 30 ngày.

API	**Ghi chú**
PATCH /users/me	Thêm *messagePermission*, *filterRequests*
GET /users/:id	Thêm *canMessage* (boolean)
POST /conversations	Lỗi mới: 403 *MESSAGE_NOT_ALLOWED*, 429 *REQUEST_DAILY_LIMIT*
GET /conversations	Mỗi hội thoại thêm *folder: INBOX | REQUESTS | FILTERED*; giữ *isRequest* cho bản app cũ (hội thoại FILTERED có *isRequest = true*)
GET /conversations/unread-count	Thêm *filtered* (chỉ để hiện số trong thư mục, không lên huy hiệu)
POST /conversations/:id/not-spam	Chuyển từ Đã lọc về Tin nhắn chờ
POST /conversations/requests/decline-all	*{ folder: "REQUESTS" | "FILTERED" }*
POST /reports (CONVERSATION)	Thêm hành vi: tin chờ bị báo cáo thì tự *DECLINED*
Thông báo đẩy	Tin chờ: "Muốn gửi tin nhắn cho bạn", không nội dung. Không đẩy và không phát socket cho hội thoại *DECLINED* hoặc *FILTERED*.

Code cần sửa: *messages.service.ts* (*open, send, list, unreadCount*), *reports.service.ts*, *users* (DTO cập nhật hồ sơ, hồ sơ công khai), màn *ConversationsScreen*, *ChatScreen*, Cài đặt; thêm một màn "Tin nhắn" trong Cài đặt.

g) Android, iOS và web

- Không cần quyền thiết bị mới, không cần thư viện mới. Mọi màn dùng thành phần React Native sẵn có, chạy giống nhau trên Android và iOS.
- Thông báo đẩy đi qua dịch vụ Expo hiện có (*notifications.service.ts* gọi *exp.host*), Expo chuyển tiếp tới APNs (iOS) và FCM (Android). Cả hai phía phải có khóa cấu hình (thuộc D8). Nội dung đẩy không còn chứa tin nhắn, nên màn hình khóa trên cả hai hệ điều hành không lộ nội dung tin chờ.
- Thanh 4 nút ở màn chat phải nằm trên vùng an toàn (safe-area) và không bị bàn phím che: kiểm tra trên iPhone có "tai thỏ" và Android có thanh điều hướng.

- Trang quản trị (web): hiện thêm *filterReason* và điểm lạm dụng ở báo cáo hội thoại.
- App Store và Google Play đều yêu cầu ứng dụng có nội dung do người dùng tạo phải có báo cáo và chặn. Tính năng này làm phần đó rõ hơn; không có chi phí dịch vụ ngoài.

h) Tiêu chí hoàn thành

- Ba lựa chọn "Ai được nhắn tin" hoạt động: kiểm thử với 3 tài khoản (người theo dõi, người lạ, người mình theo dõi); nút Nhắn tin và ô trả lời story ẩn đúng khi *canMessage = false*.
- Người lạ mở quá 20 tin chờ mới trong 24 giờ nhận 429; tài khoản mới bị giới hạn 5.
- Tin chờ chứa cụm "chuyển khoản gấp vào stk" từ tài khoản mới vào "Đã lọc", không có thông báo đẩy, không tính vào số tin chờ.
- Thông báo đẩy của tin chờ không chứa nội dung tin (kiểm trên màn hình khóa).
- Sau khi bấm Xóa, tin tiếp theo của người gửi không tạo thông báo, không socket; người gửi vẫn thấy "đang chờ".
- Người nhận đọc tin chờ: người gửi không thấy "Đã xem" và không nhận *message:read*; sau khi chấp nhận thì thấy.
- Báo cáo tin chờ: báo cáo có bản chụp, yêu cầu biến khỏi thư mục, app hỏi chặn.
- *scripts/safety-smoke.cjs* có thêm phép thử cho mọi mục trên; test đơn vị cho hàm quyết định thư mục.
- Chạy tay toàn bộ luồng trên Android (máy ảo hoặc máy thật) **và** iPhone; báo cáo ghi rõ nền tảng nào đã chạy.
- Admin thấy lý do lọc và điểm lạm dụng trong trang báo cáo.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (cài đặt quyền, hạn mức, thư mục lọc, sửa đẩy thông báo, SafetyEvent), mobile 3 ngày (màn cài đặt, thư mục Đã lọc, thanh 4 nút, xử lý *canMessage*), kiểm thử 2 ngày.
- Phụ thuộc: B3 (bộ chấm điểm lừa đảo; trước khi có B3 dùng tạm *hasScamWarning* hiện có), D8 (cấu hình đẩy APNs/FCM). B2, B3, B4 dùng lại bảng *SafetyEvent* và thư mục "Đã lọc" của B1, nên làm B1 trước.
- Rủi ro: lọc nhầm tin thật vào "Đã lọc" (người nhận bỏ lỡ). Giảm bằng nút "Không phải rác", hiện số tin trong "Đã lọc", và đo tỉ lệ "Không phải rác" trong 2 tuần đầu để chỉnh ngưỡng.

- Rủi ro: đổi mặc định sang "Người tôi theo dõi" sẽ làm app khó kết bạn mới; đề xuất giữ mặc định "Mọi người".

B2. Nhắn ẩn danh có giới hạn (nâng cấp)

Nhóm: An toàn tin nhắn · Giai đoạn: GĐ2 · Ước lượng: 10 ngày công

a) Mục đích

Cho phép người theo dõi gửi lời nhắn mà không lộ tên (hỏi thật lòng, góp ý, tỏ tình), nhưng không biến thành công cụ quấy rối hay lừa đảo. Người nhận chủ động bật, tạm dừng được bất cứ lúc nào, và có nút báo cáo đóng ngay cuộc trò chuyện. Ẩn danh chỉ với người dùng khác: nền tảng luôn biết ai gửi, quản trị viên chỉ thấy khi có báo cáo. Đây là tính năng khác biệt của sản phẩm nên phải có hạn mức và điểm lạm dụng rõ ràng.

b) Hiện trạng

Đã có trong code (*apps/api/src/modules/messages*, *reports*, *admin*; quyết định DEC-025 trong *docs/decisions.md*; chi tiết ở *docs/moderation/MODERATION_PLAN.md* mục 5):

- **Bật nhận:** người dùng bật *allowAnonymousMessages* qua màn *AnonymousMessagesScreen.tsx*, màn này liệt kê 3 rủi ro và 6 biện pháp bảo vệ trước nút "Tôi đã hiểu, bật tin nhắn ẩn danh". Tắt là một chạm.
- **Hai điểm vào:** nút "Nhắn ẩn danh" trên trang cá nhân (*POST /conversations/anonymous*, phải đang theo dõi người nhận) và trả lời story ẩn danh khi chủ story bật *allowAnonymous* cho story đó (*stories.service.ts*).
- **Điều kiện người gửi** (*openAnonymousConversation*): đã xác thực email hoặc đăng nhập Google, tài khoản từ 7 ngày, không bị tước quyền (*anonymousSuspendedAt*), không chặn nhau, tối đa **10 hội thoại ẩn danh mới mỗi 24 giờ**.
- **Hội thoại riêng:** *kind = ANON_A / ANON_B*, mỗi chiều tối đa một hội thoại, tách khỏi hội thoại thường. Bắt đầu là tin nhắn chờ (3 tin, chỉ chữ, không link / SĐT / số tài khoản).
- **Che danh tính ở máy chủ:** với người nhận, *senderId* là *anonymous* và người đối diện là "Người ẩn danh" trong API, sự kiện socket *message:new* và thông báo đẩy (tiêu đề "Người ẩn danh"). *scripts/safety-smoke.cjs* kiểm tra không lộ id hay username.
- **Tiết lộ:** chỉ người gửi tự làm, có hộp xác nhận, không thu hồi (*POST /conversations/:id/reveal*, phát *conversation:updated* cho hai bên). Không có "yêu cầu tiết lộ".

- **Chặn người ẩn danh:** người nhận bấm Chặn thì hội thoại đóng vĩnh viễn (*closedAt*), người kia không mở lại được.
- **Báo cáo:** đóng hội thoại và tước quyền gửi ẩn danh của người gửi **ngay lập tức**, lưu bản chụp 50 tin. Admin thấy danh tính thật trong *GET /admin/reports*. Admin "Bỏ qua" thì trả lại quyền, trừ khi người đó bị từ 3 người khác nhau báo cáo trong 30 ngày (*admin.service.ts*). Admin trả / tước quyền bằng tay ở danh sách người dùng.

Còn thiếu hoặc chưa đúng:

- Không có **tạm dừng**. Tắt *allowAnonymousMessages* chỉ chặn mở hội thoại từ trang cá nhân: *send()* không xét cài đặt này nên hội thoại ẩn danh cũ vẫn nhận tin, và trả lời story ẩn danh chỉ xét cờ của story (*openAnonymousConversation* không đọc *allowAnonymousMessages*).
- Không lưu thời điểm người dùng đồng ý màn rủi ro, nên không chứng minh được đã cảnh báo.
- Người **gửi** không phải đọc quy tắc nào trước lần đầu nhắn ẩn danh; nút trên trang cá nhân gọi API ngay (*ProfileView.tsx*).
- Hạn mức chỉ đếm **hội thoại mới**. Sau khi được chấp nhận, số tin ẩn danh không giới hạn; người nhận cũng không có trần số hội thoại ẩn danh nhận mỗi ngày.
- Theo dõi xong là nhắn ẩn danh được ngay (không có thời gian chờ), dễ bị "theo dõi để quấy rối".
- Không có điểm lạm dụng; tước quyền chỉ có hai trạng thái (có / không), không có thời hạn, người gửi không được báo vì sao (chỉ thấy lỗi *ANONYMOUS_SUSPENDED* khi thử gửi).
- Không có nhật ký ghi lại quản trị viên nào đã xem danh tính thật của người gửi ẩn danh.

c) Cách hoạt động

Luồng 1: Bật, tạm dừng, tắt (sơ đồ 1)

1. Người dùng mở Cài đặt → "Tin nhắn ẩn danh". App hiện màn rủi ro hiện có (giữ nội dung), thêm hai lựa chọn: **Ai được nhắn ẩn danh** (Người theo dõi tôi từ 3 ngày trở lên — mặc định; hoặc Mọi người theo dõi tôi) và **Số cuộc trò chuyện ẩn danh mới tối đa mỗi ngày** (5, 10, 20 — mặc định 10).
2. Bấm "Tôi đã hiểu, bật". Máy chủ kiểm tra đủ điều kiện bật: tài khoản không bị khóa, đã có ngày sinh từ 18 tuổi, đã xác thực email hoặc Google. Không đủ → báo lý do.

3. Máy chủ lưu cài đặt và **thời điểm đồng ý** kèm phiên bản nội dung màn rủi ro. Trang cá nhân hiện nút "Nhắn ẩn danh" cho người đủ điều kiện.
4. Về sau, người dùng bấm **Tạm dừng** (24 giờ hoặc 7 ngày) hoặc **Tắt hẳn**. Tạm dừng: mọi tin ẩn danh tới (cả hội thoại cũ, cả trả lời story) bị từ chối với mã *ANONYMOUS_PAUSED*, người gửi thấy "Người này đang tạm dừng nhận tin ẩn danh". Tắt hẳn: như tạm dừng nhưng không tự hết; hội thoại cũ vẫn đọc được.
5. Có thể "Tiếp tục nhận" trước hạn. Hết hạn tạm dừng thì tự mở lại, không cần việc chạy nền (máy chủ so giờ khi có tin tới).

Luồng 2: Gửi tin ẩn danh (sơ đồ 2)

1. Người gửi bấm "Nhắn ẩn danh" (trang cá nhân) hoặc chọn "Trả lời ẩn danh" ở story.
2. Máy chủ kiểm tra người nhận: đang bật, không tạm dừng, chưa vượt số hội thoại ẩn danh mới nhận trong ngày, và người gửi thuộc nhóm được phép (theo dõi đủ 3 ngày, dựa vào *Follow.createdAt* có sẵn). Story: thêm điều kiện chủ story bật ẩn danh (như hiện nay).
3. Kiểm tra người gửi (như hiện nay): email hoặc Google, từ 7 ngày tuổi, không bị tước quyền, không chặn nhau.
4. Lần đầu nhắn ẩn danh: máy chủ trả *ANONYMOUS_RULES_REQUIRED*, app hiện **màn quy tắc người gửi**: "Bạn ẩn danh với người nhận, không ẩn danh với chúng tôi. Quấy rối, đe dọa, lừa đảo sẽ bị báo cáo, mất quyền nhắn ẩn danh hoặc bị khóa tài khoản. Chúng tôi cung cấp danh tính cho cơ quan có thẩm quyền khi có yêu cầu hợp pháp." Bấm "Đồng ý" thì app gọi lại.
5. Đã có hội thoại: đang mở thì vào lại; đã bị đóng thì từ chối *CONVERSATION_CLOSED* (như hiện nay).
6. Chưa có: đếm hội thoại ẩn danh mới trong 24 giờ (10, giảm còn 3 khi điểm lạm dụng từ 30). Đạt trần → 429 *ANONYMOUS_DAILY_LIMIT*. Không thì tạo hội thoại *PENDING*.
7. Gửi tin: giữ kiểm tra hiện có (chỉ chữ, không liên lạc, 3 tin khi đang chờ). Mỗi lần bị chặn vì liên lạc cộng điểm lạm dụng. Thêm trần **30 tin ẩn danh mỗi 24 giờ** trên mọi hội thoại ẩn danh của người gửi (429 *ANONYMOUS_MESSAGE_LIMIT*).
8. Máy chủ chấm lừa đảo cho tin (B3), rồi tính điểm lạm dụng 30 ngày của người gửi. Từ 60 → tự tước quyền ẩn danh, tạo mục trong hàng chờ kiểm duyệt (C1), từ chối tin.
9. Lưu tin, phát socket và đẩy thông báo **đã che danh** như hiện nay. Thông báo đẩy của tin ẩn danh không chứa nội dung: "Người ẩn danh: Đã gửi cho bạn một tin

nhắn".

Luồng 3: Báo cáo, tước quyền và xét duyệt (sơ đồ 3)

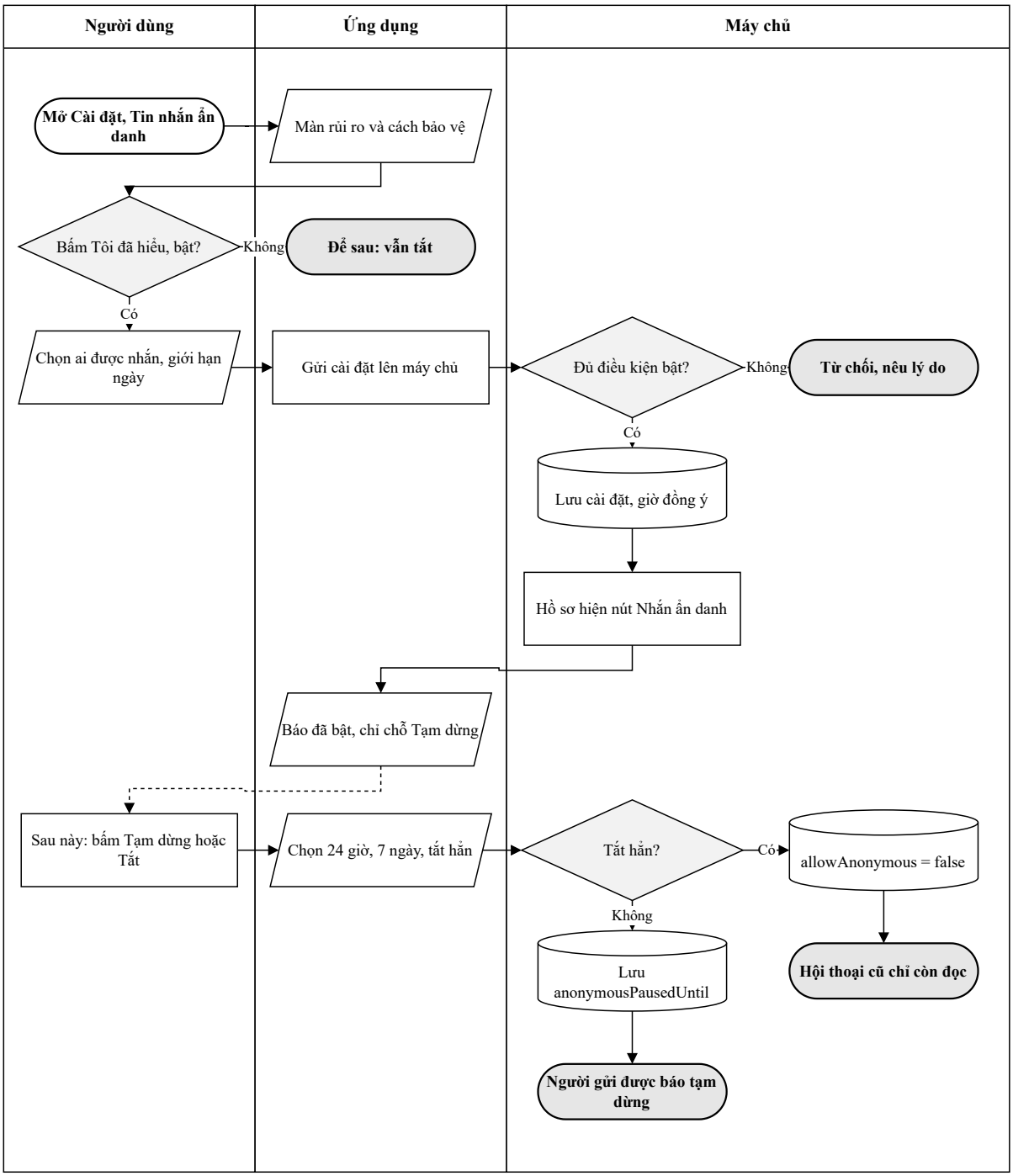
1. Người nhận bấm Báo cáo, chọn lý do. Máy chủ lưu báo cáo và bản chụp 50 tin, đóng hội thoại, tước quyền ẩn danh của người gửi ngay (như hiện nay). Người nhận thấy "Đã đóng và đã chặn".
2. **Mới:** người gửi nhận thông báo trong app "Quyền nhắn ẩn danh của bạn đang tạm dừng vì có báo cáo. Chúng tôi sẽ xem xét." Không nói ai báo cáo.
3. Máy chủ cộng 40 điểm lạm dụng, đưa báo cáo lên đầu hàng chờ.
4. Quản trị viên mở báo cáo: thấy bản chụp, danh tính thật, điểm lạm dụng và các lần bị báo trước đó. **Mỗi lần mở danh tính được ghi nhật ký** (ai xem, lúc nào, báo cáo nào) — thuộc C3.
5. Không vi phạm: nếu dưới 3 người khác nhau báo cáo trong 30 ngày thì trả lại quyền (như hiện nay), báo cáo thành *DISMISSED*; nếu từ 3 người thì giữ tước quyền, chờ xét tay.
6. Có vi phạm: lần đầu, mức nhẹ → tước 30 ngày và ghi một lần cảnh cáo; nặng hoặc tái phạm → tước vĩnh viễn hoặc khóa tài khoản (dùng lại *setBanned*). Người gửi nhận thông báo kết quả và nút kháng nghị (C2).

Luồng 4: Tiết lộ danh tính (sơ đồ 4)

1. Người gửi chọn "Tiết lộ danh tính" trong menu. App hiện hộp xác nhận nói rõ không thu hồi được.
2. Máy chủ kiểm tra người gọi đúng là bên ẩn danh (sai → 400), đã tiết lộ thì trả lại hội thoại như cũ.
3. Ghi *revealedAt* (như hiện nay). **Mới:** trả thêm *revealedAt* để app vẽ dòng hệ thống "Người này đã tiết lộ danh tính lúc ..." trong cuộc trò chuyện.
4. Phát *conversation:updated* cho hai bên. Người nhận thấy tên và ảnh thật. Từ đó luật gửi ảnh và link như hội thoại thường (code hiện tại đã bỏ chặn liên lạc khi đã tiết lộ; ảnh vẫn cấm vì *kind* vẫn là ẩn danh — **cần chủ dự án chọn** có cho gửi ảnh sau khi tiết lộ hay không).

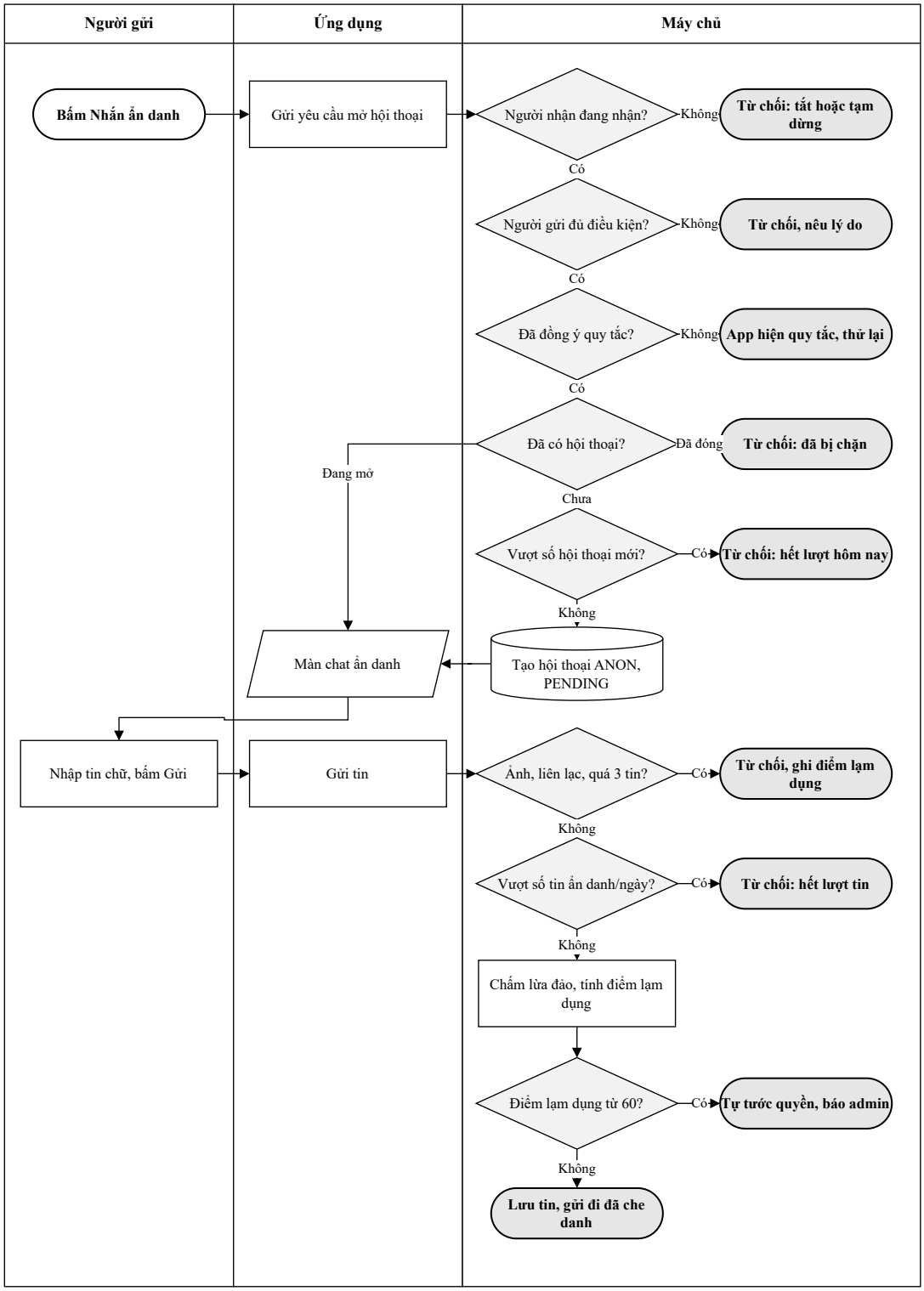
d) Flowchart

Sơ đồ 1: người nhận bật, tạm dừng, tắt tin nhắn ẩn danh.



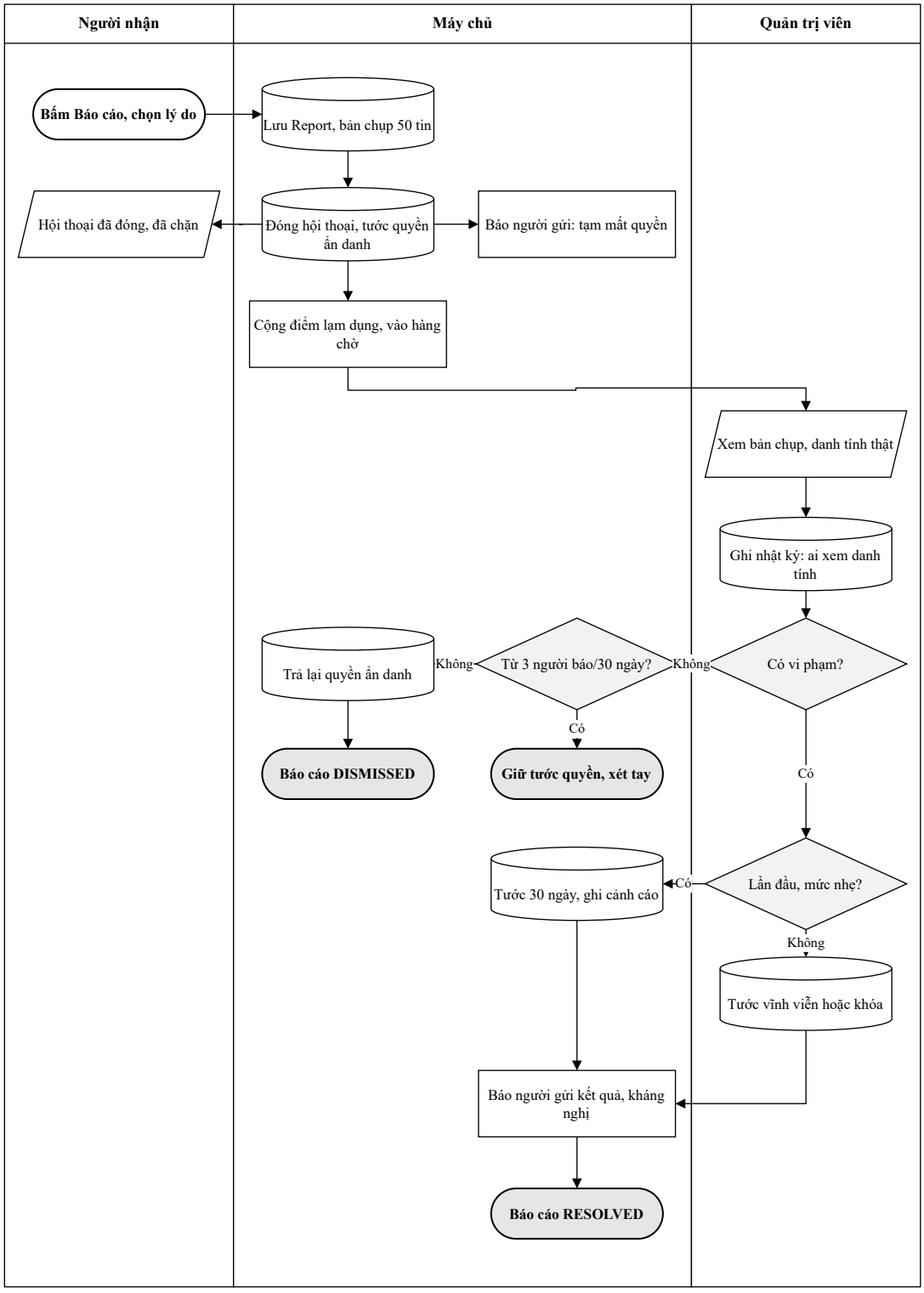
Hình 18. Bật, tạm dừng và tắt nhận tin nhắn ẩn danh

Sơ đồ 2: mọi bước kiểm tra khi gửi một tin ẩn danh, từ mở hội thoại tới lúc tin tới người nhận.



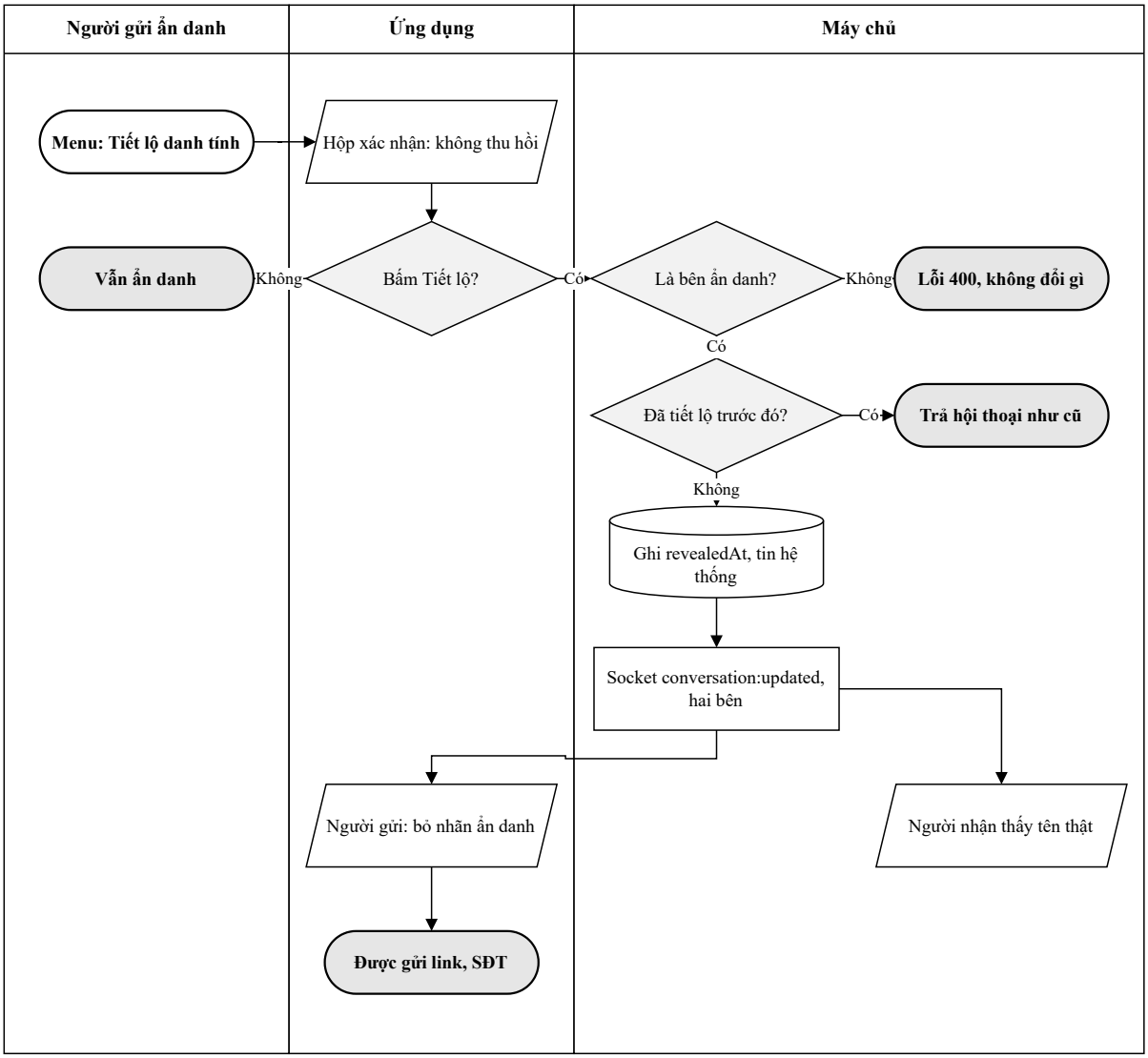
Hình 19. Gửi tin nhắn ẩn danh và các bước kiểm tra

Sơ đồ 3: báo cáo, tước quyền tự động và quản trị viên xét duyệt.



Hình 20. Báo cáo hội thoại ẩn danh, tước quyền và xét duyệt

Sơ đồ 4: người gửi tự tiết lộ danh tính.



Hình 21. Người gửi ẩn danh tự tiết lộ danh tính

e) Quy tắc, giới hạn và trường hợp đặc biệt

Giới hạn	**Hiện nay**	**Đề xuất**
Hội thoại ẩn danh mới mỗi người gửi / 24 giờ	10	10; điểm lạm dụng từ 30: 3
Tin ẩn danh mỗi người gửi / 24 giờ (mọi hội thoại)	Không giới hạn	30
Tin trước khi được trả lời	3	3
Hội thoại ẩn danh mới mỗi người nhận / 24 giờ	Không giới hạn	Người nhận chọn 5 / 10 / 20; đạt trần thì tự tạm dừng 24 giờ và gợi ý bật Giới hạn (B4)
Thời gian theo dõi trước khi được nhắn ẩn danh	0	3 ngày (mặc định)
Tuổi tài khoản người gửi	7 ngày	7 ngày

Điểm lạm dụng (tổng trong 30 ngày, bảng *SafetyEvent* của B1, các con số là đề xuất):

Sự kiện	**Điểm**
Hội thoại ẩn danh bị báo cáo	+40
Người nhận chặn (đóng) hội thoại ẩn danh	+15
Tin ẩn danh có điểm lừa đảo B3 từ 3	+10
Link nguy hiểm (B3)	+30
Bị chặn vì gửi link / SĐT / số tài khoản (tối đa 3 lần tính mỗi ngày)	+5
Tin chờ ẩn danh bị xóa	+5
Báo cáo được admin kết luận không vi phạm	Xóa điểm của báo cáo đó

Ngưỡng: từ 30 → hạn mức giảm và tin chờ của người đó vào "Đã lọc" (B1); từ 60 → tự tước quyền ẩn danh, vào hàng chờ kiểm duyệt. Admin xem được điểm và từng sự kiện.

- **Che danh tính ở mọi nơi mới:** mọi tính năng sau này chạm vào hội thoại ẩn danh (đang soạn, cảm xúc tin nhắn, thu hồi, tìm trong tin nhắn — D2, D9) phải đi qua cùng hàm che (*viewMessage / viewConversation*) và phải có phép thử trong *safety-smoke.cjs*. Không đưa danh tính vào *data* của thông báo đẩy (dữ liệu này đi qua máy chủ Expo, Apple, Google).
- **Người nhận báo cáo khi người gửi đã tiết lộ:** vẫn xử lý như hội thoại ẩn danh (đóng, tước quyền), vì nội dung đã gửi khi còn ẩn danh.
- **Người gửi bị khóa tài khoản:** hội thoại ẩn danh ẩn khỏi hộp thư người nhận; người nhận không biết đó là ai.
- **Người nhận tắt hẳn rồi bật lại:** hội thoại cũ nhận tin lại bình thường; hội thoại đã đóng thì vẫn đóng.
- **Tạo tài khoản phụ để lách tước quyền:** điều kiện 7 ngày tuổi, email đã xác thực và theo dõi đủ 3 ngày làm chậm việc này; phát hiện tài khoản phụ thật sự nằm ở kế hoạch mục 8 của MODERATION_PLAN, ngoài phạm vi B2.
- **Yêu cầu từ cơ quan chức năng:** danh tính lấy từ *Conversation* và *Message.senderId*; quy trình trả lời là việc của người vận hành, không làm trong app.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất. Phải ghi vào docs/api-contract.md và docs/decisions.md (bổ sung DEC-025) trước khi code.

Trường mới trên User	Ý nghĩa
anonymousOptInAt DateTime?, *anonymousOptInVersion* Int?	Lúc đồng ý màn rủi ro và phiên bản nội dung
anonymousAudience String, mặc định *FOLLOWERS_3D*	*FOLLOWERS* | *FOLLOWERS_3D*
anonymousDailyInbox Int, mặc định 10	Trần hội thoại ẩn danh mới nhận mỗi ngày
anonymousPausedUntil DateTime?	Tạm dừng tới lúc này
anonymousRulesAcceptedAt DateTime?	Người gửi đã đồng ý quy tắc
anonymousSuspendedUntil DateTime?	Hết hạn tước quyền; *anonymousSuspendedAt* có giá trị mà trường này trống = vô thời hạn (giữ trường cũ)

API	Ghi chú
PATCH /users/me	Thêm *anonymousAudience*, *anonymousDailyInbox*; bật *allowAnonymousMessages* thì máy chủ ghi *anonymousOptInAt*
POST /users/me/anonymous/pause { hours: 24 | 168 }, *DELETE /users/me/anonymous/pause*	Tạm dừng, tiếp tục
POST /users/me/anonymous/rules	Người gửi đồng ý quy tắc
GET /users/me/anonymous-status	*{ suspended, until, canAppeal }* cho màn thông báo của người gửi
Mã lỗi mới	403 *ANONYMOUS_PAUSED*, 403 *ANONYMOUS_RULES_REQUIRED*, 403 *ANONYMOUS_FOLLOW_TOO_NEW*, 429 *ANONYMOUS_MESSAGE_LIMIT* (thêm vào *anonymousErrors.ts* của app)
Đối tượng hội thoại	*anonymous* thêm *revealedAt*
POST /admin/reports/:id/resolve	Thêm hành động *SUSPEND_ANON_30D*, *SUSPEND_ANON_PERMANENT*
GET /admin/users/:id/safety	Điểm lạm dụng và danh sách *SafetyEvent* 30 ngày

Code cần sửa: *openAnonymousConversation* và *send* (thêm kiểm tra người nhận, trần tin), *reports.service.ts* (ghi SafetyEvent, gửi thông báo cho người gửi),

admin.service.ts (hành động mới, thời hạn), *AnonymousMessagesScreen.tsx* (lựa chọn, tạm dừng), màn quy tắc người gửi mới, *ProfileView.tsx*.

g) Android, iOS và web

- Không cần quyền thiết bị, không cần thư viện mới. Mọi màn dùng thành phần sẵn có, chạy như nhau trên hai nền tảng.
- Thông báo đẩy qua Expo → APNs và FCM (thuộc D8). Tiêu đề "Người ẩn danh", không nội dung, không id thật trong dữ liệu kèm theo — áp dụng giống nhau cho iOS và Android.
- **App Store:** ứng dụng có nhắn ẩn danh thường bị người duyệt hỏi kỹ. Cần ghi chú cho người duyệt (App Review notes) mô tả: tắt mặc định, màn rủi ro, báo cáo và chặn ngay trong cuộc trò chuyện, tước quyền tự động, 18+. Xếp hạng tuổi phải phù hợp nội dung do người dùng tạo. **Google Play:** chính sách nội dung do người dùng tạo yêu cầu báo cáo, chặn và kiểm duyệt — đã có, cần mô tả trong mục khai báo an toàn.
- Trang quản trị (web): cột điểm lạm dụng, nút tước 30 ngày / vĩnh viễn, nhật ký ai xem danh tính (C3).
- Không có chi phí dịch vụ ngoài.

h) Tiêu chí hoàn thành

- Tạm dừng 24 giờ: tin ẩn danh tới từ hội thoại cũ, hội thoại mới và trả lời story đều bị từ chối *ANONYMOUS_PAUSED*; hết hạn thì nhận lại.
- Theo dõi chưa đủ 3 ngày → *ANONYMOUS_FOLLOW_TOO_NEW*; đủ thì gửi được.
- Người gửi lần đầu thấy màn quy tắc; đồng ý rồi không thấy lại.
- Tin thứ 31 trong 24 giờ bị từ chối; hội thoại mới thứ 11 bị từ chối; người nhận đạt trần thì tự tạm dừng và nhận gợi ý Giới hạn.
- Điểm lạm dụng đạt 60 → tự tước quyền, xuất hiện trong hàng chờ admin.
- Báo cáo → hội thoại đóng, người gửi nhận thông báo tạm dừng; admin xử lý được cả 3 hướng (bỏ qua, 30 ngày, vĩnh viễn); người gửi thấy kết quả.
- Mỗi lần admin mở danh tính có một dòng nhật ký.
- *safety-smoke.cjs* kiểm tra không lộ id, username, ảnh thật trong API, socket và thông báo đẩy của mọi luồng mới (tạm dừng, tiết lộ, báo cáo).
- Chạy tay trên Android **và** iPhone; ghi rõ nền tảng đã chạy.

i) Ước lượng và phụ thuộc

- Backend 5 ngày (tạm dừng, nhóm được phép, trần tin, quy tắc người gửi, điểm lạm dụng, tước có thời hạn, thông báo người gửi), mobile 3 ngày (màn cài đặt, tạm dừng, màn quy tắc, mã lỗi mới, dòng hệ thống khi tiết lộ, màn thông báo bị tước quyền), kiểm thử 2 ngày.
- Phụ thuộc: B1 (bảng *SafetyEvent*, thư mục "Đã lọc"), B3 (chấm lừa đảo), C1 (hàng chờ cho mục tự tạo), C2 (cảnh cáo và kháng nghị), C3 (nhật ký xem danh tính). Có thể làm trước C1–C3 bằng cách tạm dùng bảng *Report* hiện có, nhưng mục tự tạo cần một tài khoản hệ thống làm người báo cáo (*Report.reporterId* bắt buộc) — cần chủ dự án quyết.
- Rủi ro: hạn mức quá chặt làm tính năng kém hấp dẫn; quá lỏng thì bị lạm dụng. Đề xuất đo 4 tuần đầu: số báo cáo trên 100 hội thoại ẩn danh, tỉ lệ bị chặn.
- Rủi ro pháp lý: nhắn ẩn danh có thể chịu nghĩa vụ xác thực tài khoản theo Nghị định 147/2024 (xem A5); cần luật sư xác nhận.

B3. Cảnh báo lừa đảo (tin nhắn, đường link, hồ sơ giả mạo)

Nhóm: An toàn tin nhắn · Giai đoạn: GĐ2 · Ước lượng: 13 ngày công

a) Mục đích

Lừa đảo qua tin nhắn ở Việt Nam thường theo vài kịch bản quen: mượn tiền qua tài khoản người quen bị chiếm, xin mã OTP, "việc nhẹ lương cao", trúng thưởng phải đóng phí, link giả ngân hàng, và tài khoản giả tên người quen. Tính năng này nhận ra các dấu hiệu đó, cảnh báo người nhận ngay cạnh tin nhắn, chặn mở link nguy hiểm, và cho một đường báo cáo lừa đảo nhanh. Mục tiêu là giảm số người chuyển tiền hoặc đưa mã OTP cho kẻ gian; không phải đọc trộm tin nhắn — mọi kiểm tra chạy tự động trên máy chủ, người không xem nội dung khi chưa có báo cáo.

b) Hiện trạng

Đã có (*apps/api/src/modules/moderation/text-safety.ts*, *messages.service.ts*, *reports*):

- *normalizeVietnamese*: bỏ dấu, chữ thường.
- *findBlockedContact*: chặn link (kể cả "abc chấm com", *t.me*, *bit.ly*, *zalo.me*), số điện thoại Việt Nam, dãy 8–19 chữ số — **chỉ** trong tin của người ẩn danh chưa tiết lộ và người mở tin nhắn chờ.
- *hasScamWarning*: 28 cụm từ (chuyển khoản, OTP, mật khẩu, nạp tiền, stk, việc nhẹ lương cao, đầu tư, USDT, Zalo, Telegram...). Có một cụm là cờ *warning = true*, app hiện "Tin nhắn có dấu hiệu lừa đảo. Đừng chuyển tiền hay gửi mã OTP." Chỉ áp dụng cho tin từ người lạ hoặc ẩn danh; **tính lúc đọc, không lưu**.
- Báo cáo hội thoại có lý do *SCAM* đứng đầu, lưu bản chụp 50 tin; admin khóa được tài khoản.

Còn thiếu:

- Không chấm điểm: một từ "zalo" và một tin "chuyển khoản gấp vào stk, gửi mã OTP" cùng một mức cảnh báo. Cảnh báo dễ bị bỏ qua vì xuất hiện quá thường.
- Hội thoại đã chấp nhận **không được kiểm tra**, trong khi kịch bản phổ biến nhất là tài khoản bạn bè bị chiếm rồi hỏi mượn tiền.
- Link trong hội thoại đã chấp nhận không được kiểm tra; trong app link chỉ là chữ, không bấm được (không có *Linking* trong *features/messages*), nên người dùng phải sao chép sang trình duyệt — không có chỗ nào cảnh báo.
- Không phát hiện tài khoản giả tên người quen; lý do báo cáo chưa có "giả mạo".
- Không lưu kết quả kiểm tra nên admin không thống kê được, không biết ai hay gửi tin bị cờ.

- Khi admin khóa một kẻ lừa đảo, những người khác đã nhận tin của họ không được báo.

c) Cách hoạt động

Luồng 1: Phân tích chữ trong tin nhắn (sơ đồ 1)

1. Người gửi gửi tin có chữ. Máy chủ chuẩn hóa: bỏ dấu (hàm hiện có), thay teencode và chữ lách phổ biến ("ck" → "chuyen khoan", "o.t.p" → "otp", số thay chữ "0" → "o" trong từ).
2. Nếu là tin chờ hoặc tin ẩn danh: chạy *findBlockedContact* như hiện nay, có liên lạc thì chặn tin.
3. Dò cụm từ theo 8 nhóm (bảng ở mục e), mỗi nhóm có điểm; một nhóm chỉ tính một lần dù xuất hiện nhiều cụm.
4. Tách các đường link trong tin, chạy kiểm tra link (luồng 2). Link đáng ngờ cộng 2, nguy hiểm cộng 5.
5. Cộng điểm bối cảnh: người lạ / ẩn danh +1; tài khoản người gửi dưới 30 ngày +1; người gửi đang có báo cáo lừa đảo chưa xử lý hoặc điểm lạm dụng (B2) từ 30 thì +2.
6. Tổng dưới 3: lưu và gửi bình thường. Từ 3: lưu mức **Cảnh báo**; từ 5: mức **Cao**. Lưu lý do (các nhóm đã khớp), ghi *SafetyEvent* cho người gửi (+10).
7. Người nhận thấy: mức Cảnh báo → thanh vàng dưới tin, ghi lý do cụ thể ("Tin này xin mã OTP. Không ai cần mã OTP của bạn, kể cả ngân hàng."). Mức Cao → tin bị che, chỉ hiện thanh đỏ "Tin này có nhiều dấu hiệu lừa đảo", nút "Vẫn xem" và "Báo cáo lừa đảo"; link trong tin không bấm được.
8. Thông báo đẩy của tin mức Cao không chứa nội dung ("Đã gửi cho bạn một tin nhắn").
9. **Nhắc trước khi gửi mã:** nếu tin gần nhất người dùng nhận trong hội thoại có lý do OTP, và người dùng sắp gửi một dãy 4–8 chữ số, app hỏi "Bạn có đang gửi mã OTP? Không ai cần mã này. Vẫn gửi?" (chạy trên app, không lưu gì).

Luồng 2: Kiểm tra đường link (sơ đồ 2)

1. Khi lưu tin có link: máy chủ chuẩn hóa (thêm *https://* nếu thiếu, bỏ phần theo dõi, chuyển tên miền dạng punycode về chữ thường), tách tên miền.
2. Tra **danh sách chặn nội bộ** (bảng *BlockedDomain*, admin thêm). Có → kết quả *NGUY HIỂM*.
3. Kiểm tra **nhái tên miền thật**: so với danh sách tên miền tin cậy để trong code (ngân hàng, ví điện tử, cơ quan nhà nước, chính app này). Tên miền giống nhưng

không trùng (ví dụ *vietc0mbank-xacminh.com*, ký tự lạ, thêm chữ "xacminh", "hotro") → *ĐÁNG NGỜ*. Dịch vụ rút gọn link (*bit.ly*, *tinyurl*...) → *ĐÁNG NGỜ* vì không biết đích (máy chủ **không** tự mở link để xem đích, tránh bị lợi dụng tấn công).

4. Còn lại: hỏi **Google Web Risk** (dịch vụ của Google cho biết một URL có nằm trong danh sách lừa đảo, mã độc hay không). Báo hại → *NGUY HIỂM*. Không → *KHÔNG RÕ*. Lưu kết quả vào bảng *LinkCheck*, dùng lại trong 24 giờ.
5. Web Risk lỗi hoặc quá chậm (quá 2 giây): lưu *KHÔNG RÕ*, tin vẫn gửi, không chặn người dùng vì lỗi dịch vụ ngoài.
6. Trong app, link trong tin **bấm được**. Khi người nhận chạm: app hỏi kết quả mới nhất (danh sách chặn có thể vừa cập nhật).
7. *NGUY HIỂM* → không mở, hiện "Trang này đã bị đánh dấu lừa đảo hoặc nguy hiểm" và nút Báo cáo.
8. Còn lại → màn "Bạn sắp rời ứng dụng", hiện rõ tên miền thật (in đậm), mức rủi ro, lời nhắc "Đừng nhập mật khẩu, mã OTP, số thẻ". Bấm "Vẫn mở" thì mở trình duyệt hệ thống, "Ở lại" thì quay về.

Luồng 3: Cảnh báo tài khoản giả mạo (sơ đồ 3)

1. Khi có tin nhắn chờ hoặc yêu cầu theo dõi mới từ tài khoản Y gửi tới người dùng N, và khi N mở trang cá nhân của Y.
2. Chỉ xét Y dưới 30 ngày tuổi (tài khoản giả thường mới).
3. So tên hiển thị và username của Y với những người N đang theo dõi (và tài khoản đã xác minh, E4): chuẩn hóa bỏ dấu, thay ký tự trông giống nhau (0/o, 1/l/i, rn/m), bỏ dấu chấm, gạch dưới; giống khi trùng hẳn sau chuẩn hóa hoặc chỉ khác 1–2 ký tự. Bỏ qua nếu N đã theo dõi Y.
4. Giống tên, khác người (X là người thật N theo dõi, X lâu năm hơn Y) → lưu *impersonationOfId = X* vào hội thoại, ghi *SafetyEvent* cho Y.
5. App hiện thanh cam ở yêu cầu và trang cá nhân của Y: "Tài khoản này có tên giống *X* mà bạn theo dõi, nhưng mới tạo 5 ngày trước. Có thể là giả mạo." Hai nút: "Xem trang của *X*" và "Báo cáo giả mạo".
6. Báo cáo giả mạo: lưu báo cáo lý do *IMPERSONATION*, xóa yêu cầu, chặn Y. Từ 3 báo cáo khác nhau trong 7 ngày → tạm lọc mọi tin của Y vào "Đã lọc" của người nhận (B1) cho tới khi admin xem. Báo cáo vào hàng chờ kiểm duyệt.

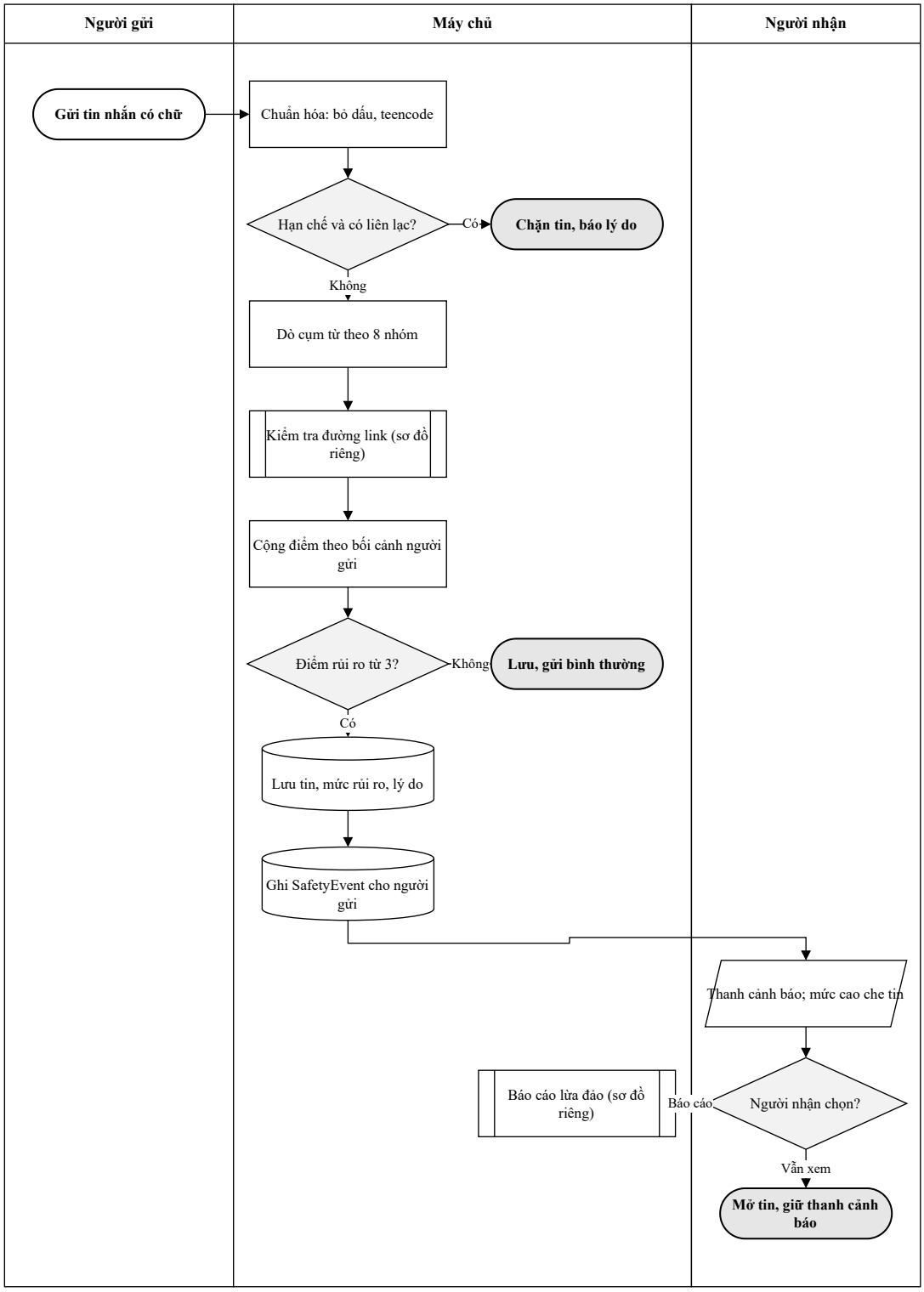
Luồng 4: Báo cáo lừa đảo và quản trị viên xử lý (sơ đồ 4)

1. Người nhận bấm "Báo cáo lừa đảo" ngay ở thanh cảnh báo (một chạm, lý do *SCAM* chọn sẵn), hoặc từ menu báo cáo.

2. Máy chủ lưu báo cáo kèm bản chụp 50 tin (như hiện nay), ẩn hội thoại khỏi hộp thư của người báo cáo, app hỏi "Chặn luôn?".
3. Từ 3 người khác nhau báo lừa đảo cùng một tài khoản trong 7 ngày → **tạm hạn chế** tài khoản đó: không mở được tin chờ mới, tin gửi người không theo dõi mình vào "Đã lọc", mất quyền ẩn danh, cho tới khi admin xem.
4. Báo cáo lừa đảo đứng đầu hàng chờ. Quản trị viên xem bản chụp, các link trong tin và kết quả kiểm tra link, lịch sử báo cáo, điểm lạm dụng.
5. Không phải lừa đảo → gỡ hạn chế, ghi "báo nhầm" (dùng để đo chất lượng bộ lọc), báo cáo *DISMISSED*.
6. Đúng lừa đảo → khóa tài khoản (hàm *setBanned* có sẵn, ghi lý do *SCAM*), thêm tên miền trong tin vào *BlockedDomain* bằng một nút, ghi nhật ký.
7. Máy chủ tìm những người khác đã nhận tin của tài khoản này trong 30 ngày, gắn cảnh báo vào hội thoại của họ ("Tài khoản này đã bị khóa vì lừa đảo. Đừng chuyển tiền hay gửi mã.") và gửi thông báo đẩy. Người báo cáo nhận "Báo cáo của bạn đã được xử lý".

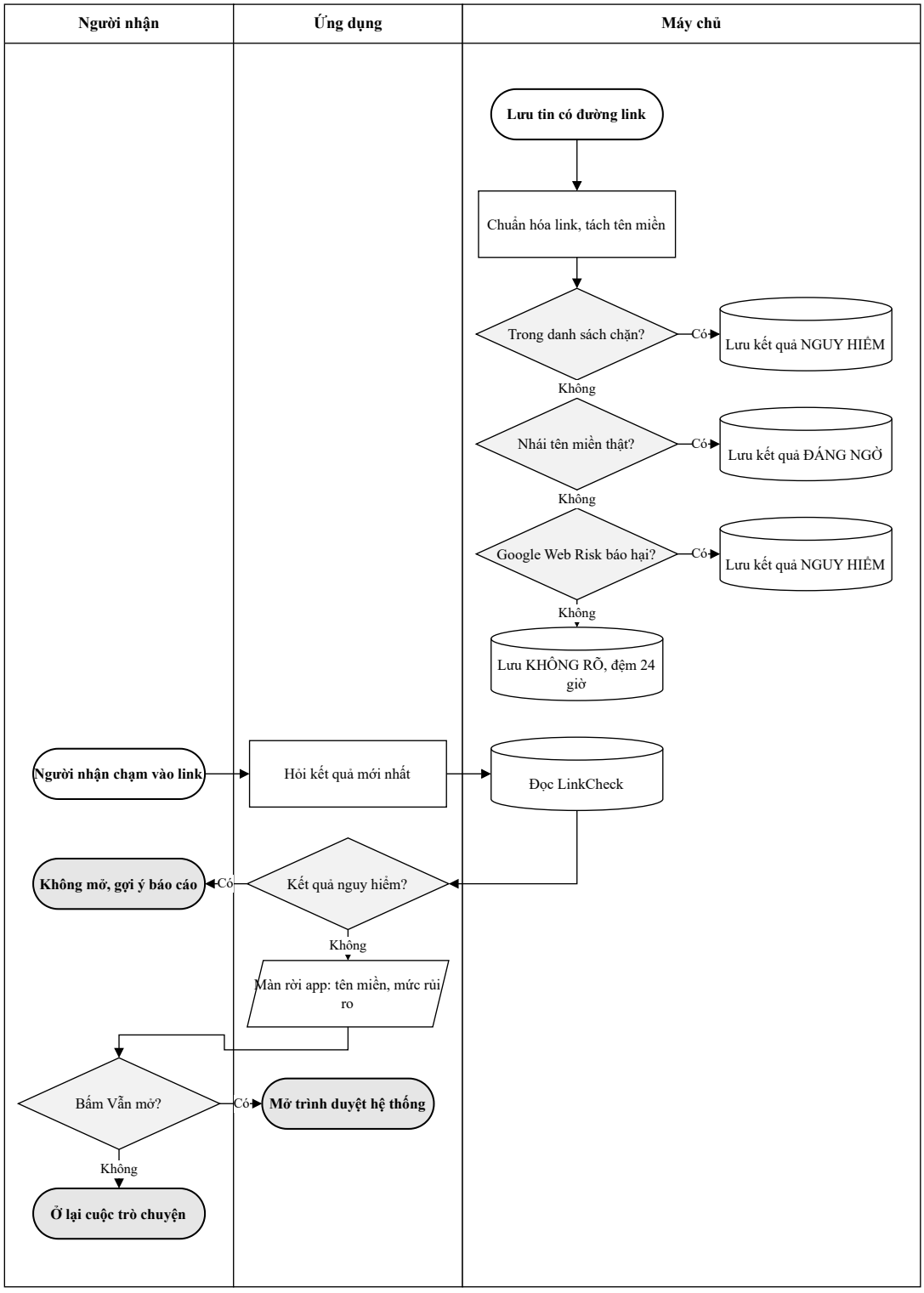
d) Flowchart

Sơ đồ 1: phân tích một tin nhắn từ lúc gửi tới lúc người nhận thấy cảnh báo.



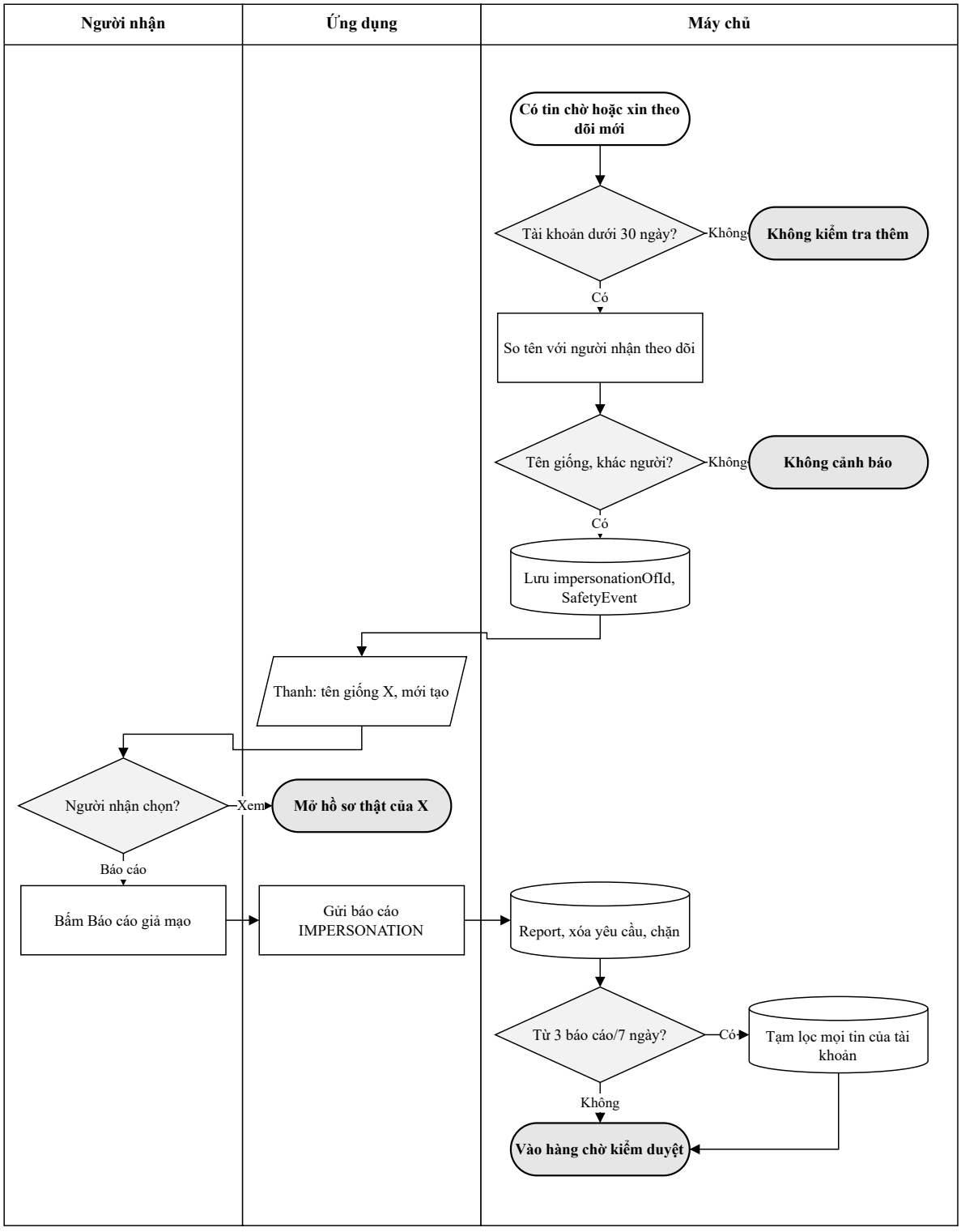
Hình 22. Phân tích tin nhắn tìm dấu hiệu lừa đảo

Sơ đồ 2: kiểm tra link khi lưu tin, và khi người nhận chạm vào link.



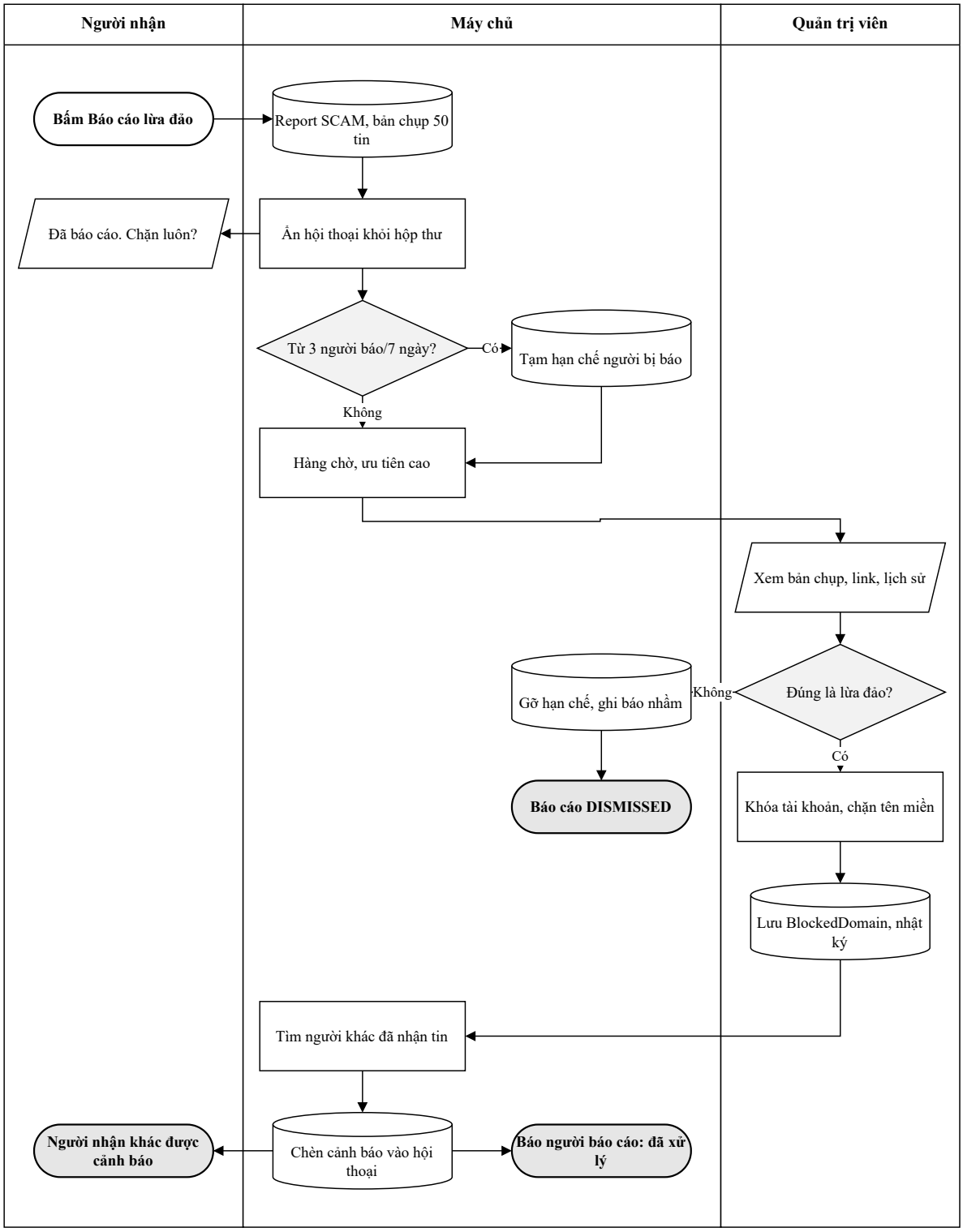
Hình 23. Kiểm tra đường link trong tin nhắn

Sơ đồ 3: phát hiện và cảnh báo tài khoản giả mạo người quen.



Hình 24. Cảnh báo tài khoản giả mạo người quen

Sơ đồ 4: báo cáo lừa đảo, hạn chế tự động và quản trị viên xử lý.



Hình 25. Báo cáo lừa đảo và xử lý của quản trị viên

e) Quy tắc, giới hạn và trường hợp đặc biệt

Nhóm cụm từ và điểm (đề xuất; danh sách nằm trong *text-safety.ts* như hiện nay, sửa một chỗ là đủ):

Nhóm	Ví dụ (sau khi bỏ dấu)	Điểm

Xin mã OTP	ma otp, ma xac nhan, ma xac thuc, gui ma, doc ma	3
Đòi chuyển tiền	chuyen khoan, ck truoc, muon tien, vay tien, ung tien, nap tien, nap the	2
Thông tin ngân hàng, thẻ	stk, so tai khoan, so the, cvv, mat khau, tên ngân hàng và ví điện tử	2
Việc làm, nhiệm vụ	viec nhe luong cao, cong tac vien, ctv, nhiem vu, hoa hong, kiem tien online	2
Trúng thưởng, đóng phí	trung thuong, nhan qua, phi nhan, phi giai ngan	2
Đầu tư, tiền ảo	dau tu, loi nhuan, lai suat, tien ao, usdt, crypto	1
Kéo ra ngoài app	zalo, telegram, ket ban, inbox rieng	1
Gấp, giả cơ quan	gap, khan cap, cong an, toa an, tai khoan se bi khoa, bo phan ho tro	1

Ví dụ: bạn bè nhắn "chuyển khoản tiền ăn hôm qua nhé" = 2 điểm, không cảnh báo. Tài khoản quen nhắn "mượn tiền gấp, chuyển khoản vào stk này" = 2 + 2 + 1 = 5, mức Cao. Người lạ nhắn "kết bạn zalo" = 1 + 1 = 2, không cảnh báo (hiện nay có cảnh báo — đây là thay đổi có chủ ý để cảnh báo ít mà trúng).

- **Hội thoại đã chấp nhận** cũng được chấm, cùng ngưỡng; người lạ chỉ được cộng thêm điểm bối cảnh.
- **Người gửi không được báo** tin của họ bị gắn cảnh báo (tránh kẻ gian dò luật).
- **Tin đã tiết lộ / hội thoại với tài khoản bị khóa:** cảnh báo giữ nguyên trên tin cũ.
- **Sửa tin** (D2): chấm lại khi sửa.
- **Link:** tối đa 5 link được kiểm tra mỗi tin; quá thì phần còn lại là *KHÔNG RÕ*. Mỗi người gửi tối đa 50 lượt hỏi Web Risk mỗi giờ (đề xuất) để tránh đốt tiền.
- **Giả mạo:** chỉ so trong phạm vi người N theo dõi (giới hạn 2.000 tài khoản đầu) và tài khoản đã xác minh; không quét toàn bộ người dùng.
- **Báo nhầm:** admin bấm "báo nhầm" thì gỡ hạn chế và xóa điểm của các báo cáo đó. Một người báo cáo lừa đảo sai nhiều lần (từ 5 lần bị kết luận báo nhầm trong 30 ngày) thì báo cáo của họ không còn tính vào ngưỡng tự hạn chế.
- **Viết số thành chữ** ("không chín một hai...") vẫn lọt — đã ghi trong hạn chế của MODERATION_PLAN; giải quyết sau bằng mô hình chữ (MODERATION_PLAN mục 8).

f) Dữ liệu và API (đề xuất)

Đây là đề xuất. Phải ghi vào docs/api-contract.md và docs/decisions.md trước khi code.

Thay đổi	**Chi tiết**
Message.riskLevel String?, *Message.riskReasons* String[]	*null* | *WARN* | *HIGH*; lý do: *OTP, MONEY, BANK, JOB, PRIZE, INVEST, OFF_PLATFORM, URGENT, LINK_SUSPICIOUS, LINK_MALICIOUS*. Không lưu điểm chi tiết.
Bảng *LinkCheck*	*urlHash* (khóa), *domain, verdict* (*SAFE* | *UNKNOWN* | *SUSPICIOUS* | *MALICIOUS*), *source* (*BLOCKLIST* | *LOOKALIKE* | *WEB_RISK* | *ADMIN*), *checkedAt, expiresAt*
Bảng *BlockedDomain*	*domain* (khóa), *reason, addedById, createdAt*
Conversation.impersonationOfId String?	Người thật mà tài khoản kia nhái tên
User.banReason String?	Dùng chung với C2; giá trị *SCAM* để gắn cảnh báo cho người đã nhận tin
Hằng số trong code	Danh sách tên miền tin cậy (ngân hàng, ví, cơ quan nhà nước) để so nhái tên

API	**Ghi chú**
Đối tượng tin nhắn	Thêm *risk: null | { level, reasons }*; giữ *warning* (= có *risk*) cho bản app cũ
Đối tượng hội thoại	Thêm *safetyNotice: null | { type: "IMPERSONATION", of: { id, username, displayName } } | { type: "PEER_BANNED_SCAM" }*
GET /links/check?url=	*{ verdict, domain }*; cần đăng nhập; giới hạn 60 lần / phút
GET /users/:id	Thêm *impersonationOf* (theo góc nhìn người xem)
POST /reports	Thêm lý do *IMPERSONATION*
GET / POST / DELETE /admin/blocked-domains	Quản lý danh sách chặn
POST /admin/reports/:id/resolve	Thêm tùy chọn *blockDomains: true* và hành động *FALSE_REPORT*

Code cần sửa: *text-safety.ts* (từ *hasScamWarning* sang hàm chấm điểm trả mức và lý do, giữ hàm cũ để không vỡ chỗ gọi), *messages.service.ts* (chấm khi lưu thay vì khi

đọc), module mới *link-safety* trong *moderation*, *reports*, *admin*, *ChatScreen.tsx* (thanh cảnh báo theo mức, link bấm được, màn rời app, nhắc trước khi gửi mã), *ProfileView.tsx* (thanh giả mạo).

g) Android, iOS và web

- Mở link: dùng *Linking.openURL* có sẵn trong React Native, mở trình duyệt hệ thống trên cả Android và iOS; không cần thư viện mới. Không dùng *Linking.canOpenURL* (trên iOS cần khai báo danh sách scheme trong *app.json*). Chỉ mở *http* và *https*; các scheme khác (*tel:*, *intent:*, ...) không biến thành link.
- Không cần quyền thiết bị mới.
- **Dịch vụ ngoài và chi phí:** Google Web Risk API (Google Cloud, cần tài khoản thanh toán). Bản Safe Browsing miễn phí chỉ cho mục đích phi thương mại, nên app thương mại dùng Web Risk. Web Risk có hạn mức miễn phí hằng tháng rồi tính phí theo số nghìn lượt gọi — **cần kiểm tra bảng giá hiện hành trước khi ký**. Bộ nhớ đệm 24 giờ theo link làm số lượt gọi thấp. Link được gửi sang Google: phải ghi trong chính sách quyền riêng tư.
- Có thể bổ sung danh sách web lừa đảo của tổ chức trong nước (ví dụ dự án chống lừa đảo của cộng đồng Việt Nam) — **cần kiểm tra giấy phép sử dụng** trước khi tích hợp.
- Trang quản trị (web): quản lý *BlockedDomain*, xem kết quả kiểm tra link trong bản chụp, nút "báo nhầm".
- App Store và Google Play: không có yêu cầu riêng; tính năng hỗ trợ phần "kiểm duyệt nội dung do người dùng tạo".

h) Tiêu chí hoàn thành

- Bộ test đơn vị cho hàm chấm điểm với ít nhất 40 câu mẫu (20 câu lừa đảo thật, 20 câu bình thường như chia tiền ăn, hẹn đi chơi): không cảnh báo nhầm câu bình thường nào ở mức Cao.
- Tin "mượn tiền gấp, chuyển khoản vào stk" trong hội thoại đã chấp nhận hiện mức Cao, tin bị che, thông báo đẩy không có nội dung.
- Link trong *BlockedDomain* không mở được; link nhái ngân hàng hiện màn rời app với mức "đáng ngờ"; Web Risk tắt mạng thì tin vẫn gửi và link là "không rõ".
- Gửi dãy 6 số ngay sau khi nhận tin xin OTP: app hỏi lại.
- Tài khoản mới đặt tên giống người mình theo dõi: thanh giả mạo hiện ở tin chờ và trang cá nhân; báo cáo giả mạo hoạt động.
- 3 người báo lừa đảo cùng một tài khoản: tài khoản bị tạm hạn chế; admin khóa thì người đã nhận tin thấy cảnh báo và nhận thông báo đẩy.

- Chạy tay trên Android **và** iPhone (đặc biệt: mở link, màn rời app, thanh cảnh báo); ghi rõ nền tảng đã chạy.

i) Ước lượng và phụ thuộc

- Backend 7 ngày (chấm điểm và lưu 2 ngày, kiểm tra link và Web Risk 2 ngày, giả mạo 1,5 ngày, báo cáo lừa đảo và cảnh báo người đã nhận 1,5 ngày), mobile 4 ngày, kiểm thử 2 ngày.
- Phụ thuộc: B1 (*SafetyEvent*, "Đã lọc"), C1 (hàng chờ ưu tiên), C2 (*banReason*, cảnh cáo), E4 (tài khoản đã xác minh làm mốc so tên — không bắt buộc). B1 và B2 dùng bộ chấm điểm này.
- Rủi ro: cảnh báo nhầm làm người dùng mất tin tưởng hoặc làm phiền giao dịch thật (bán hàng online hay nói "chuyển khoản", "stk"). Giảm bằng ngưỡng 3, chỉ che tin ở mức 5, và đo tỉ lệ "báo nhầm" hằng tuần.
- Rủi ro: kẻ gian học luật và đổi cách viết. Danh sách cụm từ cần người cập nhật định kỳ (đề xuất mỗi tháng, từ các báo cáo *SCAM*).

B4. Giới hạn tạm thời khi bị quấy rối hàng loạt

Nhóm: An toàn tương tác · Giai đoạn: GĐ2 · Ước lượng: 9 ngày công

a) Mục đích

Khi một người bất ngờ bị nhiều người lạ kéo vào bình luận hoặc nhắn tin (bài viết lan truyền, bị "ném đá", bị một nhóm nhắm vào), họ cần một nút bật nhanh để tạm thời không thấy những tương tác đó, mà không phải chặn từng người hay khóa tài khoản. Giống tính năng "Limits" của Instagram: máy chủ tự phát hiện đột biến và gợi ý; người dùng bật trong vài ngày; người bị giới hạn không biết mình bị ẩn.

b) Hiện trạng

- **Chưa có gì** cho tính năng này trong code.
- Các mảnh dùng lại được: *Follow.createdAt* (biết ai mới theo dõi), *blockedUserIds*, thư mục tin nhắn chờ (*messages.service.ts*), thông báo đẩy qua *notifications.service.ts*, chặn và báo cáo có sẵn.
- Bình luận (*comments.service.ts*, hàm *create*): ai xem được bài là bình luận được, mỗi bình luận tạo thông báo *COMMENT* cho chủ bài; không có cờ ẩn trên *Comment*; chỉ có giới hạn chung 300 request/phút theo IP.
- Không có việc chạy định kỳ (không có *@nestjs/schedule* hay hàng đợi) trong *apps/api/package.json*.

c) Cách hoạt động

Định nghĩa "người lạ" (nhóm bị giới hạn): người mà chủ tài khoản **không theo dõi**, và hoặc không theo dõi chủ tài khoản, hoặc mới theo dõi trong 7 ngày qua (người dùng chọn có tính nhóm "mới theo dõi" hay không). Người chủ tài khoản đang theo dõi và người theo dõi lâu năm không bao giờ bị ảnh hưởng.

Luồng 1: Phát hiện đột biến và gợi ý (sơ đồ 1)

1. Mỗi khi có bình luận mới trên bài của chủ tài khoản, hoặc tin nhắn chờ / tin ẩn danh mới tới họ, máy chủ (chạy sau khi lưu, không làm chậm việc đăng) kiểm tra người gửi có phải người lạ không.
2. Nếu phải: đếm người lạ đã bình luận hoặc nhắn tới chủ tài khoản trong 60 phút qua (truy vấn đếm trên *Comment* và *Conversation*, không cần bảng mới).
3. Vượt ngưỡng đột biến (mục e) và chủ tài khoản chưa bật Giới hạn, chưa được gợi ý trong 7 ngày → ghi thời điểm gợi ý, gửi thông báo đẩy "Bạn đang nhận nhiều bình luận và tin nhắn từ người lạ. Bật Giới hạn để tạm ẩn chúng?".

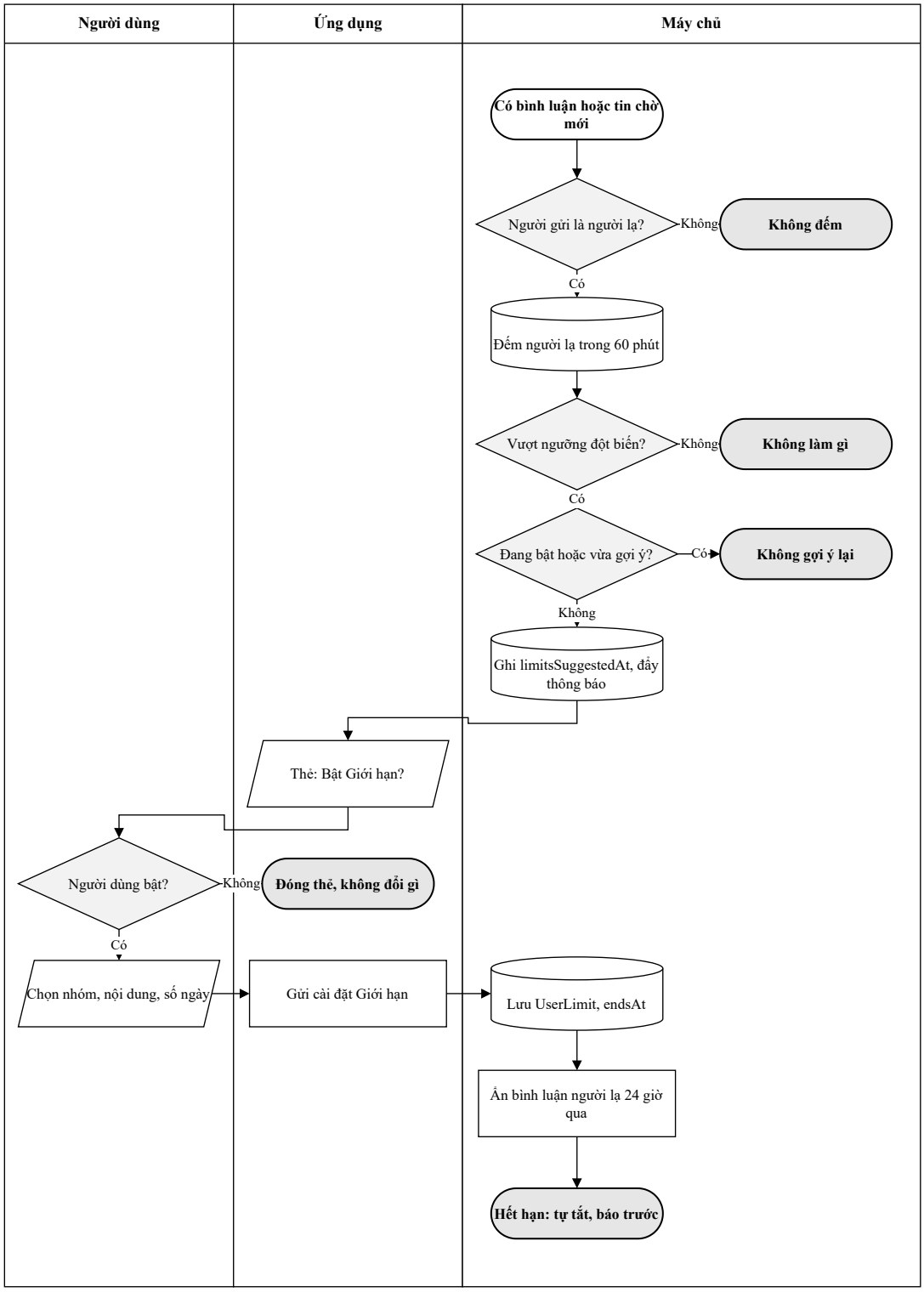
4. App hiện thẻ gợi ý ở đầu màn Thông báo và trong màn Tin nhắn. Người dùng bỏ qua thì thẻ đóng, không gợi ý lại trong 7 ngày.
5. Người dùng bấm "Bật": chọn **ai** (người không theo dõi bạn; thêm người mới theo dõi trong 7 ngày), **cái gì** (bình luận, tin nhắn — mặc định cả hai), **bao lâu** (1, 3, 7, 14 hoặc 28 ngày; mặc định 7).
6. Máy chủ lưu, áp dụng ngay cho tương tác mới, và ẩn luôn bình luận của người lạ trong 24 giờ qua (đề xuất, để dọn đợt vừa rồi).
7. Người dùng cũng bật được bằng tay bất cứ lúc nào: Cài đặt → Quyền riêng tư → "Giới hạn".
8. Hết hạn: tự tắt (máy chủ so giờ khi có tương tác, không cần việc chạy nền). Một ngày trước khi hết hạn, app hiện nhắc "Giới hạn sẽ tắt vào ngày mai. Gia hạn?" khi người dùng mở app; thông báo đẩy nhắc thì cần việc chạy định kỳ (xem phụ thuộc).

Luồng 2: Khi Giới hạn đang bật (sơ đồ 2)

1. **Bình luận** của người lạ: vẫn lưu, gắn cờ ẩn *LIMITS*. Chỉ người viết thấy bình luận của mình (họ không biết bị ẩn); người khác và chủ bài không thấy trong danh sách; không tạo thông báo; không tính vào số bình luận hiển thị.
2. Chủ bài có mục "Bình luận bị ẩn" dưới mỗi bài: xem từng bình luận, chọn **Hiện** (bỏ cờ, hiện công khai), **Xóa** hoặc để nguyên.
3. **Tin nhắn** từ người lạ (tin chờ, trả lời story): vào thư mục "Đã lọc" (B1) với lý do *LIMITS*, không thông báo đẩy. Chủ tài khoản tự xem khi muốn.
4. **Tin ẩn danh**: tạm dừng nhận ẩn danh trong thời gian Giới hạn (dùng cơ chế tạm dừng của B2), người gửi thấy "Người này đang tạm dừng nhận tin ẩn danh".
5. **Nhắc tên (@)** trong bình luận của người lạ: không tạo thông báo.
6. Hội thoại đã chấp nhận, bình luận của người được miễn: không đổi gì.

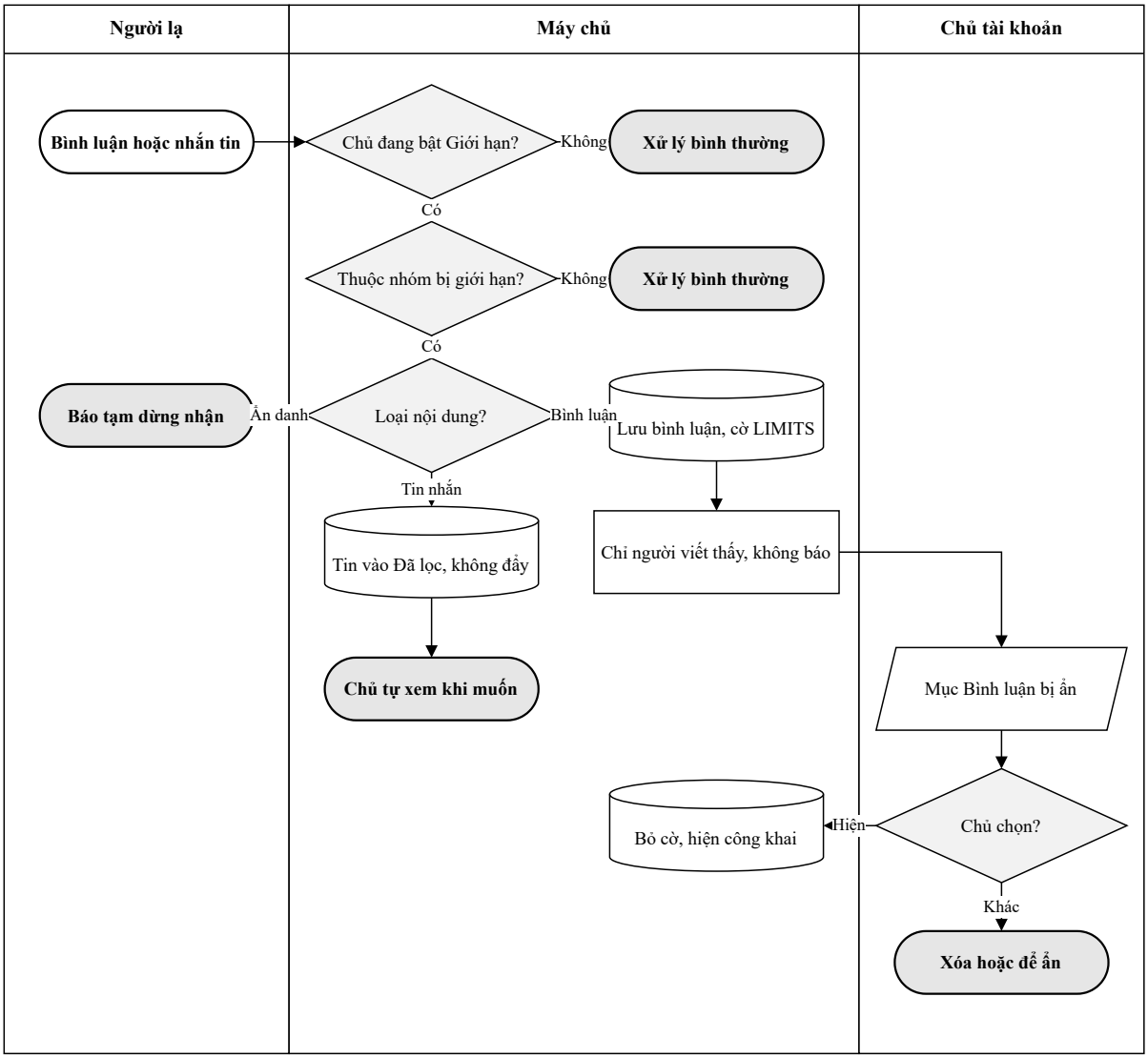
d) Flowchart

Sơ đồ 1: phát hiện đột biến, gợi ý và bật Giới hạn.



Hình 26. Phát hiện đột biến và gợi ý bật Giới hạn

Sơ đồ 2: điều gì xảy ra với bình luận và tin nhắn của người lạ khi Giới hạn đang bật.



Hình 27. Khi Giới hạn đang bật: người lạ bình luận hoặc nhắn tin

e) Quy tắc, giới hạn và trường hợp đặc biệt

Quy tắc	**Giá trị đề xuất**
Ngưỡng đột biến (một trong các điều kiện, trong 60 phút)	Từ 20 bình luận của từ 10 người lạ khác nhau; hoặc từ 10 tin chờ / tin ẩn danh mới từ 10 người lạ khác nhau; hoặc từ 3 báo cáo của chủ tài khoản về bình luận / tin nhắn
Tần suất kiểm tra	Tối đa 1 lần mỗi phút cho mỗi chủ tài khoản
Gợi ý lại	Không sớm hơn 7 ngày sau lần gợi ý trước
Thời gian bật	1, 3, 7, 14, 28 ngày; gia hạn hoặc tắt sớm bất cứ lúc nào
Ẩn ngược thời gian khi bật	Bình luận của người lạ trong 24 giờ trước đó
"Mới theo dõi"	Theo dõi dưới 7 ngày

- **Tắt Giới hạn:** bình luận đã ẩn **vẫn ẩn** (người dùng tự hiện từng cái trong mục "Bình luận bị ẩn"); tin trong "Đã lọc" vẫn ở đó. Tránh việc tắt xong cả đợt quấy rối hiện lại một lúc.
- **Người bị giới hạn không được báo**, không có mã lỗi riêng; với họ mọi thứ như bình thường (trừ tin ẩn danh, vốn đã có thông báo tạm dừng ở B2).
- **Người viết xóa tài khoản / bị khóa:** bình luận ẩn đi theo quy tắc hiện có.
- **Bài viết của người khác**: Giới hạn chỉ bảo vệ bài và hộp thư của chính chủ tài khoản; trả lời bình luận của chủ tài khoản trên bài người khác không bị ảnh hưởng (đề xuất, giống cách làm phổ biến; có thể mở rộng sau).
- **Nhiều bản API chạy song song:** mốc "1 lần mỗi phút" nếu để trong bộ nhớ sẽ sai; đặt trong cơ sở dữ liệu (cột *limitsCheckedAt*) hoặc Redis — cùng hạn chế đã ghi ở MODERATION_PLAN mục 12.
- **Lạm dụng ngược** (dùng Giới hạn để im lặng mọi phản biện): đây là quyền của chủ tài khoản trên bài của mình, không cần ngăn.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất. Phải ghi vào docs/api-contract.md và docs/decisions.md trước khi code.

Thay đổi	**Chi tiết**
Bảng mới *UserLimit*	*id, userId, comments* (Boolean), *messages* (Boolean), *includeRecentFollowers* (Boolean), *source* (*SUGGESTED* | *MANUAL*), *startsAt, endsAt, endedAt?*; chỉ mục *(userId, endsAt)*. Đang bật = *endedAt* trống và *endsAt* chưa qua.
User.limitsSuggestedAt, *User.limitsCheckedAt*	DateTime?
Comment.filteredAt, *Comment.filterReason*	Hai trường do B8 tạo (lý do *RESTRICTED*), B7 thêm *OFFENSIVE*, *HIDDEN_WORD*; B4 chỉ thêm giá trị *LIMITS*, không tạo trường mới
Conversation.filterReason	Thêm giá trị *LIMITS* (trường đề xuất ở B1)

API	**Ghi chú**
GET /users/me/limits	*{ active: null | { comments, messages, includeRecentFollowers, endsAt }, suggested: boolean }*; app dùng để hiện thẻ gợi ý và nhắc sắp hết hạn (không cần thêm loại thông báo vào bảng *Notification*, vốn bắt buộc có người gây ra)
PUT /users/me/limits	*{ comments, messages, includeRecentFollowers, days }*, *days* thuộc 1, 3, 7, 14, 28

DELETE /users/me/limits	Tắt sớm
GET /posts/:id/comments/filtered, *POST /comments/:id/approve*	Dùng lại API của B8 (chủ bài xem và hiện bình luận bị ẩn); trả thêm lý do *LIMITS*
Danh sách bình luận, số bình luận	Bỏ bình luận có *filterReason*, trừ khi người xem là người viết

Code cần sửa: *comments.service.ts* (gắn cờ khi tạo, lọc khi liệt kê, đếm), *notifications.service.ts* (không gửi thông báo từ người bị giới hạn), *messages.service.ts* (thư mục "Đã lọc" lý do *LIMITS*, tạm dừng ẩn danh), màn Cài đặt "Giới hạn", thẻ gợi ý, mục "Bình luận bị ẩn" ở màn bình luận.

g) Android, iOS và web

- Không cần quyền thiết bị, không cần thư viện mới trên app. Các màn mới (cài đặt Giới hạn, thẻ gợi ý, bình luận bị ẩn) dùng thành phần sẵn có, chạy như nhau trên Android và iOS; kiểm tra vùng an toàn và bàn phím trên cả hai.
- Thông báo đẩy gợi ý qua Expo → APNs và FCM (thuộc D8). Nếu người dùng tắt thông báo, thẻ gợi ý trong app vẫn hiện.
- Nhắc "sắp hết hạn" bằng thông báo đẩy cần một việc chạy định kỳ phía máy chủ: thư viện *@nestjs/schedule* (thêm phụ thuộc backend) hoặc dùng chung bộ lập lịch của D8 nếu D8 thêm trước. Không có thì chỉ nhắc khi người dùng mở app.
- Không có chi phí dịch vụ ngoài. App Store và Google Play không có yêu cầu riêng; tính năng hỗ trợ phần chống quấy rối của chính sách nội dung do người dùng tạo.

h) Tiêu chí hoàn thành

- Script giả lập 25 bình luận từ 12 tài khoản lạ trong 10 phút: chủ bài nhận đúng 1 thông báo gợi ý; chạy lại trong 7 ngày không nhận thêm.
- Bật Giới hạn 7 ngày: bình luận mới của người lạ chỉ người viết thấy, không thông báo, không tính vào số bình luận; bình luận của người theo dõi lâu năm vẫn hiện.
- Chủ bài hiện lại được một bình luận ẩn; xóa được bình luận ẩn.
- Tin chờ từ người lạ vào "Đã lọc", không thông báo; tin ẩn danh bị từ chối với thông báo tạm dừng.
- Hết hạn (chỉnh giờ trong test): tương tác mới không còn bị ẩn; bình luận đã ẩn vẫn ẩn.
- Người bị giới hạn không thấy bất kỳ dấu hiệu nào (so sánh dữ liệu API trước và sau khi bật).

- Test tự động cho hàm "người này có thuộc nhóm bị giới hạn không" và hàm phát hiện đột biến.
- Chạy tay trên Android **và** iPhone; ghi rõ nền tảng đã chạy.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (bảng, phát hiện, ẩn bình luận, lọc tin, API), mobile 3 ngày (màn cài đặt, thẻ gợi ý, mục bình luận bị ẩn, nhắc hết hạn), kiểm thử 2 ngày.
- Phụ thuộc: B1 (thư mục "Đã lọc", *filterReason*), B2 (tạm dừng ẩn danh), B8 (tạo cờ ẩn bình luận *Comment.filteredAt / filterReason*, cách "chỉ người viết thấy" và API xem bình luận bị ẩn — phải làm trước), B7 (mục "Bình luận bị ẩn" dùng chung), D8 (thông báo đẩy, bộ lập lịch).
- Rủi ro: ngưỡng đột biến không hợp với tài khoản rất lớn (hàng chục nghìn người theo dõi luôn có nhiều bình luận lạ). Đề xuất sau 4 tuần chuyển sang ngưỡng tương đối (gấp 5 lần trung bình 30 ngày của chính tài khoản đó).
- Rủi ro hiệu năng: truy vấn đếm chạy sau mỗi bình luận; giới hạn 1 lần mỗi phút cho mỗi chủ tài khoản và chỉ mục sẵn có *Comment(postId, createdAt)* giữ chi phí thấp — cần kiểm tra bằng dữ liệu thật trước khi phát hành.

B5. Làm mờ nội dung nhạy cảm toàn app

Nhóm: An toàn và kiểm duyệt · Giai đoạn: GĐ2 · Ước lượng: 13–15 ngày công

a) Mục đích

Hiện nay chỉ ảnh trong tin nhắn được máy tự nhận diện và làm mờ. Ảnh bài viết, video, story, ảnh đại diện và ảnh bìa thì hiện thẳng, nên người dùng có thể bất ngờ thấy ảnh khỏa thân hoặc gợi dục trên bảng tin. Tính năng này đưa cùng bộ nhận diện sang mọi nơi có ảnh và video công khai, cho tác giả tự gắn nhãn "nhạy cảm", cho người xem chọn làm mờ hay ẩn hẳn, và đưa nội dung có điểm rất cao vào hàng đợi kiểm duyệt (C1). Người được lợi là người xem (không bị sốc), tác giả (không bị gỡ bài oan vì một ảnh hở da) và đội kiểm duyệt (chỉ phải xem phần rủi ro cao).

b) Hiện trạng

- **Bộ nhận diện ảnh đã có**: *apps/api/src/modules/moderation/image-moderation.service.ts*. Mô hình ONNX *AdamCodd/vit-base-nsfw-detector* (ảnh 384×384, hai nhãn sfw / nsfw), chạy trên máy chủ bằng *onnxruntime-node*, ảnh được giải mã bằng *sharp*. Hàm *classify(buffer)* chỉ trả *{ sensitive: true/false }*, không trả điểm. Ngưỡng *IMAGE_MODERATION_THRESHOLD* mặc định 0,7.
- **Khi không có mô hình** (chưa tải hoặc nạp lỗi): *classify* trả "không nhạy cảm", trừ khi đặt *IMAGE_MODERATION_REQUIRED=true* thì ném lỗi 503. **Khi ảnh hỏng, chấm lỗi**: coi là nhạy cảm. Hàm *status()* trả *ready / unavailable* và trang quản trị hiện cảnh báo (*admin.service.ts*, mục thống kê).
- **Nơi duy nhất đang gọi bộ nhận diện**: gửi ảnh tin nhắn trong *messages/messages.service.ts*. Kết quả lưu vào *Message.sensitive*. Ứng dụng làm mờ bằng *blurRadius* của *expo-image* và hiện "Ảnh có thể nhạy cảm · Chạm để xem" (*apps/mobile/src/features/messages/screens/ChatScreen.tsx*); người gửi thấy dòng báo ảnh bị làm mờ với người nhận.
- **Ảnh bài viết**: đi qua máy chủ (*POST /posts*, *PATCH /posts/:id*, tối đa 4 ảnh, mỗi ảnh ≤ 5 MB, JPEG/PNG/WebP) trong *posts/posts.service.ts*. Không quét. Bảng *PostMedia* không có cột nhạy cảm.
- **Video bài viết và story**: điện thoại tải thẳng tệp lên kho qua *POST /media/upload-url*; máy chủ chỉ đọc loại tệp và dung lượng (*HeadObject*), không đọc nội dung (*posts.service.ts* hàm *createWithMedia*, *stories/stories.service.ts* hàm *create*). Ảnh bìa video do điện thoại tạo bằng *expo-video-thumbnails* ở giây 0,5 (*reel/services/reelService.ts*). Thời lượng video do điện thoại báo (có ghi chú "shortcut" trong code). *StorageService* chưa có hàm đọc tệp từ kho.

- **Ảnh đại diện, ảnh bìa**: đi qua máy chủ (*POST /users/me/avatar*, */users/me/cover*, ≤ 5 MB) trong *users/users.service.ts* hàm *setImage*. Không quét.
- **Báo cáo**: đã có lý do *SENSITIVE* ("Nội dung nhạy cảm") cho bài viết, bình luận, người dùng (*reports/dto/create-report.dto.ts*). Báo cáo chỉ vào danh sách cho quản trị viên, không tự làm mờ.
- **Chưa có**: nhãn nhạy cảm cho bài viết / story / ảnh đại diện; tác giả tự gắn nhãn; cài đặt của người xem; quét video; quét bù; hàng đợi kiểm duyệt (C1, chưa có trong code). *docs/moderation/MODERATION_PLAN.md* mục 8 đã ghi đây là kế hoạch.

c) Cách hoạt động

Mỗi ảnh hoặc video công khai có một **nhãn nhạy cảm** (có / không) kèm **nguồn**: tác giả tự gắn, máy nhận diện, nhiều người báo cáo, hoặc quản trị viên. Nội dung có điểm rất cao thì bị **giữ lại**: chỉ tác giả thấy, kèm dòng "Đang được xem xét", cho tới khi người duyệt quyết định.

Đề xuất hai ngưỡng: **0,7** (đang dùng cho tin nhắn) thì làm mờ; **0,9** thì giữ lại và đưa vào hàng đợi C1. Theo nguyên tắc ở *MODERATION_PLAN.md*, máy chủ không lưu điểm số, chỉ lưu kết quả đã quy đổi (bình thường / làm mờ / giữ lại).

Luồng 1: Đăng ảnh qua máy chủ (ảnh bài viết, ảnh đại diện, ảnh bìa)

1. Người dùng chọn ảnh. Ở màn tạo bài có công tắc "Đánh dấu nội dung nhạy cảm" (mặc định tắt). Ảnh đại diện và ảnh bìa không có công tắc này.
2. Ứng dụng gửi ảnh kèm cờ tự gắn nhãn như hiện nay (multipart).
3. Máy chủ kiểm tra loại và dung lượng như hiện nay.
4. Máy chủ xem bộ nhận diện có sẵn không:
    - Không có, và *IMAGE_MODERATION_REQUIRED=true*: trả 503, không lưu ảnh. Ứng dụng báo "Chưa kiểm tra được ảnh, vui lòng thử lại sau".
    - Không có, và không bắt buộc: lưu như bình thường và tạo một việc quét ở trạng thái chờ (bảng *ScanJob* của C1). Khi mô hình chạy lại, máy chủ quét bù (luồng 4).
5. Có mô hình: chấm từng ảnh (khoảng 0,5–0,7 giây một ảnh trên CPU; bài 4 ảnh mất tới khoảng 3 giây). Ảnh hỏng, chấm lỗi thì coi như đạt ngưỡng làm mờ, giống tin nhắn.
6. Điểm ≥ 0,7, hoặc tác giả tự gắn: ảnh có nhãn nhạy cảm, ghi nguồn (MODEL hoặc AUTHOR).

7. Điểm ≥ 0,9: bài (hoặc ảnh đại diện, ảnh bìa mới) bị giữ lại. Tác giả thấy "Đang được xem xét". Máy chủ tạo một mục trong hàng đợi C1. Với ảnh đại diện / ảnh bìa bị giữ, người khác vẫn thấy ảnh cũ (hoặc ảnh mặc định nếu chưa có ảnh cũ).
8. Còn lại: lưu và hiện ngay. Ảnh có nhãn thì người xem thấy bản mờ.

Luồng 2: Đăng video hoặc story (tệp tải thẳng lên kho)

1. Điện thoại tạo ảnh bìa và tải tệp lên kho như hiện nay, gửi kèm cờ tự gắn nhãn.
2. Máy chủ kiểm tra loại và dung lượng như hiện nay, rồi lưu bài / story ở trạng thái "đang xử lý". Tác giả thấy bài của mình kèm nhãn "Đang xử lý". Người khác chưa thấy.
3. Tiến trình quét nền của C1 (chạy trong chính tiến trình API, lấy việc từ bảng *ScanJob*, không thêm hệ thống hàng đợi) lấy ảnh bìa và 3–5 khung hình (đầu, 25%, 50%, 75%, cuối) rồi chấm từng khung. Story ảnh thì chấm chính ảnh đó. Có hai cách lấy khung hình, chủ dự án chọn (mục g).
4. Chấm lỗi (đọc tệp hỏng, mô hình không có): thử lại sau 1 phút, tối đa 3 lần. Vẫn lỗi thì xử lý như khi thiếu mô hình: nếu không bắt buộc quét thì công khai với trạng thái "chưa quét"; nếu bắt buộc thì giữ ẩn và báo trên trang quản trị.
5. Khung nào ≥ 0,9: giữ ẩn, đưa vào hàng đợi C1.
6. Khung nào ≥ 0,7, hoặc tác giả tự gắn: gắn nhãn nhạy cảm.
7. Công khai. Thông thường toàn bộ mất 2–10 giây (đề xuất giới hạn: quá 2 phút vẫn "đang xử lý" thì coi là lỗi và xử lý như bước 4).

Luồng 3: Người xem mở bảng tin, Reels, story, trang cá nhân

1. Máy chủ lọc trước khi trả danh sách. Nội dung bị giữ chỉ trả cho tác giả. Bộ lọc này đặt trong *visiblePostWhere* (*posts/post-view.ts*), nơi duy nhất quyết định ai xem được bài nào, nên mọi màn hình dùng chung.
2. Người xem chọn "Ẩn hẳn" trong Cài đặt: bảng tin, Reels, tìm kiếm và khay story bỏ hẳn nội dung có nhãn. Trên trang cá nhân và màn chi tiết bài viết, ứng dụng hiện ô "Nội dung nhạy cảm đã ẩn · Xem".
3. Người xem để mặc định "Làm mờ": máy chủ trả kèm *sensitive: true*. Ứng dụng hiện ảnh mờ (cùng cách tin nhắn đang làm), dòng "Nội dung có thể nhạy cảm", nút "Xem". Video không tự phát, chỉ hiện ảnh bìa mờ. Story dừng đếm giờ cho tới khi người xem chọn "Xem" hoặc "Bỏ qua".
4. Người xem chạm "Xem": hiện rõ lần đó. Ứng dụng nhớ lựa chọn cho bài đó trong phiên đang mở, không lưu lên máy chủ.
5. Tác giả luôn thấy bản gốc của mình, kèm nhãn và nguồn nhãn (ví dụ "Hệ thống đã đánh dấu ảnh này là nhạy cảm · Yêu cầu xem lại").

6. Ảnh đại diện có nhãn: ở danh sách (bảng tin, bình luận, tin nhắn, tìm kiếm) ứng dụng hiện ảnh mặc định, vì ảnh nhỏ không có chỗ cho nút "Xem". Trên trang cá nhân thì hiện bản mờ, chạm để xem. Ảnh bìa có nhãn hiện mờ, chạm để xem.
7. Tin nhắn giữ nguyên cách đang làm (luôn làm mờ với người nhận). Cài đặt "Ẩn hẳn" không áp dụng cho tin nhắn, vì người nhận cần biết có ảnh gửi đến.

Luồng 4: Quét bù khi mô hình chạy lại

1. Khi API khởi động và nạp được mô hình, tiến trình quét lấy các việc quét còn chờ của ảnh, video, story trong 7 ngày gần nhất (story: còn hạn) và chấm lần lượt, tối đa 2 tệp cùng lúc để không chiếm hết CPU.
2. Kết quả xử lý như luồng 1 và 2. Bài đã đăng mà bị giữ thì tác giả nhận thông báo "Bài viết của bạn đang được xem xét".

Luồng 5: Nhiều người báo cáo "Nội dung nhạy cảm"

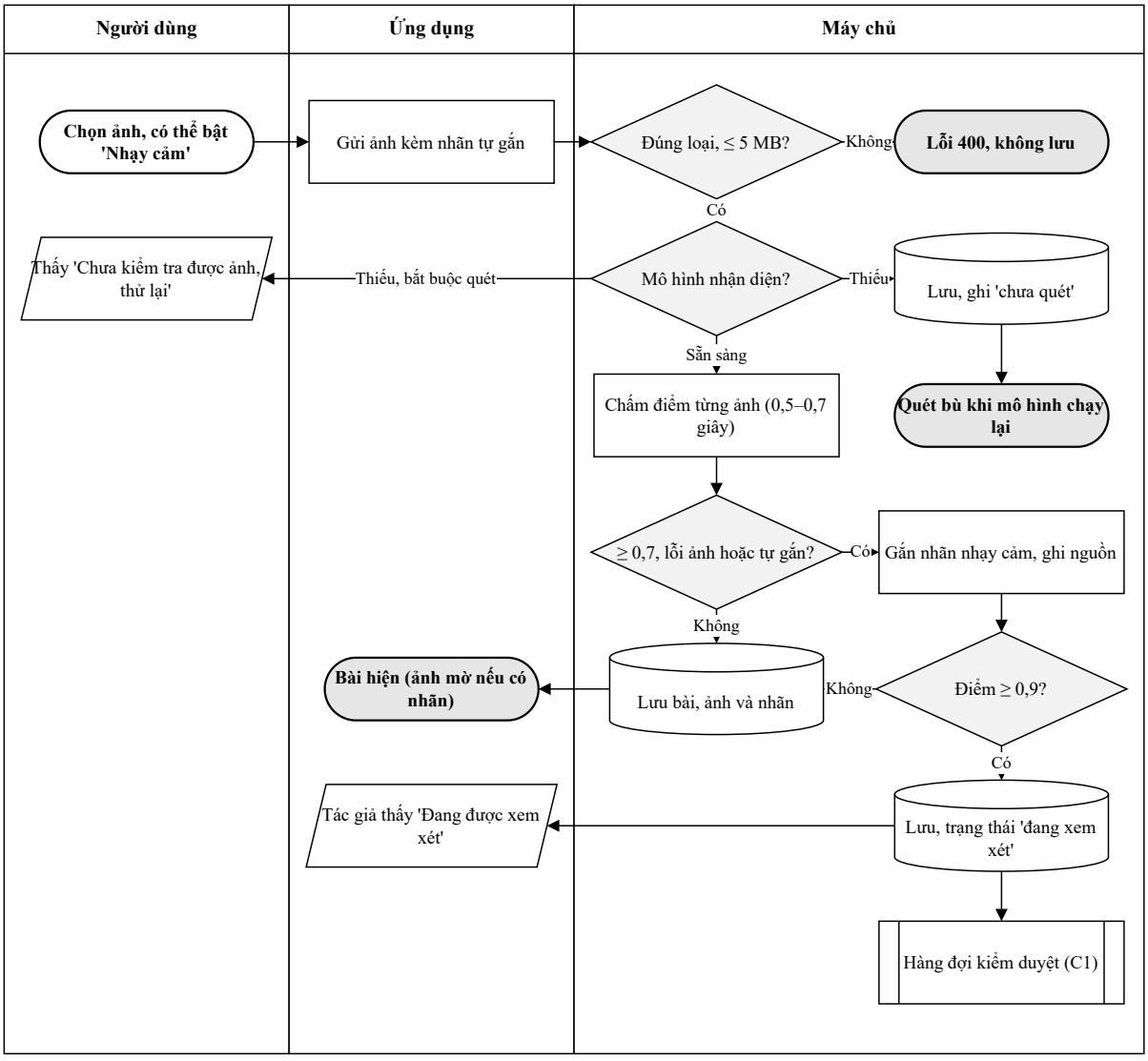
1. Một bài nhận báo cáo lý do *SENSITIVE* từ 3 người khác nhau (đề xuất) trong 7 ngày: máy chủ tự gắn nhãn nhạy cảm (nguồn REPORT) và đưa vào hàng đợi C1.
2. Người duyệt quyết định: bỏ nhãn, giữ nhãn, hoặc gỡ bài (C2).

Luồng 6: Tác giả không đồng ý với nhãn

1. Tác giả bấm "Yêu cầu xem lại" trên bài của mình. Mỗi ảnh / video chỉ được yêu cầu một lần.
2. Yêu cầu vào hàng đợi C1 với mức ưu tiên thấp. Trong lúc chờ, nhãn vẫn giữ.
3. Người duyệt bỏ nhãn hoặc giữ. Tác giả nhận thông báo kết quả. Nhãn do tác giả tự gắn thì tác giả tự gỡ được bất cứ lúc nào bằng cách sửa bài.

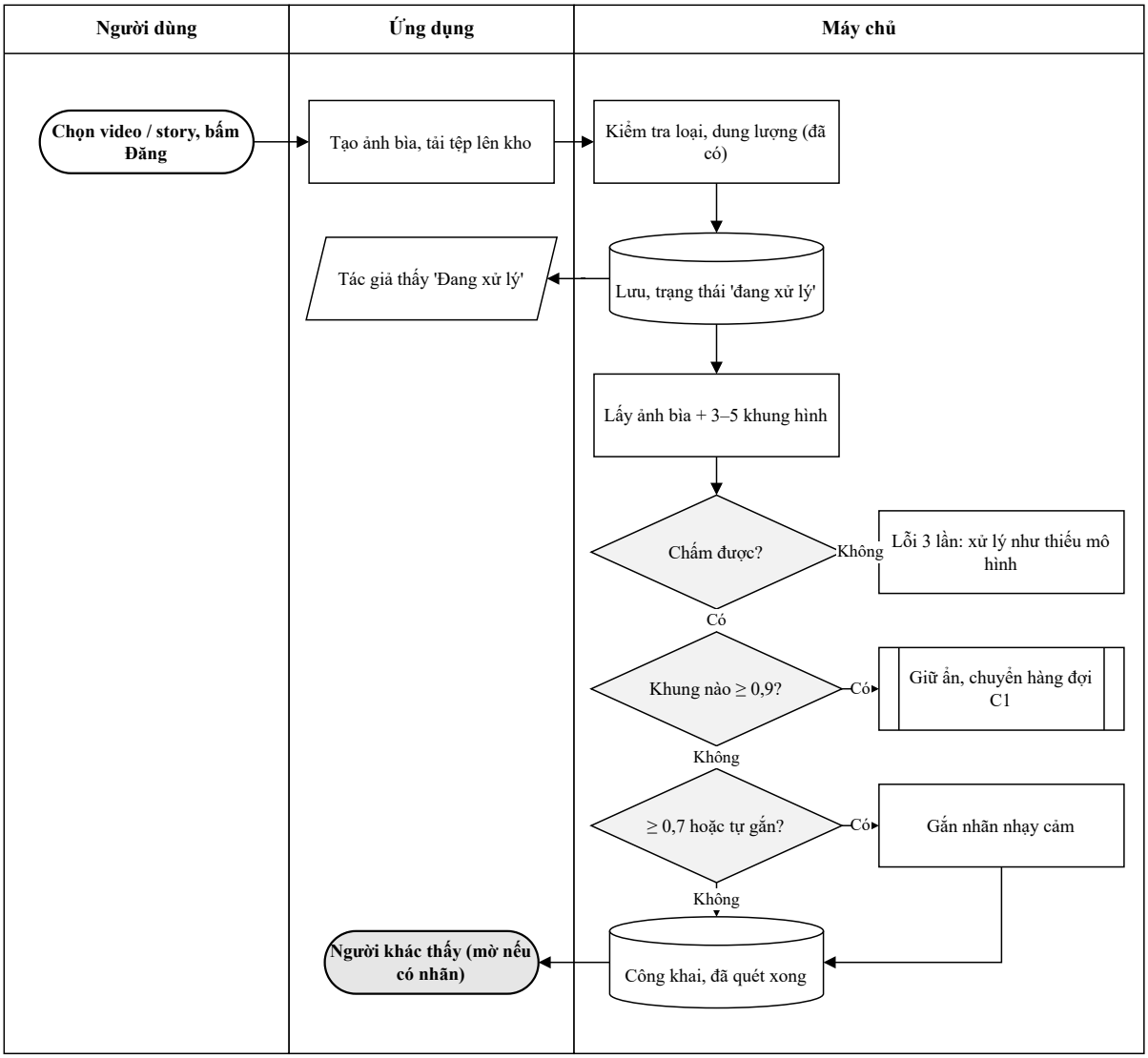
d) Flowchart

Sơ đồ 1: quét ảnh đi qua máy chủ khi tải lên và gắn nhãn.



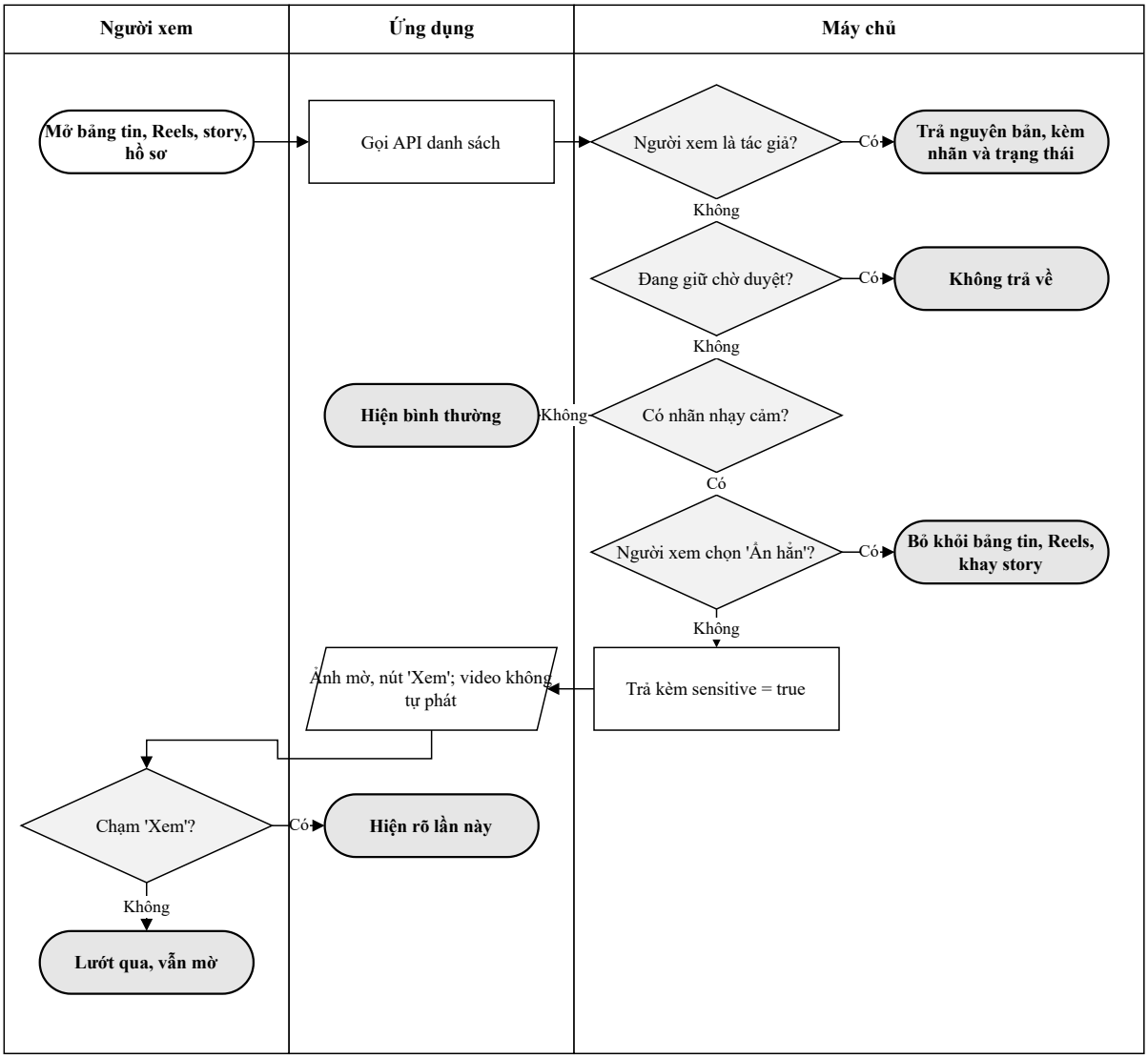
Hình 28. Quét ảnh tải lên qua máy chủ (ảnh bài viết, ảnh đại diện, ảnh bìa)

Sơ đồ 2: quét video và story được điện thoại tải thẳng lên kho.



Hình 29. Quét video bài viết và story (tệp tải thẳng lên kho)

Sơ đồ 3: máy chủ và ứng dụng quyết định cách hiện nội dung cho từng người xem.



Hình 30. Quyết định hiển thị nội dung nhạy cảm cho người xem

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Ngưỡng (đề xuất)**: làm mờ từ 0,7 (giữ như tin nhắn); giữ lại chờ duyệt từ 0,9. Hai ngưỡng đặt bằng biến môi trường. Trước khi chốt, đo trên 200–300 ảnh có gán nhãn (*MODERATION_PLAN.md* mục 8.6) để biết tỉ lệ giữ nhầm.
- **Mô hình chỉ nhận diện khỏa thân, gợi dục.** Nó không nhận diện bạo lực, máu me, ma túy. Các loại này chỉ có nhãn khi tác giả tự gắn, khi bị báo cáo, hoặc khi thêm mô hình khác (ngoài phạm vi B5).
- **Ảnh xâm hại trẻ em**: mô hình này không phát hiện đáng tin, không dùng thay công cụ chuyên dụng (đối chiếu dấu vân tay ảnh đã biết). Việc đăng ký công cụ đó và báo cáo cho cơ quan chức năng là trách nhiệm người vận hành (*MODERATION_PLAN.md* mục 4).

- **Thiếu mô hình**: mặc định vẫn đăng được, ghi "chưa quét", trang quản trị hiện cảnh báo đỏ kèm số mục chưa quét. Bật *IMAGE_MODERATION_REQUIRED=true* thì ảnh qua máy chủ bị từ chối (503), còn video / story nằm ở "đang xử lý" cho tới khi quét được. Story hết hạn sau 24 giờ thì bỏ qua.
- **Chấm lỗi một ảnh** (tệp hỏng, định dạng lạ): coi là nhạy cảm (làm mờ), không đưa vào hàng đợi.
- **Tải chậm**: bài 4 ảnh chờ thêm tới khoảng 3 giây. Ứng dụng giữ trạng thái "Đang đăng" như hiện nay. Nếu thấy chậm, chuyển ảnh sang quét nền như video (đổi lại: ảnh hiện ra rồi mới mờ).
- **Sửa bài** (thêm, thay ảnh): ảnh mới được quét như khi đăng. Bỏ ảnh có nhãn thì nhãn đi theo ảnh đó.
- **Đăng lại (repost)**: dùng nhãn của bài gốc.
- **Người xem đổi cài đặt**: áp dụng từ lần tải danh sách tiếp theo.
- **Lạm dụng báo cáo** để làm mờ bài của người khác: hậu quả nhẹ (chỉ mờ) và quản trị viên gỡ được. Chỉ tính người báo cáo có tài khoản từ 7 ngày tuổi (đề xuất, giống luật nhắn ẩn danh).
- **Làm mờ ở ứng dụng chỉ để tôn trọng người xem**, không phải để giấu ảnh: ứng dụng vẫn tải ảnh gốc. Ảnh công khai vẫn nằm trong kho công khai như hiện nay.
- **Riêng tư**: ảnh không gửi ra ngoài; không lưu điểm số; nhật ký máy chủ không ghi nội dung ảnh.
- **Nhiều bản API**: tiến trình quét phải khóa việc trước khi làm để hai bản không quét trùng (C1 đã ghi cách làm).
- **Chỗ B5 khác đề xuất C1, chủ dự án chọn**: (1) C1 cho nội dung hiện ngay rồi mới quét; B5 đề xuất ảnh qua máy chủ được quét trước khi lưu (chờ thêm tới 3 giây), video và story chỉ hiện với người khác sau khi quét (2–10 giây), để không có lúc ảnh nhạy cảm hiện rõ trên bảng tin. (2) C1 đưa mọi nội dung có ảnh vào hàng đợi khi mô hình không chạy; B5 đề xuất chỉ ghi việc quét chờ và quét bù, vì mô hình hỏng một ngày có thể đẩy hàng nghìn mục vào hàng đợi. (3) Ảnh 0,7–0,9: B5 đề xuất chỉ làm mờ, không vào hàng đợi; C1 có mức "cần xem" (P3), cần thống nhất ngưỡng.

f) Dữ liệu và API (đề xuất)

Tất cả là đề xuất, cần đưa vào *docs/api-contract.md* và thống nhất với người phụ trách backend trước khi code.

Bảng	Trường mới	Ý nghĩa

PostMedia	sensitive Boolean (mặc định false), sensitiveSource String? (AUTHOR / MODEL / REPORT / ADMIN)	Nhãn theo từng ảnh / video. Trạng thái quét nằm ở bảng *ScanJob* của C1; ảnh cũ được tạo việc quét bù một lần.
Post	markedSensitive Boolean, pendingScan Boolean	Tác giả tự gắn nhãn; đang chờ quét lần đầu (video). Việc "giữ chờ duyệt" dùng trường *hiddenAt* và mục *ModerationCase* mà C1 đề xuất, không thêm trường riêng.
Story	sensitive, sensitiveSource, markedSensitive, pendingScan	Như trên; giữ chờ duyệt dùng *hiddenAt* của C1
User	avatarSensitive Boolean, coverSensitive Boolean, avatarHeldUrl String?, coverHeldUrl String?, sensitiveFilter String (BLUR / HIDE, mặc định BLUR)	Nhãn ảnh đại diện, ảnh bìa; ảnh mới đang chờ duyệt; cài đặt của người xem

API	**Thay đổi**
POST /posts, PATCH /posts/:id	Thêm trường multipart *markSensitive* (true/false). Có thể trả 503 *IMAGE_CHECK_UNAVAILABLE* khi bắt buộc quét mà thiếu mô hình.
POST /posts/media, POST /stories	Thêm *markSensitive*. Trả bài / story với *processing: true* cho tới khi quét xong.
Bài viết, story trả về	Mỗi media thêm *sensitive*. Chỉ tác giả nhận thêm *sensitiveSource*, *held*, *processing*.
authorSelect (mọi chỗ trả người dùng)	Thêm *avatarSensitive*. Hồ sơ thêm *coverSensitive*.
PATCH /users/me	Thêm *sensitiveFilter* (BLUR / HIDE).
POST /posts/:id/media/:mediaId/review-request	Tác giả yêu cầu xem lại nhãn (một lần mỗi media).
Quản trị	Thống kê thêm số mục chưa quét; POST /admin/media/:id/sensitive và DELETE (gắn / bỏ nhãn); hàng đợi do C1 định nghĩa.

Trong code: *ImageModerationService* thêm hàm trả xác suất (chỉ dùng trong bộ nhớ, không lưu); *StorageService* thêm hàm đọc tệp từ kho (*GetObject*); tiến trình quét nền và bảng *ScanJob* dùng chung với C1 cho video, story và quét bù.

g) Android, iOS và web

- **Làm mờ**: dùng *blurRadius* của *expo-image*, đã chạy trong tin nhắn và hỗ trợ cả Android và iOS. Nên tách thành một thành phần dùng chung (ảnh mờ + nút "Xem" + nhãn cho trình đọc màn hình), dùng ở *PostCard*, *FeedVideo*, *ReelPlayer*, *StoryViewerScreen*, *ProfileHeader*. Không cần thư viện mới. Độ mờ phải đủ trên cả hai nền tảng (Android và iOS xử lý *blurRadius* khác nhau một chút): kiểm tra bằng mắt trên máy thật cả hai bên.
- **Video**: video có nhãn không tự phát trên cả hai nền tảng; hiện ảnh bìa mờ thay cho trình phát cho tới khi chạm.
- **Lấy khung hình video, chủ dự án chọn một**:
  - Cách A: máy chủ dùng ffmpeg (thư viện mới phía backend, khoảng 70 MB, tốn CPU). Tin được vì máy chủ đọc chính tệp đã tải lên; cũng dùng được để đo thời lượng thật (đang tin số điện thoại báo).
  - Cách B: điện thoại tạo thêm 3–5 khung hình bằng *expo-video-thumbnails* (đã cài, chạy cả hai nền tảng) và tải lên cùng video. Làm nhanh, không thêm thư viện, nhưng người cố ý có thể gửi khung hình giả.

  Đề xuất: Cách A.
- **Quyền thiết bị**: không cần quyền mới.
- **App Store / Google Play**: cả hai yêu cầu app có nội dung người dùng tạo phải có lọc nội dung, báo cáo và chặn. Tính năng này góp phần đáp ứng. Mức "Không làm mờ" (hiện thẳng nội dung nhạy cảm) không đưa vào bản này vì có thể vướng quy định App Store về nội dung khiêu dâm: cần chủ dự án quyết và kiểm tra quy định trước khi thêm.
- **Web**: trang quản trị đã làm mờ ảnh tin nhắn cho người duyệt; hàng đợi C1 dùng cùng cách. Nếu ứng dụng chạy trên web (*react-native-web* đang có trong dự án) thì *blurRadius* trên web cần kiểm tra.
- **Chi phí**: không có dịch vụ ngoài. Tốn thêm CPU máy chủ: khoảng 0,5–0,7 giây cho mỗi ảnh; mỗi video thêm 3–5 lần chấm. Máy chủ nhiều lượt đăng thì cần thêm CPU hoặc tách tiến trình quét riêng.

h) Tiêu chí hoàn thành

- Đăng bài có ảnh nhạy cảm (ảnh thử ≥ 0,7): người theo dõi thấy ảnh mờ, chạm "Xem" thì hiện rõ; tác giả thấy bản gốc kèm nhãn.
- Ảnh thử ≥ 0,9: bài bị giữ, tác giả thấy "Đang được xem xét", người khác không thấy, hàng đợi C1 có mục mới.

- Tác giả bật "Đánh dấu nội dung nhạy cảm": bài mờ với người khác dù ảnh bình thường.
- Video và story nhạy cảm: không tự phát, ảnh bìa mờ; story dừng đếm giờ cho tới khi chọn.
- Ảnh đại diện nhạy cảm: danh sách hiện ảnh mặc định; trang cá nhân hiện mờ.
- Người xem chọn "Ẩn hẳn": bảng tin, Reels, tìm kiếm, khay story không còn nội dung có nhãn; trang cá nhân hiện ô "đã ẩn".
- Tắt mô hình (đổi tên thư mục mô hình): ảnh vẫn đăng được, ghi "chưa quét", trang quản trị cảnh báo; bật lại thì quét bù. Với *IMAGE_MODERATION_REQUIRED=true*: đăng ảnh bị 503 với thông báo tiếng Việt.
- Tệp ảnh hỏng: bị làm mờ, không làm sập máy chủ.
- 3 người báo cáo "Nội dung nhạy cảm": bài tự mờ và vào hàng đợi.
- Chạy trên Android và trên iPhone, ghi rõ máy đã thử trong *docs/change.md*.
- Test tự động: thêm vào *safety-smoke.cjs* (ảnh thử nhạy cảm / bình thường, bài bị giữ không lộ ra bảng tin người khác, cài đặt "Ẩn hẳn").

i) Ước lượng và phụ thuộc

- Backend 7 ngày (nhãn và lọc trong *visiblePostWhere* 1,5; quét ảnh qua máy chủ 1; quét nền video / story và quét bù 2,5; báo cáo tự làm mờ, yêu cầu xem lại, quản trị 2). Mobile 5 ngày (thành phần làm mờ dùng chung và gắn vào 6 màn 2,5; công tắc tự gắn nhãn 0,5; cài đặt người xem 1; nhãn và "Đang xử lý" / "Đang được xem xét" cho tác giả 1). Kiểm thử 2 ngày.
- Phụ thuộc: **C1** (hàng đợi kiểm duyệt, bảng *ScanJob*, tiến trình quét, trường *hiddenAt*) cho nội dung bị giữ, quét nền và yêu cầu xem lại; **C2** nếu gỡ bài kèm cảnh cáo. Nếu C1 chưa xong, tạm dùng bảng *Report* có sẵn (tạo báo cáo hệ thống) để nội dung bị giữ hiện trong trang quản trị.
- Rủi ro: mô hình làm mờ nhầm ảnh hở da (đã biết, chủ ý chặt tay); giữ nhầm bài ở ngưỡng 0,9 làm tác giả khó chịu, cần đo trước; CPU máy chủ tăng; quyết định ffmpeg là thêm thư viện backend.

B6. Bảo vệ 18+ và xác minh tuổi

Nhóm: An toàn và kiểm duyệt · Giai đoạn: GĐ2 · Ước lượng: 11–12 ngày công (chưa tính tích hợp dịch vụ xác minh bên ngoài)

a) Mục đích

Ứng dụng chỉ dành cho người từ 18 tuổi. Hiện nay tuổi do người dùng tự khai, nên người dưới 18 khai sai vẫn vào được. Tính năng này cho cộng đồng báo cáo "người này có thể chưa đủ 18 tuổi", cho quản trị viên xem xét, yêu cầu xác minh hoặc khóa, và cho người bị khóa oan một đường kháng nghị có bằng chứng. Người được lợi: người dưới 18 (được đưa ra khỏi môi trường không dành cho họ), người dùng trưởng thành (ít nguy cơ tiếp xúc với trẻ vị thành niên), và người vận hành (có quy trình rõ ràng khi cơ quan chức năng hỏi).

b) Hiện trạng

- **Ngày sinh khi đăng ký bằng email**: bắt buộc, dạng *YYYY-MM-DD*. Dưới 18 thì máy chủ trả 403 *AGE_RESTRICTED* (*auth/auth.service.ts*, *moderation/age.ts*). Tuổi tính theo ngày giờ Việt Nam; ngày không có thật, trước năm 1900 hoặc trong tương lai bị từ chối.
- **Tài khoản cũ và đăng ký bằng Google**: *birthDate* để trống. Ứng dụng chặn ở *BirthDateScreen* trước mọi màn khác (*apps/mobile/src/navigation/RootNavigator.tsx*). Ngày sinh khai một lần qua *PATCH /users/me/birth-date*; khai lần hai trả 409 (*users/users.service.ts* hàm *setBirthDate*).
- **Khóa vì tuổi**: khai dưới 18 thì đặt *User.ageLockedAt* và thêm vào danh sách trong bộ nhớ *ageLockedUserIds* (*auth/ban-list.ts*). Đăng nhập (email và Google) và mọi request có token trả 401 *AGE_RESTRICTED* (*auth/strategies/jwt.strategy.ts*). Dữ liệu không bị xóa.
- **Màn khóa trên điện thoại**: chỉ hiện ngay sau khi khai ngày sinh dưới 18 ("Chưa đủ 18 tuổi … Nếu bạn khai nhầm ngày sinh, hãy liên hệ bộ phận hỗ trợ"). Trong app không có kênh liên hệ hỗ trợ: cần kiểm tra. Khi tài khoản đã khóa đăng nhập lại, *LoginScreen* chỉ xử lý riêng lỗi *EMAIL_NOT_VERIFIED*, nên lỗi tuổi hiện dưới dạng thông báo lỗi chung lấy từ máy chủ (câu tiếng Anh): cần kiểm tra trên máy.
- **Quản trị**: "Mở khóa tuổi" (*DELETE /admin/users/:id/age-lock*) xóa cả *ageLockedAt* và *birthDate* để người dùng khai lại (*admin/admin.service.ts* hàm *unlockAge*). Không có bước kiểm tra bằng chứng.

- **Báo cáo**: lý do hiện có là SPAM, HARASSMENT, SENSITIVE, MISINFORMATION, SCAM, OTHER. Chưa có lý do "chưa đủ 18 tuổi".
- **Nội dung của tài khoản bị khóa**: *visiblePostWhere* (*posts/post-view.ts*) không lọc theo *bannedAt* hay *ageLockedAt*, nên theo code đọc được, bài của tài khoản bị khóa vẫn hiện với người khác: cần kiểm tra.
- **Hạn chế đã ghi trong *MODERATION_PLAN.md* mục 6**: tuổi tự khai, không phải xác minh thật; máy chủ chỉ chặn tài khoản chưa có ngày sinh ở phía ứng dụng, không chặn ở mọi API. Danh sách khóa nằm trong bộ nhớ một tiến trình.

c) Cách hoạt động

Luồng 1: Báo cáo "Có thể chưa đủ 18 tuổi"

1. Người dùng mở menu Báo cáo trên trang cá nhân, bài viết, bình luận hoặc cuộc trò chuyện, chọn lý do mới "Người này có thể chưa đủ 18 tuổi", có thể ghi chú (tối đa 500 ký tự như hiện nay).
2. Báo cáo luôn gắn vào **tài khoản** (báo cáo từ bài viết hay bình luận được đổi sang tác giả). Báo cáo lại cùng người chỉ cập nhật lý do, như hiện nay.
3. Ứng dụng hiện "Đã gửi báo cáo. Cảm ơn bạn." Người báo cáo không được biết kết quả cụ thể (để bảo vệ người bị báo cáo), chỉ nhận "Chúng tôi đã xem xét báo cáo của bạn".
4. Máy chủ đếm số người báo cáo khác nhau trong 30 ngày. Chỉ tính người có tài khoản từ 7 ngày tuổi và đã xác thực email (giống luật nhắn ẩn danh hiện có).
5. Dưới 3 người (đề xuất): báo cáo vào hàng đợi C1, mức ưu tiên thường.
6. Từ 3 người: tài khoản vào **chế độ hạn chế tạm** (nên làm bằng cơ chế "hạn chế tính năng" của C2, cùng cách B3 tạm hạn chế tài khoản bị báo lừa đảo, để không có ba cơ chế giống nhau) và báo cáo được đẩy lên đầu hàng đợi. Chế độ hạn chế tạm (đề xuất): không hiện trong tìm kiếm và gợi ý theo dõi; không mở được cuộc trò chuyện mới với người không theo dõi mình; không gửi được tin ẩn danh. Người đó thấy một dòng trung tính "Một số tính năng đang tạm giới hạn trong khi chúng tôi xem xét tài khoản", không nêu ai báo cáo.

Luồng 2: Quản trị viên xem xét

1. Người duyệt mở mục báo cáo trong hàng đợi. Màn duyệt hiện: ngày sinh đã khai, ngày tạo tài khoản, ảnh đại diện, tiểu sử, bài viết và bình luận gần đây, số người báo cáo và ghi chú của họ. Tin nhắn riêng không hiện (chỉ hiện khi có báo cáo cuộc trò chuyện, như hiện nay).
2. Người duyệt chọn một trong ba kết luận:
    - **Không có dấu hiệu**: đóng mọi báo cáo tuổi của người đó, gỡ hạn chế tạm.

- **Nghi ngờ**: yêu cầu xác minh tuổi (luồng 3).
- **Rõ ràng dưới 18** (ví dụ tự ghi tuổi trong tiểu sử, ảnh giấy tờ học sinh): khóa vì tuổi ngay (luồng 4).

3. Mọi quyết định được ghi lại: ai duyệt, lúc nào, kết luận gì (nhật ký thao tác do C3 định nghĩa).

Luồng 3: Yêu cầu xác minh tuổi

1. Máy chủ ghi hạn xác minh là 14 ngày (đề xuất). Người dùng nhận thông báo đẩy và email "Cần xác minh tuổi".
2. Mỗi lần mở app, trước mọi màn khác, ứng dụng hiện màn "Xác minh tuổi" (giống cách *BirthDateScreen* đang chặn), với nút "Xác minh ngay" và "Để sau". Chọn "Để sau" thì vẫn dùng app ở chế độ hạn chế tạm.
3. Nhắc lại vào ngày thứ 7 và ngày thứ 12 (đề xuất).
4. Người dùng chọn một cách xác minh (mục e) và gửi bằng chứng. Kết quả đạt: gỡ hạn chế, ghi "đã xác minh" và ngày sinh đã xác minh. Không đạt hoặc hết hạn: khóa vì tuổi.

Luồng 4: Khóa vì tuổi

1. Máy chủ đặt *ageLockedAt* và lý do khóa (tự khai / bị báo cáo / hết hạn xác minh / xác minh không đạt), thêm vào danh sách khóa. Mọi phiên đang mở bị từ chối từ request tiếp theo (như hiện nay).
2. Bài viết, bình luận, story và trang cá nhân của tài khoản bị khóa không còn hiện với người khác (đề xuất; dùng chung bộ lọc với khóa thường của C2).
3. Người dùng nhận email "Tài khoản của bạn đã bị khóa vì chưa đủ 18 tuổi", kèm cách kháng nghị.

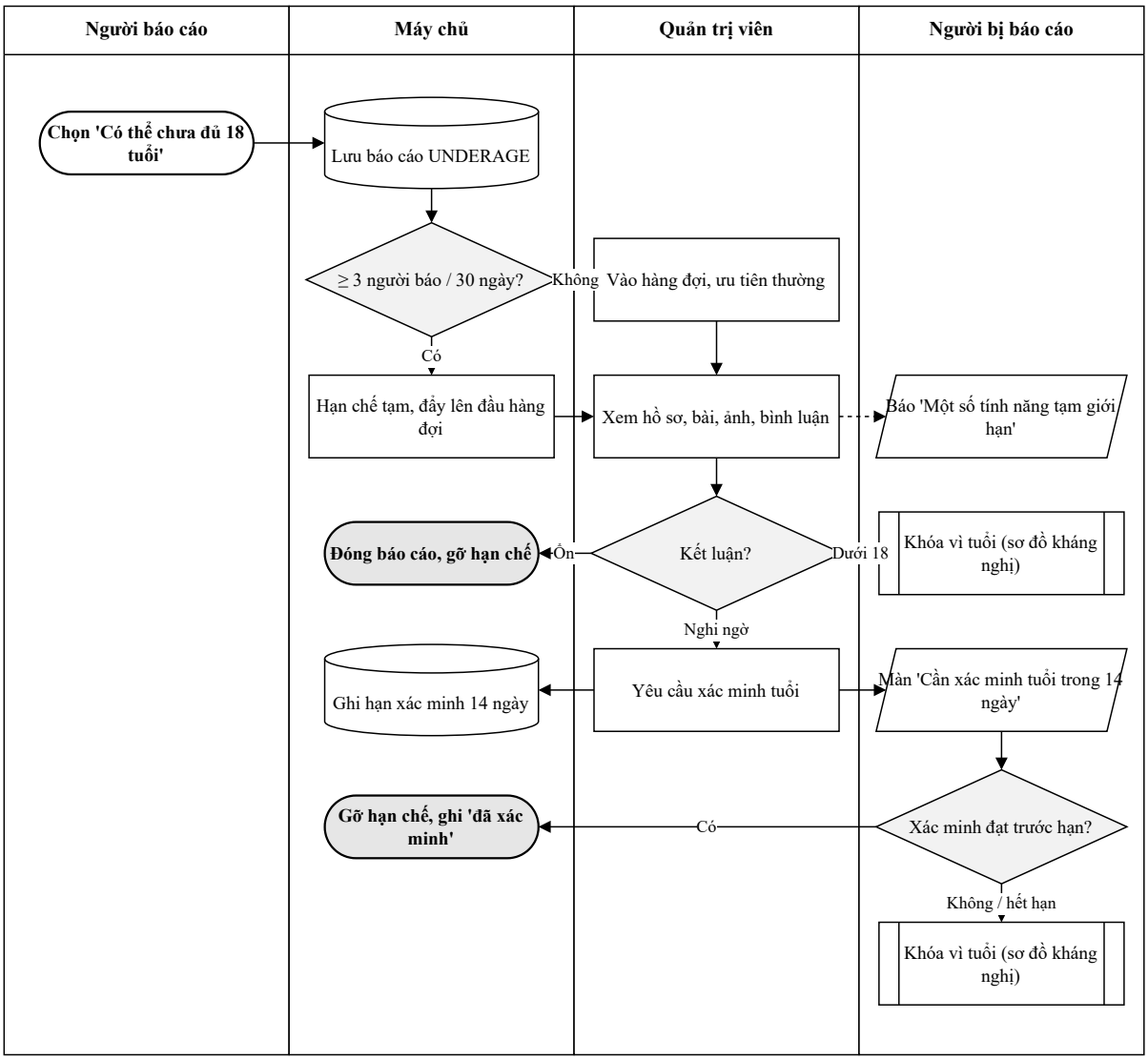
Luồng 5: Kháng nghị

1. Người dùng đăng nhập. Máy chủ vẫn trả 401 *AGE_RESTRICTED*, nhưng kèm một **mã kháng nghị** (*appealToken*, cùng cơ chế C2 đề xuất cho tài khoản bị khóa: sống 15 phút) chỉ gọi được các API kháng nghị, cùng số lượt kháng nghị còn lại.
2. Ứng dụng hiện màn "Tài khoản bị khóa vì tuổi" (thay cho thông báo lỗi chung), có nút "Kháng nghị" nếu còn lượt, và nút "Đăng xuất".
3. Người dùng chọn cách xác minh, gửi bằng chứng (ảnh giấy tờ chọn từ thư viện hoặc chụp, hoặc đi qua trang của dịch vụ xác minh).
4. Máy chủ lưu kháng nghị. Ảnh giấy tờ nằm trong kho riêng (*S3_PRIVATE_BUCKET*, đang dùng cho ảnh tin nhắn), chỉ người duyệt xem được qua link có chữ ký hết hạn.

5. Người duyệt (hoặc kết quả từ dịch vụ xác minh) quyết định trong 72 giờ (đề xuất):
    - **Đủ 18 tuổi**: mở khóa, ghi ngày sinh theo giấy tờ, ghi "đã xác minh". Gửi email và thông báo.
    - **Không đủ** hoặc giấy tờ không hợp lệ: giữ khóa, ghi lý do, gửi email.
6. Ảnh giấy tờ bị xóa khỏi kho 30 ngày sau quyết định (đề xuất), dù kết quả thế nào. Chỉ giữ lại: cách xác minh, kết quả, ngày sinh, thời điểm.
7. Tài khoản bị khóa vì tuổi quá 90 ngày mà không kháng nghị thành công thì bị xóa theo luồng xóa tài khoản (E2). Con số này cần luật sư xác nhận.

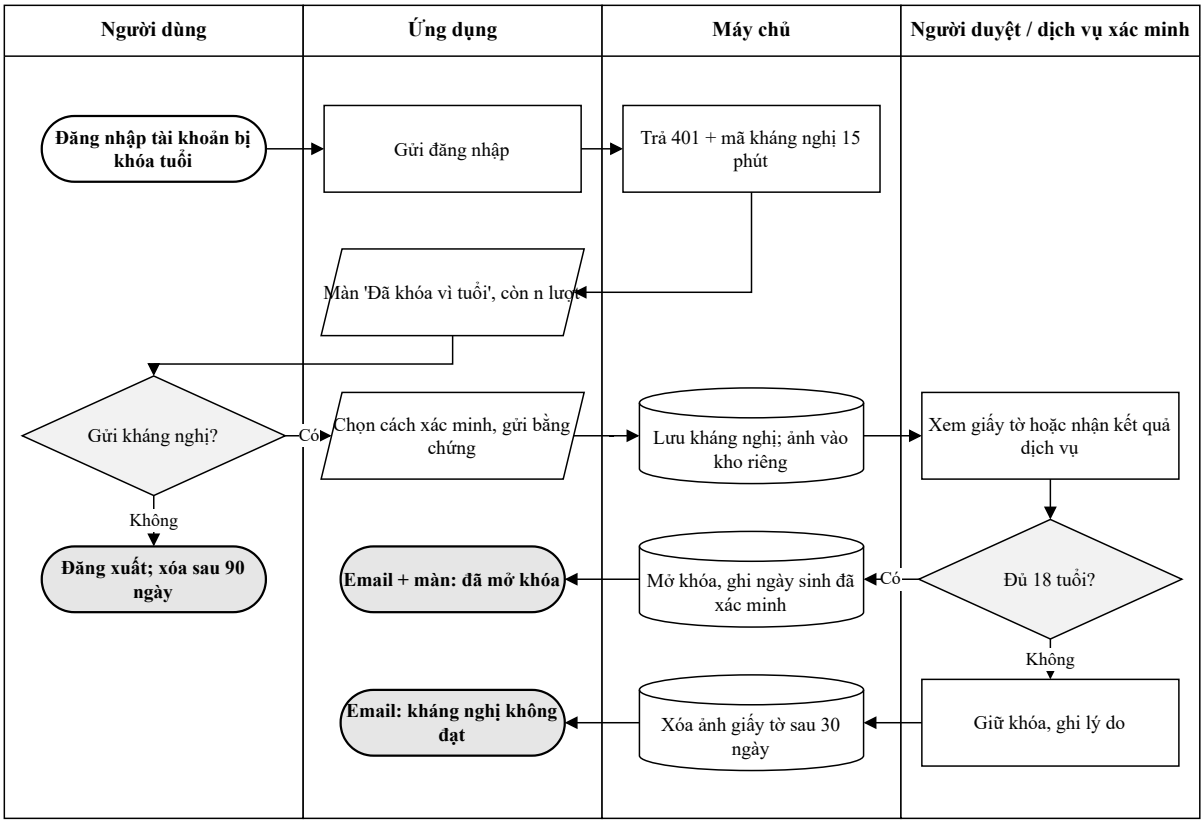
d) Flowchart

Sơ đồ 1: từ báo cáo tới hạn chế tạm, xem xét và yêu cầu xác minh.



Hình 31. Báo cáo người có thể dưới 18 tuổi và xem xét

Sơ đồ 2: tài khoản đã bị khóa vì tuổi gửi kháng nghị.



Hình 32. Tài khoản bị khóa vì tuổi: kháng nghị và xác minh

e) Quy tắc, giới hạn và trường hợp đặc biệt

Các cách xác minh tuổi (chủ dự án chọn; tài liệu này không chọn nhà cung cấp)

Cách	Người dùng làm gì	Dữ liệu thu	Quyền riêng tư	Chi phí, độ tin cậy
1. Ảnh giấy tờ, người duyệt xem tay	Chụp CCCD, hộ chiếu hoặc giấy phép lái xe; được che số giấy tờ, chỉ cần lộ ngày sinh, họ tên, ảnh	Ảnh giấy tờ	Rủi ro cao nếu lộ. Phải có đồng ý rõ ràng, lưu kho riêng, xóa sau 30 ngày, chỉ người duyệt xem	Không tốn phí dịch vụ; tốn thời gian người duyệt. Tin cậy trung bình (giấy tờ mượn, sửa ảnh)

2. Giấy tờ + ảnh chân dung qua nhà cung cấp eKYC	Chụp giấy tờ và quay mặt trong luồng của nhà cung cấp	Ảnh giấy tờ, ảnh khuôn mặt (dữ liệu sinh trắc, thuộc loại nhạy cảm)	Dữ liệu đi qua bên thứ ba; nếu máy chủ của họ ở nước ngoài thì phải đánh giá tác động chuyển dữ liệu ra nước ngoài. Cần hợp đồng xử lý dữ liệu	Tính phí mỗi lượt (cần báo giá). Tin cậy cao
3. Ước lượng tuổi từ khuôn mặt	Quay mặt vài giây, không cần giấy tờ	Ảnh khuôn mặt, nhà cung cấp xóa ngay sau khi trả kết quả (phải ghi trong hợp đồng)	Không lộ giấy tờ; vẫn là xử lý sinh trắc	Tính phí mỗi lượt. Sai số vài tuổi, nên chỉ cho qua khi ước lượng rõ ràng trên 18 (ví dụ từ 21 trở lên), còn lại chuyển sang cách 1 hoặc 2
4. Định danh điện tử quốc gia (VNeID) hoặc dịch vụ xác thực điện tử được cấp phép	Xác nhận qua ứng dụng định danh	Kết quả xác thực, ngày sinh	Ít dữ liệu nhất cho ứng dụng	Điều kiện kết nối cho doanh nghiệp tư nhân: cần kiểm tra. Có thể trùng với nghĩa vụ xác thực tài khoản theo Nghị định 147/2024 (xem A5)
5. Tín hiệu tuổi từ kho ứng dụng	Không làm gì; Apple / Google cho biết khoảng tuổi của tài khoản trên máy	Khoảng tuổi	Ít dữ liệu	Apple (Declared Age Range) và Google Play (Age Signals) có API loại này nhưng phạm vi quốc gia và cách gọi từ Expo cần kiểm tra. Chỉ nên dùng làm tín hiệu thêm, không thay được cách 1–3

- **Lượt kháng nghị** (đề xuất): mỗi lần khóa được 2 lượt; mỗi lúc chỉ một kháng nghị đang chờ; kháng nghị bị từ chối thì 30 ngày sau mới gửi lại được.
- **Báo cáo sai có chủ đích**: người có từ 3 báo cáo tuổi bị kết luận "Không có dấu hiệu" trong 30 ngày thì báo cáo tuổi của họ không còn được tính vào ngưỡng tự hạn chế (đề xuất). Ngưỡng tự hạn chế không bao giờ tự khóa tài khoản; khóa luôn cần người duyệt hoặc hết hạn xác minh.

- **Người bị báo cáo đã xác minh trước đó**: báo cáo tuổi mới vào hàng đợi thường, không kích hoạt hạn chế tạm.
- **Khai nhầm ngày sinh** (người lớn khai nhầm thành dưới 18): đi luồng kháng nghị. Nút "Mở khóa tuổi" hiện có của quản trị viên giữ lại cho trường hợp đặc biệt, nhưng nên bắt buộc ghi lý do.
- **Đăng nhập Google tạo tài khoản mới** sau khi tài khoản cũ bị khóa: phát hiện tài khoản phụ nằm ở *MODERATION_PLAN.md* mục 8.8, ngoài phạm vi B6; ghi là rủi ro.
- **Tin nhắn với tài khoản bị khóa**: cuộc trò chuyện còn nguyên với người kia nhưng không gửi thêm được (tài khoản khóa không gọi được API).
- **Lỗi mạng khi gửi bằng chứng**: ứng dụng giữ ảnh đã chọn và cho gửi lại; mã kháng nghị hết hạn sau 15 phút thì đăng nhập lại để lấy mã mới.
- **Danh sách khóa trong bộ nhớ**: chạy nhiều bản API thì phải chuyển sang Redis hoặc kiểm tra cơ sở dữ liệu (đã ghi trong *ban-list.ts*).
- **Pháp lý**: Nghị định 13/2023 và Luật Bảo vệ dữ liệu cá nhân (hiệu lực từ 01/01/2026) áp dụng cho ảnh giấy tờ và dữ liệu sinh trắc. Thời hạn giữ dữ liệu, thời hạn xóa tài khoản người dưới 18 và văn bản đồng ý cần luật sư xem.

f) Dữ liệu và API (đề xuất)

Tất cả là đề xuất, cần đưa vào *docs/api-contract.md* trước khi code.

Bảng	**Trường mới**	**Ý nghĩa**
User	ageLockReason String? (SELF_DECLARED / REPORTED / VERIFY_EXPIRED / VERIFY_FAILED), ageReviewAt DateTime?, ageVerifyDueAt DateTime?, ageVerifiedAt DateTime?, ageVerifyMethod String?	Lý do khóa; đang hạn chế tạm; hạn xác minh; đã xác minh lúc nào, bằng cách nào
AgeAppeal (mới)	id, userId, kind (VERIFY_REQUEST / APPEAL), method, evidenceKey String? (khóa trong kho riêng), status (PENDING / APPROVED / REJECTED), reviewerId, decidedAt, verifiedBirthDate, note, evidenceDeletedAt, createdAt	Một lần xác minh hoặc kháng nghị
Report	Thêm giá trị lý do *UNDERAGE*	Không đổi cấu trúc bảng. C1 cũng thêm lý do mới (*CHILD_SAFETY*, *NUDITY*…); gộp thành một danh sách

API	Mô tả
POST /reports	Nhận thêm *reason: UNDERAGE*; với POST / COMMENT thì máy chủ đổi sang USER là tác giả
POST /auth/login, /auth/google	Khi khóa vì tuổi: vẫn 401 *AGE_RESTRICTED*, thêm *appealToken* (như C2), *appealsLeft*
GET /users/me	Thêm *ageReview*: null hoặc *{ verifyDueAt }*
POST /age-verification	Gửi bằng chứng (multipart ảnh hoặc mã kết quả từ dịch vụ). Dùng token thường (luồng 3) hoặc *appealToken* (luồng 5)
GET /age-verification/status	Trạng thái kháng nghị gần nhất
GET /admin/age-reviews, POST /admin/age-reviews/:id/decide	Hàng đợi và quyết định (DISMISS / REQUEST_VERIFY / LOCK / APPROVE / REJECT); xem ảnh qua link có chữ ký

Một tác vụ chạy định kỳ (mỗi giờ, trong tiến trình API) khóa tài khoản quá hạn xác minh và xóa ảnh giấy tờ quá 30 ngày.

g) Android, iOS và web

- **Chọn ảnh giấy tờ**: dùng *expo-image-picker* đã cài, chạy cả Android và iOS. Quyền thư viện ảnh đã khai báo trong *app.json*. Nếu cho **chụp trực tiếp** thì phải khai thêm trong cùng thay đổi: *cameraPermission* của plugin *expo-image-picker* (iOS cần câu mô tả quyền máy ảnh, thiếu là app bị đóng khi mở máy ảnh) và quyền CAMERA phía Android.
- **Dịch vụ xác minh bên ngoài**: ưu tiên luồng web của nhà cung cấp mở trong trình duyệt trong app, chạy giống nhau trên hai nền tảng và không cần mã gốc. Nếu nhà cung cấp chỉ có SDK gốc, SDK đó phải có bản Android và iOS, hỗ trợ Expo SDK 57 qua config plugin; nếu không thì không dùng. Thư viện mở trình duyệt (ví dụ *expo-web-browser*) chưa có trong dự án, cài bằng *expo install* nếu cần.
- **Màn khóa và màn xác minh**: dùng safe-area và *KeyboardAvoidingView* như *BirthDateScreen* hiện có.
- **App Store / Google Play**: khai báo độ tuổi 18+ ở cả hai cửa hàng. Chính sách quyền riêng tư (*LegalScreen*, đang là bản nháp) phải thêm: thu ảnh giấy tờ / sinh trắc để xác minh tuổi, ai xem, giữ bao lâu. Nhãn quyền riêng tư của App Store và mục An toàn dữ liệu của Google Play phải khai thêm loại dữ liệu này.
- **Web**: trang quản trị thêm mục "Xác minh tuổi" (danh sách, xem ảnh qua link có chữ ký, nút quyết định).

- **Chi phí**: cách 1 không tốn phí dịch vụ; cách 2, 3 tính phí mỗi lượt (cần báo giá); thời gian người duyệt.

h) Tiêu chí hoàn thành

- Báo cáo "Có thể chưa đủ 18 tuổi" từ trang cá nhân, bài viết, bình luận, cuộc trò chuyện; báo cáo luôn gắn vào tài khoản.
- 3 tài khoản hợp lệ báo cáo cùng một người: người đó vào hạn chế tạm (không hiện trong tìm kiếm, không nhắn được người lạ, không gửi ẩn danh), thấy dòng thông báo trung tính. Tài khoản dưới 7 ngày tuổi báo cáo thì không tính.
- Quản trị viên: bỏ qua, yêu cầu xác minh, khóa; mỗi thao tác có nhật ký.
- Yêu cầu xác minh: màn xác minh hiện khi mở app; hết 14 ngày không xác minh thì tài khoản bị khóa tự động.
- Tài khoản bị khóa đăng nhập: thấy màn khóa tiếng Việt và nút kháng nghị (không còn lỗi chung tiếng Anh); gửi được ảnh giấy tờ; mã kháng nghị không gọi được API khác (thử gọi */posts/feed* phải bị từ chối).
- Kháng nghị được chấp nhận: đăng nhập lại bình thường, ngày sinh đã cập nhật. Bị từ chối: vẫn khóa, lượt còn lại giảm.
- Ảnh giấy tờ: không mở được bằng link công khai; bị xóa sau 30 ngày (kiểm tra bằng cách chỉnh thời gian trong test).
- Bài viết của tài khoản bị khóa vì tuổi không hiện với người khác.
- Chạy trên Android và trên iPhone, ghi rõ trong *docs/change.md* máy nào đã chạy.
- Test tự động trong *safety-smoke.cjs*: ngưỡng báo cáo, hạn chế tạm, phạm vi của mã kháng nghị, khóa khi hết hạn.

i) Ước lượng và phụ thuộc

- Backend 5 ngày (lý do báo cáo và ngưỡng 1; hạn chế tạm 1; mã kháng nghị và API xác minh 1,5; quản trị và tác vụ định kỳ 1,5). Mobile 4 ngày (lý do báo cáo 0,5; màn xác minh và nhắc 1,5; màn khóa và gửi kháng nghị 2). Kiểm thử 2 ngày. Tích hợp một dịch vụ xác minh bên ngoài: thêm 3–5 ngày tùy nhà cung cấp.
- Phụ thuộc: **C1** (hàng đợi), **C3** (nhật ký thao tác, quyền người duyệt), **C2** (ẩn nội dung của tài khoản bị khóa, dùng chung bộ lọc), **E2** (xóa tài khoản sau 90 ngày), **A5** nếu chọn xác minh qua định danh điện tử.
- Rủi ro: lưu ảnh giấy tờ là dữ liệu rất nhạy cảm; báo cáo sai để quấy rối; người dưới 18 dùng giấy tờ của người khác; chi phí dịch vụ xác minh; yêu cầu pháp lý chưa được luật sư xác nhận.

B7. Bộ lọc bình luận và từ ngữ ẩn; giới hạn ai được bình luận

Nhóm: An toàn và kiểm duyệt · Giai đoạn: GĐ2 · Ước lượng: 9–10 ngày công

a) Mục đích

Bình luận là nơi dễ bị chửi bới, công kích nhất. Hiện nay ai xem được bài là bình luận được, và mọi bình luận hiện ngay. Tính năng này chặn bình luận có từ ngữ nặng, tự ẩn bình luận có thể xúc phạm, cho mỗi người tự đặt danh sách từ cần ẩn, và cho chủ bài chọn ai được bình luận (mọi người, người theo dõi, không ai). Chủ bài vẫn xem lại được những bình luận đã bị ẩn để hiện lại nếu máy ẩn nhầm. Người được lợi chủ yếu là người đăng bài, nhất là người hay bị công kích.

b) Hiện trạng

- **Gửi bình luận**: *apps/api/src/modules/comments/comments.service.ts*. Máy chủ chỉ kiểm tra người bình luận có xem được bài không (*visiblePostWhere*: bài chưa xóa, không chặn nhau, đúng quyền riêng tư). Nội dung chỉ được cắt khoảng trắng, tối đa 1000 ký tự (*dto/create-comment.dto.ts*). Không lọc chữ.
- **Trả lời**: chỉ hai cấp; trả lời một câu trả lời thì gắn vào bình luận gốc. Sửa bình luận (*PATCH /comments/:id*) không kiểm tra lại nội dung.
- **Danh sách bình luận** loại người đang chặn nhau với người xem. Không có trạng thái ẩn.
- **Xóa**: người viết hoặc chủ bài xóa được (xóa thật, kéo theo các trả lời).
- **Thông báo**: bình luận tạo thông báo COMMENT / REPLY và MENTION khi có @tên; không tạo thông báo giữa hai người chặn nhau (*notifications/notifications.service.ts*).
- **Báo cáo, quản trị**: báo cáo bình luận đã có; quản trị viên "Gỡ nội dung" thì xóa bình luận.
- **Công cụ chữ có sẵn**: *moderation/text-safety.ts* có hàm *normalizeVietnamese* (bỏ dấu, chữ thường), luật phát hiện link, số điện thoại, số tài khoản và danh sách cụm từ lừa đảo. Hiện chỉ dùng cho tin nhắn ẩn danh và tin nhắn chờ.
- **Chưa có**: lọc từ ngữ xúc phạm; danh sách từ ẩn cá nhân; cài đặt ai được bình luận (bài viết chỉ có quyền xem *PUBLIC / FRIENDS / PRIVATE*); mục "bình luận đã ẩn". *MODERATION_PLAN.md* mục 8.1 đã ghi kế hoạch lọc chữ tiếng Việt.

c) Cách hoạt động

Có bốn lớp, máy chủ kiểm tra theo thứ tự mỗi khi có bình luận mới hoặc bình luận được sửa:

1. **Quyền bình luận** theo cài đặt của chủ bài.
2. **Từ mức nặng** (danh sách chung của nền tảng): chặn, không lưu.
3. **Lý do phải ẩn**: người viết đang bị chủ bài hạn chế (B8); có từ mức nhẹ và chủ bài bật "Ẩn bình luận có thể xúc phạm"; có từ trong danh sách từ ẩn của chủ bài.
4. Không có gì: hiện với mọi người như hiện nay.

Luồng 1: Chủ bài đặt ai được bình luận

1. Vào Cài đặt → Quyền riêng tư → "Bình luận". Chọn mặc định cho mọi bài: Mọi người (mặc định) / Người theo dõi bạn / Không ai.
2. Khi tạo hoặc sửa bài, trong menu quyền riêng tư của bài (*PostPrivacyModal*) có thêm mục "Ai được bình luận" để đặt riêng cho bài đó.
3. "Người theo dõi bạn" là người đang theo dõi chủ bài (đã được chấp nhận nếu là tài khoản riêng tư). Chủ bài luôn bình luận được trên bài của mình.
4. Đổi cài đặt không xóa bình luận cũ, chỉ áp dụng cho bình luận mới. Trả lời đi theo cùng quy tắc của bài.
5. Người không được bình luận thấy ô nhập bị thay bằng dòng "Chủ bài viết đã giới hạn người có thể bình luận". Máy chủ vẫn kiểm tra (trả 403) để không lách được bằng cách gọi API thẳng.

Luồng 2: Gửi hoặc sửa bình luận

1. Người dùng viết bình luận và bấm Gửi.
2. Máy chủ kiểm tra quyền xem bài (đã có) và quyền bình luận (luồng 1).
3. Máy chủ chuẩn hóa nội dung: bỏ dấu, chữ thường (dùng *normalizeVietnamese*); bỏ ký tự chèn giữa chữ ("đ.m", "đ m"); gộp chữ lặp ("nguuuu"); đổi số và ký hiệu thay chữ (0→o, 1→i, 3→e, 4→a, @→a); quy đổi teencode phổ biến.
4. **Có từ mức nặng** (chửi tục nặng, đe dọa bạo lực, kỳ thị vùng miền, tôn giáo, giới tính, xúc phạm ngoại hình nặng): trả lỗi, không lưu. Ứng dụng hiện "Bình luận có từ ngữ vi phạm tiêu chuẩn cộng đồng" và giữ nguyên chữ trong ô nhập để người viết sửa. Máy chủ chỉ đếm số lần bị chặn, không lưu nội dung.
5. **Có lý do phải ẩn**: lưu bình luận ở trạng thái ẩn kèm lý do (HẠN CHẾ / XÚC PHẠM / TỪ ẨN). Không gửi thông báo cho chủ bài và cho người được nhắc tên. Người viết thấy bình luận của mình như bình thường (đề xuất, chủ dự án quyết; xem mục e). Người khác không thấy và số bình luận họ thấy không tính bình luận này.
6. **Không có gì**: lưu và hiện như hiện nay, gửi thông báo như hiện nay.

7. Sửa bình luận chạy lại các bước 3–5. Bình luận đang hiện mà sửa thành có từ ẩn thì chuyển sang ẩn; sửa thành có từ nặng thì bị từ chối, giữ nội dung cũ.

Luồng 3: Danh sách từ ẩn cá nhân

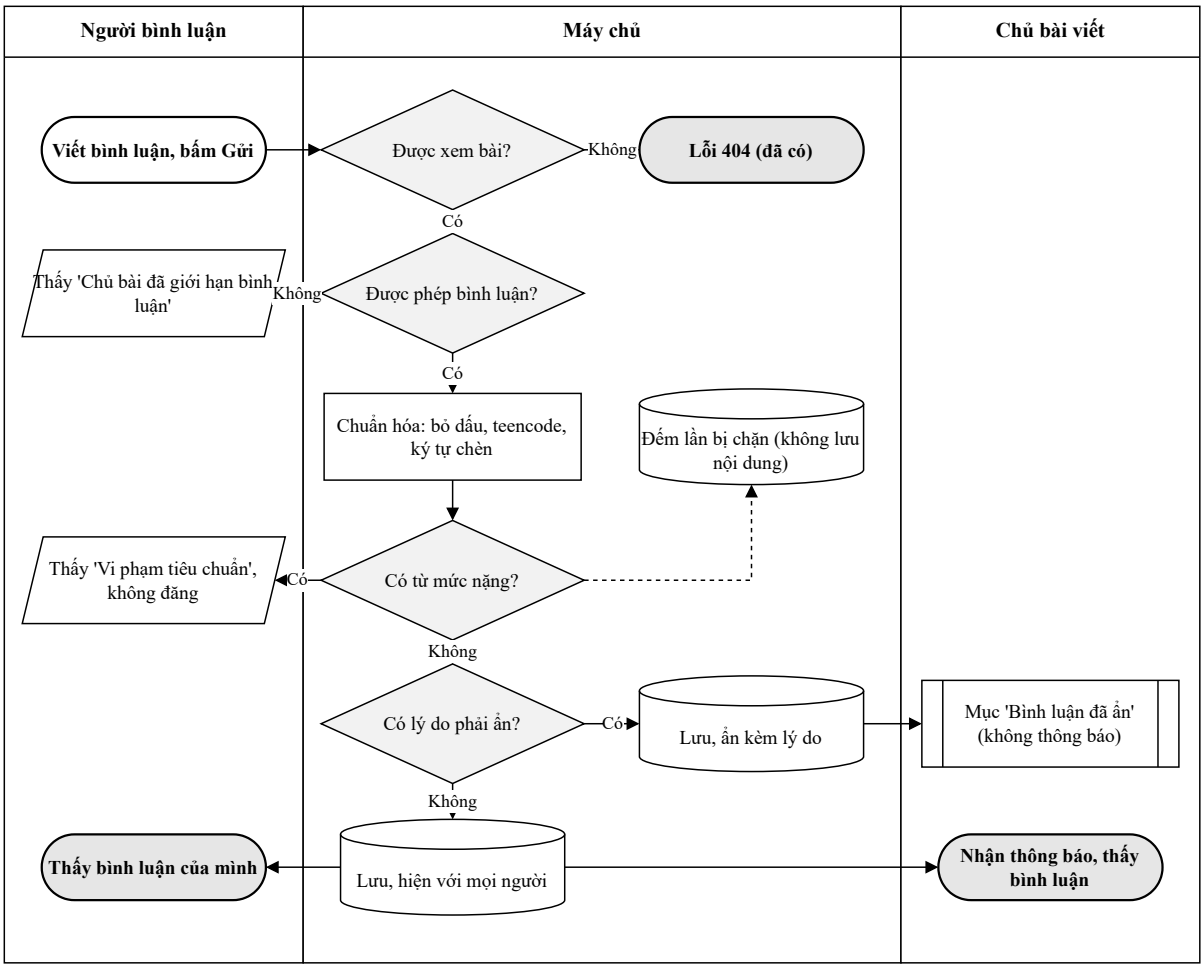
1. Cài đặt → Quyền riêng tư → "Từ ngữ ẩn". Người dùng thêm từ hoặc cụm từ (mỗi mục 1–50 ký tự, tối đa 200 mục, đề xuất). Có thể thêm cả biểu tượng cảm xúc.
2. Máy chủ lưu cả bản người dùng gõ (để hiển thị) và bản đã chuẩn hóa (để so khớp). Từ trùng thì bỏ qua.
3. Từ ẩn áp dụng cho bình luận **mới** trên bài của người đó (và trả lời trong các bình luận đó). Bình luận đã có không bị đổi.
4. Xóa một từ không làm hiện lại bình luận đã ẩn vì từ đó; chủ bài hiện lại bằng tay ở luồng 4.
5. Bật "Ẩn bình luận có thể xúc phạm" (mặc định bật) nằm cùng màn này.

Luồng 4: Chủ bài xem bình luận đã ẩn

1. Cuối danh sách bình luận của bài mình, chủ bài thấy dòng "Bình luận đã ẩn (n)". Người khác không thấy dòng này.
2. Bấm vào, ứng dụng tải danh sách. Máy chủ kiểm tra người gọi là chủ bài, nếu không trả 403.
3. Mỗi bình luận hiện kèm lý do ẩn ("Có từ trong danh sách của bạn", "Có thể xúc phạm", "Từ người bạn đã hạn chế").
4. Chủ bài chọn:
    - **Hiện**: bình luận hiện với mọi người. Không gửi thông báo bù.
    - **Xóa**: xóa như hiện nay. Người viết không được báo.
    - Sau khi xóa, có thể **chặn** (đã có) hoặc **hạn chế** (B8) người viết, hoặc báo cáo.
    - Không làm gì: bình luận vẫn ẩn.

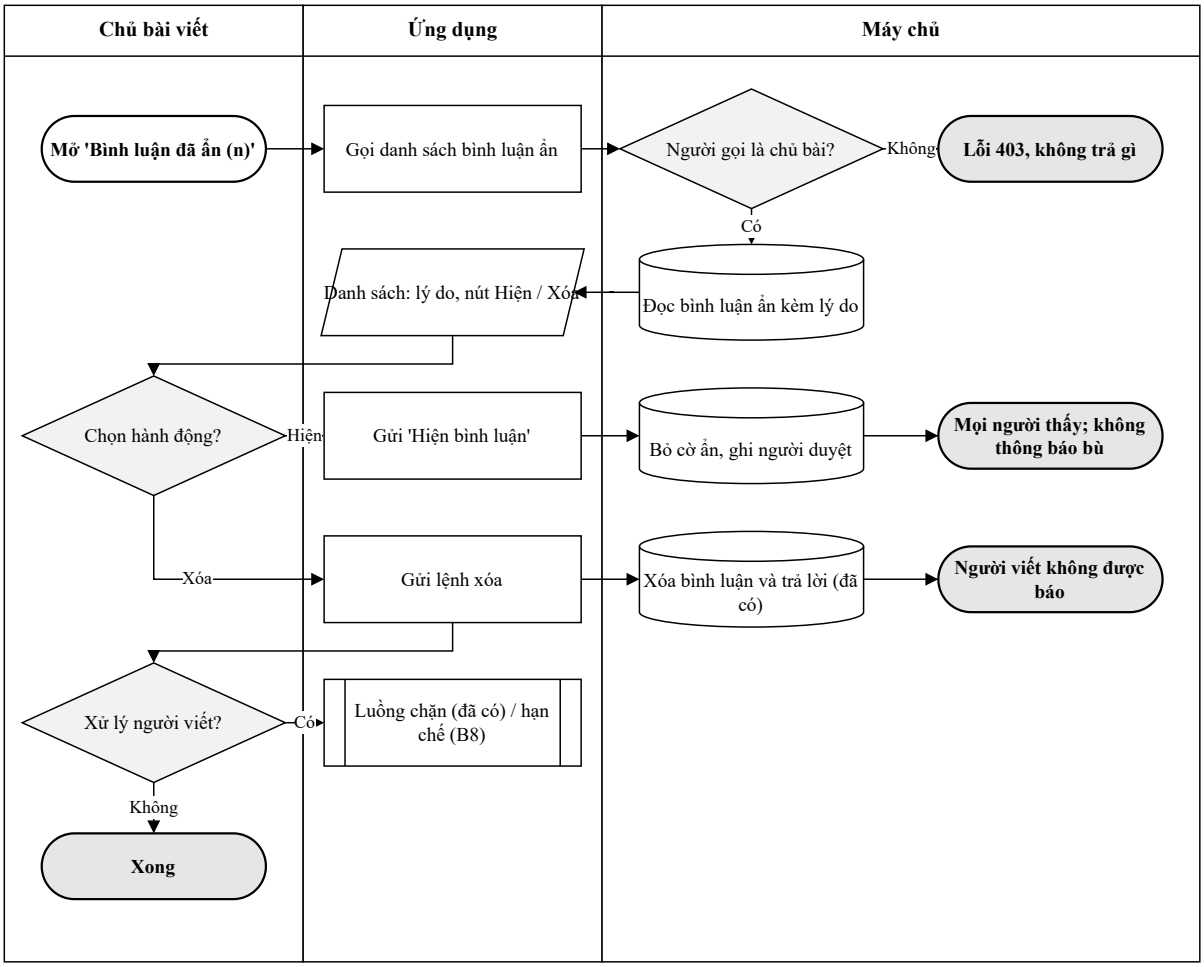
d) Flowchart

Sơ đồ 1: máy chủ kiểm tra một bình luận mới hoặc bình luận được sửa.



Hình 33. Gửi hoặc sửa bình luận: quyền bình luận, bộ lọc và từ ẩn

Sơ đồ 2: chủ bài xem và xử lý bình luận đã ẩn.



Hình 34. Chủ bài viết xem và xử lý bình luận đã ẩn

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Danh sách từ của nền tảng** nằm trong một tệp mã nguồn (giống *SCAM_PHRASES*), chia hai mức nặng / nhẹ. Nội dung danh sách do chủ dự án hoặc người kiểm duyệt soạn và duyệt; giai đoạn sau có thể sửa trên trang quản trị (C3). Mỗi lần đổi danh sách nên chạy lại bộ câu thử có sẵn.
- **Bỏ dấu dễ bắt nhầm**: nhiều từ tiếng Việt chỉ khác dấu. Từ nào bỏ dấu sẽ trùng từ bình thường thì chỉ so khớp ở dạng còn dấu. So khớp theo nguyên từ (không bắt chữ nằm giữa từ khác).
- **Bình luận ẩn**: không tính vào số bình luận người khác thấy (người viết thấy số có tính bình luận của mình); không tạo thông báo COMMENT, REPLY, MENTION; các trả lời cho bình luận ẩn cũng ẩn theo.
- **Người viết có được biết bình luận bị ẩn không**: đề xuất không báo (giống Instagram), để người cố tình công kích không thử lách từng chữ. Đổi lại kém minh bạch với người bị ẩn nhầm. Chủ dự án quyết.

- **Lạm dụng**: người bị chặn vì từ mức nặng 5 lần trong 1 giờ thì không bình luận được trong 1 giờ (429, đề xuất). Giới hạn chung của API (throttler trong *app.module.ts*) vẫn áp dụng.
- **Lỗi mạng**: giữ chữ trong ô nhập khi gửi lỗi như hiện nay; gửi lại không tạo trùng vì lần đầu chưa lưu.
- **Người chặn nhau**: không thấy bài của nhau nên không bình luận được (đã có).
- **Bài đổi sang "Không ai được bình luận"**: bình luận cũ vẫn hiện; ô nhập ẩn đi.
- **Tài khoản riêng tư**: chỉ người theo dõi mới xem được bài, nên "Mọi người" và "Người theo dõi" cho kết quả như nhau.
- **Quản trị**: bình luận ẩn không vào hàng đợi trừ khi bị báo cáo. Trang quản trị thêm số bình luận bị chặn / bị ẩn mỗi ngày để theo dõi tỉ lệ chặn nhầm.
- **Ngoài phạm vi**: lọc chữ trong bài viết, tên, tiểu sử (C1 và *MODERATION_PLAN.md* mục 8.1); mô hình phân loại chữ tiếng Việt.

f) Dữ liệu và API (đề xuất)

Tất cả là đề xuất, cần đưa vào *docs/api-contract.md* trước khi code. Hai trường ẩn của *Comment* và API xem / hiện bình luận ẩn được tạo trong B8 (giai đoạn 1); B7 dùng lại và thêm lý do.

Bảng	**Trường mới**	**Ý nghĩa**
Comment	filteredAt DateTime?, filterReason String? (RESTRICTED / OFFENSIVE / HIDDEN_WORD)	Bình luận bị bộ lọc của chủ bài ẩn và lý do (tạo ở B8, B7 thêm hai lý do). Khác với *hiddenAt* của C1 (ẩn tạm chờ kiểm duyệt viên duyệt); hai trường độc lập, tên khác nhau để không lẫn
User	commentPolicy String (EVERYONE / FOLLOWERS / OFF, mặc định EVERYONE), hideOffensiveComments Boolean (mặc định true)	Cài đặt mặc định của chủ bài
Post	commentPolicy String? (null = theo cài đặt tài khoản)	Cài đặt riêng của bài
HiddenWord (mới)	userId, normalized String, display String, createdAt; khóa chính (userId, normalized)	Danh sách từ ẩn cá nhân

API	**Mô tả**

POST /posts/:id/comments, POST /comments/:id/replies, PATCH /comments/:id	Thêm lỗi 403 *COMMENTS_RESTRICTED*, 400 *COMMENT_BLOCKED*, 429 *COMMENT_COOLDOWN*. Bình luận trả về cho người viết có thêm *hidden* chỉ khi chủ dự án chọn cho người viết biết
Bài viết trả về	Thêm *commentPolicy* và *canComment* (người xem có được bình luận không)
POST /posts, PATCH /posts/:id	Nhận *commentPolicy*
PATCH /users/me	Nhận *commentPolicy*, *hideOffensiveComments*
GET /users/me/hidden-words, POST /users/me/hidden-words, DELETE /users/me/hidden-words/:word	Quản lý từ ẩn
GET /posts/:id/comments/filtered, POST /comments/:id/approve	Chủ bài xem và hiện bình luận ẩn (tạo ở B8). Xóa dùng *DELETE /comments/:id* đã có

Trong code: thêm tệp danh sách từ và hàm chuẩn hóa mở rộng trong *moderation/* (cạnh *text-safety.ts*), kèm test đơn vị với các câu mẫu (có dấu, không dấu, chèn ký tự, teencode, câu bình thường dễ bắt nhầm).

g) Android, iOS và web

- Toàn bộ là màn hình và logic thường, không dùng API riêng của nền tảng nào, không cần quyền thiết bị, không cần thư viện mới.
- Màn "Từ ngữ ẩn" có ô nhập: dùng *KeyboardAvoidingView* đúng hành vi từng nền tảng và safe-area như các màn cài đặt hiện có.
- Thao tác trên bình luận ẩn dùng menu / hộp xác nhận chung của app (không dùng *ActionSheetIOS* hay menu chỉ có trên Android).
- **App Store / Google Play**: cả hai yêu cầu app có nội dung người dùng tạo phải có cách lọc nội dung phản cảm, báo cáo và chặn. Tính năng này giúp đáp ứng phần lọc.
- **Web**: trang quản trị thêm số liệu chặn / ẩn. Không có phần nào khác cho web.
- **Chi phí**: không có dịch vụ ngoài.

h) Tiêu chí hoàn thành

- Chủ bài chọn "Người theo dõi bạn": người không theo dõi thấy dòng giới hạn, gọi API thẳng nhận 403. Chọn "Không ai": chỉ chủ bài bình luận được. Cài đặt riêng của bài ghi đè cài đặt tài khoản.
- Bình luận có từ mức nặng (cả viết có dấu, không dấu, chèn dấu chấm, teencode) bị từ chối với thông báo tiếng Việt; chữ vẫn còn trong ô nhập.

- Bình luận có từ mức nhẹ: ẩn khi chủ bài bật lọc, hiện khi chủ bài tắt lọc.
- Thêm từ ẩn "abc": bình luận mới chứa "abc" bị ẩn, bình luận cũ không đổi.
- Bình luận ẩn: người khác không thấy, số bình luận không tính, không có thông báo; chủ bài thấy trong "Bình luận đã ẩn" kèm lý do, hiện lại hoặc xóa được.
- Sửa bình luận đang hiện thành có từ nặng: bị từ chối; thành có từ ẩn: chuyển sang ẩn.
- Bộ câu thử tiếng Việt bình thường (ít nhất 100 câu) không bị chặn nhầm.
- Chạy trên Android và trên iPhone, ghi rõ máy đã chạy trong *docs/change.md*.
- Test tự động: test đơn vị cho hàm chuẩn hóa và so khớp; thêm vào *social-smoke.cjs* các trường hợp quyền bình luận và bình luận ẩn.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (chuẩn hóa và so khớp kèm test 1,5; quyền bình luận 1; từ ẩn và lọc khi gửi / sửa 1; số liệu quản trị 0,5). Mobile 4 ngày (cài đặt bình luận và mục trong *PostPrivacyModal* 1; màn từ ẩn 1; ô nhập bị giới hạn, lỗi bị chặn 0,5; "Bình luận đã ẩn" mở rộng từ B8 1,5). Kiểm thử 2 ngày.
- Phụ thuộc: **B8** (trường ẩn của bình luận và mục "Bình luận đã ẩn" làm ở giai đoạn 1). Danh sách từ cần chủ dự án / người kiểm duyệt soạn trước khi kiểm thử. Có thể dùng chung từ ẩn cho tin nhắn chờ nếu nhóm B1 (G2) muốn.
- Rủi ro: chặn nhầm câu bình thường vì tiếng Việt bỏ dấu dễ trùng; người dùng lách bằng cách viết khác đi (danh sách cần cập nhật thường xuyên); danh sách từ là dữ liệu nhạy cảm để soạn và duyệt.

B8. Hạn chế (Restrict) và tắt tiếng (Mute)

Nhóm: An toàn và kiểm duyệt · Giai đoạn: GĐ1 · Ước lượng: 8–9 ngày công

a) Mục đích

Hiện nay người dùng chỉ có một cách đối phó với người làm phiền: chặn. Chặn mạnh và người bị chặn dễ nhận ra (không xem được trang cá nhân, mất theo dõi hai chiều), nên nhiều người ngại chặn bạn bè, đồng nghiệp hay người đang quấy rối mà họ sợ bị trả đũa. **Hạn chế** cho phép lặng lẽ giảm ảnh hưởng của một người: bình luận của họ chỉ họ thấy cho tới khi mình duyệt, tin nhắn của họ vào mục chờ, mình không nhận thông báo từ họ, còn họ không biết. **Tắt tiếng** cho phép không thấy bài, story hoặc thông báo tin nhắn của một người mà không phải bỏ theo dõi.

b) Hiện trạng

- **Chặn đã có**: bảng *Block* (*apps/api/prisma/schema.prisma*). *blockedUserIds* (*posts/post-view.ts*) tính cả hai chiều và được dùng ở bảng tin, chi tiết bài, bình luận, Reels, story, tìm kiếm, gợi ý, tin nhắn. Chặn xóa theo dõi và yêu cầu theo dõi cả hai chiều (*users/users.service.ts* hàm *setBlocked*). Không tạo thông báo giữa hai người chặn nhau (*notifications.service.ts*). Không nhắn được cho nhau (*messages.service.ts*). Người bị chặn mở trang cá nhân của người chặn thì nhận 404. Danh sách "Người dùng đã chặn" trong Cài đặt (*BlockedUsersScreen.tsx*). Nút chặn có trên trang cá nhân và trong cuộc trò chuyện.
- **Ẩn một bài**: bảng *HiddenPost*, "Ẩn bài viết" trong menu bài (*PostOptionsModal.tsx*). Chỉ ẩn từng bài, không ẩn theo người.
- **Tin nhắn chờ**: hội thoại có trạng thái *PENDING* / *ACCEPTED* dùng chung cho cả hai người (*Conversation.status*), kèm thời điểm đọc của từng bên (*userAReadAt*, *userBReadAt*).
- **Chưa có**: hạn chế, tắt tiếng người dùng, tắt thông báo một cuộc trò chuyện, trạng thái ẩn của bình luận. Trong ứng dụng, chữ "mute" chỉ xuất hiện ở nút tắt âm thanh video Reels.

c) Cách hoạt động

So sánh ba cách (A là người thao tác, B là người bị áp dụng):

	Chặn (đã có)	**Hạn chế (mới)**	**Tắt tiếng (mới)**
B có được báo?	Không, nhưng dễ nhận ra	Không, khó nhận ra	Không, khó nhận ra

Theo dõi	Bị xóa hai chiều	Giữ nguyên	Giữ nguyên
B xem bài, story của A	Không	Có, như cũ	Có, như cũ
A xem bài, story của B	Không	Có, như cũ	Không hiện ở bảng tin / khay story (tùy chọn), vẫn xem được trên trang cá nhân của B
B bình luận bài của A	Không được	Được, nhưng chỉ B và A thấy cho tới khi A duyệt	Như bình thường
B nhắn tin cho A	Không được	Được; với A, tin vào mục "Tin nhắn chờ", không thông báo; B không thấy "Đã xem"	Tin đến bình thường nhưng không có thông báo đẩy (nếu A tắt tiếng tin nhắn)
Thông báo từ B tới A (thích, bình luận, nhắc tên, theo dõi, cảm xúc story)	Không	Không	Như bình thường
Bỏ	Bỏ chặn; theo dõi không tự quay lại	Bỏ hạn chế; bình luận đang chờ vẫn chờ A duyệt	Bỏ tắt tiếng; nội dung hiện lại ngay

Luồng 1: Hạn chế

1. A mở menu trên trang cá nhân của B, trên một bình luận của B ở bài của A, hoặc trong cuộc trò chuyện với B, chọn "Hạn chế". Ứng dụng giải thích ngắn: "B sẽ không biết. Bình luận mới của B trên bài của bạn chỉ hiện khi bạn duyệt. Tin nhắn của B sẽ vào mục Tin nhắn chờ."
2. Máy chủ kiểm tra hai người không chặn nhau (đang chặn thì trả 409, vì chặn đã mạnh hơn), rồi ghi bản ghi hạn chế. Theo dõi giữ nguyên. Không gửi gì cho B.
3. **B bình luận hoặc trả lời trên bài của A**: máy chủ lưu bình luận ở trạng thái ẩn, lý do "hạn chế". B thấy bình luận của mình như thường. Người khác không thấy. A không nhận thông báo; A thấy bình luận trong mục "Bình luận chờ duyệt" của bài và chọn Hiện / Xóa / để nguyên. Bình luận của B trên bài người khác không bị ảnh hưởng.
4. **B nhắn tin cho A**: máy chủ lưu tin như bình thường, B gửi được không giới hạn như trước. Trong hộp thư của A, cuộc trò chuyện với B nằm ở mục "Tin nhắn chờ"

và không tính vào số chưa đọc. A không nhận thông báo đẩy. B không thấy "Đã xem" dù A đã mở. Trả lời story của A từ B cũng đi theo cách này.

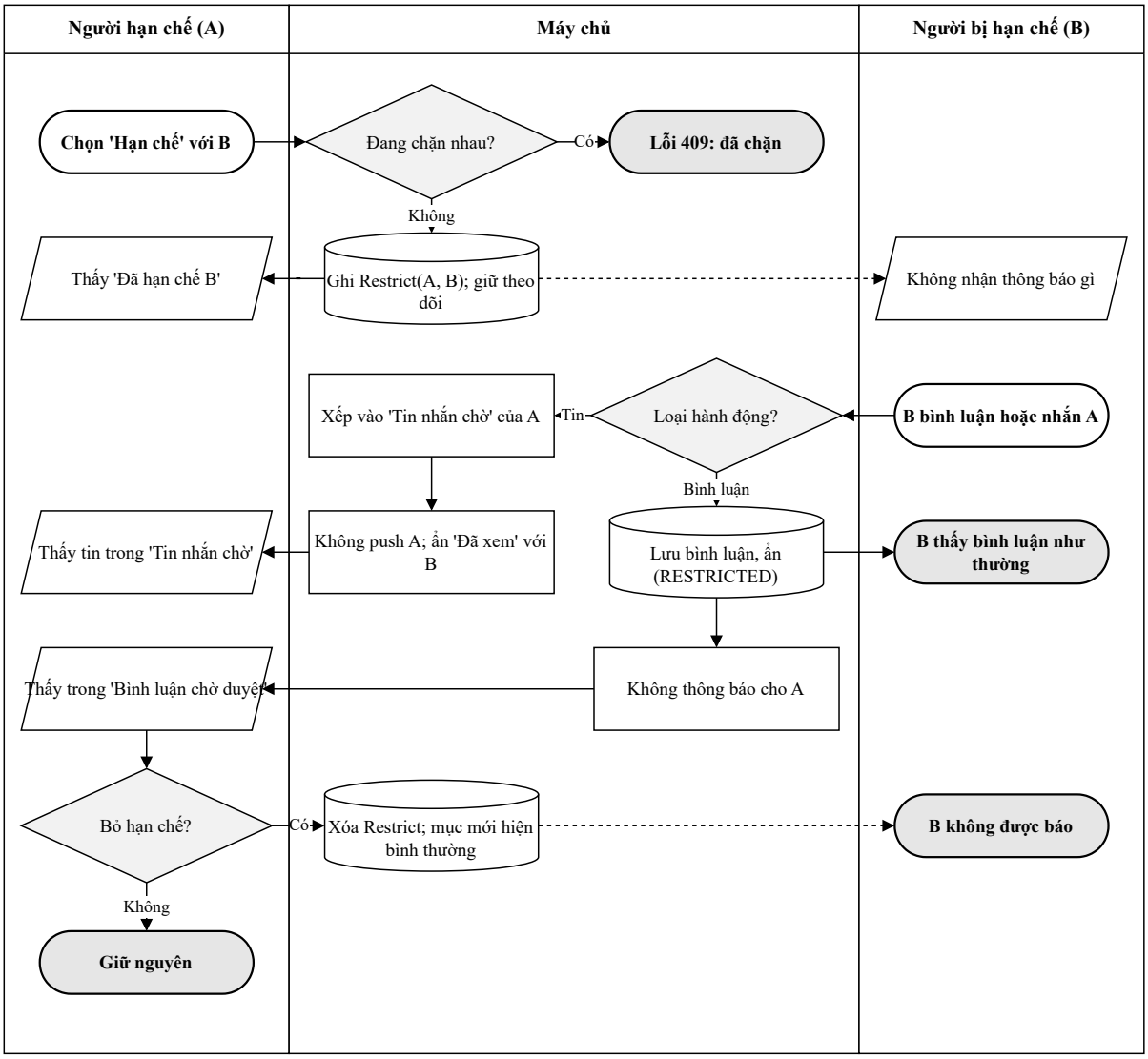
5. **Mọi thông báo khác từ B tới A** (thích, cảm xúc, nhắc tên, đăng lại, theo dõi, cảm xúc story) không được tạo.
6. **Bỏ hạn chế**: từ trang cá nhân của B hoặc Cài đặt → Quyền riêng tư → "Tài khoản bị hạn chế". Bình luận mới của B hiện bình thường. Bình luận đang chờ vẫn chờ A duyệt. Cuộc trò chuyện quay về hộp thư chính. B không được báo.

Luồng 2: Tắt tiếng

1. A mở menu trên trang cá nhân của B, chọn "Tắt tiếng", rồi chọn: Bài viết, Story (chọn một hoặc cả hai). Trong cuộc trò chuyện, chọn "Tắt thông báo" với thời hạn 1 giờ, 8 giờ, 24 giờ hoặc "Cho tới khi bật lại".
2. Máy chủ ghi bản ghi tắt tiếng (hoặc thời hạn tắt thông báo của cuộc trò chuyện). Không gửi gì cho B.
3. **Bài viết**: bài và lượt đăng lại của B không hiện trong bảng tin và Reels của A.
4. **Story**: vòng story của B không hiện trong khay story của A.
5. **Tin nhắn**: tin vẫn đến và vẫn tính chưa đọc, nhưng không có thông báo đẩy cho tới hết thời hạn. Áp dụng cả cho cuộc trò chuyện ẩn danh (không lộ danh tính ai).
6. A vẫn mở trang cá nhân của B và xem đủ mọi thứ. Thông báo tương tác từ B (thích, bình luận) vẫn đến; muốn chặn những thông báo đó thì dùng Hạn chế.
7. **Bỏ tắt tiếng**: từ trang cá nhân của B hoặc Cài đặt → Quyền riêng tư → "Tài khoản đã tắt tiếng". Nội dung hiện lại từ lần tải tiếp theo.

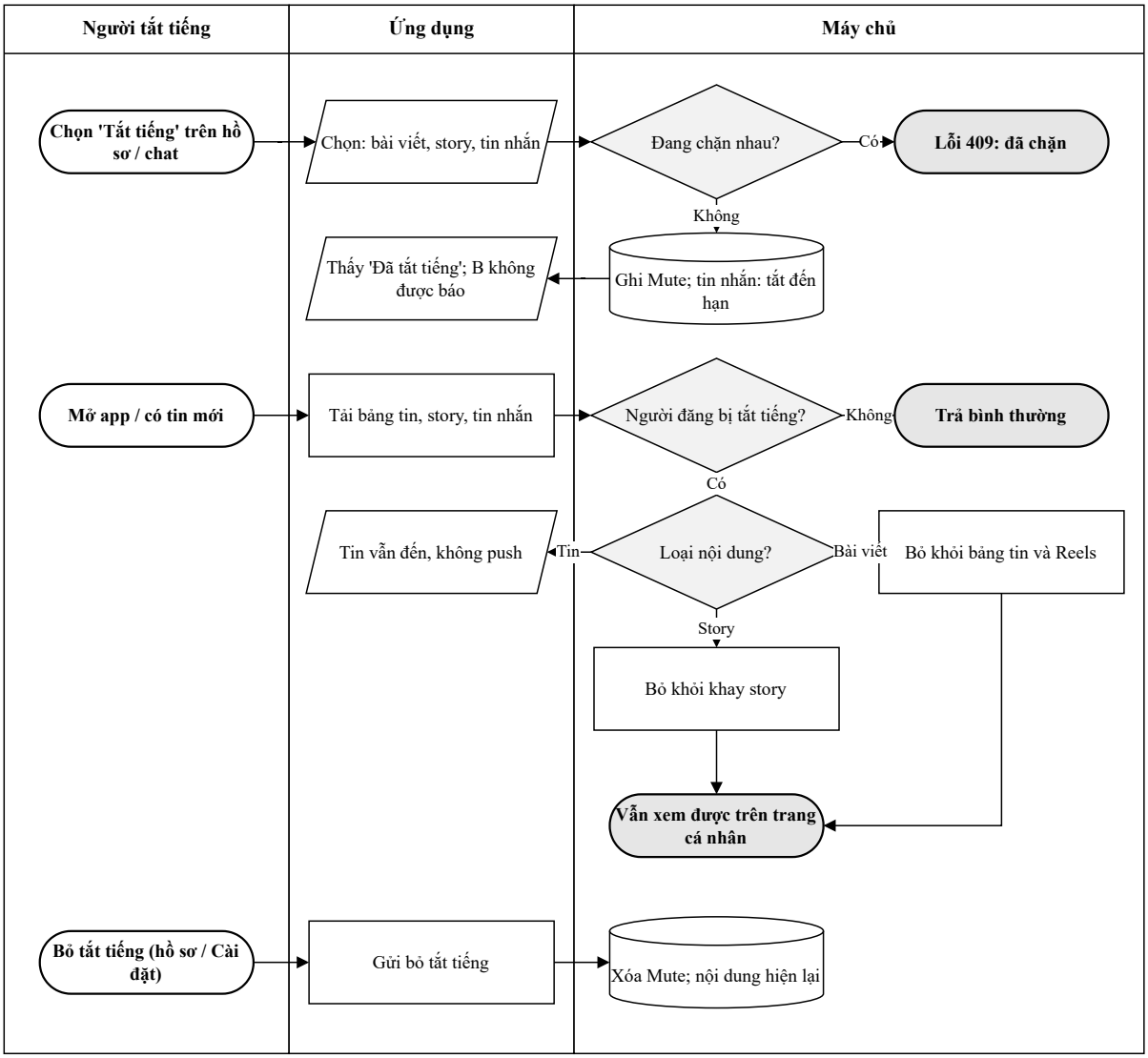
d) Flowchart

Sơ đồ 1: A hạn chế B, rồi B bình luận hoặc nhắn tin.



Hình 35. Hạn chế (Restrict): A hạn chế B, rồi B bình luận hoặc nhắn tin

Sơ đồ 2: tắt tiếng và bỏ tắt tiếng.



Hình 36. Tắt tiếng (Mute) bài viết, story và tin nhắn

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Chặn thắng tất cả**: chặn một người thì xóa luôn bản ghi hạn chế và tắt tiếng giữa hai người (hai chiều). Bỏ chặn không khôi phục lại.
- **Không để lộ**: mọi phản hồi API mà B nhận phải giống hệt như khi chưa bị hạn chế. Ví dụ: số bình luận B thấy có tính bình luận của chính B; tin nhắn của B không bị giới hạn 3 tin như tin nhắn chờ thật; không có trường nào cho B biết. Thêm phép thử tự động so sánh phản hồi trước và sau khi hạn chế.
- **Hạn chế người ẩn danh**: không có, vì A không biết đó là ai. Với cuộc trò chuyện ẩn danh vẫn chỉ có Chặn và Báo cáo như hiện nay; Tắt thông báo thì có.
- **Giới hạn** (đề xuất): tối đa 1000 tài khoản bị hạn chế và 1000 tài khoản bị tắt tiếng mỗi người. Giới hạn tần suất API chung vẫn áp dụng.

- **Người bị hạn chế bị nhắc tên trong bài của A**: không ảnh hưởng. Hạn chế chỉ một chiều, từ B tới A.
- **B trả lời một bình luận của người khác trên bài của A**: vẫn ẩn chờ duyệt (vì là bài của A).
- **Tài khoản B bị khóa hoặc xóa**: bản ghi xóa theo tài khoản (khóa ngoại xóa dây chuyền).
- **Lỗi mạng khi bấm Hạn chế / Tắt tiếng**: thao tác lặp lại không tạo bản ghi trùng (ghi đè); ứng dụng chỉ đổi trạng thái nút sau khi máy chủ xác nhận.
- **Thông báo cũ**: thông báo đã nhận từ B trước khi hạn chế giữ nguyên.
- **"Cho tới khi bật lại"** của tắt thông báo cuộc trò chuyện lưu bằng một mốc rất xa (năm 9999). Đây là cách đơn giản, đủ dùng.

f) Dữ liệu và API (đề xuất)

Tất cả là đề xuất, cần đưa vào *docs/api-contract.md* trước khi code.

Bảng	**Trường**	**Ý nghĩa**
Restrict (mới)	restricterId, restrictedId, createdAt; khóa chính (restricterId, restrictedId); chỉ mục theo restrictedId	A hạn chế B. Cấu trúc giống *Block*
Mute (mới)	muterId, mutedId, posts Boolean, stories Boolean, createdAt; khóa chính (muterId, mutedId)	A tắt tiếng bài / story của B
Conversation	userAMutedUntil DateTime?, userBMutedUntil DateTime?	Tắt thông báo theo từng bên, giống cặp *userAReadAt* / *userBReadAt* đã có
Comment	filteredAt DateTime?, filterReason String?	Bình luận bị ẩn bởi lựa chọn của chủ bài; B8 dùng lý do RESTRICTED, B7 thêm lý do khác. Không dùng tên *hiddenAt* vì C1 đã dùng tên đó cho "ẩn tạm chờ duyệt"

API	**Mô tả**
POST /users/:id/restrict, DELETE /users/:id/restrict	Hạn chế / bỏ hạn chế. 409 nếu đang chặn nhau, 400 nếu tự hạn chế mình
GET /users/me/restricted	Danh sách tài khoản bị hạn chế
PUT /users/:id/mute *{ posts, stories }*, DELETE /users/:id/mute	Tắt tiếng / bỏ tắt tiếng

GET /users/me/muted	Danh sách tài khoản đã tắt tiếng
POST /conversations/:id/mute *{ duration: 1h / 8h / 24h / always }*, DELETE /conversations/:id/mute	Tắt / bật thông báo một cuộc trò chuyện
GET /users/:id	Thêm *isRestricted*, *muted: { posts, stories }*; chỉ là cài đặt của chính người xem
Hội thoại trả về	Thêm *mutedUntil* của chính người gọi
GET /posts/:id/comments/filtered, POST /comments/:id/approve	Chủ bài xem và hiện bình luận chờ duyệt (403 nếu không phải chủ bài)

Nơi phải sửa trong code: *comments.service.ts* (tạo bình luận ẩn, lọc khi đọc, đếm); *notifications.service.ts* hàm *notify* (bỏ qua khi người nhận hạn chế người gửi, giống cách đang bỏ qua khi chặn); *messages.service.ts* (xếp hộp thư theo người xem, ẩn "Đã xem" với B, không đẩy thông báo khi hạn chế hoặc đang tắt thông báo); *posts.service.ts* hàm bảng tin, *reels.service.ts*, *stories.service.ts* hàm *feed* (bỏ người bị tắt tiếng); *users.service.ts* hàm *setBlocked* (xóa hạn chế và tắt tiếng khi chặn).

g) Android, iOS và web

- Không dùng API riêng của nền tảng, không cần quyền thiết bị, không cần thư viện mới.
- Menu trên trang cá nhân, bình luận và cuộc trò chuyện dùng menu / hộp xác nhận chung của app (không dùng *ActionSheetIOS*). Thao tác giữ lâu trên bình luận phải có cách thay thế bằng nút "…" để dùng được với trình đọc màn hình trên cả hai nền tảng.
- Hai màn danh sách mới ("Tài khoản bị hạn chế", "Tài khoản đã tắt tiếng") làm theo mẫu *BlockedUsersScreen.tsx*.
- Tắt thông báo cuộc trò chuyện chặn ở máy chủ (không gửi thông báo đẩy), nên giống nhau trên Android (FCM) và iOS (APNs), không cần cấu hình riêng.
- **Web**: không có thay đổi cho trang quản trị.
- **Chi phí**: không có.

h) Tiêu chí hoàn thành

- A hạn chế B: B vẫn theo dõi A, vẫn xem bài và story của A; phản hồi API B nhận không có dấu hiệu bị hạn chế.
- B bình luận bài của A: B thấy bình luận; người thứ ba không thấy; A không có thông báo, thấy trong "Bình luận chờ duyệt", hiện lại được.

- B nhắn tin cho A: tin vào "Tin nhắn chờ" của A, không thông báo đẩy, B không thấy "Đã xem".
- B thích bài, nhắc tên A: A không nhận thông báo.
- A tắt tiếng bài viết của B: bài của B không còn trong bảng tin và Reels của A, vẫn có trên trang cá nhân của B. Tắt tiếng story: vòng story của B biến khỏi khay.
- Tắt thông báo cuộc trò chuyện 1 giờ: không có thông báo đẩy trong 1 giờ, sau đó có lại.
- Chặn B sau khi đã hạn chế / tắt tiếng: bản ghi bị xóa; bỏ chặn không khôi phục.
- Bỏ hạn chế, bỏ tắt tiếng từ trang cá nhân và từ Cài đặt.
- Chạy trên Android và trên iPhone, ghi rõ máy đã chạy trong *docs/change.md*.
- Test tự động: thêm vào *social-smoke.cjs* các trường hợp trên, gồm phép so sánh phản hồi của B trước và sau khi bị hạn chế.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (bảng và API 1; bình luận ẩn và đếm 1; tin nhắn và thông báo 1,5; bảng tin, Reels, story 0,5). Mobile 3 ngày (menu ở 3 nơi 1; "Bình luận chờ duyệt" 1; hai màn danh sách và tắt thông báo cuộc trò chuyện 1). Kiểm thử 2 ngày.
- Phụ thuộc: không phụ thuộc mã nào chưa làm. B8 tạo trường ẩn của bình luận và mục xem bình luận ẩn mà **B7** dùng lại. Cách xếp tin nhắn vào "Tin nhắn chờ" phải thống nhất với **B1** (nhóm G2) nếu B1 đổi cấu trúc tin nhắn chờ. Cài đặt thông báo theo loại thuộc **D8**; tắt thông báo cuộc trò chuyện ở đây là một trường hợp riêng, cần thống nhất để không làm hai lần.
- Rủi ro: lộ việc bị hạn chế qua một chi tiết nhỏ trong phản hồi API (số đếm, trạng thái đã xem); xếp hộp thư theo từng người xem làm truy vấn hộp thư phức tạp hơn.

NHÓM C. KIỂM DUYỆT VÀ QUẢN TRỊ

C1. Hàng đợi kiểm duyệt (tự động quét + người duyệt)

Nhóm: Kiểm duyệt và quản trị · Giai đoạn: GĐ1 · Ước lượng: 13–15 ngày công

a) Mục đích

Hiện nay báo cáo của người dùng nằm thành một danh sách xếp theo thời gian, và bài viết, bình luận, ảnh công khai không được máy kiểm tra. Nội dung nguy hiểm (lừa đảo, xâm hại trẻ em, đe dọa bạo lực) có thể nằm trên bảng tin hàng giờ trước khi có người xem tới. Tính năng này gom hai nguồn tín hiệu (máy quét tự động và báo cáo của người dùng) vào **một hàng đợi duy nhất**, xếp theo mức nguy hiểm và có hạn xử lý (SLA, tức thời hạn tối đa từ lúc vào hàng đợi đến lúc có người quyết). Người dùng được lợi vì nội dung xấu bị ẩn sớm; người báo cáo và người đăng đều được báo kết quả; người duyệt biết việc nào cần làm trước.

b) Hiện trạng

- **Báo cáo** (*apps/api/src/modules/reports*): *POST /reports* nhận đối tượng *POST*, *COMMENT*, *USER*, *CONVERSATION* và lý do *SPAM*, *HARASSMENT*, *SENSITIVE*, *MISINFORMATION*, *SCAM*, *OTHER*. Mỗi người chỉ có một báo cáo cho một đối tượng (báo cáo lại chỉ cập nhật lý do). Báo cáo hội thoại lưu bản chụp 50 tin gần nhất; hội thoại ẩn danh bị đóng ngay và người gửi ẩn danh mất quyền gửi ẩn danh cho tới khi admin xem.
- **Chưa báo cáo được story**: app có nút báo cáo ở bài viết, bình luận, Reels, trang cá nhân và cuộc trò chuyện (*apps/mobile/src/features/report/ReportModal.tsx*), không có ở story.
- **Chưa có lý do** cho xâm hại trẻ em, bạo lực, tự hại, thù ghét, giả mạo danh tính.
- **Server không chặn tự báo cáo chính mình** và không có giới hạn riêng cho báo cáo; chỉ có trần chung 300 request mỗi phút mỗi IP (*app.module.ts*).
- **Trang quản trị** (*apps/api/src/modules/admin*, trang *admin.html*): tab Báo cáo liệt kê từng báo cáo theo trạng thái *OPEN / RESOLVED / DISMISSED*, xếp **mới nhất trước**, không có mức ưu tiên, không có SLA, không gộp các báo cáo cùng một đối tượng thành một mục. Ba hành động: *DISMISS*, *REMOVE_CONTENT* (chỉ bài viết và bình luận), *BAN_USER*. Xử lý một báo cáo thì mọi báo cáo đang mở cùng đối tượng được đóng cùng lúc; ghi *resolvedById*, *resolvedAt*.
- **Gỡ bình luận là xóa hẳn** (*comment.deleteMany*), nên không khôi phục được nếu kháng nghị thắng (C2). Gỡ bài viết là xóa mềm (*Post.deletedAt*).

- **Máy quét** (*apps/api/src/modules/moderation*): mô hình ảnh NSFW (*image-moderation.service.ts*, chạy ngay trên server, ngưỡng 0,7) **chỉ chạy cho ảnh trong tin nhắn**. Luật chữ (*text-safety.ts*) chỉ chạy cho tin nhắn ẩn danh và tin nhắn chờ. Bài viết, bình luận, story, ảnh đại diện, ảnh bìa **không được quét**.
- **Không tự ẩn** nội dung theo số báo cáo. **Không báo** cho người báo cáo hay người đăng biết kết quả. Bảng *Notification* bắt buộc có *actorId* (người gây ra thông báo), nên chưa gửi được thông báo "từ hệ thống".
- Không có hệ thống chạy việc nền (không Redis, không BullMQ, không *@nestjs/schedule*). Gửi email đã có (*nodemailer*, *modules/mail*).

c) Cách hoạt động

Luồng 1: Nội dung mới được quét tự động

1. Người dùng đăng bài, bình luận, story, hoặc đổi ảnh đại diện / ảnh bìa / tiểu sử. Máy chủ lưu và hiển thị ngay, không bắt người dùng chờ quét.
2. Máy chủ ghi một việc quét vào cơ sở dữ liệu (trạng thái "chờ quét"). Một tiến trình nền lấy việc ra lần lượt.
3. Quét chữ: chạy luật từ khóa và luật liên lạc (link, số điện thoại, số tài khoản) của *text-safety.ts* cùng danh sách từ cấm của B7. Kết quả là mã luật bị khớp và mức: không có gì / cần xem / nặng.
4. Nếu có ảnh: chạy mô hình NSFW sẵn có. Video: chấm ảnh bìa (*thumbnailUrl* đã có cho video); chấm nhiều khung hình thuộc B5.
5. Mô hình không chạy được (chưa tải, lỗi): ghi lỗi, trang quản trị hiện cảnh báo đỏ như hiện nay, và nội dung có ảnh được **đưa thẳng vào hàng đợi** để người xem.
6. Dưới ngưỡng cần duyệt: giữ nguyên, chỉ lưu kết quả quét (mã luật, mức), không lưu điểm số ảnh.
7. Vượt ngưỡng cần duyệt nhưng chưa tới ngưỡng ẩn: vào hàng đợi, nội dung vẫn hiện (ảnh có thể bị làm mờ theo B5).
8. Vượt ngưỡng ẩn ngay: nội dung bị ẩn tạm với mọi người trừ người đăng; người đăng thấy nhãn "Đang được xem xét" và nhận thông báo. Mục vào hàng đợi.

Luồng 2: Người dùng báo cáo

1. Người dùng bấm Báo cáo, chọn lý do (danh sách mới ở mục f), có thể ghi chú tối đa 500 ký tự.
2. Máy chủ kiểm tra: đối tượng còn tồn tại, không tự báo cáo chính mình, chưa vượt giới hạn báo cáo. Sai thì trả lỗi, app hiện lời nhắn ngắn.

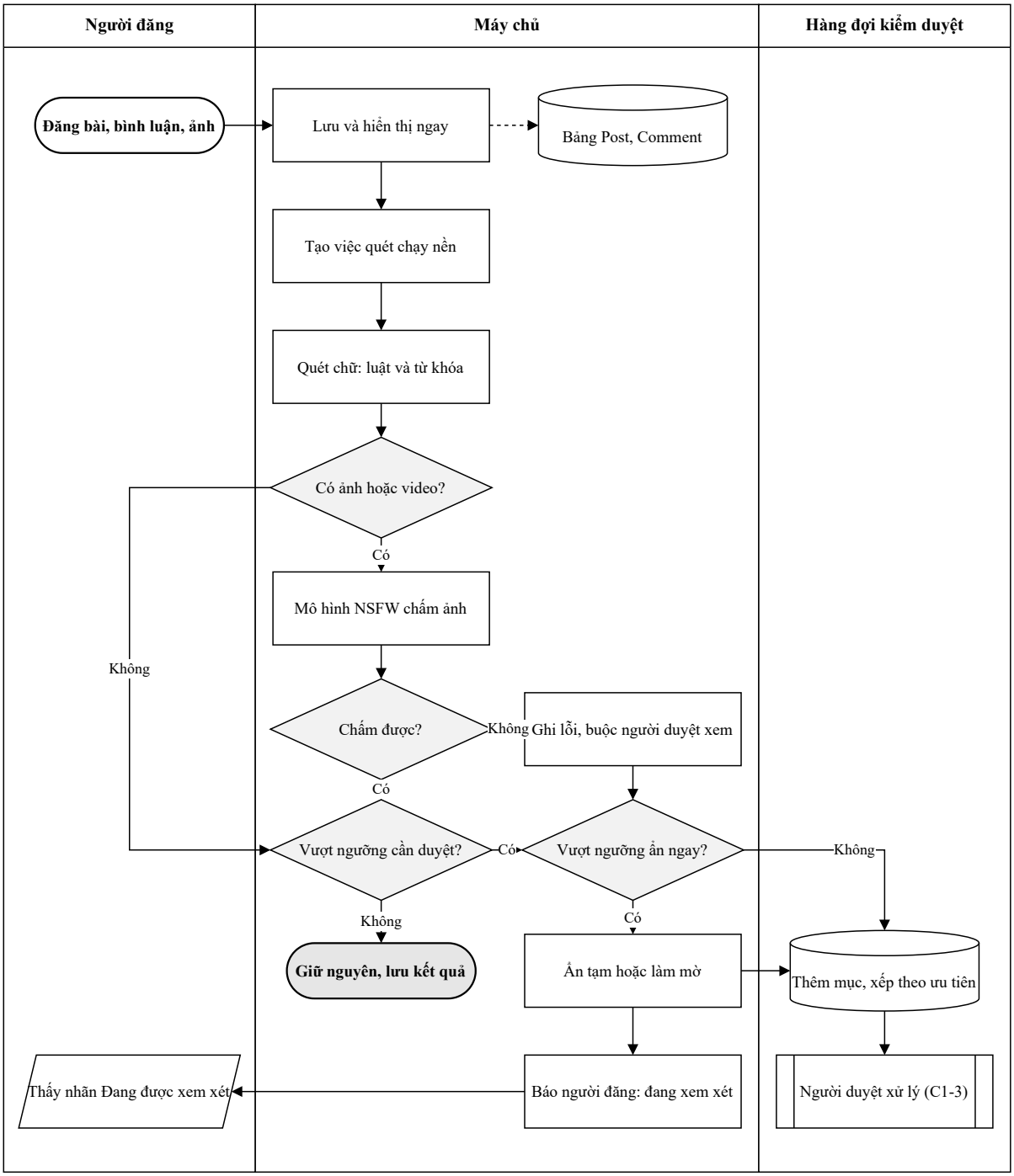
3. Lưu báo cáo. Bài viết và bình luận cũng được chụp lại nội dung lúc báo cáo (như hội thoại hiện nay), để người đăng sửa hay xóa thì bằng chứng vẫn còn.
4. Máy chủ gộp báo cáo vào **mục hàng đợi của đối tượng đó** (mỗi đối tượng một mục), tính lại mức ưu tiên và đếm số người báo cáo khác nhau.
5. Đủ ngưỡng tự ẩn (bảng ở mục e): ẩn tạm và báo người đăng "Đang được xem xét".
6. App hiện "Cảm ơn, chúng tôi đã nhận báo cáo" và gợi ý chặn hoặc tắt tiếng người kia (B8). Người báo cáo xem trạng thái ở mục "Báo cáo của bạn" trong Cài đặt.
7. Báo cáo hội thoại ẩn danh giữ nguyên hành vi hiện có (đóng ngay, tước quyền gửi ẩn danh) và vào hàng đợi mức P1.

Luồng 3: Người duyệt xử lý một mục

1. Kiểm duyệt viên mở tab Hàng đợi. Máy chủ giao mục có ưu tiên cao nhất, trong cùng mức thì mục sắp quá hạn trước, và giữ mục đó cho người này 15 phút để hai người không xử lý trùng.
2. Màn hình hiện: nội dung (ảnh bị làm mờ cho tới khi bấm), mọi báo cáo và lý do, kết quả máy quét, lịch sử vi phạm của người đăng (số điểm cảnh cáo C2), các lần xử lý trước đó.
3. Chưa đủ chắc: bấm "Chuyển lên quản trị viên". Mục chuyển sang trạng thái chờ quản trị viên, giữ nguyên hạn SLA.
4. Không vi phạm: bấm "Bỏ qua". Nội dung đang bị ẩn tạm thì hiện lại; các báo cáo đóng với trạng thái "không vi phạm".
5. Có vi phạm: chọn hành động (gỡ nội dung, đánh dấu nhạy cảm/làm mờ, hoặc khóa tài khoản) và chọn **điều khoản bị vi phạm** trong danh sách cố định. Máy chủ thực hiện, rồi gọi C2 để cộng điểm cảnh cáo.
6. Máy chủ đóng mọi báo cáo cùng đối tượng, ghi nhật ký thao tác (C3), và gửi thông báo:
    - Người báo cáo: "Chúng tôi đã xem báo cáo của bạn. Nội dung đã bị gỡ" hoặc "không vi phạm tiêu chuẩn cộng đồng". Không nói người kia bị phạt thế nào.
    - Người đăng (chỉ khi có xử lý): nội dung nào, vi phạm điều khoản nào, hậu quả, nút "Kháng nghị" (C2).

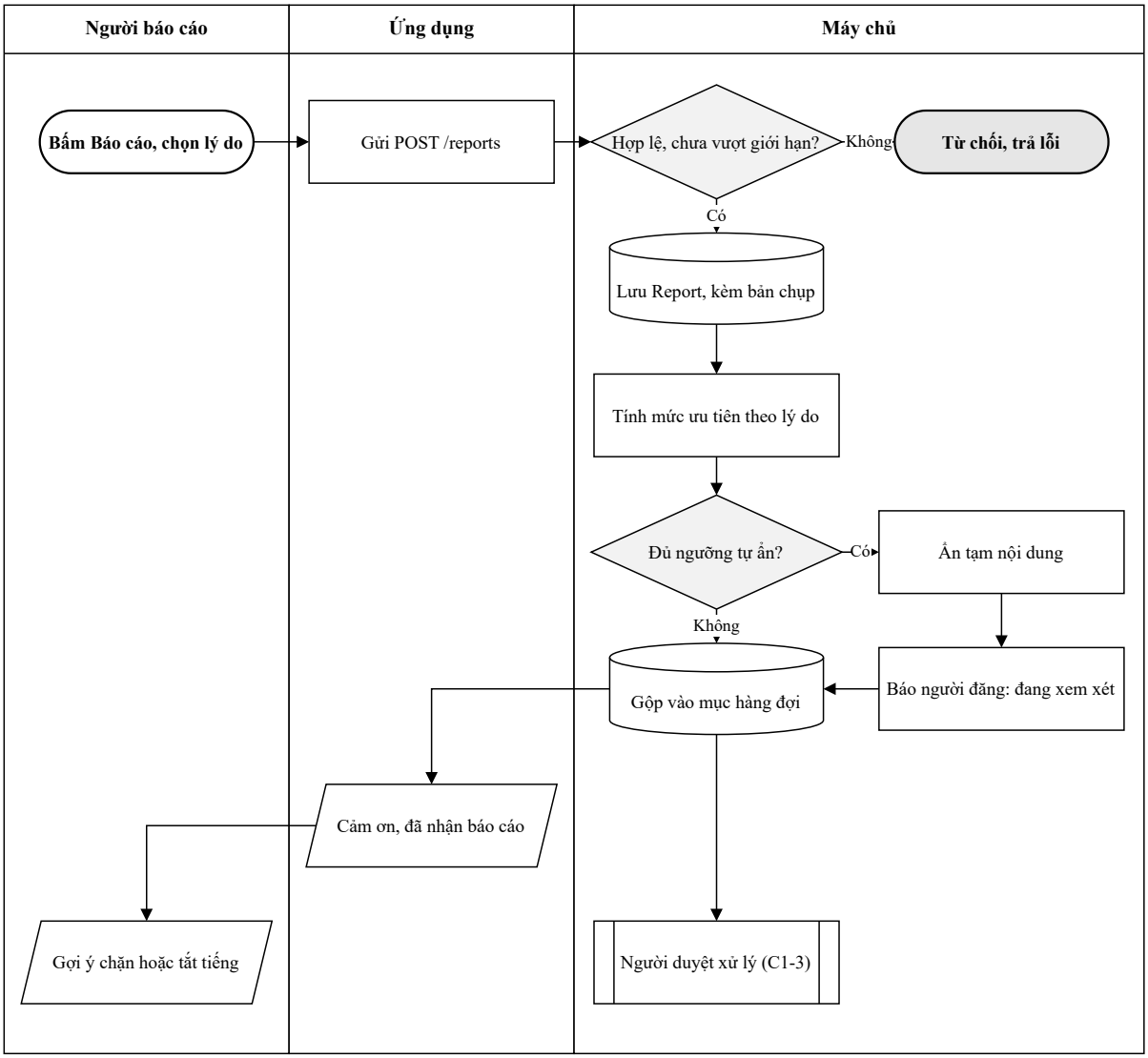
d) Flowchart

Sơ đồ C1-1: nội dung mới đi qua máy quét tự động.



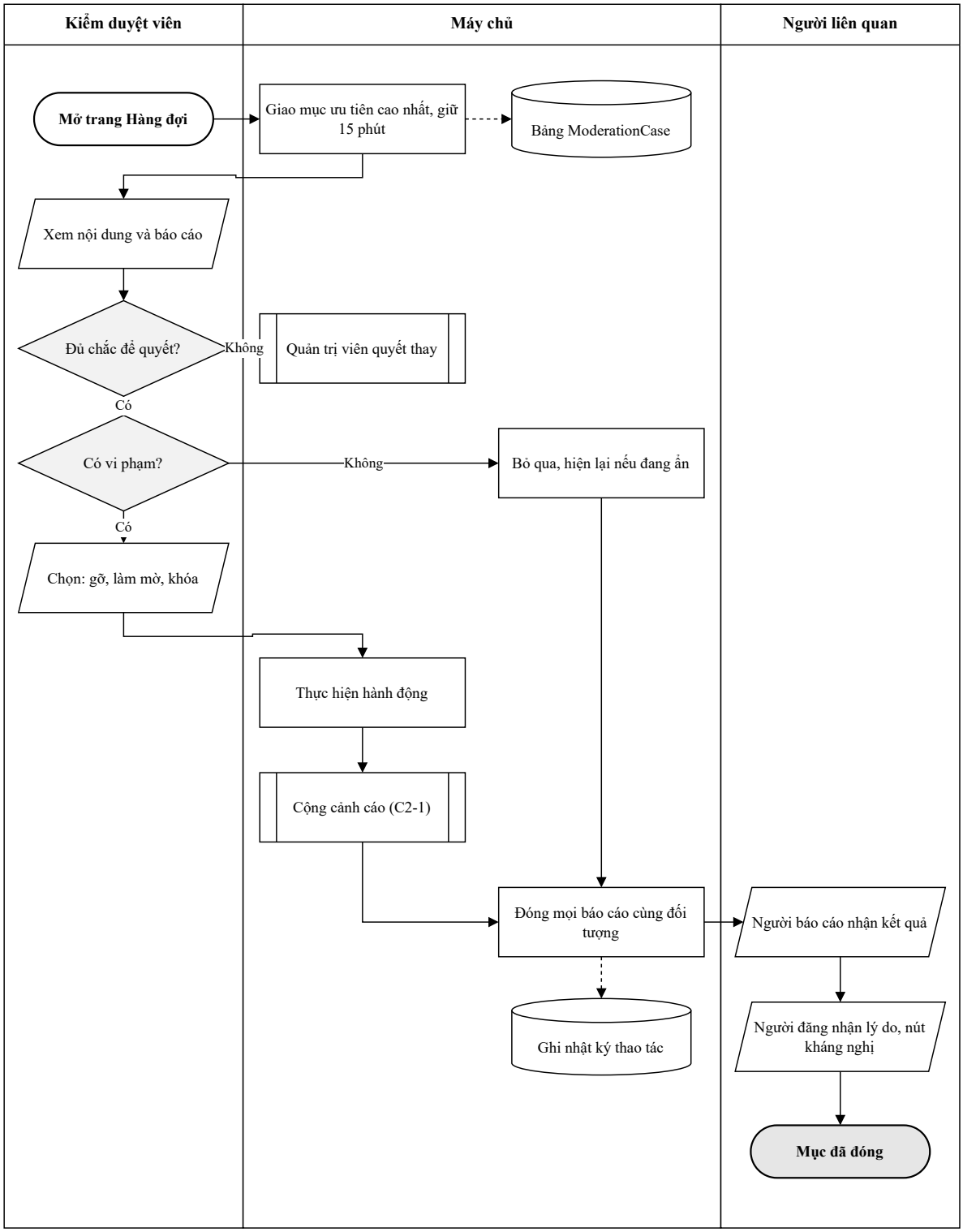
Hình 37. Nội dung mới được quét tự động và đưa vào hàng đợi

Sơ đồ C1-2: báo cáo của người dùng và ngưỡng tự ẩn.



Hình 38. Người dùng báo cáo và ngưỡng tự ẩn

Sơ đồ C1-3: người duyệt xử lý một mục.



Hình 39. Người duyệt xử lý một mục trong hàng đợi

e) Quy tắc, giới hạn và trường hợp đặc biệt

Mức ưu tiên và SLA (đề xuất)

Mức	Loại	SLA	Tự ẩn khi

P0	Xâm hại trẻ em (*CHILD_SAFETY*), nguy cơ tự hại (*SELF_HARM*), đe dọa giết người hoặc khủng bố	1 giờ	1 báo cáo hợp lệ (xâm hại trẻ em, đe dọa). Tự hại: không ẩn, app hiện thông tin đường dây hỗ trợ cho người đăng
P1	Lừa đảo (*SCAM*), bạo lực (*VIOLENCE*), báo cáo hội thoại ẩn danh	4 giờ	3 người khác nhau trong 24 giờ
P2	Quấy rối, thù ghét, khỏa thân/nhạy cảm, giả mạo danh tính; nội dung máy quét đánh giá "nặng"	24 giờ	5 người khác nhau trong 24 giờ, hoặc máy quét đánh giá "nặng" (ảnh NSFW từ 0,9)
P3	Spam, thông tin sai lệch, lý do khác; máy quét đánh giá "cần xem"	72 giờ	Không tự ẩn

- **Nâng mức**: mục có từ 10 người báo cáo khác nhau được nâng một mức. Mục có nhiều lý do lấy lý do có mức cao nhất.
- **Quá hạn SLA**: mục quá hạn nổi lên đầu hàng đợi và tô đỏ. Mục P0 quá hạn 30 phút thì gửi email cho mọi quản trị viên.
- **Báo cáo được tính vào ngưỡng tự ẩn** chỉ khi tài khoản báo cáo từ 7 ngày tuổi, đã xác thực email, và chưa có từ 3 báo cáo bị kết luận "không vi phạm" trong 30 ngày. Báo cáo không đủ điều kiện vẫn vào hàng đợi, chỉ không đẩy việc tự ẩn. Mục đích: chống nhóm người hùa nhau báo cáo để ẩn bài của người khác.
- **Không tự ẩn tài khoản** (đối tượng *USER*). Khóa tài khoản luôn do người quyết, trừ cơ chế ẩn danh đã có.
- **Giới hạn báo cáo**: 20 báo cáo mỗi giờ mỗi người (đề xuất). Không báo cáo được chính mình. Báo cáo lại cùng đối tượng chỉ cập nhật lý do, không đếm thêm (giữ như hiện nay).
- **Người đăng tự xóa nội dung khi đang chờ duyệt**: mục vẫn mở, người duyệt xem bản chụp; vẫn có thể cộng cảnh cáo.
- **Người đăng đã bị khóa**: mục vẫn xử lý để ra kết luận cho người báo cáo.
- **Báo cáo sau khi mục đã đóng**: mục mở lại nếu có lý do mức cao hơn kết luận cũ, hoặc thêm 5 người khác nhau báo cáo. Nếu không, báo cáo được ghi nhận và đóng ngay với kết luận cũ.
- **Lỗi mạng khi báo cáo**: app cho gửi lại; server dùng upsert nên gửi lại không tạo bản ghi trùng (đã đúng ở code hiện tại).
- **Ảnh nghi xâm hại trẻ em**: mô hình NSFW không phát hiện đáng tin loại này (*MODERATION_PLAN.md*, mục 4). Báo cáo *CHILD_SAFETY* được ẩn ngay; người duyệt không tải ảnh về, không chuyển tiếp; quy trình báo cơ quan chức

năng do người vận hành quyết, **cần luật sư xác nhận**. Công cụ đối chiếu ảnh đã biết (ví dụ PhotoDNA) cần xin cấp quyền riêng, không nằm trong ước lượng này.

- **Yêu cầu gỡ từ cơ quan chức năng** (Nghị định 147/2024 đặt thời hạn gỡ khi có yêu cầu; con số cụ thể **cần luật sư xác nhận**): quản trị viên tạo mục thủ công mức P0.
- **Sức khỏe người duyệt**: ảnh và video mặc định bị làm mờ và đen trắng trong trang quản trị cho tới khi bấm xem.
- **Máy quét chậm**: mỗi ảnh mất khoảng 0,5–0,7 giây trên CPU. Hàng việc quét tồn quá 1.000 việc thì trang quản trị hiện cảnh báo.

f) Dữ liệu và API (đề xuất)

Toàn bộ mục này là đề xuất, cần đưa vào *docs/api-contract.md* và thống nhất trước khi code. Các route cũ *GET /admin/reports* và *POST /admin/reports/:id/resolve* giữ chạy trong thời gian chuyển đổi.

Thay đổi	**Nội dung**
Bảng mới *ModerationCase*	*id, targetType, targetId, ownerId* (người đăng), *status* (*OPEN* | *ESCALATED* | *RESOLVED* | *DISMISSED*), *priority* (0–3), *category*, *source* (*SCAN* | *REPORT* | *BOTH* | *MANUAL*), *autoHidden*, *reporterCount*, *dueAt* (hạn SLA), *assigneeId*, *lockedUntil*, *decision*, *policyCode* (điều khoản vi phạm), *decisionNote*, *resolvedById*, *resolvedAt*, *createdAt*. Duy nhất theo (*targetType, targetId*). Chỉ mục theo (*status, priority, dueAt*).
Bảng mới *ScanJob*	*id, targetType, targetId, status* (*PENDING* | *DONE* | *FAILED*), *attempts*, *verdict* (*CLEAN* | *REVIEW* | *HIDE*), *ruleCodes* (mảng mã luật), *createdAt, doneAt*. Không lưu điểm số ảnh.
Report	Thêm *caseId*; *snapshot* dùng cho cả bài viết và bình luận; thêm *counted* (báo cáo có được tính vào ngưỡng tự ẩn không). Sửa chú thích *targetType* trong schema (hiện ghi thiếu *CONVERSATION*).
Post, *Comment*, *Story*	Thêm *hiddenAt* (ẩn tạm chờ duyệt) và *removedAt* (bị gỡ do vi phạm). Bình luận chuyển sang xóa mềm khi admin gỡ, để khôi phục được khi kháng nghị thắng. Trường "nhạy cảm" cho bài viết thuộc B5, dùng chung tên trường.
Notification	Thêm loại *REPORT_RESULT*, *CONTENT_UNDER_REVIEW*, *CONTENT_REMOVED*; *actorId* cho phép rỗng (thông báo từ hệ thống). Phối hợp với D8.

Endpoint	**Mô tả**

POST /reports	Thêm *targetType: STORY*; thêm lý do *CHILD_SAFETY, SELF_HARM, VIOLENCE, HATE, NUDITY, IMPERSONATION*. Lỗi mới: *CANNOT_REPORT_SELF*, *REPORT_LIMIT* (429).
GET /reports/mine	Người báo cáo xem báo cáo của mình: đối tượng, lý do, trạng thái (*Đang xem xét / Đã gỡ / Không vi phạm*).
GET /admin/queue? status=&priority=&category=&page=	Danh sách mục, xếp theo ưu tiên rồi *dueAt*; mỗi mục có số báo cáo, lý do, kết quả quét, hạn SLA.
POST /admin/queue/next	Nhận mục tiếp theo và giữ 15 phút.
POST /admin/cases/:id/release	Trả mục về hàng đợi.
POST /admin/cases/:id/decision	*{ action: DISMISS | REMOVE | MARK_SENSITIVE | BAN_USER | ESCALATE, policyCode, severity, note }*. Từ chối nếu mục đang được người khác giữ.
GET /admin/stats	Thêm số mục mở theo mức, số mục quá hạn, số việc quét đang tồn.

Tiến trình quét chạy trong chính tiến trình API, lấy việc từ bảng *ScanJob* mỗi vài giây. Đây là cách làm tạm cho một máy chủ; khi chạy nhiều bản API cần khóa hàng (*SELECT ... FOR UPDATE SKIP LOCKED*) hoặc chuyển sang hàng đợi Redis. Thêm thư viện lập lịch hay Redis là quyết định kiến trúc, phải ghi vào *docs/decisions.md*.

g) Android, iOS và web

- Trang quản trị là web (*admin.html* do API phục vụ), không phụ thuộc nền tảng di động.
- App: thêm lý do báo cáo mới và nút báo cáo story; nhãn "Đang được xem xét" trên bài của chính mình; màn hình "Báo cáo của bạn" trong Cài đặt; xử lý ba loại thông báo mới. Toàn bộ là giao diện React Native thường, chạy giống nhau trên Android và iOS, không cần quyền thiết bị mới, không cần thư viện mới.
- Thông báo đẩy dùng hạ tầng hiện có (FCM cho Android, APNs cho iOS); D8 phải chạy được trên cả hai thì C1 mới báo đẩy được.
- **Yêu cầu cửa hàng**: App Store (Guideline 1.2) và Google Play yêu cầu app có nội dung người dùng tạo phải có cách báo cáo, cách chặn, và xử lý báo cáo kịp thời. C1 đáp ứng phần "xử lý kịp thời"; nên ghi SLA vào phần ghi chú khi nộp duyệt.

- Chi phí: máy quét chạy trên CPU của máy chủ, không tốn phí dịch vụ ngoài. Ước tính 5.000 ảnh mỗi ngày chiếm khoảng 1 giờ CPU mỗi ngày.

h) Tiêu chí hoàn thành

- Bài viết có ảnh NSFW điểm cao bị ẩn tạm trong 1 phút sau khi đăng, người đăng thấy nhãn "Đang được xem xét", mục xuất hiện trong hàng đợi mức P2.
- Tắt mô hình ảnh: bài có ảnh vẫn đăng được và vào hàng đợi; trang quản trị hiện cảnh báo.
- 3 tài khoản đủ điều kiện báo cáo lừa đảo cùng một bài trong 24 giờ: bài bị ẩn tạm. 3 tài khoản mới tạo hôm nay: bài không bị ẩn nhưng vẫn vào hàng đợi.
- Hàng đợi xếp đúng P0 trước P3, trong cùng mức mục sắp quá hạn trước; hai người duyệt mở cùng lúc không nhận cùng một mục.
- Bỏ qua một mục đang ẩn: nội dung hiện lại. Gỡ một bình luận: bình luận bị ẩn mềm, khôi phục được.
- Người báo cáo và người đăng nhận đúng thông báo; người báo cáo không thấy hình phạt của người kia.
- Không tự báo cáo được chính mình; báo cáo thứ 21 trong một giờ bị từ chối.
- Báo cáo story và các lý do mới chạy trên Android và iPhone (ghi rõ thiết bị đã chạy trong *docs/change.md*).
- Bổ sung phép thử vào *apps/api/scripts/safety-smoke.cjs* cho ngưỡng tự ẩn, thứ tự hàng đợi, khóa mục 15 phút.

i) Ước lượng và phụ thuộc

- Backend 8 ngày (bảng mới, tiến trình quét, gộp báo cáo, ngưỡng tự ẩn, ẩn nội dung ở bảng tin/trang cá nhân/tìm kiếm, API hàng đợi), trang quản trị 2 ngày (tính trong backend vì là *admin.html*), mobile 3 ngày, kiểm thử 2 ngày.
- Phụ thuộc: B5 (làm mờ và trường nhạy cảm cho bài viết, chấm nhiều khung hình video), B7 (danh sách từ cấm cho bình luận), B3 (luật lừa đảo), D8 (thông báo đẩy và loại thông báo hệ thống), C3 (nhật ký thao tác; nếu C3 làm sau, C1 ghi tạm vào *ModerationCase*). C2 dùng kết quả của C1.
- Rủi ro: ẩn nhầm do người dùng hùa nhau báo cáo (giảm bằng điều kiện tài khoản báo cáo); mô hình ảnh chặt tay nên hàng đợi P2 có thể đông; không đủ người duyệt để giữ SLA P0 1 giờ ngoài giờ hành chính. Đội ngũ trực là quyết định vận hành của chủ dự án.

C2. Cảnh cáo, xử phạt theo bậc và kháng nghị

Nhóm: Kiểm duyệt và quản trị · Giai đoạn: GĐ2 · Ước lượng: 11–12 ngày công

a) Mục đích

Hiện tại quản trị viên chỉ có hai lựa chọn với một người vi phạm: không làm gì, hoặc khóa hẳn tài khoản. Với vi phạm nhẹ thì khóa hẳn là quá tay, còn không làm gì thì người đó tái phạm. Tính năng này đưa vào **điểm cảnh cáo** (strike) có thời hạn và **các bậc xử phạt tăng dần**: cảnh cáo, hạn chế tính năng, tạm khóa, khóa vĩnh viễn. Người bị xử lý luôn được báo lý do và có quyền **kháng nghị** một lần với một người duyệt khác. Người dùng thường được đối xử công bằng hơn; người tái phạm bị xử nặng dần một cách nhất quán.

b) Hiện trạng

- **Khóa tài khoản** (*apps/api/src/modules/admin/admin.service.ts*, *setBanned*): chỉ có cột *User.bannedAt*, khóa vô thời hạn cho tới khi admin mở. Không lưu lý do, không lưu ai khóa (tham số *adminId* chỉ dùng để chặn tự khóa mình). Quản trị viên không bị khóa được.
- **Thực thi khóa**: danh sách id bị khóa nằm trong bộ nhớ một tiến trình API (*apps/api/src/modules/auth/ban-list.ts*), nạp lúc khởi động. *JwtStrategy* và đăng nhập (*auth.service.ts*) trả *401 ACCOUNT_BANNED* "This account has been suspended". Token đăng nhập sống 30 ngày (*auth.module.ts*).
- **App**: không có xử lý riêng cho *ACCOUNT_BANNED*; lỗi 401 xóa token, màn đăng nhập hiện nguyên câu tiếng Anh từ server (*useAuthSubmission.ts*). Người bị khóa không biết lý do, không có nút kháng nghị.
- **Hạn chế một tính năng** chỉ có một trường hợp: tước quyền gửi tin ẩn danh (*User.anonymousSuspendedAt*), tự động khi bị báo cáo hội thoại ẩn danh, admin trả lại bằng tay. Đây là tiền lệ cho "hạn chế tính năng".
- **Khóa vì tuổi** (*ageLockedAt*) là cơ chế riêng, không phải xử phạt; kháng nghị khóa tuổi thuộc B6.
- **Chưa có**: điểm cảnh cáo, thời hạn xử phạt, tạm khóa có ngày hết hạn, thông báo lý do, kháng nghị, đảo ngược quyết định có ghi lại.

c) Cách hoạt động

Luồng 1: Cộng cảnh cáo và áp bậc phạt

1. Người duyệt kết luận có vi phạm trong hàng đợi (C1-3) và chọn điều khoản bị vi phạm. Mỗi điều khoản có sẵn mức nặng và số điểm (bảng ở mục e).

2. Máy chủ tạo một cảnh cáo: điều khoản, lý do hiển thị cho người dùng, số điểm, ngày hết hiệu lực (90 ngày sau).
3. Vi phạm cực nặng (xâm hại trẻ em, khủng bố, buôn người, tài khoản lập ra để lách khóa): máy chủ không tự tính bậc mà tạm khóa ngay và đưa đề xuất khóa vĩnh viễn cho quản trị viên xác nhận. Người dùng nhận email báo khóa và cách kháng nghị.
4. Trường hợp còn lại: máy chủ cộng tổng điểm còn hiệu lực và chọn bậc:
    - 1–2 điểm: chỉ cảnh cáo.
    - 3–5 điểm: hạn chế tính năng 7 ngày (tính năng bị lạm dụng, ví dụ bình luận hoặc nhắn tin cho người lạ).
    - Từ 6 điểm: tạm khóa tài khoản (lần đầu 7 ngày, lần hai 30 ngày) và đăng xuất mọi thiết bị. Lần tạm khóa thứ ba trong 365 ngày thì đề xuất khóa vĩnh viễn.
5. Máy chủ ghi hình phạt kèm ngày hết hạn, ghi nhật ký thao tác (C3).
6. Gửi thông báo trong app và email: nội dung nào, điều khoản nào, bậc phạt, đến khi nào, tổng điểm hiện tại, nút "Kháng nghị".
7. Lần mở app kế tiếp, người dùng thấy một màn hình cảnh cáo phải bấm "Tôi đã hiểu" mới đi tiếp. Mục "Tình trạng tài khoản" trong Cài đặt luôn liệt kê cảnh cáo còn hiệu lực và ngày hết hạn.

Luồng 2: Khi đang bị hạn chế hoặc tạm khóa

1. Bị hạn chế: người dùng vẫn đọc, xem, nhắn tin trong hội thoại đã có. Khi bấm vào tính năng bị hạn chế (ví dụ ô bình luận), app hiện "Bạn đang bị hạn chế bình luận đến 14:00 ngày 12/11" và nút xem lý do. Máy chủ cũng tự từ chối (*403 FEATURE_RESTRICTED*), không dựa vào app.
2. Bị tạm khóa: đăng nhập trả lỗi riêng kèm ngày mở lại và lý do. App hiện màn hình "Tài khoản tạm khóa đến …" có nút "Kháng nghị". Server cấp một mã ngắn hạn chỉ đủ quyền xem tình trạng và gửi kháng nghị.
3. Hết hạn: hình phạt tự gỡ, không cần ai làm gì. Máy chủ so ngày hết hạn ngay lúc kiểm tra, nên không phụ thuộc tác vụ định kỳ. Người dùng nhận thông báo "Tài khoản đã hoạt động lại".
4. Điểm cảnh cáo hết hiệu lực sau 90 ngày thì không còn tính vào tổng, nhưng bản ghi vẫn giữ cho nhân viên xem lịch sử.

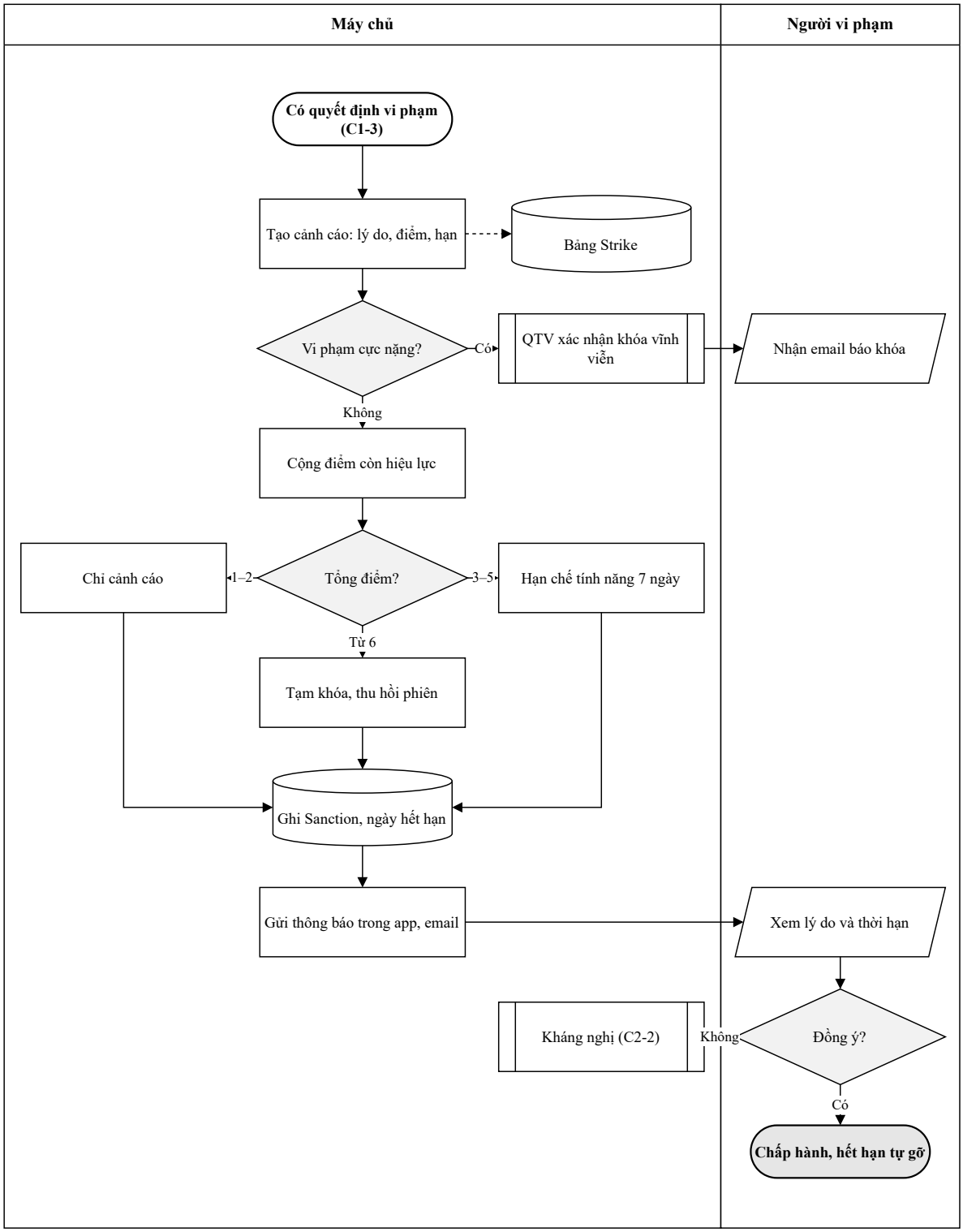
Luồng 3: Kháng nghị

1. Người dùng bấm "Kháng nghị" từ thông báo, từ Tình trạng tài khoản, hoặc từ màn hình tạm khóa. Nhập lý do (tối đa 1.000 ký tự).

2. Máy chủ kiểm tra: quyết định thuộc về người này, còn trong 30 ngày, chưa kháng nghị lần nào. Sai thì app báo "Không thể kháng nghị quyết định này" và lý do.
3. Lưu kháng nghị ở trạng thái "Chờ xem xét". Hình phạt **vẫn áp dụng** trong lúc chờ.
4. Máy chủ giao cho một người duyệt **khác** người đã ra quyết định. Kháng nghị khóa vĩnh viễn chỉ quản trị viên xử lý.
5. Người duyệt thứ hai xem quyết định cũ, bằng chứng (bản chụp nội dung) và lý do kháng nghị, rồi chọn:
   - **Giữ nguyên**: không đổi gì.
   - **Đảo ngược**: thu hồi cảnh cáo, gỡ hình phạt (mở khóa ngay), khôi phục nội dung bị gỡ.
   - **Giảm bậc**: hạ mức nặng hoặc rút ngắn thời hạn.
6. Máy chủ ghi kết quả và nhật ký, gửi thông báo kết quả kèm lý do. Kết quả kháng nghị là quyết định cuối cùng.

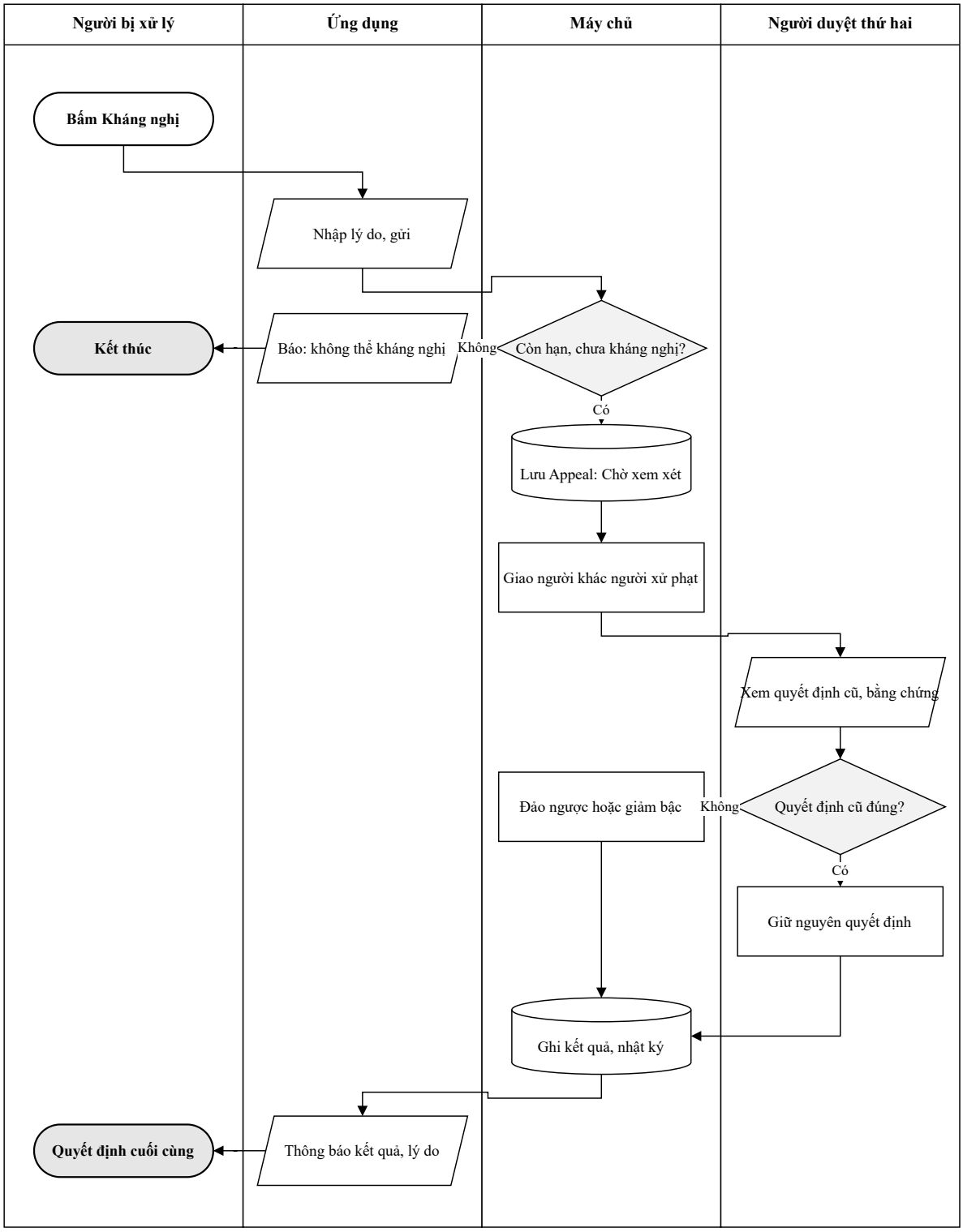
d) Flowchart

Sơ đồ C2-1: cộng cảnh cáo và áp bậc xử phạt.



Hình 40. Cộng cảnh cáo và áp bậc xử phạt

Sơ đồ C2-2: kháng nghị với người duyệt thứ hai.



Hình 41. Kháng nghị với người duyệt thứ hai

e) Quy tắc, giới hạn và trường hợp đặc biệt

Mức nặng và số điểm (đề xuất, chủ dự án duyệt danh sách điều khoản)

Mức	Ví dụ	Điểm

Nhẹ	Spam, ngôn từ thô tục, thông tin sai lệch không gây hại trực tiếp	1
Vừa	Quấy rối, bắt nạt, nội dung nhạy cảm không đánh dấu, giả mạo người khác	2
Nặng	Lừa đảo, đe dọa bạo lực, đăng ảnh riêng tư của người khác, kích động thù ghét	3
Cực nặng	Xâm hại trẻ em, khủng bố, buôn người, lách khóa bằng tài khoản khác	Tạm khóa ngay, đề xuất khóa vĩnh viễn

Bậc xử phạt theo tổng điểm còn hiệu lực (đề xuất)

Tổng điểm	**Bậc**	**Thời hạn**
1–2	Cảnh cáo	Không hạn chế
3–5	Hạn chế tính năng bị lạm dụng (đăng bài, story, bình luận, nhắn người lạ, gửi ẩn danh)	7 ngày
Từ 6	Tạm khóa tài khoản	Lần 1: 7 ngày; lần 2: 30 ngày
Lần tạm khóa thứ 3 trong 365 ngày, hoặc cực nặng	Khóa vĩnh viễn (quản trị viên xác nhận)	Vô thời hạn

- **Một nội dung chỉ bị phạt một lần**, dù có bao nhiêu báo cáo.
- **Gộp vi phạm nhẹ**: nhiều vi phạm nhẹ cùng loại trong 24 giờ (ví dụ 10 bình luận spam được duyệt cùng lúc) tính là một cảnh cáo.
- **Điểm hết hiệu lực** sau 90 ngày. Bản ghi giữ 2 năm cho nhân viên (thời hạn lưu **cần luật sư xác nhận**).
- **Kháng nghị**: trong 30 ngày, một lần cho mỗi quyết định, lý do 20–1.000 ký tự. SLA xử lý: 48 giờ với tạm khóa, 72 giờ với các loại khác (đề xuất). Kháng nghị quá hạn hiện đỏ trong trang quản trị.
- **Người duyệt kháng nghị** phải khác người ra quyết định. Đội chỉ có một người thì quản trị viên phải tự xử lý và nhật ký ghi rõ "cùng người"; đây là điểm chủ dự án cần quyết.
- **Đảo ngược** phải khôi phục đủ: xóa cảnh cáo (đánh dấu thu hồi, không xóa bản ghi), gỡ hình phạt, hiện lại nội dung, trả quyền gửi ẩn danh nếu bị tước cùng lúc. Người báo cáo không được báo khi quyết định bị đảo ngược.
- **Quản trị viên và kiểm duyệt viên** không bị cộng cảnh cáo bởi người cùng cấp hoặc thấp hơn (giữ quy tắc hiện tại "Administrators cannot be banned", mở rộng theo C3).

- **Tạo tài khoản mới để lách khóa**: là vi phạm cực nặng. Phát hiện tài khoản phụ (cùng thiết bị, cùng email gốc) là việc riêng, chưa nằm trong ước lượng này (*MODERATION_PLAN.md*, mục 8.8).
- **Nhiều bản API**: danh sách khóa trong bộ nhớ hiện tại phải thêm ngày hết hạn; khi chạy nhiều bản API phải chuyển sang Redis hoặc kiểm tra database (hạn chế đã ghi trong *ban-list.ts*).
- **Đang tạm khóa thì không mở hội thoại, không đăng**; nội dung đã đăng vẫn hiện, trừ khi khóa vĩnh viễn (khi đó bài viết và trang cá nhân bị ẩn với người khác).
- **Email không tới được** (địa chỉ cũ): thông báo vẫn nằm trong app và hiện ở lần đăng nhập kế tiếp.

f) Dữ liệu và API (đề xuất)

Toàn bộ mục này là đề xuất, cần đưa vào *docs/api-contract.md* trước khi code.

Thay đổi	**Nội dung**
Bảng mới *Strike*	*id, userId, caseId* (mục C1), *policyCode, severity* (*MINOR* | *MODERATE* | *SEVERE* | *EXTREME*), *points, userReason* (lời giải thích cho người dùng), *createdById, createdAt, expiresAt, revokedAt, revokedById, revokeReason*.
Bảng mới *Sanction*	*id, userId, strikeId, type* (*WARNING* | *RESTRICT* | *SUSPEND* | *BAN*), *features* (mảng: *POST, STORY, COMMENT, MESSAGE_REQUEST, ANONYMOUS*), *startsAt, endsAt* (rỗng = vô thời hạn), *acknowledgedAt* (người dùng đã bấm "Tôi đã hiểu"), *liftedAt, liftedById, createdById*.
Bảng mới *Appeal*	*id, userId, sanctionId* hoặc *strikeId, reason, status* (*PENDING* | *UPHELD* | *REVERSED* | *REDUCED*), *assigneeId, dueAt, decidedById, decidedAt, decisionNote, createdAt*. Duy nhất theo quyết định bị kháng nghị.
User	Thêm *suspendedUntil*. Giữ *bannedAt* cho khóa vĩnh viễn để không đổi hành vi hiện tại. *anonymousSuspendedAt* giữ nguyên, được đặt cùng lúc khi hình phạt có *ANONYMOUS*.

Endpoint	**Mô tả**
POST /auth/login (thay đổi lỗi)	Tạm khóa: *401 { code: ACCOUNT_SUSPENDED, until, reason, appealToken }*. Khóa vĩnh viễn: *ACCOUNT_BANNED* như hiện tại, thêm *reason* và *appealToken*. *appealToken* sống 15 phút, chỉ gọi được hai route dưới.
GET /users/me/standing	Tổng điểm, cảnh cáo còn hiệu lực, hình phạt đang áp dụng, kháng nghị.

POST /appeals	*{ sanctionId | strikeId, reason }*. Lỗi: *APPEAL_WINDOW_CLOSED*, *APPEAL_EXISTS*.
POST /users/me/sanctions/:id/ack	Đánh dấu đã đọc màn hình cảnh cáo.
Route ghi nội dung (bài, story, bình luận, tin nhắn)	Trả *403 { code: FEATURE_RESTRICTED, feature, until }* khi đang bị hạn chế.
GET /admin/appeals?status=, *POST /admin/appeals/:id/decision*	*{ outcome: UPHOLD | REVERSE | REDUCE, note, points?, endsAt? }*. Từ chối nếu người gọi là người ra quyết định cũ.
POST /admin/users/:id/strikes, *DELETE /admin/strikes/:id*	Cộng cảnh cáo bằng tay (ngoài hàng đợi), thu hồi cảnh cáo kèm lý do.
POST /admin/users/:id/ban (thay đổi)	Bắt buộc *reason*; chỉ quản trị viên; tạo *Sanction* loại *BAN*.

g) Android, iOS và web

- App thêm: màn hình cảnh cáo bắt buộc đọc, mục "Tình trạng tài khoản" trong Cài đặt, thông báo hạn chế ở ô soạn bài/bình luận/tin nhắn, màn hình tạm khóa ở bước đăng nhập, form kháng nghị. Tất cả là giao diện React Native thường, chạy giống nhau trên Android và iOS. Form kháng nghị dùng *KeyboardAvoidingView* với hành vi riêng cho từng nền tảng như các form hiện có.
- Không cần quyền thiết bị mới, không cần thư viện mới.
- Thông báo đẩy dùng FCM (Android) và APNs (iOS) qua D8. Người bị tạm khóa không nhận đẩy được (đã đăng xuất) nên phải có email; email dùng *nodemailer* sẵn có, không thêm chi phí ngoài nhà cung cấp SMTP hiện dùng.
- Trang quản trị (web): tab Kháng nghị, lịch sử cảnh cáo trong chi tiết người dùng.

h) Tiêu chí hoàn thành

- Ba vi phạm vừa liên tiếp (6 điểm) dẫn tới tạm khóa 7 ngày; đăng nhập hiện đúng ngày mở lại và lý do bằng tiếng Việt.
- Đổi ngày hết hạn về quá khứ trong cơ sở dữ liệu: tài khoản dùng lại được ngay ở request kế tiếp, không cần khởi động lại API.
- Bị hạn chế bình luận: app báo rõ, gọi thẳng API cũng bị từ chối *FEATURE_RESTRICTED*; nhắn tin trong hội thoại cũ vẫn được.
- Điểm quá 90 ngày không còn tính vào tổng.
- Kháng nghị lần hai cùng quyết định bị từ chối; người ra quyết định cũ không xử lý được kháng nghị đó.

- Đảo ngược: nội dung hiện lại, cảnh cáo bị đánh dấu thu hồi, tài khoản mở khóa ngay.
- Người bị tạm khóa gửi được kháng nghị từ màn hình đăng nhập trên Android và trên iPhone (ghi rõ thiết bị đã chạy trong *docs/change.md*).
- Phép thử tự động trong *safety-smoke.cjs* cho tính bậc, hết hạn, kháng nghị.

i) Ước lượng và phụ thuộc

- Backend 6 ngày (bảng mới, tính bậc, kiểm tra hạn chế ở các route ghi, đổi lỗi đăng nhập, mã kháng nghị, trang quản trị), mobile 4 ngày, kiểm thử 2 ngày.
- Phụ thuộc: C1 (quyết định vi phạm và điều khoản), C3 (nhật ký thao tác, vai trò được tạm khóa / khóa vĩnh viễn), A2 (thu hồi phiên trên mọi thiết bị khi tạm khóa; trước khi có A2 thì dựa vào danh sách khóa trong bộ nhớ như hiện nay), D8 (thông báo hệ thống).
- Rủi ro: danh sách điều khoản và số điểm là quyết định chính sách, sai thì phạt quá tay hoặc quá nhẹ; đội nhỏ khó đảm bảo "người duyệt thứ hai"; kháng nghị bị dùng để spam (giới hạn một lần mỗi quyết định).

C3. Phân quyền quản trị (admin / kiểm duyệt viên) và nhật ký thao tác

Nhóm: Kiểm duyệt và quản trị · Giai đoạn: GĐ3 · Ước lượng: 8–9 ngày công

a) Mục đích

Hiện chỉ có một loại nhân viên là quản trị viên, và ai có quyền này thì làm được mọi việc, kể cả xem danh tính thật của người gửi ẩn danh, mà không để lại dấu vết. Khi đội có thêm người kiểm duyệt hoặc người hỗ trợ khách hàng, cần chia quyền: mỗi người chỉ làm được phần việc của mình. Mọi thao tác của nhân viên, nhất là việc xem dữ liệu nhạy cảm, phải được ghi vào **nhật ký thao tác** (audit log, tức sổ ghi lại ai làm gì, lúc nào, vì sao) không sửa được. Tài khoản nhân viên bắt buộc dùng xác thực hai lớp (2FA). Người dùng được bảo vệ khỏi nhân viên lạm quyền; chủ dự án tra được mọi quyết định khi có khiếu nại hoặc yêu cầu pháp lý.

b) Hiện trạng

- **Vai trò**: cột *User.role* kiểu chuỗi, chỉ có *USER* và *ADMIN* (*apps/api/prisma/schema.prisma*).
- **Kiểm tra quyền**: *AdminGuard* (*apps/api/src/modules/admin/admin.controller.ts*) đọc vai trò từ cơ sở dữ liệu ở mỗi request và chỉ chấp nhận *ADMIN*, nên tước quyền có hiệu lực ngay. Mọi route */admin/** (thống kê, báo cáo, người dùng, khóa, mở khóa tuổi, quyền ẩn danh) dùng chung một mức quyền.
- **Cấp quyền**: chỉ bằng script *apps/api/scripts/make-admin.cjs* chạy trên máy chủ, sửa thẳng database. Không có giao diện quản lý nhân viên và không ghi lại ai cấp.
- **Đăng nhập trang quản trị**: *admin.html* gọi */auth/login* thường, giữ token 30 ngày trong *sessionStorage* của trình duyệt. Không có 2FA (2FA cho mọi người dùng là A1, chưa có).
- **Dữ liệu nhạy cảm**: *GET /admin/reports* trả thẳng danh tính thật của người bị báo cáo trong hội thoại ẩn danh và bản chụp 50 tin trong cùng danh sách, không cần bước xác nhận. *GET /admin/users* trả email đầy đủ và ngày sinh. Ảnh nhạy cảm trong bản chụp bị làm mờ cho tới khi bấm.
- **Nhật ký**: không có. Chỉ *Report.resolvedById* và *resolvedAt* ghi người đóng báo cáo. Khóa/mở khóa, mở khóa tuổi, trả/tước quyền ẩn danh không lưu ai làm.
- **Giới hạn đã có**: quản trị viên không bị khóa được (*setBanned*).

c) Cách hoạt động

Các vai trò (đề xuất)

- **Hỗ trợ** (*SUPPORT*): trả lời người dùng về tài khoản, xem tình trạng tài khoản, không xử lý nội dung.

- **Kiểm duyệt viên** (*MODERATOR*): xử lý hàng đợi C1, cảnh cáo và hạn chế C2, xử lý kháng nghị.
- **Quản trị viên** (*ADMIN*): mọi quyền, cộng quản lý nhân viên, khóa vĩnh viễn, xem toàn bộ nhật ký, trả lời yêu cầu của cơ quan chức năng.

Luồng 1: Nhân viên đăng nhập trang quản trị

1. Nhân viên mở trang quản trị, nhập email và mật khẩu.
2. Máy chủ kiểm tra mật khẩu (sai nhiều lần thì khóa tạm theo A4), rồi kiểm tra vai trò. Không phải nhân viên: từ chối và ghi nhật ký.
3. Nhân viên chưa bật 2FA: không vào được, trang yêu cầu thiết lập 2FA theo A1 rồi đăng nhập lại.
4. Trang hiện ô nhập mã 6 số. Nhân viên nhập mã từ ứng dụng xác thực. Sai 5 lần thì khóa 15 phút.
5. Đúng: máy chủ cấp **phiên quản trị riêng** sống 8 giờ (khác token 30 ngày của app), ghi nhật ký đăng nhập kèm IP.
6. Trang chỉ hiện các tab mà vai trò được dùng. Không thao tác 30 phút thì trang tự đăng xuất.

Luồng 2: Xem dữ liệu nhạy cảm

1. Kiểm duyệt viên mở báo cáo hội thoại ẩn danh. Mặc định trang chỉ hiện "Người ẩn danh" và tin của người báo cáo, che danh tính thật và tin của bên bị báo cáo.
2. Bấm "Xem danh tính và bản chụp", chọn lý do (ví dụ "Xử lý báo cáo lừa đảo") và có thể ghi chú.
3. Máy chủ kiểm tra vai trò được phép và mục báo cáo đang mở. Kiểm tra lần nhập 2FA gần nhất: quá 15 phút thì bắt nhập lại mã.
4. Máy chủ ghi nhật ký (ai, xem gì, mục nào, lý do, lúc nào) **trước** khi trả dữ liệu. Ghi nhật ký lỗi thì không trả dữ liệu.
5. Trả dữ liệu, hiện trong 15 phút rồi che lại. Màn hình có dòng chữ chìm tên người xem, để hạn chế chụp màn hình đem ra ngoài.
6. Một người xem quá 20 lần mỗi ngày thì quản trị viên nhận cảnh báo để rà nhật ký, và có thể thu hồi quyền.

Luồng 3: Cấp hoặc đổi vai trò nhân viên

1. Quản trị viên mở tab Nhân viên, tìm tài khoản, chọn vai trò mới.
2. Máy chủ kiểm tra người gọi là quản trị viên và vừa nhập 2FA trong 15 phút.
3. Tài khoản đích chưa bật 2FA: yêu cầu được giữ lại, người đó nhận email "hãy bật 2FA để nhận quyền"; vai trò chỉ có hiệu lực sau khi bật.

4. Không cho hạ quyền quản trị viên cuối cùng; không cho tự đổi vai trò của mình.
5. Đổi vai trò, thu hồi các phiên quản trị đang mở của người đó, ghi nhật ký (vai trò cũ, vai trò mới, ai đổi). Người đó nhận email báo đổi quyền và phải đăng nhập lại.
6. Script *make-admin.cjs* giữ lại chỉ để tạo quản trị viên đầu tiên hoặc cứu hộ khi mất hết quản trị viên; mỗi lần chạy cũng phải ghi một dòng nhật ký.

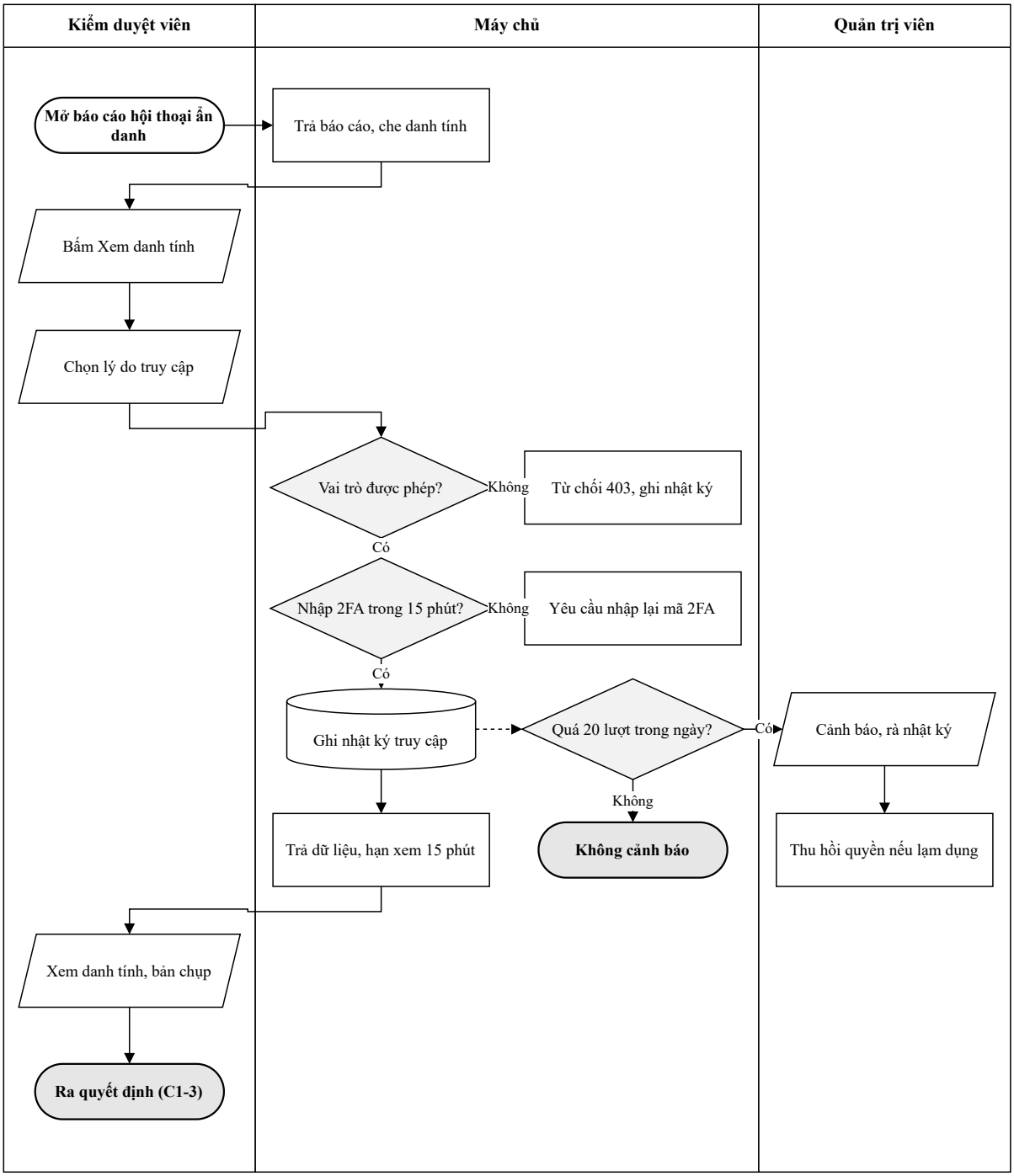
d) Flowchart

Sơ đồ C3-1: nhân viên đăng nhập trang quản trị, bắt buộc 2FA.



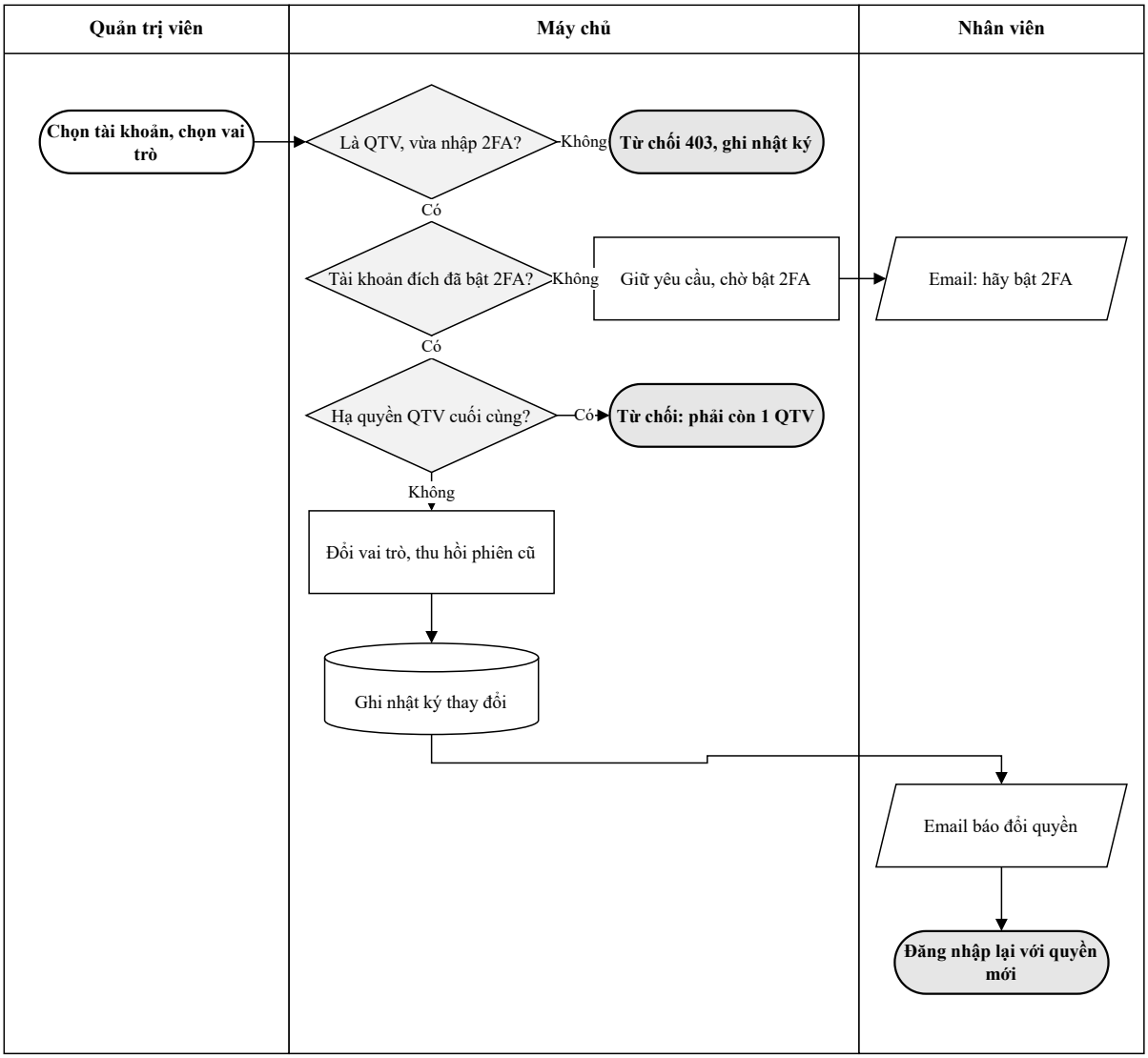
Hình 42. Nhân viên đăng nhập trang quản trị (bắt buộc 2FA)

Sơ đồ C3-2: xem danh tính thật và bản chụp hội thoại.



Hình 43. Xem danh tính thật và bản chụp hội thoại

Sơ đồ C3-3: cấp hoặc đổi vai trò nhân viên.



Hình 44. Cấp hoặc đổi vai trò nhân viên

e) Quy tắc, giới hạn và trường hợp đặc biệt

Bảng quyền (đề xuất)

Việc	Hỗ trợ	Kiểm duyệt viên	Quản trị viên
Xem thống kê	Có	Có	Có
Xem hàng đợi, xử lý nội dung (bỏ qua, gỡ, làm mờ)	Không	Có	Có
Cảnh cáo, hạn chế, tạm khóa đến 7 ngày	Không	Có	Có
Tạm khóa trên 7 ngày, khóa vĩnh viễn, mở khóa vĩnh viễn	Không	Đề xuất	Có
Xử lý kháng nghị (không phải quyết định của mình)	Không	Có	Có

Xem danh tính thật người ẩn danh, bản chụp hội thoại	Không	Có, chỉ trong báo cáo đang mở, có lý do	Có, có lý do
Xem email đầy đủ, ngày sinh	Có, có lý do	Che một phần (ví dụ *ng***@gmail.com*)	Có
Mở khóa tuổi, trả/tước quyền gửi ẩn danh	Không	Có	Có
Quản lý nhân viên, đổi vai trò	Không	Không	Có
Xem nhật ký thao tác	Của mình	Của mình	Toàn bộ
Xuất dữ liệu cho cơ quan chức năng	Không	Không	Có, ghi số văn bản yêu cầu

- **Ghi nhật ký những gì**: mọi thao tác thay đổi (xử lý báo cáo, cảnh cáo, khóa, mở khóa, đổi vai trò, mở khóa tuổi, quyền ẩn danh, quyết định kháng nghị), mọi lần xem dữ liệu nhạy cảm (danh tính thật, bản chụp hội thoại, email/ngày sinh đầy đủ, xuất dữ liệu), đăng nhập thành công và thất bại của nhân viên. Xem danh sách thường không ghi để nhật ký không bị ngập.
- **Không sửa, không xóa**: code không có route sửa hay xóa nhật ký. Ở mức database, nên bỏ quyền *UPDATE*/*DELETE* trên bảng nhật ký của tài khoản database mà API dùng. Việc này đổi cấu hình database trên Supabase nên **phải phối hợp với người phụ trách backend** theo RULE.md.
- **Thời gian lưu nhật ký**: 2 năm (đề xuất; **cần luật sư xác nhận** theo Nghị định 13/2023, Luật Bảo vệ dữ liệu cá nhân và Nghị định 147/2024).
- **Nhân viên không xử lý chính mình** và không xử lý nhân viên cùng cấp hoặc cấp cao hơn. Nhân viên vi phạm do quản trị viên xử lý.
- **Mất điện thoại 2FA**: nhân viên dùng mã dự phòng (A1). Không còn mã dự phòng thì một quản trị viên khác đặt lại 2FA, có ghi nhật ký. Quản trị viên duy nhất mất cả hai thì dùng script trên máy chủ.
- **Nghỉ việc**: hạ vai trò về *USER* ngay trong ngày; phiên quản trị bị thu hồi. *AdminGuard* đã đọc vai trò từ database mỗi request nên tước quyền có hiệu lực ngay.
- **Token app thường không gọi được route quản trị**: chỉ phiên quản trị (sau 2FA) mới gọi được, để token 30 ngày bị lộ trên điện thoại không mở được trang quản trị.
- **Cảnh báo lạm dụng**: quá 20 lần xem dữ liệu nhạy cảm mỗi ngày, hoặc xem dữ liệu của người không có báo cáo đang mở, thì quản trị viên nhận email.

- **Người dùng có được biết khi nhân viên xem tin nhắn của họ?** Đề xuất: không báo từng lần, nhưng chính sách quyền riêng tư nói rõ nhân viên xem tin nhắn khi có báo cáo (*MODERATION_PLAN.md*, mục 9). Chủ dự án quyết.

f) Dữ liệu và API (đề xuất)

Toàn bộ mục này là đề xuất, cần đưa vào *docs/api-contract.md* và ghi quyết định vào *docs/decisions.md* trước khi code.

Thay đổi	Nội dung
User.role	Thêm giá trị *SUPPORT*, *MODERATOR* (vẫn là chuỗi, không cần migration đổi kiểu). API đã trả *role* trong thông tin người dùng hiện tại; app di động hiện không dùng trường này nên không bị ảnh hưởng.
Bảng mới *AuditLog*	*id, actorId, actorRole, action* (ví dụ *CASE_DECIDE, USER_BAN, IDENTITY_REVEAL, ROLE_CHANGE, STAFF_LOGIN*), *targetType, targetId, reason, metadata* (JSON: giá trị trước/sau), *ip, userAgent, createdAt*. Chỉ mục theo (*actorId, createdAt*) và (*targetType, targetId*). Chỉ thêm, không sửa.
Bảng mới *StaffSession* (hoặc dùng bảng phiên của A2)	*id, userId, mfaAt* (lần nhập 2FA gần nhất), *expiresAt, revokedAt, ip*.
Bảng mới *PendingRoleChange*	*userId, role, requestedById, createdAt*: vai trò chờ người nhận bật 2FA.

Endpoint	Mô tả
POST /admin/auth/login, *POST /admin/auth/2fa*	Cấp phiên quản trị 8 giờ sau khi qua 2FA. Lỗi *STAFF_2FA_REQUIRED* khi chưa bật 2FA.
POST /admin/auth/step-up	Nhập lại mã 2FA, cập nhật *mfaAt*.
POST /admin/cases/:id/reveal	*{ reason, note? }*, trả danh tính thật và bản chụp. Yêu cầu *mfaAt* trong 15 phút. *GET /admin/reports* và hàng đợi C1 không còn trả các trường này.
GET /admin/staff, *POST /admin/staff/:userId/role*	Danh sách nhân viên; đổi vai trò *{ role }*. Lỗi: *LAST_ADMIN*, *CANNOT_CHANGE_SELF*, *TARGET_2FA_REQUIRED*.
POST /admin/staff/:userId/reset-2fa	Quản trị viên đặt lại 2FA cho nhân viên khác.

GET /admin/audit? actorId=&action=&targetId=&from=&to=	Tra nhật ký (quản trị viên xem tất cả, người khác chỉ xem của mình).

Trong code: thay *AdminGuard* bằng một guard đọc danh sách vai trò được phép gắn trên từng route (ví dụ *@Roles('MODERATOR','ADMIN')*), vẫn đọc vai trò từ database mỗi request như hiện nay. Mọi thao tác trong *AdminService* nhận thêm người làm và lý do, ghi *AuditLog* trong cùng giao dịch database với thao tác.

g) Android, iOS và web

- Toàn bộ tính năng nằm ở máy chủ và trang quản trị web (*admin.html*), không đổi app di động. Không có quyền thiết bị, không có thư viện mobile mới.
- 2FA của nhân viên dùng ứng dụng xác thực bất kỳ (Google Authenticator, Microsoft Authenticator…) trên điện thoại Android hoặc iPhone của nhân viên; thư viện TOTP phía máy chủ do A1 chọn.
- Trang quản trị chỉ nên mở qua HTTPS; nên giới hạn IP truy cập */admin* ở tầng máy chủ web nếu đội làm việc từ chỗ cố định (tùy chọn, không tốn phí).
- Không có chi phí dịch vụ ngoài. Email cảnh báo dùng *nodemailer* sẵn có.

h) Tiêu chí hoàn thành

- Tài khoản *MODERATOR* xử lý được hàng đợi nhưng gọi *POST /admin/staff/:id/role* nhận 403; *SUPPORT* không thấy tab Hàng đợi và gọi API hàng đợi nhận 403.
- Nhân viên chưa bật 2FA không vào được trang quản trị; token app 30 ngày gọi route quản trị nhận 401.
- Danh sách báo cáo hội thoại ẩn danh không còn chứa danh tính thật; xem danh tính tạo đúng một dòng nhật ký có lý do; quá 15 phút từ lần nhập 2FA thì bị hỏi lại mã.
- Không hạ được quản trị viên cuối cùng; đổi vai trò làm phiên cũ của người đó hết hiệu lực ngay.
- Mọi hành động trong bảng quyền tạo một dòng *AuditLog*; không có route nào sửa hay xóa nhật ký.
- Trang quản trị chạy trên Chrome và Safari (máy tính); ghi rõ trình duyệt đã chạy trong *docs/change.md*.
- Phép thử tự động cho bảng quyền: mỗi vai trò gọi mỗi route quản trị, so với kết quả mong đợi.

i) Ước lượng và phụ thuộc

- Backend 5 ngày (guard theo vai trò, phiên quản trị, nhật ký, route xem dữ liệu nhạy cảm, quản lý nhân viên), trang quản trị 2 ngày (tính trong backend), mobile 0 ngày, kiểm thử 1,5 ngày.
- Phụ thuộc: A1 (TOTP, mã dự phòng) là điều kiện bắt buộc; A2 (bảng phiên, nếu có thì dùng chung); A4 (khóa khi dò mật khẩu). C1 và C2 ghi vào nhật ký này.
- Rủi ro: C3 nằm ở GĐ3 nhưng C1 (GĐ1) đã cho nhiều người xử lý báo cáo và xem danh tính thật; nếu có thêm người kiểm duyệt trước GĐ3 thì việc xem dữ liệu nhạy cảm vẫn không có dấu vết. Đề xuất làm sớm phần nhật ký và bước "bấm xem kèm lý do" cùng C1 (khoảng 2 ngày), phần còn lại giữ ở GĐ3. Chủ dự án quyết.

NHÓM D. MẠNG XÃ HỘI

D1. Nhắn tin nhóm

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ3 · Ước lượng: 19–21 ngày công

a) Mục đích

Cho phép từ 3 đến 50 người trò chuyện chung trong một cuộc hội thoại (nhóm bạn, nhóm lớp, nhóm làm việc). Đây là tính năng người dùng mạng xã hội mặc định mong có. Khó nhất không phải là gửi tin cho nhiều người, mà là giữ nguyên các quy tắc an toàn đang có (tin nhắn chờ, chặn, cảnh báo lừa đảo) khi một hội thoại có nhiều người.

b) Hiện trạng

- **Mô hình dữ liệu chỉ cho hai người.** Bảng *Conversation* trong *apps/api/prisma/schema.prisma* có đúng hai cột người dùng *userAId*, *userBId*, cột *kind* (DIRECT, ANON_A, ANON_B) và ràng buộc duy nhất *(userAId, userBId, kind)*. Thời điểm đọc lưu ở hai cột *userAReadAt*, *userBReadAt*. Trạng thái tin nhắn chờ (*status* ACCEPTED, PENDING, DECLINED; *requesterId*), ẩn danh (*revealedAt*) và đóng hội thoại (*closedAt*) đều gắn với một cặp người.
- **Mã máy chủ giả định hai người ở mọi chỗ.** Trong *apps/api/src/modules/messages/messages.service.ts*: *requireMember* chỉ so với userA/userB và trả về một *peerId*; *unreadByConversation* là câu SQL đọc *userAReadAt*/*userBReadAt*; *send* phát socket cho đúng hai người (*peerId*, *userId*) và push cho một người; *markRead* phát *message:read* cho một người. *apps/api/src/modules/reports/reports.service.ts* coi "người bị báo cáo" là người còn lại của cặp.
- **Thời gian thực:** *notifications.gateway.ts* chỉ đẩy từ máy chủ xuống (*emitToUser* vào phòng *user:<id>*), chưa nhận sự kiện nào từ ứng dụng. Chỉ có một máy chủ, chưa có Redis adapter (cần kiểm tra lại khi chạy nhiều máy chủ).
- **Ứng dụng:** *apps/mobile/src/features/messages* (ChatScreen, ConversationsScreen, NewMessageScreen, messageService). Kiểu *Conversation* có trường bắt buộc *peer* (một người); tiêu đề, ảnh đại diện và "Đã xem" trong ChatScreen đều dựa vào *peer* và *peerReadAt*.
- **Thiếu:** không có bảng thành viên, tên nhóm, ảnh nhóm, vai trò quản trị, tin hệ thống ("A đã thêm B"), không có API hay màn hình nào cho nhóm.

Ý nghĩa với nhóm chat: bắt buộc phải đổi cấu trúc dữ liệu (migration). Có ba cách:

Cách	Làm gì	Ưu	Nhược
A (đề xuất)	Thêm bảng *ConversationMember* cho **mọi** hội thoại (chép sẵn 2 dòng cho mỗi hội thoại cũ). Hội thoại 1-1 giữ *userAId/userBId* để tìm cặp nhanh; nhóm để hai cột này trống. Thời điểm đọc chuyển sang *ConversationMember.lastReadAt*.	Một đường code cho đọc, chưa đọc, phát socket; 1-1 vẫn giữ nguyên quy tắc ẩn danh và tin nhắn chờ.	Phải sửa và kiểm thử lại toàn bộ luồng 1-1 đang chạy.
B	Tạo bảng riêng *GroupConversation*, *GroupMessage*, không đụng 1-1.	Không rủi ro cho 1-1.	Hai bộ code gần giống nhau; báo cáo, xóa tài khoản, tìm kiếm tin nhắn (D9) phải làm hai lần.
C	Bỏ hẳn userA/userB, mọi thứ qua bảng thành viên.	Gọn nhất về lâu dài.	Ràng buộc "mỗi cặp một hội thoại thường, một hội thoại ẩn danh mỗi chiều" phải viết lại bằng code; rủi ro cao nhất.

Chọn cách nào là quyết định kiến trúc, phải ghi vào *docs/decisions.md* và bàn với người phụ trách backend trước khi làm (RULE.md, mục 7 và 9).

c) Cách hoạt động

Luồng 1: Tạo nhóm

1. Người dùng vào Tin nhắn, bấm "Tạo nhóm", chọn 2–49 người (tìm theo tên, ưu tiên người mình theo dõi), đặt tên nhóm (bắt buộc, 1–50 ký tự), chọn ảnh nhóm (không bắt buộc).
2. Ứng dụng gửi tên, ảnh và danh sách người lên máy chủ.
3. Máy chủ kiểm tra số người (2–49), giới hạn tạo nhóm (tối đa 10 nhóm mỗi 24 giờ, đề xuất).
4. Máy chủ lặng lẽ bỏ những người có quan hệ chặn với người tạo (chiều nào cũng vậy). Người tạo chỉ thấy câu chung "Một số người không thể được thêm", không biết ai đã chặn mình.

5. Với từng người còn lại: nếu người đó **đang theo dõi người tạo** thì được thêm thẳng; nếu không thì nhận **lời mời vào nhóm** trong mục "Tin nhắn chờ" (giống quy tắc tin nhắn chờ 1-1 hiện có).
6. Máy chủ ghi hội thoại loại GROUP, các dòng thành viên (người tạo là quản trị viên), tin hệ thống "A đã tạo nhóm", rồi phát socket *conversation:new* cho thành viên và push cho người được mời.
7. Ứng dụng mở màn hình nhóm.

Luồng 2: Lời mời vào nhóm (người được mời)

1. Người được mời thấy trong "Tin nhắn chờ": tên nhóm, ai mời, số thành viên, 3 thành viên mình có theo dõi (nếu có). Không thấy nội dung tin nhắn của nhóm.
2. Có ba nút: "Tham gia", "Xóa lời mời", "Báo cáo". Xóa lời mời thì người mời không được báo (giống tin nhắn chờ 1-1).
3. Tham gia: trở thành thành viên, thấy tin từ thời điểm vào nhóm (không thấy lịch sử trước đó, đề xuất), các thành viên thấy tin hệ thống "B đã tham gia".
4. Lời mời không trả lời tự hết hạn sau 30 ngày (đề xuất).

Luồng 3: Gửi tin và "Đã xem"

1. Thành viên gửi tin chữ hoặc ảnh, kèm *clientId* như hiện nay.
2. Máy chủ kiểm tra người gửi còn là thành viên, kiểm tra *clientId* trùng (gửi lại khi mất mạng), độ dài, quét ảnh nhạy cảm bằng *ImageModerationService* như 1-1.
3. Máy chủ lưu tin, cập nhật *lastMessageAt*, rồi gửi socket *message:new* cho từng thành viên đang hoạt động. Thành viên đang bật tắt tiếng nhóm hoặc đã chặn người gửi thì không nhận push.
4. Thành viên mở nhóm: ứng dụng gọi đánh dấu đã đọc, máy chủ lưu *lastReadAt* của thành viên đó và phát *message:read* cho cả nhóm.
5. Dưới tin cuối của mình, người gửi thấy "Đã xem bởi 3 người"; chạm vào để xem danh sách ảnh đại diện. Khi mọi người đã xem: "Mọi người đã xem".

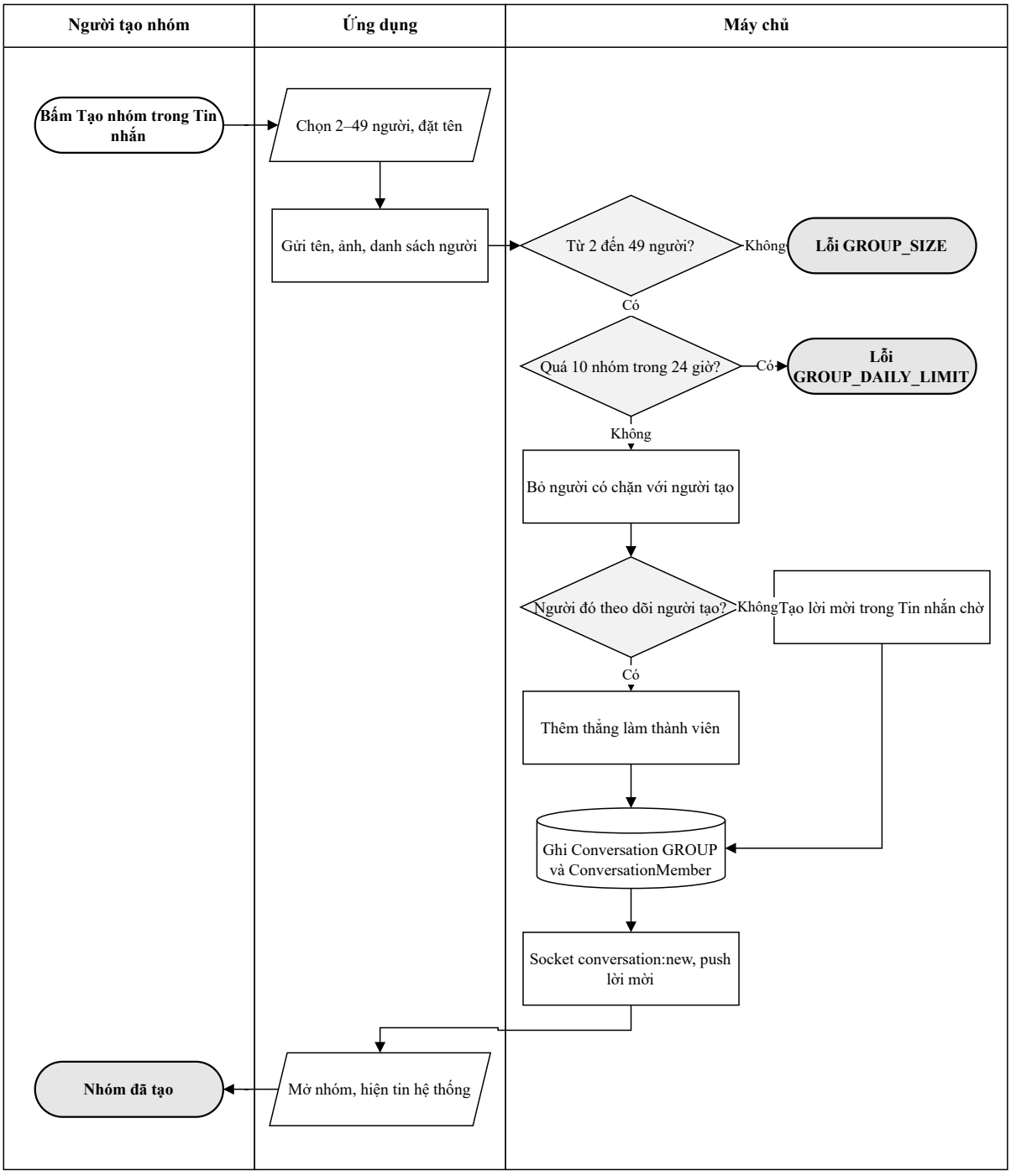
Luồng 4: Quản trị nhóm, rời nhóm, xóa thành viên

1. Quản trị viên được: thêm người (cùng quy tắc theo dõi/lời mời ở luồng 1), xóa thành viên, đổi tên và ảnh nhóm, chỉ định hoặc bỏ quản trị viên khác, bật "Chỉ quản trị viên được đổi thông tin nhóm" (mặc định bật, đề xuất).
2. Thành viên thường được: thêm người nếu nhóm cho phép (mặc định cho phép, đề xuất), rời nhóm, tắt tiếng nhóm, báo cáo nhóm hoặc một tin.
3. Rời nhóm hoặc bị xóa: máy chủ ghi *leftAt*, thêm tin hệ thống, nhóm biến khỏi hộp thư người đó. Người đã rời không đọc được tin mới; tin cũ vẫn lưu cho báo cáo.

4. Nếu quản trị viên cuối cùng rời đi, quyền chuyển cho thành viên vào nhóm lâu nhất. Nếu không còn ai, nhóm và tệp ảnh của nhóm bị xóa.

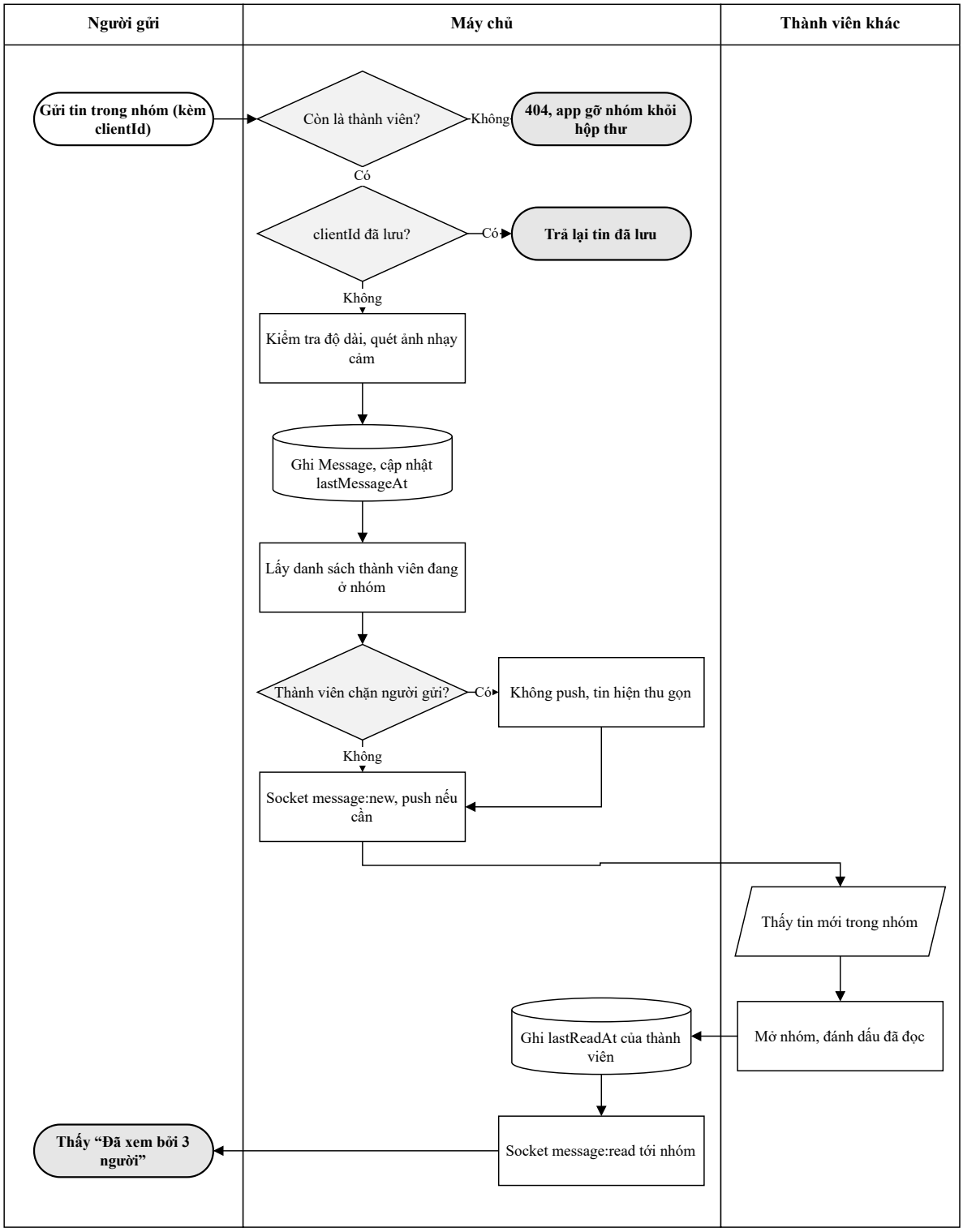
d) Flowchart

Tạo nhóm và quy tắc thêm người:



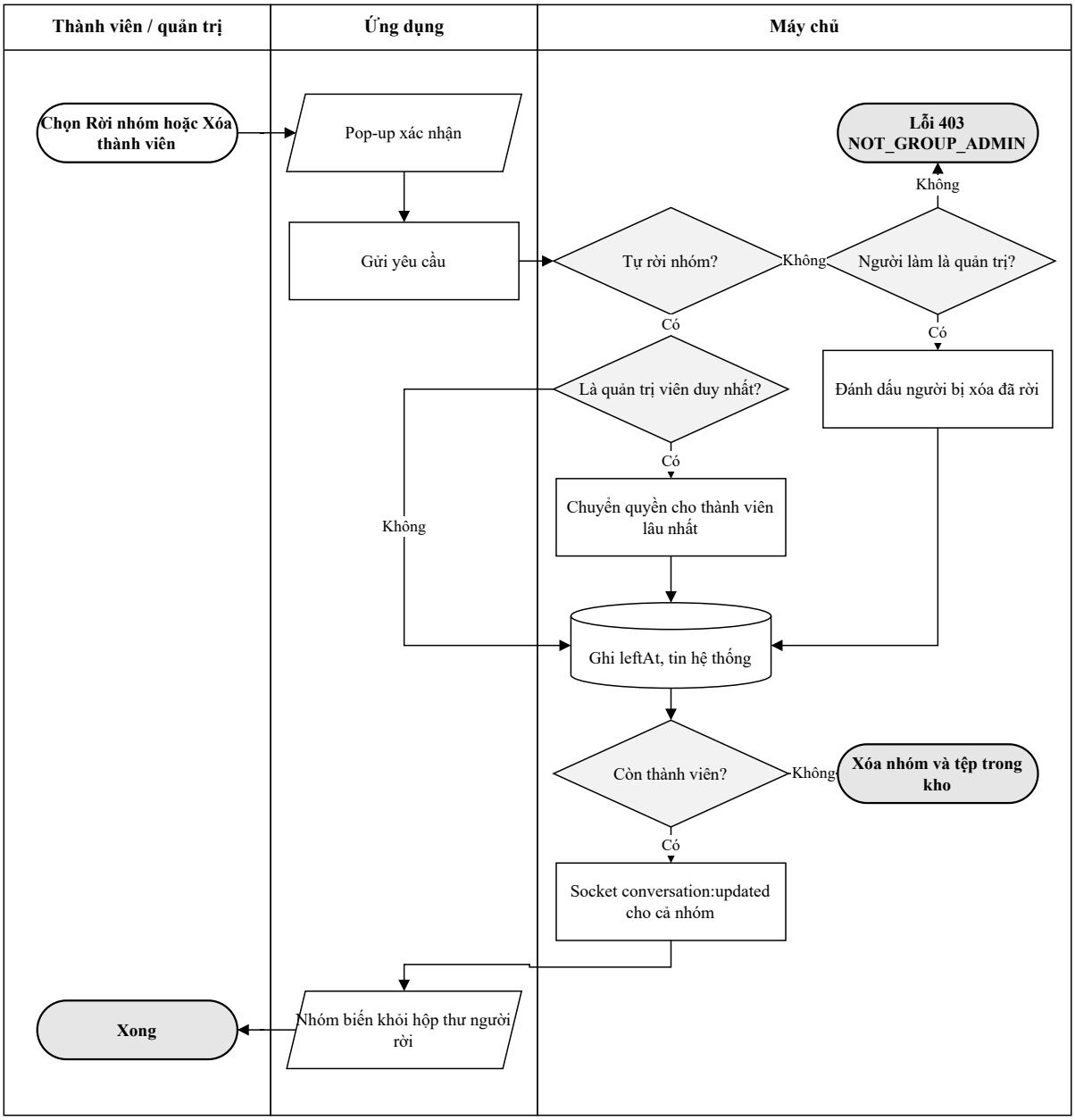
Hình 45. Tạo nhóm chat và thêm thành viên

Gửi tin trong nhóm, xử lý người bị chặn và "Đã xem":



Hình 46. Gửi tin trong nhóm và trạng thái Đã xem

Rời nhóm, xóa thành viên và chuyển quyền quản trị:



Hình 47. Rời nhóm, xóa thành viên và chuyển quyền quản trị

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Số thành viên:** tối đa 50 người một nhóm (đề xuất; Messenger cho 250). Con số nhỏ giữ chi phí phát socket và push thấp, và giảm nguy cơ nhóm bị dùng để spam. Có thể nâng sau.
- **Giới hạn chống spam (đề xuất):** tạo tối đa 10 nhóm/24 giờ; thêm tối đa 20 người/giờ mỗi người; tối đa 30 tin/phút mỗi người (dùng *@nestjs/throttler* đã có trong *apps/api/package.json*).
- **Không có ẩn danh trong nhóm.** Nhóm không có chế độ gửi ẩn danh; trả lời story ẩn danh vẫn chỉ mở hội thoại 1-1 như hiện nay. Lý do: ẩn danh trong nhóm khó kiểm duyệt và dễ thành công cụ bắt nạt tập thể.

- **Chặn trong nhóm (đề xuất, cần chủ dự án duyệt):** hai người chặn nhau vẫn ở chung nhóm đã có. Tin của người mình chặn hiện thu gọn "Tin từ người bạn đã chặn — chạm để xem", không có push. Người bị chặn không thể thêm người chặn mình vào nhóm mới. Ứng dụng hiện dòng nhắc "Có người bạn đã chặn trong nhóm này".
- **Tin nhắn chờ:** lời mời từ người mình không theo dõi nằm ở "Tin nhắn chờ". Chưa chấp nhận thì không nhận tin, không ai biết mình đã xem lời mời.
- **Cảnh báo lừa đảo:** cờ *warning* hiện có tính theo người xem: tin từ thành viên mà người xem không theo dõi và có cụm từ lừa đảo (*hasScamWarning*) thì hiện cảnh báo. Không chặn link trong nhóm đã chấp nhận (giống 1-1 đã chấp nhận).
- **Báo cáo:** báo cáo một tin hoặc cả nhóm. Bản chụp gồm 50 tin gần nhất như báo cáo hội thoại hiện có, nhưng phải ghi người bị báo cáo là người gửi tin được chọn, không phải "người còn lại".
- **Mất mạng, gửi lại:** giữ cơ chế *clientId* hiện có; cùng *clientId* thì trả lại tin đã lưu.
- **Tài khoản bị khóa hoặc xóa:** tài khoản bị khóa không gửi được; tin cũ vẫn hiện tên. Xóa tài khoản: hiện nay *Message.sender* có *onDelete: Cascade*, nghĩa là xóa tài khoản sẽ xóa cả tin của họ trong nhóm, làm hội thoại của người khác bị thủng. Cần quyết: giữ cascade (đơn giản) hay đổi thành "Người dùng đã xóa" (liên quan E2).
- **Socket:** mỗi tin gọi *emitToUser* cho tối đa 50 người, mỗi lần ký lại URL ảnh riêng tư theo từng kết nối. Với 50 người chấp nhận được; nhóm lớn hơn thì nên cho socket vào phòng theo hội thoại.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất theo cách A, cần đưa vào *docs/api-contract.md* và *docs/decisions.md* trước khi code.

Bảng / trường	**Nội dung**
Conversation (sửa)	*kind* thêm giá trị GROUP; *userAId*, *userBId* cho phép trống với GROUP; thêm *name*, *avatarUrl* (lưu kho riêng tư, dạng *s3p:*), *createdById*, *membersCanAdd* (Boolean).
ConversationMember (mới)	*conversationId*, *userId*, *role* (ADMIN | MEMBER), *status* (ACTIVE | INVITED | LEFT), *invitedById*, *joinedAt*, *leftAt*, *lastReadAt*, *mutedUntil*. Khóa chính *(conversationId, userId)*, chỉ mục *(userId, status)*. Hội thoại 1-1 cũ được chép thành 2 dòng.
Message (sửa)	Thêm *systemEvent* (CREATED, MEMBER_ADDED, MEMBER_LEFT, MEMBER_REMOVED, RENAMED, ADMIN_CHANGED) và *systemTargetId* cho tin hệ thống.

Endpoint	Việc
POST */conversations/groups*	Tạo nhóm. Multipart: *name*, *memberIds[]*, *avatar* (tùy chọn). Lỗi: GROUP_SIZE, GROUP_DAILY_LIMIT.
PATCH */conversations/:id*	Đổi tên, ảnh, *membersCanAdd*. Lỗi NOT_GROUP_ADMIN.
GET */conversations/:id/members*	Danh sách thành viên, vai trò, *lastReadAt*.
POST */conversations/:id/members*	Thêm người *{ userIds }*.
DELETE */conversations/:id/members/:userId*	Quản trị viên xóa thành viên.
POST */conversations/:id/leave*	Rời nhóm.
POST / DELETE */conversations/:id/admins/:userId*	Thêm, bỏ quản trị viên.
POST */conversations/:id/accept*, */decline* (đã có)	Dùng lại cho lời mời vào nhóm.
POST */conversations/:id/mute*	Tắt tiếng nhóm *{ until }* (liên quan D8).

Đối tượng hội thoại thêm *kind* và *group: { name, avatarUrl, memberCount, myRole }*; với nhóm, *peer* là null (ứng dụng phải sửa mọi chỗ đang dùng *peer*). Socket: thêm *conversation:new*; *message:read* thêm *userId*; *conversation:updated* (đã có) dùng cho đổi tên, thêm/bớt người.

g) Android, iOS và web

- Không cần quyền thiết bị mới: chọn ảnh nhóm dùng *expo-image-picker* đã cấu hình trong *app.json* (plugin có câu xin quyền thư viện ảnh *photosPermission* cho iOS, dùng chung cho Android).
- Không cần thư viện mới. Màn hình mới dùng thành phần sẵn có (PeerAvatar, ConfirmModal, toast). Ảnh đại diện nhóm ghép từ 2 ảnh thành viên khi chưa có ảnh nhóm.
- Push nhóm: tiêu đề là tên nhóm, nội dung "Tên: tin nhắn". Dùng Expo push hiện có (APNs và FCM qua Expo), không đổi gì riêng cho nền tảng nào.
- Bàn phím và vùng an toàn: màn hình thông tin nhóm có ô sửa tên phải dùng *KeyboardAvoidingView* đúng hành vi từng nền tảng như ChatScreen.
- Web quản trị (*apps/api/src/modules/admin/admin.html*): báo cáo nhóm phải hiện tên nhóm, danh sách thành viên và người bị báo cáo.
- Chi phí ngoài: không có.

h) Tiêu chí hoàn thành

- Tạo nhóm 3 người, gửi chữ và ảnh, cả ba thấy tin ngay qua socket; người không mở app nhận push.
- Người không theo dõi người tạo nhận lời mời trong "Tin nhắn chờ", không thấy tin cho tới khi tham gia; xóa lời mời thì người mời không được báo.
- Không thêm được người đã chặn hoặc bị chặn; thông báo không lộ ai chặn ai.
- "Đã xem bởi N người" đúng sau khi từng người mở nhóm.
- Rời nhóm, bị xóa, quản trị viên cuối rời đi (quyền tự chuyển), nhóm hết người (bị xóa cùng tệp).
- Hội thoại 1-1, tin nhắn chờ, ẩn danh, tiết lộ danh tính, báo cáo hội thoại vẫn chạy như trước sau migration (test hồi quy).
- Vượt giới hạn: nhóm 50 người, 10 nhóm/ngày, 30 tin/phút trả đúng mã lỗi, app hiện câu tiếng Việt.
- Chạy trên máy Android và iPhone thật (ghi rõ đã chạy máy nào trong *docs/change.md*).
- Test tự động: migration chép đúng 2 thành viên cho mỗi hội thoại cũ; quyền quản trị; quy tắc chặn; đếm chưa đọc nhóm.
- Quản trị viên app xem được báo cáo nhóm với bản chụp tin và đúng người bị báo cáo.

i) Ước lượng và phụ thuộc

- Backend 9 ngày (migration và sửa lại luồng 1-1: 4; API nhóm và quyền: 3; socket, push, báo cáo: 2). Mobile 8 ngày (sửa kiểu dữ liệu và ChatScreen cho nhóm: 3; tạo nhóm, thông tin nhóm, thành viên: 3; lời mời, Đã xem nhóm: 2). Kiểm thử 3 ngày.
- Phụ thuộc: B1 (quy tắc tin nhắn chờ dùng chung cho lời mời), D8 (tắt tiếng và cài đặt push theo nhóm), E2 (xóa tài khoản xử lý tin trong nhóm). Nên làm trước D2 vì D2 thêm nhiều trường vào *Message*, làm cùng lúc dễ xung đột migration.
- Rủi ro: migration làm hỏng luồng 1-1 đang chạy (cần test hồi quy kỹ); ChatScreen đã 990 dòng, thêm nhóm nên tách thành phần.

D2. Tin nhắn nâng cao: thu hồi, sửa, trả lời trích dẫn, cảm xúc, đang soạn, gửi video, ghi âm

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ3 · Ước lượng: 22–24 ngày công

a) Mục đích

Đưa phần nhắn tin lên mức người dùng quen ở Messenger, Zalo: gỡ tin gửi nhầm, sửa lỗi chính tả, trả lời đúng một tin, thả cảm xúc, biết người kia đang gõ, gửi video và tin nhắn thoại, và không mất tin khi mạng chập chờn. Mỗi phần nhỏ có thể làm và phát hành riêng.

b) Hiện trạng

- **Bảng Message** (*apps/api/prisma/schema.prisma*) chỉ có: *id* (do thiết bị sinh ra), *conversationId*, *senderId*, *content*, *imageUrl*, *createdAt*, *sensitive*, *storyId*. Không có trường sửa, thu hồi, trả lời, loại tin, video hay âm thanh. Không có bảng cảm xúc cho tin nhắn (cảm xúc chỉ có cho bài viết, bảng *Like*, và story, bảng *StoryReaction*).
- **API** (*apps/api/src/modules/messages/messages.controller.ts*): chỉ có tạo và đọc tin; không có sửa, xóa hay thu hồi. Gửi tin nhận JSON hoặc multipart với trường *image* (JPEG/PNG/WebP, tối đa 5 MB), chữ tối đa 2000 ký tự. Ảnh đi qua API rồi lưu vào kho riêng tư bằng *StorageService.upload(..., { private: true })*, đọc bằng URL có chữ ký hạn 1 giờ (*media-url.ts*).
- **Tải tệp lớn:** *StorageService.createUploadUrl* (URL có chữ ký để điện thoại tải thẳng lên kho) và *head* hiện **chỉ làm việc với kho công khai**. Video bài viết và Reels dùng cách này qua *POST /media/upload-url*, giới hạn video 30 MB, MP4/MOV (*reels.service.ts*). Tin nhắn chưa có cách tải video vào kho riêng tư.
- **Thời gian thực:** có *message:new*, *message:read*, *conversation:updated*. Gateway không nhận sự kiện từ ứng dụng nên chưa thể làm "đang soạn".
- **Gửi lại khi mất mạng (ứng dụng):** *ChatScreen.tsx* tạo *clientId* dạng *thời-gian-chuỗi-ngẫu-nhiên*, hiện tin mờ ngay, lỗi mạng thì tin chuyển đỏ và **người dùng phải chạm để gửi lại**. Hàng đợi nằm trong bộ nhớ của màn hình (*outgoingRef*): rời màn hình hoặc tắt app là mất tin chưa gửi. Lỗi do quy tắc (có *code*, ví dụ REQUEST_LIMIT) thì gỡ tin và hiện toast. Khi socket kết nối lại thì tải lại hội thoại. Máy chủ đã chống trùng theo *clientId*.
- **Ứng dụng:** chỉ chọn ảnh từ thư viện (*mediaTypes: ['images']*). *app.json* chỉ có câu xin quyền thư viện ảnh; **chưa có quyền micro, chưa có quyền camera**. Đã có

expo-video (phát video) và *expo-video-thumbnails* (tạo ảnh bìa) trong *package.json*; chưa có thư viện ghi âm.

c) Cách hoạt động

Luồng 1: Thu hồi tin

1. Người gửi nhấn giữ tin của mình, chọn "Thu hồi". Pop-up hỏi lại: "Thu hồi với mọi người?".
2. Máy chủ kiểm tra: đúng người gửi, tin chưa bị thu hồi, còn trong 24 giờ kể từ lúc gửi (đề xuất).
3. Máy chủ ghi *unsentAt*, xóa nội dung khỏi tin (xem mục e về lưu giữ cho báo cáo), phát *message:updated* cho hai bên.
4. Hai bên thấy dòng "Tin nhắn đã được thu hồi" ở đúng chỗ tin cũ. Tin trả lời trích dẫn tin này cũng chỉ còn "Tin đã thu hồi".
5. Thông báo push đã hiện trên máy người nhận **không thu hồi được**; ứng dụng chỉ cập nhật khi mở ra.

Luồng 2: Sửa tin

1. Người gửi nhấn giữ tin chữ của mình (không áp dụng tin ảnh/video/thoại), chọn "Sửa". Ô soạn tin hiện nội dung cũ.
2. Máy chủ kiểm tra: đúng người gửi, trong 15 phút kể từ lúc gửi, tối đa 5 lần sửa (đề xuất), và **chạy lại đúng các luật như lúc gửi**: độ dài, chặn link/số điện thoại/số tài khoản trong tin nhắn chờ và ẩn danh (*findBlockedContact*), cảnh báo lừa đảo (*hasScamWarning*). Nếu không, người lạ có thể gửi câu vô hại rồi sửa thành đường link để lách luật.
3. Máy chủ lưu bản cũ vào bảng lịch sử, ghi *editedAt*, phát *message:updated*.
4. Tin hiện nhãn "(đã sửa)". Chạm vào nhãn để xem các bản trước (cả hai bên đều xem được, đề xuất). Mục đích: kẻ lừa đảo không thể sửa lại lời hứa sau khi nạn nhân đã đọc.

Luồng 3: Trả lời trích dẫn

1. Vuốt sang phải một tin (hoặc nhấn giữ, chọn "Trả lời"). Phía trên ô soạn tin hiện khung trích dẫn có tên người và 1 dòng nội dung, có nút X để bỏ.
2. Ứng dụng gửi tin kèm *replyToId*. Máy chủ kiểm tra tin được trả lời thuộc cùng hội thoại.
3. Bóng tin mới hiện khung trích dẫn; chạm vào thì cuộn tới tin gốc (nếu tin gốc chưa tải thì tải thêm trang cũ).

4. Trong hội thoại ẩn danh, tên trong khung trích dẫn vẫn là "Người ẩn danh" (dùng lại *viewMessage*).

Luồng 4: Cảm xúc trên tin nhắn

1. Nhấn giữ một tin, thanh 6 cảm xúc hiện ra (dùng lại danh sách *REACTION_TYPES* của bài viết: LIKE, LOVE, HAHA, WOW, SAD, ANGRY).
2. Mỗi người một cảm xúc trên mỗi tin; chọn lại cảm xúc khác thì thay; chọn lại cùng cảm xúc thì bỏ.
3. Máy chủ lưu, phát *message:reaction*. Người gửi tin nhận push "A đã bày tỏ cảm xúc về tin nhắn của bạn" (tắt được trong D8).
4. Chỉ dùng được trong hội thoại đã chấp nhận (không thả cảm xúc trong tin nhắn chờ, để người lạ không có thêm cách gây chú ý).

Luồng 5: Đang soạn tin

1. Khi người dùng gõ, ứng dụng gửi sự kiện socket *typing* tối đa 1 lần mỗi 3 giây.
2. Máy chủ kiểm tra người đó là thành viên hội thoại (lưu tạm trong bộ nhớ 1 phút để không hỏi cơ sở dữ liệu mỗi lần), rồi chuyển cho người kia. Không ghi vào cơ sở dữ liệu.
3. Người kia thấy "đang soạn tin…" dưới tin cuối; tự tắt sau 5 giây không có sự kiện mới hoặc khi tin đến.
4. Không gửi "đang soạn" cho người mở tin nhắn chờ (giống quy tắc ẩn "Đã xem" hiện có). Trong hội thoại ẩn danh, người nhận chỉ thấy "Người ẩn danh đang soạn tin".

Luồng 6: Gửi video và tin nhắn thoại

1. Video: bấm nút đính kèm, chọn video từ thư viện (tối đa 60 giây, 30 MB, đề xuất). Thoại: giữ nút micro để ghi (tối đa 2 phút), thả tay để gửi, vuốt sang trái để hủy.
2. Lần đầu, hệ điều hành hỏi quyền micro (thoại) hoặc thư viện ảnh (video). Từ chối thì app hiện hướng dẫn mở Cài đặt.
3. Ứng dụng xin URL tải lên, gửi loại tệp và dung lượng. Máy chủ kiểm tra loại tệp, dung lượng và quyền gửi (giống quy tắc ảnh: không được gửi trong hội thoại ẩn danh và khi đang là người mở tin nhắn chờ).
4. Ứng dụng tải tệp thẳng lên kho riêng tư (không qua API). Với video, ứng dụng tạo thêm ảnh bìa bằng *expo-video-thumbnails* và tải lên cùng.
5. Ứng dụng gửi tin kèm *storageKey*. Máy chủ kiểm tra tệp có thật trong kho và nằm đúng thư mục của hội thoại, quét ảnh bìa video bằng bộ nhận diện ảnh nhạy cảm, lưu tin.

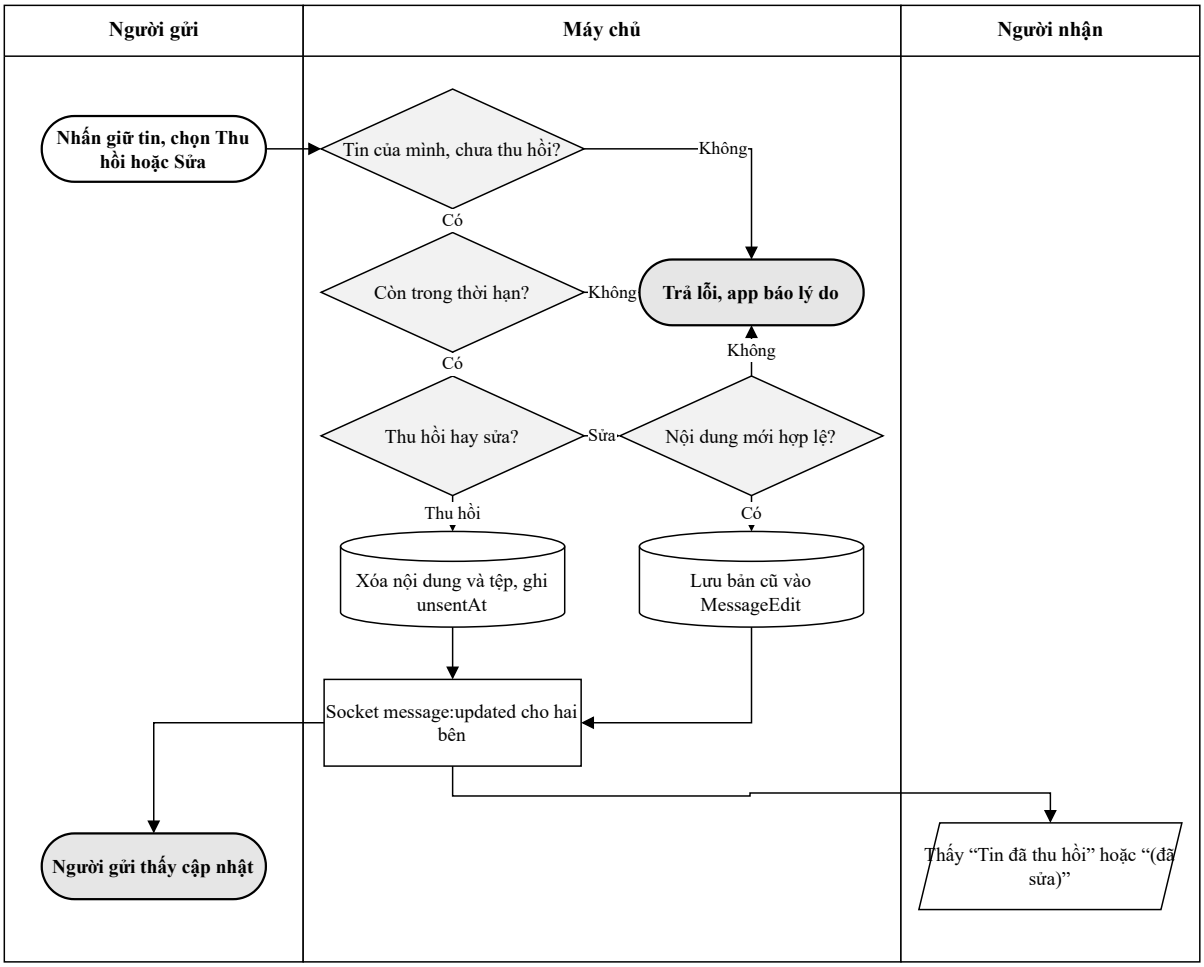
6. Người nhận thấy bóng tin có nút phát (video phát bằng *expo-video*; thoại có thanh thời lượng). Push ghi "Đã gửi một video" hoặc "Đã gửi tin nhắn thoại", không bao giờ kèm nội dung.

Luồng 7: Gửi khi mất mạng, tự gửi lại

1. Bấm Gửi: ứng dụng tạo *clientId*, hiện tin mờ và lưu tin vào hàng đợi trên máy (một tệp JSON trong thư mục của app, dùng *expo-file-system* đã có), nên tắt app vẫn không mất.
2. Không có mạng: chờ tới khi socket kết nối lại (*notificationSocket.onReconnect* đã có) rồi gửi.
3. Gửi lỗi mạng: tự thử lại sau 2, 4, 8, 16, 32 giây. Sau 5 lần vẫn lỗi thì tin chuyển đỏ "Chạm để gửi lại".
4. Bị luật chặn (máy chủ trả *code*): gỡ tin khỏi hàng đợi, hiện lý do, không thử lại (giữ cách đang làm).
5. Thành công (kể cả khi máy chủ trả lại tin cũ vì trùng *clientId*): thay tin mờ bằng tin thật, xóa khỏi hàng đợi.
6. Tin trong cùng một hội thoại gửi lần lượt từng tin để giữ đúng thứ tự.

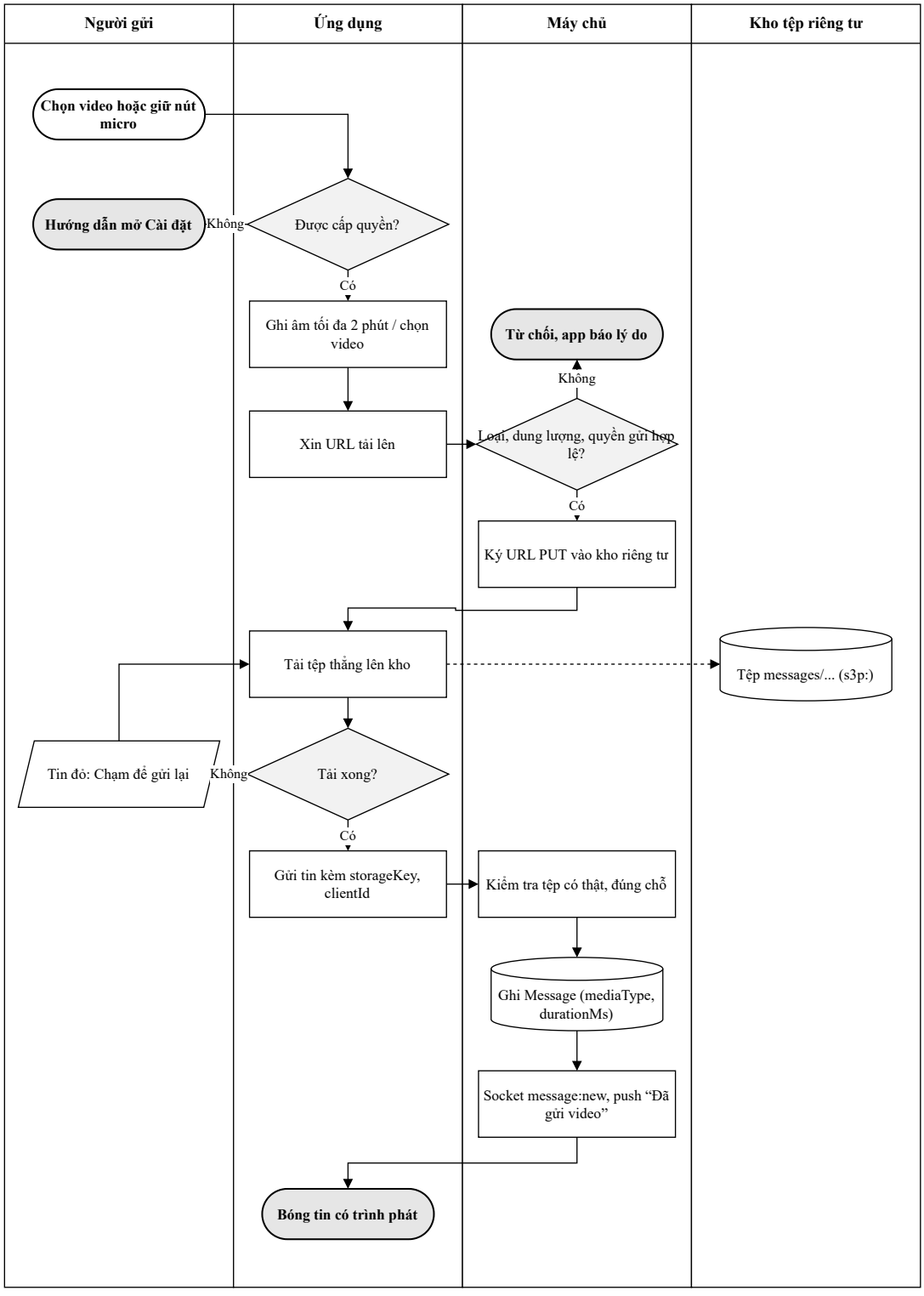
d) Flowchart

Thu hồi và sửa tin (cùng một bộ kiểm tra ở máy chủ):



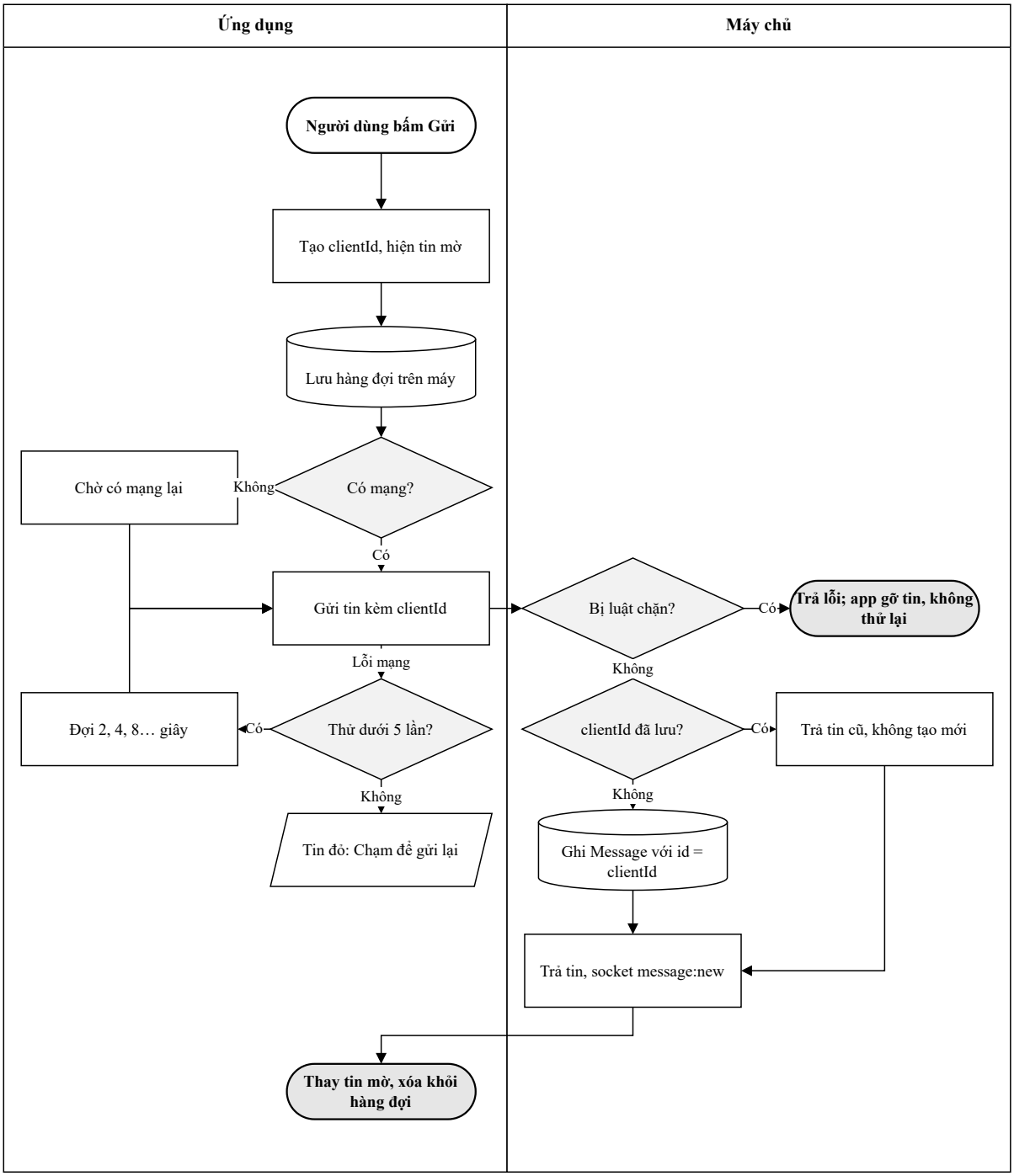
Hình 48. Thu hồi và sửa tin nhắn

Gửi video và tin nhắn thoại qua kho riêng tư:



Hình 49. Gửi video và tin nhắn thoại

Hàng đợi gửi trên máy và tự gửi lại:



Hình 50. Gửi khi mất mạng và tự gửi lại

e) Quy tắc, giới hạn và trường hợp đặc biệt

Việc	**Giới hạn đề xuất**
Thu hồi	Trong 24 giờ sau khi gửi; mọi loại tin.
Sửa	Trong 15 phút; tối đa 5 lần; chỉ tin chữ; chạy lại luật như lúc gửi.
Video	MP4 hoặc MOV, tối đa 30 MB và 60 giây; 1 video mỗi tin.
Tin nhắn thoại	M4A (AAC), tối đa 2 phút, tối đa 5 MB.

Đang soạn	Ứng dụng gửi tối đa 1 lần/3 giây; máy chủ bỏ qua nếu nhiều hơn; hiện trong 5 giây.
Hàng đợi trên máy	Tối đa 50 tin, giữ tối đa 7 ngày; đăng xuất thì xóa hàng đợi.

- **Lưu giữ tin đã thu hồi để xử lý báo cáo (cần chủ dự án quyết):** nếu xóa hẳn ngay, kẻ quấy rối có thể gửi lời đe dọa rồi thu hồi trước khi bị báo cáo. Đề xuất: nội dung và tệp được giữ ẩn 30 ngày, không ai trong app xem được, chỉ đưa vào bản chụp khi người nhận báo cáo hội thoại; sau 30 ngày xóa hẳn. Cần ghi rõ trong chính sách quyền riêng tư. Backend hiện chưa có tác vụ chạy định kỳ (không thấy *@nestjs/schedule*), cần thêm để dọn sau 30 ngày.
- **Ẩn danh:** không cho gửi tin nhắn thoại trong hội thoại ẩn danh, kể cả sau khi đã chấp nhận, vì giọng nói làm lộ danh tính. Video cũng không (theo quy tắc "ẩn danh chỉ chữ" hiện có).
- **Tin nhắn chờ:** người mở chỉ gửi chữ (giữ nguyên); không có cảm xúc, không có "đang soạn". Thu hồi được; sửa được nhưng chạy lại luật và vẫn tính vào giới hạn 3 tin.
- **Video và âm thanh không được quét nội dung.** Chỉ quét ảnh bìa video. Tin thoại không được quét. Đây là giới hạn thật; báo cáo hội thoại vẫn là cách xử lý chính. Có thể bổ sung dịch vụ quét video sau (chi phí riêng).
- **Tệp tải lên nhưng không gửi tin:** tệp mồ côi trong kho riêng tư. Cần tác vụ dọn tệp trong thư mục *messages/* không có tin nào sau 24 giờ.
- **Hạn URL có chữ ký 1 giờ:** video đang phát dở mà URL hết hạn sẽ lỗi; ứng dụng tải lại tin để lấy URL mới (theo ghi chú đã có trong *docs/api-contract.md*: lưu bộ nhớ đệm theo id tin, không theo URL).
- **Người bị chặn:** mọi thao tác (sửa, cảm xúc, đang soạn) bị từ chối như gửi tin. Thu hồi vẫn cho phép.
- **Xóa tài khoản:** mã xóa tài khoản hiện chỉ gom *imageUrl* của tin nhắn để xóa tệp; phải thêm tệp video, ảnh bìa, âm thanh.
- **Lạm dụng cảm xúc:** mỗi người tối đa 60 thao tác cảm xúc/phút (đề xuất); push cảm xúc gộp lại nếu nhiều trong 1 phút.

f) Dữ liệu và API (đề xuất)

Đề xuất, cần đưa vào *docs/api-contract.md* trước khi code.

Bảng / trường	**Nội dung**

Message (thêm)	*replyToId* (tự liên kết, xóa tin gốc thì để trống), *editedAt*, *unsentAt*, *mediaType* (VIDEO | AUDIO), *mediaUrl*, *thumbnailUrl*, *durationMs*. Tên trường kết thúc bằng *Url* để *resolveMediaUrls* tự ký URL như *imageUrl*.
MessageEdit (mới)	*id*, *messageId*, *content* (bản trước khi sửa), *createdAt*.
MessageReaction (mới)	*messageId*, *userId*, *type*, *createdAt*; khóa chính *(messageId, userId)*.

Endpoint / sự kiện	**Việc**
POST */conversations/:id/upload-url*	*{ kind: video | audio | thumbnail, mimeType, sizeBytes }* → *{ storageKey, uploadUrl, method, headers }*, cùng dạng với */media/upload-url* nhưng ký vào kho riêng tư, thư mục *messages/<conversationId>/*.
POST */conversations/:id/messages* (mở rộng)	Thêm *replyToId*, *storageKey*, *thumbnailKey*, *mediaType*, *durationMs*. Lỗi mới: MEDIA_NOT_ALLOWED, MEDIA_NOT_FOUND.
PATCH */messages/:id*	Sửa *{ content }*. Lỗi: EDIT_WINDOW_EXPIRED, EDIT_LIMIT, CONTACT_INFO_BLOCKED.
GET */messages/:id/edits*	Lịch sử sửa.
POST */messages/:id/unsend*	Thu hồi. Lỗi: UNSEND_WINDOW_EXPIRED.
PUT / DELETE */messages/:id/reaction*	Đặt hoặc bỏ cảm xúc *{ type }*.
Socket *message:updated*	*{ conversationId, message }* sau sửa, thu hồi.
Socket *message:reaction*	*{ conversationId, messageId, reactions: { type: count }, mine }*.
Socket *typing* (hai chiều)	Ứng dụng gửi *{ conversationId }*; máy chủ chuyển *{ conversationId, userId }* (*userId* là "anonymous" nếu bên đó đang ẩn danh). Đây là handler nhận sự kiện đầu tiên của gateway.

Sửa nhỏ trong *StorageService*: *createUploadUrl* và *head* nhận thêm tùy chọn kho riêng tư. Trường *canSendImages* của hội thoại nên đổi nghĩa thành "được gửi tệp" hoặc thêm *canSendVoice* (ẩn danh: không).

g) Android, iOS và web

- **Thư viện mới:** *expo-audio* (ghi âm và phát âm thanh, thuộc Expo SDK, hỗ trợ cả Android và iOS, chạy được trong Expo Go). Cài bằng *npx expo install expo-audio*. Không cần thư viện mạng riêng: dùng sự kiện kết nối lại của socket. Không cần

thư viện nén video: dùng tùy chọn chất lượng và thời lượng tối đa của *expo-image-picker* (cần kiểm tra mức nén thực tế trên Android, có thể khác iOS).

- **Quyền micro, khai báo cả hai phía trong cùng thay đổi:** thêm plugin *expo-audio* vào *app.json* với *microphonePermission*, ví dụ "Ứng dụng cần dùng micro để bạn ghi và gửi tin nhắn thoại." Plugin thêm *NSMicrophoneUsageDescription* (iOS) và *RECORD_AUDIO* (Android). Thiếu câu mô tả trên iOS thì app bị tắt ngay khi xin quyền.
- **Quay video bằng camera** (không bắt buộc ở bản đầu): nếu làm thì phải thêm *cameraPermission* và *microphonePermission* cho plugin *expo-image-picker* (iOS *NSCameraUsageDescription*, Android *CAMERA*). Đề xuất bản đầu chỉ chọn từ thư viện.
- **iOS:** mặc định âm thanh không phát khi gạt nút im lặng; cần đặt chế độ âm thanh "phát cả khi im lặng" cho tin thoại (*setAudioModeAsync*, cần kiểm tra tên tùy chọn trong SDK 57). Android không có khái niệm này; ghi chú lý do trong code theo RULE.md.
- **Định dạng ghi âm:** dùng mẫu chất lượng cao của *expo-audio* cho ra M4A/AAC trên cả hai nền tảng, phát được ở cả hai. Cần kiểm tra MIME thực tế mỗi bên trả về (*audio/mp4*, *audio/m4a* hoặc *audio/x-m4a*) và cho phép đủ.
- **Vuốt để trả lời và nhấn giữ:** dùng cử chỉ hoạt động trên cả hai; không dùng *android_ripple* hay *ActionSheetIOS* riêng một bên, dùng pop-up chung của app.
- **Chi phí:** dung lượng kho và băng thông tăng theo video (30 MB/video). Ví dụ 1.000 video/ngày ≈ 30 GB/ngày ≈ 900 GB/tháng lưu trữ nếu không xóa; cần quyết thời hạn giữ tệp tin nhắn hoặc giới hạn dung lượng.

h) Tiêu chí hoàn thành

- Thu hồi trong 24 giờ: hai bên thấy "Tin nhắn đã được thu hồi"; quá hạn trả lỗi đúng; tệp không còn xem được.
- Sửa trong 15 phút: nhãn "(đã sửa)", xem được lịch sử; sửa thành đường link trong tin nhắn chờ bị chặn.
- Trả lời trích dẫn: chạm khung trích dẫn cuộn đúng tin gốc; tin gốc bị thu hồi thì hiện "Tin đã thu hồi".
- Cảm xúc: thêm, đổi, bỏ; cập nhật ngay ở máy kia; không dùng được trong tin nhắn chờ.
- "Đang soạn" hiện và tự tắt; không hiện cho người mở tin nhắn chờ.
- Gửi video 30 MB và tin thoại 2 phút, phát được ở máy kia; từ chối quyền micro thì hiện hướng dẫn; không gửi được thoại trong ẩn danh.

- Tắt mạng, gửi 3 tin, tắt hẳn app, mở lại khi có mạng: 3 tin được gửi đúng thứ tự, không trùng.
- Chạy trên Android và iPhone thật, ghi rõ trong *docs/change.md*. Riêng tin thoại phải thử: ghi trên Android phát trên iPhone và ngược lại.
- Test tự động: thời hạn sửa/thu hồi, chạy lại luật khi sửa, kiểm tra *storageKey* đúng thư mục hội thoại, cảm xúc mỗi người một cái.
- Quản trị viên app thấy tin đã thu hồi và lịch sử sửa trong bản chụp báo cáo (nếu chủ dự án chọn giữ 30 ngày).

i) Ước lượng và phụ thuộc

Phần	**Backend**	**Mobile**
Thu hồi và sửa (kèm lịch sử)	2	2
Trả lời trích dẫn	0,5	1,5
Cảm xúc	1	1,5
Đang soạn (handler socket đầu tiên)	1	1
Gửi video (kho riêng tư, URL ký sẵn)	1,5	2
Tin nhắn thoại	0,5	2,5
Hàng đợi trên máy, tự gửi lại	0	2
Tác vụ dọn tệp, giữ tin thu hồi 30 ngày	1	0
Cộng	**7,5**	**12,5**

- Kiểm thử 3 ngày. Tổng 22–24 ngày công.
- Phụ thuộc: nên làm sau D1 (cùng sửa *Message*; nếu D1 làm trước thì mọi phần ở đây phải tính cho nhóm: "Đã xem", "đang soạn" nhiều người). D8 (cài đặt push cho cảm xúc). C1 (bản chụp báo cáo có tin thu hồi và lịch sử sửa). B1, B2 (luật tin nhắn chờ và ẩn danh áp dụng cho sửa, thoại).
- Rủi ro: ChatScreen đã 990 dòng; thêm 7 phần sẽ khó bảo trì, nên tách bóng tin, thanh soạn tin và hàng đợi ra tệp riêng trước. Định dạng âm thanh khác nhau giữa hai nền tảng cần thử sớm.

D3. Nhóm cộng đồng (Groups)

Nhóm: Mở rộng · Giai đoạn: GĐ4 · Ước lượng: 33–36 ngày công

a) Mục đích

Cho người dùng lập cộng đồng theo sở thích, khu vực hoặc lớp học, giống Facebook Groups: có trang nhóm, bảng tin riêng, nội quy, quản trị viên và người kiểm duyệt của nhóm. Lợi ích: người dùng quay lại app vì cộng đồng, không chỉ vì bạn bè. Đổi lại, nhóm là nơi dễ phát sinh nội dung xấu nhất, nên phần kiểm duyệt phải làm cùng lúc, không để sau.

b) Hiện trạng

- **Chưa có gì cho nhóm cộng đồng.** Trong *apps/api/prisma/schema.prisma* không có bảng hay trường nào về nhóm; không có module *groups* trong *apps/api/src/modules* hay *apps/mobile/src/features*.
- **Bài viết** (*Post*) có *privacy* (PUBLIC và các mức khác), *deletedAt*, *reelEligible*; không có trường trạng thái duyệt bài và không có trường gắn với nhóm.
- **Quyền xem bài** nằm ở một chỗ duy nhất: *visiblePostWhere* trong *apps/api/src/modules/posts/post-view.ts* (đã lọc người chặn nhau, bài đã xóa, tài khoản riêng tư). Bảng tin, trang cá nhân, Reels đều dựa vào điều kiện này. Thêm bài nhóm mà quên sửa chỗ này thì bài của nhóm kín sẽ lọt ra bảng tin.
- **Báo cáo** (*reports*) nhận *targetType* POST, COMMENT, USER, CONVERSATION; chưa có thông tin nhóm. Quản trị viên app duyệt báo cáo ở *apps/api/src/modules/admin*.
- **Có thể dùng lại:** soạn bài và đăng ảnh/video (luồng 3 bước qua */media/upload-url*), cảm xúc, bình luận, bộ quét ảnh nhạy cảm, bộ lọc chữ *text-safety*, thông báo trong app và push, điều kiện "tài khoản đủ 7 ngày và đã xác minh email" đang dùng cho nhắn ẩn danh.

c) Cách hoạt động

Ba loại nhóm

Loại	Ai tìm thấy nhóm	Ai xem được bài	Vào nhóm
Công khai	Mọi người (tìm kiếm, trang nhóm)	Mọi người	Bấm "Tham gia" là vào ngay (quản trị viên có thể bật duyệt thành viên)
Riêng tư	Mọi người thấy tên, mô tả, nội quy, số thành viên	Chỉ thành viên	Gửi đơn, trả lời câu hỏi, chờ duyệt

Ẩn	Chỉ thành viên và người được mời	Chỉ thành viên	Chỉ qua lời mời của thành viên, rồi chờ duyệt

Luồng 1: Tạo nhóm

1. Người dùng chọn "Tạo nhóm cộng đồng". Máy chủ kiểm tra tài khoản đủ 7 ngày và đã xác minh email (dùng lại điều kiện nhắn ẩn danh), tối đa 3 nhóm mới/ngày (đề xuất).
2. Nhập tên (3–75 ký tự), mô tả, chọn loại nhóm, ảnh bìa. Tên và mô tả đi qua bộ lọc chữ; ảnh bìa qua bộ quét ảnh nhạy cảm.
3. Bước tiếp: thêm nội quy (tối đa 10 điều), câu hỏi cho người xin vào (tối đa 3 câu), bật/tắt duyệt bài.
4. Người tạo là chủ nhóm (quản trị viên cao nhất).

Luồng 2: Xin vào nhóm

1. Người dùng bấm "Tham gia". Máy chủ kiểm tra người đó được thấy nhóm (nhóm ẩn mà không có lời mời thì trả 404 như không tồn tại) và không bị nhóm cấm.
2. Nhóm công khai: vào ngay. Nhóm riêng tư hoặc ẩn: nếu có câu hỏi, app hiện câu hỏi và nội quy; người dùng trả lời (mỗi câu tối đa 500 ký tự) và tích "Tôi đồng ý nội quy".
3. Máy chủ lưu đơn ở trạng thái chờ, báo cho quản trị viên và người kiểm duyệt nhóm.
4. Quản trị nhóm xem đơn cùng thông tin cơ bản của người xin (ngày tạo tài khoản, số nhóm chung, đã từng bị nhóm cấm chưa) và câu trả lời, rồi duyệt hoặc từ chối.
5. Duyệt: người xin thành thành viên, nhận thông báo "Bạn đã được duyệt vào nhóm X". Từ chối: người xin thấy đơn đã đóng, được xin lại sau 7 ngày (đề xuất). Đơn không ai xử lý tự hết hạn sau 30 ngày.

Luồng 3: Đăng bài trong nhóm và duyệt bài

1. Thành viên viết bài trong trang nhóm (dùng lại màn soạn bài). Máy chủ kiểm tra là thành viên, không bị cấm đăng hay đang bị tạm khóa trong nhóm.
2. Bài đi qua bộ lọc chung của app (chữ, ảnh). Bị gắn cờ thì bài vào hàng đợi kiểm duyệt của app (C1), chưa hiện.
3. Nhóm bật duyệt bài: bài ở trạng thái chờ, chỉ người đăng và quản trị nhóm thấy. Quản trị nhóm duyệt hoặc từ chối (có thể ghi lý do).
4. Không bật duyệt bài, hoặc đã duyệt: bài hiện ở bảng tin nhóm, thành viên nhận thông báo nếu bật "Thông báo mọi bài" cho nhóm đó (mặc định tắt).

Luồng 4: Báo cáo trong nhóm

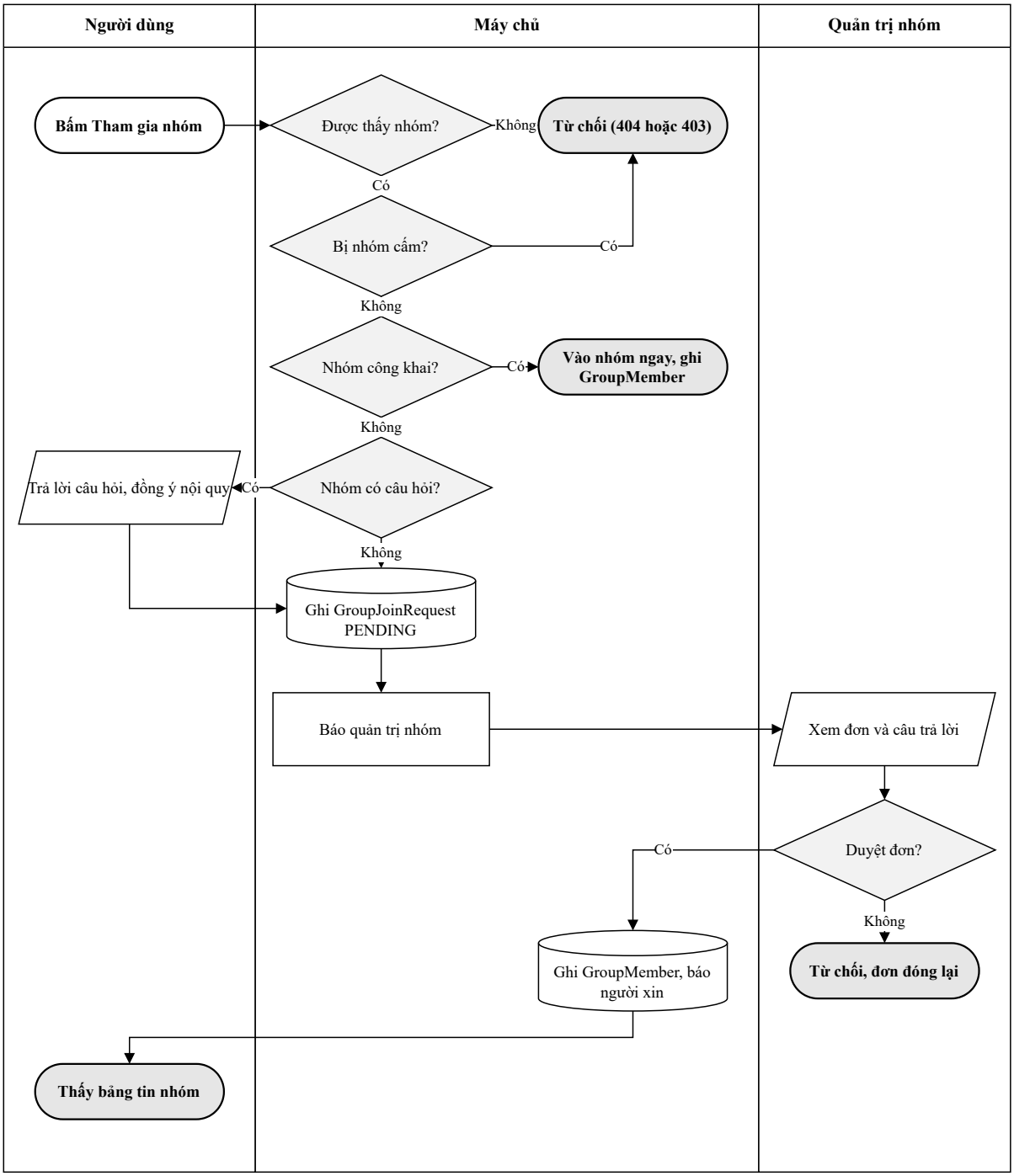
1. Thành viên bấm "Báo cáo" trên bài hoặc bình luận trong nhóm, chọn lý do. Danh sách lý do có hai phần: "Vi phạm nội quy nhóm" và lý do theo luật app (lừa đảo, khiêu dâm, bạo lực, xâm hại trẻ em, quấy rối...).
2. Lý do theo luật app: báo cáo vào thẳng hàng đợi của quản trị viên app (C1). Quản trị nhóm không thấy người báo cáo là ai.
3. Vi phạm nội quy nhóm: báo cáo vào hàng chờ của nhóm. Quản trị nhóm chọn: gỡ bài (kèm cảnh cáo, tắt tiếng hoặc cấm thành viên khỏi nhóm), bỏ qua, hoặc chuyển lên quản trị viên app.
4. Mọi thao tác của quản trị nhóm được ghi nhật ký. Quản trị viên app xem được nhật ký này và có thể đình chỉ nhóm hoặc gỡ quyền quản trị nhóm.

Luồng 5: Bảng tin nhóm và bảng tin chính

1. Trang nhóm có bảng tin riêng, bài mới nhất trước, có bài ghim của quản trị (tối đa 3).
2. Thêm một mục "Nhóm" trong app gộp bài mới từ các nhóm mình tham gia.
3. Ở bản đầu, bài nhóm **không** hiện ở bảng tin chính, trang cá nhân hay Reels (đề xuất). Như vậy không phải sửa thuật toán xếp hạng (D5) và không có nguy cơ lộ bài nhóm kín.
4. Bài trong nhóm riêng tư và ẩn không chia sẻ (đăng lại) ra ngoài được, không hiện trong tìm kiếm chung.

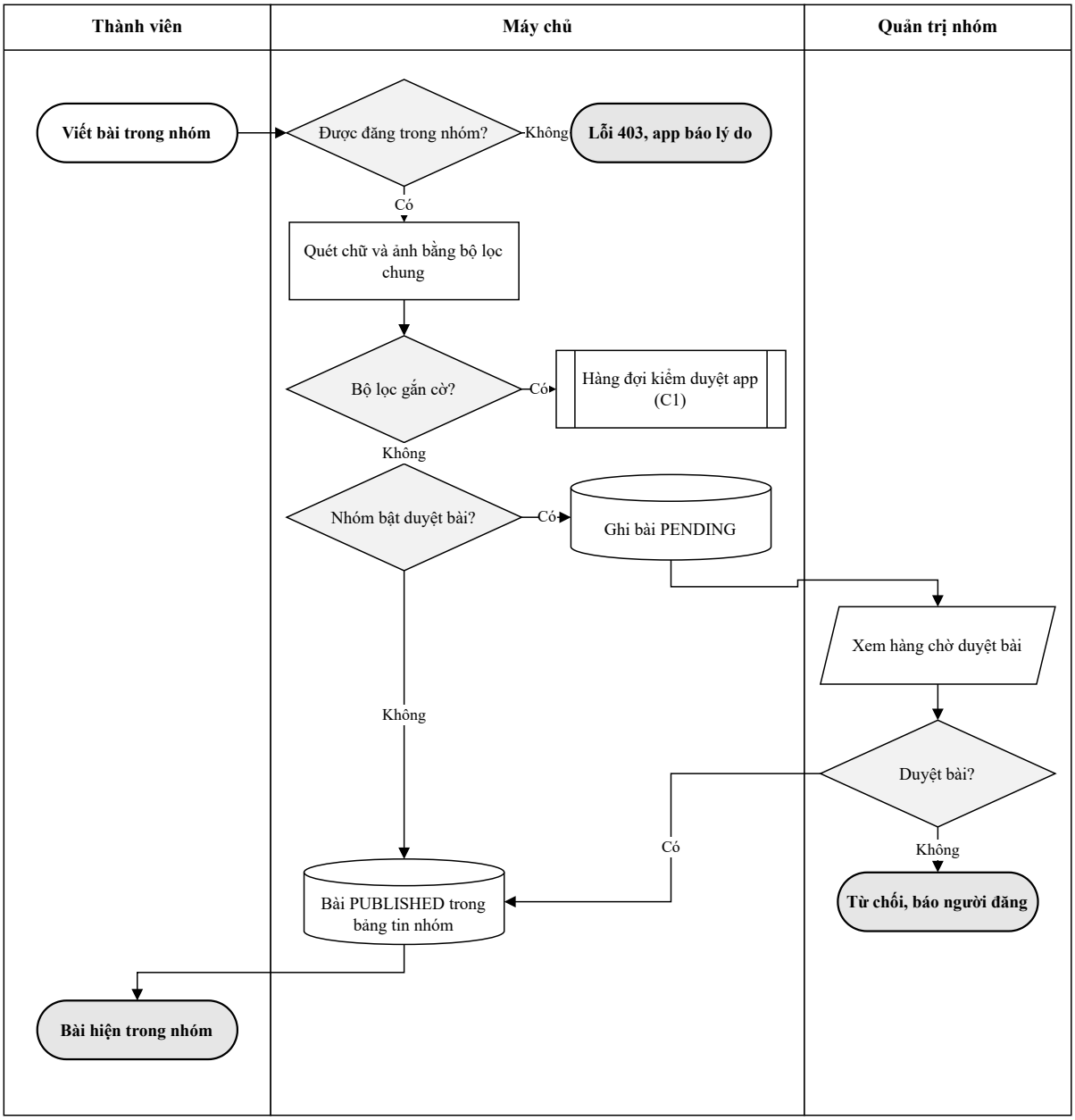
d) Flowchart

Xin vào nhóm, với câu hỏi và duyệt đơn:



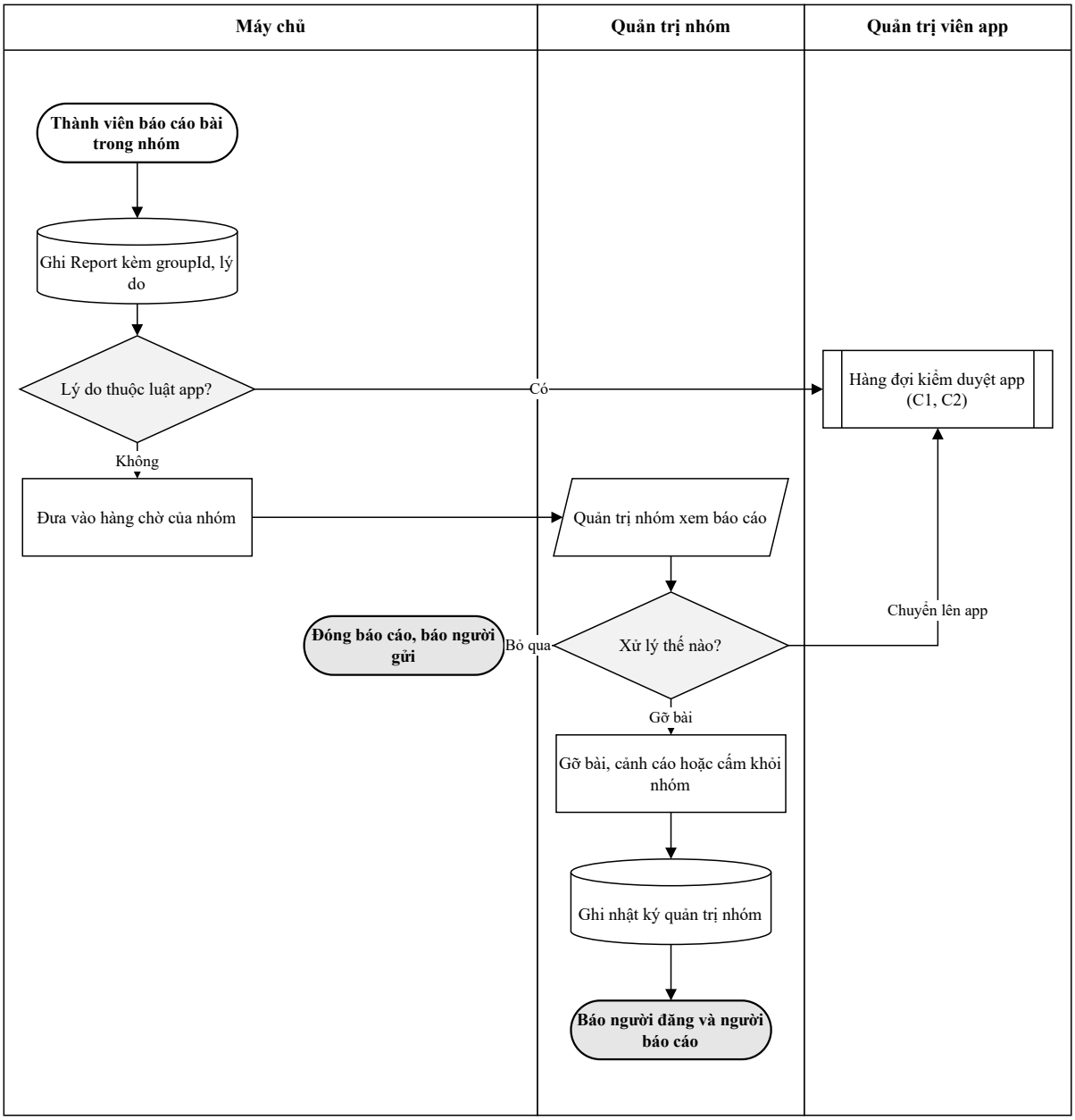
Hình 51. Xin vào nhóm cộng đồng

Đăng bài và duyệt bài trong nhóm:



Hình 52. Đăng bài trong nhóm và duyệt bài

Báo cáo trong nhóm và chuyển lên quản trị viên app:



Hình 53. Báo cáo trong nhóm và chuyển lên quản trị viên app

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Vai trò trong nhóm:** chủ nhóm (1 người, chuyển được), quản trị viên (tối đa 10, đề xuất), người kiểm duyệt (duyệt đơn, duyệt bài, xử lý báo cáo; không đổi cài đặt nhóm), thành viên. Chủ nhóm rời đi phải chọn người thay; xóa tài khoản thì quyền chuyển cho quản trị viên lâu nhất, không còn ai thì nhóm bị khóa đăng bài và quản trị viên app xử lý.
- **Giới hạn đề xuất:** 3 nhóm mới/ngày mỗi người; tham gia tối đa 200 nhóm; gửi tối đa 20 đơn xin vào/ngày; mời tối đa 50 người/ngày vào nhóm ẩn; đăng tối đa 20 bài/ngày trong một nhóm.

- **Chặn:** bài và bình luận của người mình chặn (hoặc chặn mình) bị ẩn với nhau trong nhóm, giống bảng tin (dùng lại *blockedUserIds*). Không ai mời được người đã chặn mình vào nhóm ẩn.
- **Ẩn danh trong nhóm:** không có ở bản đầu. Facebook có "đăng ẩn danh trong nhóm" nhưng quản trị nhóm vẫn thấy danh tính; nếu muốn làm sau, phải theo các luật của B2 (cần chủ dự án quyết).
- **Nhóm 18+ và người dưới 18:** chủ nhóm có thể đánh dấu nhóm chỉ dành cho người từ 18 tuổi; người chưa xác minh tuổi không vào được (phụ thuộc B6).
- **Nhóm vi phạm nhiều:** quản trị viên app có thể ẩn nhóm khỏi tìm kiếm, khóa đăng bài, đình chỉ hoặc xóa nhóm; số báo cáo được xác nhận của nhóm tính vào xử phạt theo bậc của chủ nhóm (C2).
- **Quản trị nhóm lạm quyền** (ví dụ cấm hàng loạt để quấy rối, đổi nhóm thành nơi lừa đảo): thành viên báo cáo nhóm theo luật app; quản trị viên app xem nhật ký thao tác của nhóm.
- **Bị cấm khỏi nhóm:** không thấy bài mới, không xin lại được; nhóm công khai vẫn xem được như khách (không bình luận).
- **Lỗi mạng:** thao tác tham gia, duyệt đơn, duyệt bài đều là thao tác một lần, gửi lại không tạo trùng (khóa duy nhất theo *(groupId, userId)*).
- **Yêu cầu cửa hàng ứng dụng:** App Store (mục 1.2 về nội dung người dùng tạo) và Google Play yêu cầu có báo cáo, chặn và lọc nội dung; báo cáo trong nhóm là bắt buộc, không phải phần thêm.

f) Dữ liệu và API (đề xuất)

Đề xuất, cần đưa vào *docs/api-contract.md* và ghi quyết định vào *docs/decisions.md* (bài viết có thêm "chủ sở hữu" là nhóm) trước khi code.

Bảng / trường	**Nội dung**
Group	*id*, *name*, *description*, *coverUrl*, *privacy* (PUBLIC | PRIVATE), *hidden* (Boolean), *adultOnly*, *postApproval*, *memberApproval*, *rules* (JSON, tối đa 10), *questions* (JSON, tối đa 3), *ownerId*, *memberCount*, *createdAt*, *suspendedAt*, *deletedAt*.
GroupMember	*groupId*, *userId*, *role* (OWNER | ADMIN | MODERATOR | MEMBER), *joinedAt*, *mutedUntil* (bị tạm khóa đăng), *notifyAllPosts*. Khóa chính *(groupId, userId)*.
GroupBan	*groupId*, *userId*, *bannedById*, *reason*, *createdAt*.
GroupJoinRequest	*id*, *groupId*, *userId*, *answers* (JSON), *status* (PENDING | APPROVED | REJECTED | EXPIRED), *reviewedById*, *createdAt*, *reviewedAt*.

GroupInvite	*groupId*, *inviterId*, *inviteeId*, *status*, *createdAt*.
GroupModLog	*id*, *groupId*, *actorId*, *action*, *targetType*, *targetId*, *reason*, *createdAt*.
Post (thêm)	*groupId* (trống với bài thường), *groupStatus* (PUBLISHED | PENDING | REJECTED), *pinnedAt*. *visiblePostWhere* thêm điều kiện *groupId = null* cho bảng tin, trang cá nhân, Reels.
Report (thêm)	*groupId*, *scope* (GROUP_RULE | APP_RULE).

Endpoint	**Việc**
POST */groups*, PATCH */groups/:id*, DELETE */groups/:id*	Tạo, sửa, xóa nhóm.
GET */groups/:id*, GET */groups?query=*, GET */me/groups*	Trang nhóm (404 nếu nhóm ẩn và không có quyền), tìm nhóm, nhóm của tôi.
POST */groups/:id/join { answers }*, POST */groups/:id/leave*	Tham gia hoặc gửi đơn; rời nhóm.
GET */groups/:id/requests*, POST */groups/:id/requests/:rid/approve | reject*	Duyệt đơn.
POST */groups/:id/invites { userIds }*	Mời vào nhóm (bắt buộc với nhóm ẩn).
GET */groups/:id/posts*, POST */groups/:id/posts*	Bảng tin nhóm, đăng bài trong nhóm.
GET */groups/:id/pending-posts*, POST */groups/:id/posts/:postId/approve | reject*	Duyệt bài.
PUT */groups/:id/members/:userId { role }*, POST */groups/:id/bans*, DELETE */groups/:id/bans/:userId*	Đổi vai trò, cấm, bỏ cấm.
GET */groups/:id/reports*, POST */groups/:id/reports/:rid/resolve { action }*	Hàng chờ báo cáo của nhóm (không lộ người báo cáo).
GET */groups/:id/mod-log*	Nhật ký quản trị nhóm (quản trị nhóm và quản trị viên app).
GET */feed/groups*	Bài mới từ các nhóm của tôi.

g) Android, iOS và web

- Không cần quyền thiết bị mới (ảnh bìa và ảnh bài viết dùng *expo-image-picker* đã cấu hình). Không cần thư viện mới.
- Mobile: thư mục mới *apps/mobile/src/features/groups* theo cách tổ chức theo tính năng (DEC-001): trang nhóm, tạo nhóm, câu hỏi khi xin vào, bảng quản trị nhóm (đơn, bài chờ, báo cáo, thành viên, cấm, nhật ký). Dùng lại PostCard và màn soạn bài.

- Liên kết sâu tới nhóm (ví dụ *mobilesocial://groups/<id>*) phải chạy trên cả hai nền tảng (scheme *mobilesocial* đã có trong *app.json*).
- Web quản trị app: thêm trang danh sách nhóm, báo cáo theo nhóm, nhật ký quản trị nhóm, nút đình chỉ nhóm.
- Chi phí: không có dịch vụ ngoài mới; tải cơ sở dữ liệu và kho tệp tăng theo số bài.

h) Tiêu chí hoàn thành

- Tạo được ba loại nhóm; nhóm ẩn trả 404 với người ngoài, kể cả khi đoán đúng id.
- Xin vào nhóm riêng tư có câu hỏi; quản trị nhóm duyệt và từ chối; người xin nhận thông báo; đơn hết hạn sau 30 ngày.
- Bài trong nhóm riêng tư không hiện ở bảng tin chính, trang cá nhân, Reels, tìm kiếm, và không đăng lại được (test tự động trên *visiblePostWhere*).
- Nhóm bật duyệt bài: bài chờ chỉ người đăng và quản trị thấy; duyệt xong mới hiện.
- Báo cáo theo luật app vào thẳng hàng đợi của app; báo cáo nội quy vào hàng chờ của nhóm; "chuyển lên" hoạt động; quản trị nhóm không thấy người báo cáo.
- Người bị cấm khỏi nhóm không đăng, không xin lại được; người chặn nhau không thấy bài của nhau trong nhóm.
- Quản trị viên app xem nhật ký nhóm, đình chỉ nhóm được.
- Chạy trên Android và iPhone thật, ghi rõ trong *docs/change.md*.

i) Ước lượng và phụ thuộc

- Backend 15 ngày (bảng và quyền: 4; đơn xin vào, lời mời: 3; bài nhóm, duyệt bài, sửa *visiblePostWhere*: 3; báo cáo, nhật ký, công cụ quản trị app: 3; thông báo: 2). Mobile 14 ngày (trang nhóm, bảng tin nhóm: 4; tạo nhóm, câu hỏi: 3; bảng quản trị nhóm: 5; mục Nhóm, thông báo: 2). Kiểm thử 5 ngày.
- Phụ thuộc: C1 (hàng đợi kiểm duyệt app), C2 (xử phạt theo bậc cho chủ nhóm), C3 (phân quyền quản trị app để xem nhóm), B6 (nhóm 18+), B7 (bộ lọc bình luận dùng trong nhóm), D8 (cài đặt thông báo theo nhóm), D5 nếu sau này muốn đưa bài nhóm lên bảng tin chính.
- Rủi ro: lộ bài nhóm kín nếu có một truy vấn bài viết nào không đi qua *visiblePostWhere* (cần rà toàn bộ truy vấn *post.findMany*); khối lượng kiểm duyệt tăng mạnh; quản trị nhóm là người dùng thường, có thể lạm quyền.

D4. Gọi thoại và gọi video 1-1

Nhóm: Mở rộng · Giai đoạn: GĐ4 · Ước lượng: 28–32 ngày công (chưa tính thời gian chờ duyệt cửa hàng)

a) Mục đích

Cho hai người đã nhắn tin với nhau gọi thoại hoặc gọi video ngay trong app, đổ chuông như cuộc gọi điện thoại kể cả khi app đang tắt. Đây là tính năng **khó và tốn kém nhất** trong nhóm này: phải viết phần native (mã riêng cho từng hệ điều hành), cần máy chủ chuyển tiếp TURN có chi phí theo dung lượng, cần thêm hai kênh push riêng (VoIP của Apple và FCM của Google), và không chạy được trong Expo Go.

b) Hiện trạng

- **Chưa có gì cho cuộc gọi:** không có bảng, API hay màn hình nào; không có thư viện WebRTC (công nghệ truyền âm thanh/video trực tiếp giữa hai máy) trong *apps/mobile/package.json* hay *apps/api/package.json*.
- **Kênh thời gian thực có sẵn:** Socket.IO namespace */notifications* (*notifications.gateway.ts*) xác thực bằng JWT, mỗi người một phòng *user:<id>*. Hiện chỉ đẩy từ máy chủ xuống; chưa nhận sự kiện nào từ ứng dụng. Chỉ một máy chủ, chưa có Redis adapter.
- **Push:** *NotificationsService.pushToUser* gửi qua dịch vụ push của Expo (*exp.host*), lưu token ở bảng *DeviceToken* (*token*, *userId*, *platform*), đăng ký qua *POST /notifications/devices*. Dịch vụ push của Expo không gửi được push VoIP của Apple, nên không dùng được để đánh thức cuộc gọi trên iPhone.
- **Quyền thiết bị:** *app.json* chưa khai báo micro, camera, chế độ chạy nền nào.
- **Cách chạy thử hiện nay:** nhóm đang chạy thử bằng Expo Go (có tệp *apps/mobile/Expo-Go-57.0.9.apk*; báo cáo tính năng ghi "Android (BlueStacks, Expo Go)"). *expo-dev-client* đã có trong *package.json*, nhưng cần kiểm tra đã từng build bản development (bản app riêng có mã native) cho cả hai nền tảng chưa.
- **Có thể dùng lại:** quy tắc ai được nhắn cho ai trong *messages.service.ts* (chặn, tin nhắn chờ, ẩn danh, hội thoại đã đóng) và báo cáo hội thoại.

c) Cách hoạt động

Các thành phần, nói đơn giản

- **WebRTC:** âm thanh và hình ảnh đi thẳng giữa hai điện thoại, không qua máy chủ API.
- **Báo hiệu (signalling):** trước khi nói chuyện, hai máy phải trao đổi "thư giới thiệu" (offer, answer) và danh sách đường mạng có thể dùng (ICE candidate). Phần này

đi qua Socket.IO sẵn có.

- **STUN:** máy chủ nhỏ giúp mỗi điện thoại biết địa chỉ mạng công khai của mình. Rẻ, có loại miễn phí.
- **TURN:** khi hai máy không nối thẳng được (mạng 4G, mạng công ty, tường lửa), âm thanh/video đi vòng qua máy chủ TURN. Có chi phí theo dung lượng.
- **CallKit (iOS) và ConnectionService (Android):** màn hình cuộc gọi của hệ điều hành, hiện cả khi khóa máy, giống cuộc gọi điện thoại thường.
- **Push VoIP (iOS, PushKit) và FCM ưu tiên cao (Android):** đánh thức app khi đang tắt để đổ chuông.

Luồng 1: Gọi đi

1. Trong màn chat, người gọi bấm nút gọi thoại hoặc gọi video.
2. Ứng dụng xin quyền micro (và camera nếu gọi video). Từ chối thì hiện hướng dẫn bật trong Cài đặt.
3. Ứng dụng gọi API tạo cuộc gọi. Máy chủ kiểm tra người gọi có được gọi người này không (mục e), người nhận có đang trong cuộc gọi khác không, giới hạn số cuộc gọi.
4. Máy chủ tạo bản ghi cuộc gọi trạng thái RINGING, gửi *call:incoming* qua socket tới mọi thiết bị đang mở của người nhận, đồng thời gửi push VoIP (iPhone) hoặc FCM ưu tiên cao (Android) tới thiết bị không mở app.
5. Người gọi nghe tiếng chuông chờ, có nút hủy.
6. Người nhận bắt máy trong 45 giây: cuộc gọi chuyển ACTIVE, hai bên bắt đầu kết nối (luồng 3). Từ chối hoặc hết 45 giây: ghi DECLINED hoặc MISSED, người gọi thấy "Không trả lời", trong chat có tin "Cuộc gọi nhỡ".

Luồng 2: Nhận cuộc gọi khi app đang tắt

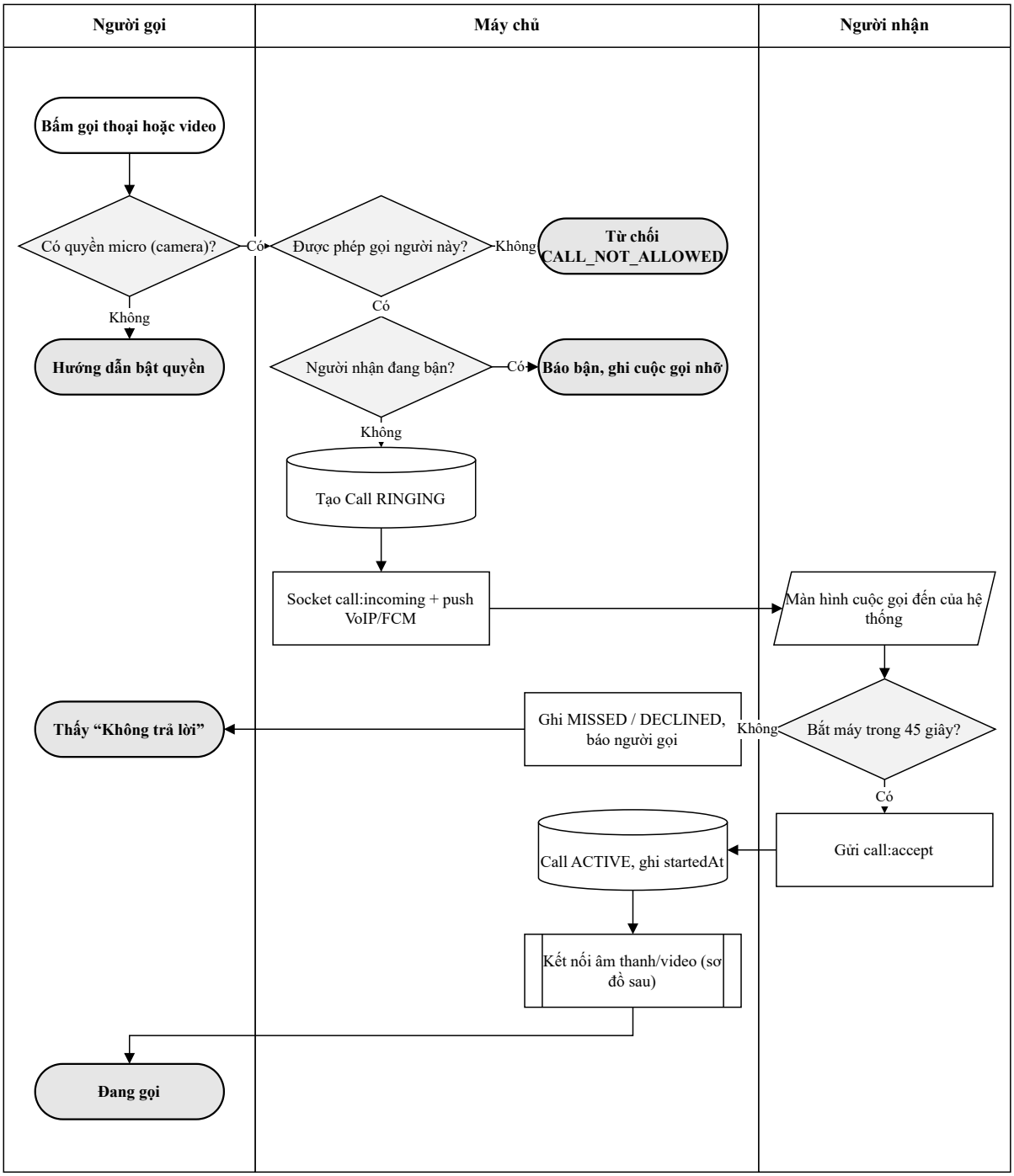
1. iPhone: Apple gửi push VoIP; hệ điều hành đánh thức app; app **phải báo cho CallKit ngay lập tức** (luật của Apple từ iOS 13: không báo thì iOS tắt app và có thể ngừng gửi push VoIP cho app).
2. Android: FCM gửi tin dữ liệu ưu tiên cao; app xử lý ở chế độ nền và mở màn hình cuộc gọi qua ConnectionService (kèm thông báo toàn màn hình khi khóa máy).
3. Màn hình cuộc gọi của hệ thống hiện tên và ảnh người gọi, nút Bắt máy / Từ chối.
4. Bắt máy: app mở, kết nối socket, gửi chấp nhận. Máy chủ kiểm tra cuộc gọi còn chờ (người gọi có thể vừa hủy). Các thiết bị khác của người nhận ngừng đổ chuông.
5. Từ chối: gửi từ chối, máy chủ ghi lại và báo người gọi.

Luồng 3: Kết nối âm thanh và video

1. Ứng dụng lấy danh sách máy chủ STUN/TURN kèm mật khẩu tạm (hạn 1 giờ) từ API.
2. Hai máy trao đổi offer, answer, ICE candidate qua socket. Máy chủ chỉ chuyển tiếp giữa đúng hai người của cuộc gọi.
3. Nối thẳng được (phần lớn trường hợp): âm thanh/video đi trực tiếp. Không được: đi qua TURN.
4. Trong cuộc gọi: tắt/bật micro, tắt/bật camera, đổi camera trước/sau, loa ngoài, thời lượng cuộc gọi. Đổi mạng (Wi-Fi sang 4G) thì thử kết nối lại (ICE restart) trong 15 giây trước khi báo mất kết nối.
5. Kết thúc: một bên bấm tắt, máy chủ ghi *endedAt*, trong chat có tin "Cuộc gọi video · 3 phút".

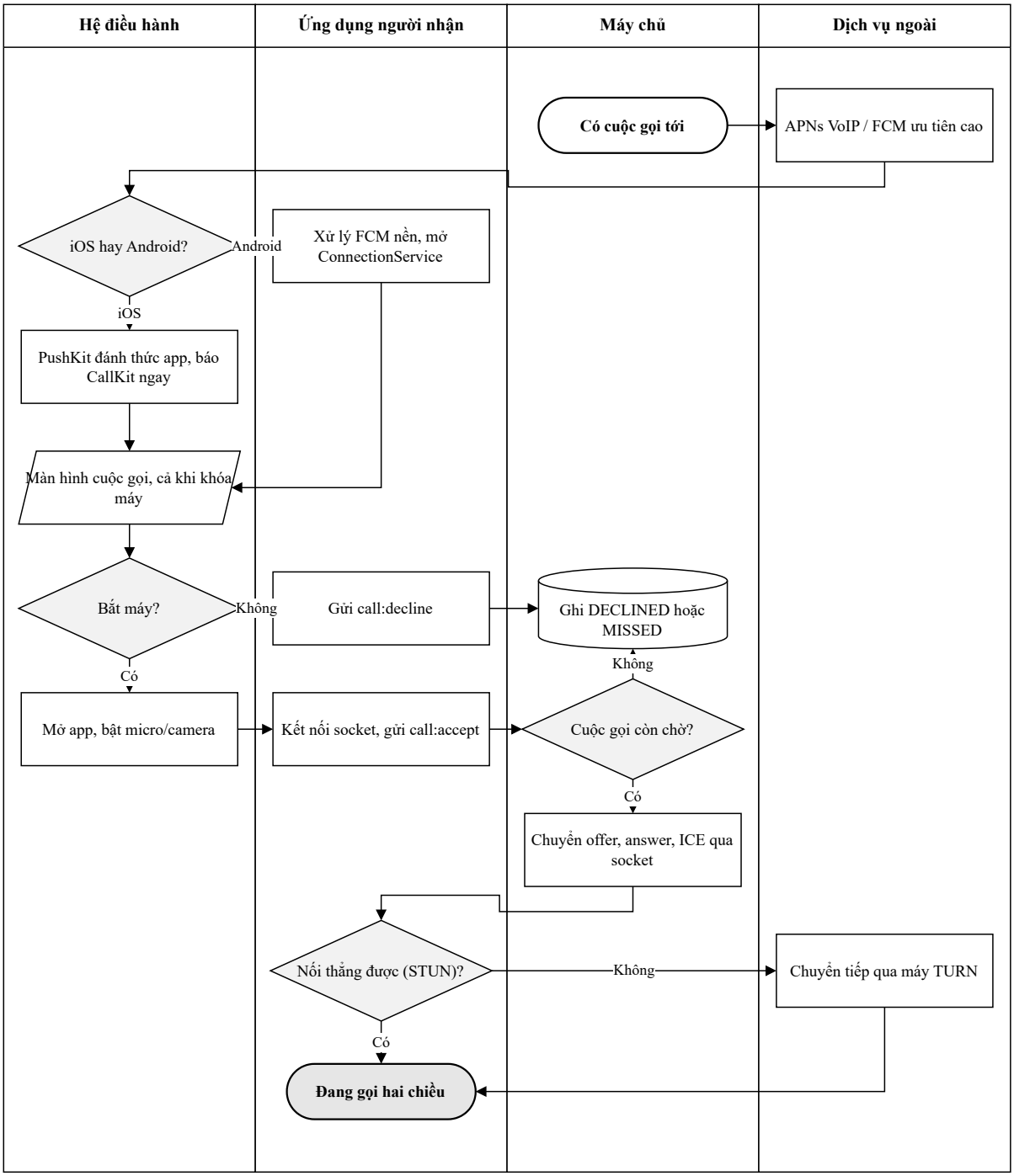
d) Flowchart

Gọi đi, kiểm tra quyền và đổ chuông:



Hình 54. Gọi đi: kiểm tra quyền và đổ chuông

Nhận cuộc gọi khi app đang tắt, rồi kết nối âm thanh/video (kể cả khi cần TURN):



Hình 55. Nhận cuộc gọi khi app đang tắt và kết nối âm thanh/video

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Ai được gọi cho ai (đề xuất):** chỉ trong hội thoại 1-1 thường (DIRECT) đã ở trạng thái ACCEPTED, không bị đóng, không có quan hệ chặn hai chiều. **Không gọi được** từ tin nhắn chờ (người lạ không được làm điện thoại reo) và **không gọi được trong hội thoại ẩn danh** (giọng nói, khuôn mặt lộ danh tính). Người nhận có cài đặt "Ai được gọi cho bạn": người đã nhắn tin với bạn (mặc định), chỉ người bạn theo dõi, không ai.

- **Chống quấy rối bằng cuộc gọi (đề xuất):** tối đa 20 cuộc gọi đi mỗi giờ; gọi một người 3 lần liên tiếp không ai nghe trong 15 phút thì bị khóa gọi người đó 1 giờ. Người nhận có nút "Chặn" và "Báo cáo" ngay trên màn hình cuộc gọi nhỡ. Liên quan B4.
- **Không ghi âm, không ghi hình cuộc gọi** ở máy chủ. Báo cáo cuộc gọi chỉ có nhật ký cuộc gọi (ai gọi, lúc nào, bao lâu) trong bản chụp báo cáo hội thoại.
- **Bận:** người nhận đang trong cuộc gọi khác thì người gọi thấy "Đang bận", người nhận có tin "Cuộc gọi nhỡ".
- **Nhiều thiết bị:** đổ chuông tất cả; máy nào bắt trước thì các máy khác dừng.
- **Chặn giữa cuộc gọi, tài khoản bị khóa:** máy chủ ngắt cuộc gọi ngay.
- **Mất mạng:** người gọi hủy trước khi người nhận bắt máy thì màn hình cuộc gọi bên kia phải tắt (gửi thêm push hủy). Không kết nối lại được sau 15 giây thì kết thúc với lý do "Mất kết nối".
- **Điện thoại Android tiết kiệm pin mạnh** (một số hãng phổ biến ở Việt Nam) có thể làm FCM đến chậm hoặc không đến khi app bị tắt. Đây là giới hạn thật; cần hướng dẫn người dùng tắt tối ưu pin cho app.
- **Gọi nhóm:** không có trong tính năng này. Gọi nhóm cần máy chủ trung gian (SFU) và chi phí khác hẳn.

f) Dữ liệu và API (đề xuất)

Đề xuất, cần đưa vào *docs/api-contract.md* và ghi quyết định chọn cách làm (tự làm hay dùng dịch vụ) vào *docs/decisions.md*.

Bảng / trường	**Nội dung**
Call (mới)	*id*, *conversationId*, *callerId*, *calleeId*, *type* (AUDIO | VIDEO), *status* (RINGING | ACTIVE | ENDED | MISSED | DECLINED | BUSY | CANCELED | FAILED), *createdAt*, *answeredAt*, *endedAt*, *endReason*, *relayed* (có qua TURN không, để theo dõi chi phí).
DeviceToken (thêm)	*kind*: EXPO (như hiện nay) | APNS_VOIP | FCM.
User (thêm)	*allowCallsFrom*: CONVERSATIONS | FOLLOWING | NOBODY.
Message	Tin hệ thống cho nhật ký cuộc gọi (dùng trường *systemEvent* đề xuất ở D1, giá trị CALL kèm *callId*).

Endpoint / sự kiện	**Việc**

GET */calls/ice-servers*	Danh sách STUN/TURN kèm tên đăng nhập và mật khẩu tạm hạn 1 giờ (sinh bằng khóa bí mật chung với máy TURN).
POST */calls { conversationId, type }*	Tạo cuộc gọi. Lỗi: CALL_NOT_ALLOWED, CALLEE_BUSY, CALL_RATE_LIMIT.
POST */calls/:id/accept* | *decline* | *cancel* | *end*	Dùng REST để màn hình CallKit/ConnectionService gọi được ngay cả khi socket chưa kịp kết nối.
GET */calls*	Lịch sử cuộc gọi.
POST */notifications/devices* (mở rộng)	Nhận thêm *kind* để lưu token VoIP và FCM.
Socket *call:incoming*, *call:accepted*, *call:ended*	Máy chủ báo trạng thái cho hai bên và các thiết bị khác.
Socket *call:signal* (hai chiều)	*{ callId, description* | *candidate }*; máy chủ chỉ chuyển nếu người gửi là một trong hai người của cuộc gọi đang ACTIVE hoặc RINGING.

Backend cần gửi thẳng tới APNs (push VoIP, khóa *.p8*, chủ đề *com.mobilesocial.app.voip*) và FCM (tin dữ liệu ưu tiên cao). Đây là hai dịch vụ ngoài mới bên cạnh Expo push.

g) Android, iOS và web

Ba cách làm, cần chủ dự án chọn:

Cách	**Gồm**	**Ưu**	**Nhược**
1. Tự làm	*react-native-webrtc* (kèm config plugin), thư viện CallKit/ConnectionService (ví dụ *react-native-callkeep*), thư viện PushKit cho iOS, FCM native cho Android, máy TURN tự chạy (coturn).	Không trả phí theo phút; dữ liệu không qua bên thứ ba.	Nhiều mã native nhất; các thư viện cộng đồng cần kiểm tra còn được bảo trì và chạy với React Native 0.86, Expo SDK 57, kiến trúc mới. Rủi ro tiến độ cao.
2. Dịch vụ gọi có sẵn đổ chuông	SDK của một nhà cung cấp có sẵn phần đổ chuông kèm CallKit, push VoIP và config plugin cho Expo (ví dụ Stream Video; Agora, LiveKit cần tự làm thêm phần đổ chuông).	Ít mã native nhất; TURN có sẵn.	Phí theo phút người dùng; phụ thuộc nhà cung cấp; cần kiểm tra hỗ trợ SDK 57 và báo giá.

3. Chỉ gọi khi app đang mở (bước đệm)	WebRTC + socket, không CallKit, không push VoIP.	Khoảng 12 ngày công.	Người nhận tắt app là không biết có cuộc gọi; trải nghiệm kém, không nên phát hành lâu dài.

- **Bắt buộc dùng bản development, không dùng được Expo Go** cho cả ba cách (WebRTC là mã native). Cần build bằng EAS Build hoặc Xcode/Android Studio cho cả hai nền tảng; build iOS cần tài khoản Apple Developer (99 USD/năm) và máy Mac nếu build tại chỗ.
- **iOS, khai báo trong *app.json*:** *NSMicrophoneUsageDescription* ("Ứng dụng cần micro để bạn gọi thoại và gọi video."), *NSCameraUsageDescription* ("Ứng dụng cần camera để bạn gọi video."), *UIBackgroundModes*: *audio*, *voip*, *remote-notification*; bật Push Notifications cho bundle *com.mobilesocial.app*. Apple yêu cầu push VoIP chỉ dùng cho cuộc gọi thật. CallKit không được phép ở cửa hàng Trung Quốc; nếu phát hành ở đó phải tắt CallKit cho khu vực này.
- **Android, khai báo cùng thay đổi:** *RECORD_AUDIO*, *CAMERA*, *MODIFY_AUDIO_SETTINGS*, *BLUETOOTH_CONNECT* (tai nghe, Android 12+), *POST_NOTIFICATIONS* (Android 13+), *USE_FULL_SCREEN_INTENT*, *MANAGE_OWN_CALLS*, *FOREGROUND_SERVICE* cùng loại dịch vụ nền cho gọi điện, micro, camera (Android 14+). Google Play yêu cầu khai báo lý do dùng thông báo toàn màn hình và dịch vụ nền trong Play Console (thường kèm video minh họa).
- **FCM native trên Android** cần tệp *google-services.json* và cấu hình Firebase cho *com.mobilesocial.app*. Phía iOS dùng APNs (push VoIP), không dùng FCM. Cả hai phía phải làm trong cùng đợt (RULE.md mục 10); phía nào chưa làm được thì ghi là việc còn mở.
- **Kiểm thử cần máy thật:** trình giả lập iOS không nhận push VoIP và không có camera. Tối thiểu 2 iPhone và 2 điện thoại Android (trong đó có một máy hãng tiết kiệm pin mạnh).
- **Chi phí TURN (tham khảo, cần kiểm tra lại giá lúc làm):** gọi thoại khoảng 35–50 MB/giờ, gọi video 720p khoảng 1,2–1,5 GB/giờ khi phải đi qua TURN. Thường khoảng 10–20% cuộc gọi cần TURN. Tự chạy coturn trên một VPS khoảng 10–20 USD/tháng cộng phí băng thông vượt mức. TURN dịch vụ: Cloudflare khoảng 0,05 USD/GB, Twilio khoảng 0,40 USD/GB. Ví dụ 1.000 giờ gọi video/tháng, 20% qua TURN ≈ 270 GB ≈ 14 USD (Cloudflare) hoặc ≈ 110 USD (Twilio).

- **Máy chủ:** khi chạy nhiều máy chủ API, socket báo hiệu cần Redis adapter để hai người ở hai máy chủ khác nhau vẫn trao đổi được.
- **Web:** không có. Web quản trị chỉ xem nhật ký cuộc gọi trong báo cáo.

h) Tiêu chí hoàn thành

- Gọi thoại và gọi video giữa: Android–Android, iPhone–iPhone, Android–iPhone, trên Wi-Fi và 4G.
- Người nhận đã tắt hẳn app vẫn thấy màn hình cuộc gọi của hệ thống, kể cả khi khóa máy, trên cả iPhone và Android.
- Hai máy sau tường lửa chặn nối thẳng vẫn gọi được (qua TURN; trường *relayed* đúng).
- Không gọi được từ tin nhắn chờ, hội thoại ẩn danh, khi có chặn, khi người nhận chọn "Không ai"; app hiện câu tiếng Việt rõ ràng.
- Gọi 3 lần không ai nghe thì bị khóa gọi 1 giờ; cuộc gọi nhỡ có nút chặn và báo cáo.
- Người gọi hủy khi đang đổ chuông thì màn hình bên kia tắt; bận; hết 45 giây; đổi mạng giữa cuộc gọi.
- Nhật ký cuộc gọi hiện trong chat và trong bản chụp báo cáo của quản trị viên app.
- Bản development và bản phát hành build được cho cả hai nền tảng; quyền khai báo đủ; Play Console đã khai báo dịch vụ nền. Ghi rõ máy đã chạy trong *docs/change.md*.

i) Ước lượng và phụ thuộc

- Cách 1 (tự làm): backend 8 ngày (bảng, API, quy tắc quyền: 2; báo hiệu socket: 2; push APNs VoIP và FCM: 3; TURN và mật khẩu tạm: 1). Mobile 16 ngày (WebRTC và màn hình cuộc gọi: 5; CallKit/ConnectionService: 5; push VoIP và FCM nền: 4; quyền, build, cấu hình hai nền tảng: 2). Kiểm thử 6 ngày trên máy thật. Cộng khoảng 30 ngày công, chưa tính thời gian Google Play và App Store duyệt quyền.
- Cách 2 (dịch vụ có sẵn): khoảng 15–18 ngày công cộng phí dịch vụ hằng tháng (cần báo giá).
- Phụ thuộc: B1 (quy tắc ai được liên hệ), B4 (giới hạn khi bị quấy rối), D8 (hạ tầng push, token theo loại), D1 hoặc D2 (tin hệ thống trong chat cho nhật ký cuộc gọi), A2 (phiên đăng nhập: thu hồi phiên thì xóa token VoIP).
- Rủi ro: thư viện native cộng đồng không theo kịp phiên bản React Native; iOS ngừng gửi push VoIP nếu app không báo CallKit kịp; FCM bị hãng điện thoại chặn khi tiết kiệm pin; chi phí TURN tăng theo số giờ gọi video. Đề xuất làm một bản

thử nhỏ (2–3 ngày) gọi thoại Android–iPhone qua bản development trước khi cam kết tiến độ.

D5. Xếp hạng bảng tin và Reels theo tương tác

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ3 · Ước lượng: 11–13 ngày công

a) Mục đích

Bảng tin hiện xếp bài theo thời gian. Người theo dõi nhiều tài khoản sẽ bỏ lỡ bài của người thân quen vì bị bài mới hơn đẩy xuống. Tính năng này xếp bài theo một công thức đơn giản, giải thích được: bài của người mình hay tương tác, bài mới, bài được nhiều người quan tâm đứng trước; bài bị báo cáo hoặc nhạy cảm bị hạ xuống. Mỗi bài có nút "Vì sao tôi thấy bài này" để người dùng hiểu và tự điều chỉnh (Không quan tâm, Bỏ theo dõi). Reels dùng cùng bộ tín hiệu, nâng cấp từ bản xếp hạng đầu tiên đang chạy.

b) Hiện trạng

- **Bảng tin** (*apps/api/src/modules/posts/posts.service.ts*, hàm *getFeed*): gồm bài của chính mình và của người mình theo dõi, cộng các lượt đăng lại (repost) của những người đó. Hai nguồn được lấy riêng, ghép lại và **xếp thuần theo thời gian** (*createdAt* giảm dần, trùng giờ thì theo id). Phân trang kiểu *page/limit* (mặc định 10, tối đa 50); vì ghép hai nguồn nên trang càng sâu càng chậm (ghi chú *shortcut* trong code và DEC-020).
- **Quyền xem** dùng chung hàm *visiblePostWhere* (*posts/post-view.ts*): chưa xóa, không chặn nhau hai chiều, bài PUBLIC (tài khoản riêng tư thì chỉ người theo dõi), bài của chính mình, bài FRIENDS khi theo dõi hai chiều. Bài đã ẩn (*HiddenPost*) bị loại khỏi bảng tin và Reels.
- **Ẩn bài và "Không quan tâm"**: *POST /posts/:id/hide* và *POST /posts/:id/not-interested* làm cùng một việc (ghi *HiddenPost*). App có "Ẩn bài viết" ở bảng tin và "Không quan tâm" ở Reels. Cả hai chỉ ẩn đúng bài đó, **không** ảnh hưởng tới bài khác của cùng tác giả.
- **Reels** (*apps/api/src/modules/reels/reels.service.ts*): lấy 200 video dọc mới nhất mà người xem được phép xem, chấm điểm trong bộ nhớ: *2/(1 + tuổi giờ/24) + log(1 + thích + 2×bình luận + 3×đăng lại) + 1,5 nếu đang theo dõi tác giả − 100 nếu đã xem trong 7 ngày*. Mỗi video trả kèm *reason* (*FOLLOWING*, *TRENDING*, *FRESH*). Phân trang bằng danh sách id đã hiện (*exclude*, tối đa 50 id).
- **Ghi tương tác Reels**: app (*apps/mobile/src/features/reel/hooks/useReelViewTracker.ts*) gom sự kiện *VIEW*, *COMPLETE* (xem ≥ 90% hoặc phát lại), *REPLAY*, *SKIP* (lướt qua dưới 2 giây), *LIKE*, *SAVE*, *NOT_INTERESTED*; gửi theo lô khi đủ 10 sự kiện, mỗi 10 giây và khi app vào nền; mất mạng thì giữ tối đa 200 sự kiện. Máy chủ ghi vào

ContentInteraction, bỏ sự kiện trùng *eventId* và sự kiện của bài không còn tồn tại. Máy chủ **chưa kiểm tra** người gửi có quyền xem bài đó không.

- **Dữ liệu ghi rồi nhưng chưa dùng**: ngoài "đã xem 7 ngày", *ContentInteraction* chưa được dùng để xếp hạng (chưa có *COMPLETE* rate, chưa có điểm sở thích). Bảng tin chưa ghi sự kiện nào.
- **"Vì sao tôi thấy"**: API Reels đã trả *reason*, nhưng app **chưa hiển thị** (không thấy dùng trong *features/reel*). Bảng tin chưa có lý do.
- **An toàn**: bài viết chưa có cờ nhạy cảm (chỉ tin nhắn có *Message.sensitive*); báo cáo (*Report*) không ảnh hưởng thứ hạng. Cần kiểm tra: bảng tin, Reels và tìm kiếm hiện không lọc bài của tác giả bị khóa (*User.bannedAt*); khóa chỉ chặn đăng nhập (*auth.service.ts*).
- **Kế hoạch cũ**: *docs/reel/REEL_FINAL_SPEC_AND_PLAN.md* mục 6 đã đề xuất bộ máy gợi ý cho Reels (chủ đề, *UserInterest*, *PostStats*, *RecommendationLog*). Các bảng đó **chưa có** trong *schema.prisma*. Đặc tả này dùng lại công thức và trọng số của tài liệu đó cho Reels, và thêm phần bảng tin.

c) Cách hoạt động

Luồng 1: Dựng một trang bảng tin

1. Người dùng mở tab Trang chủ hoặc kéo xuống để làm mới. App gửi *GET /posts/feed*, kèm con trỏ (cursor, tức "dấu trang" do máy chủ trả ở lần trước) nếu đang cuộn tiếp.
2. Máy chủ xem có bản xếp hạng còn hạn của người này không (*FeedSnapshot*, sống 15 phút, đề xuất). Có và người dùng đang cuộn tiếp thì cắt 10 bài kế tiếp từ bản đó, khỏi tính lại. Kéo để làm mới luôn tính lại.
3. Không có thì lấy **ứng viên** (candidate, tức các bài có thể được hiện): bài và lượt đăng lại của người mình theo dõi trong 7 ngày (tối đa 300), bài của chính mình trong 7 ngày.
4. Nếu dưới 100 ứng viên và chủ dự án bật "gợi ý" (xem câu hỏi mở), thêm tối đa 30 bài công khai nổi bật trong 3 ngày từ tài khoản công khai. Khi tắt, bảng tin vẫn chỉ gồm người mình theo dõi như DEC-023.
5. **Lọc**: dùng *visiblePostWhere*, bỏ bài đã ẩn, bài của tác giả bị khóa, bài bị kiểm duyệt ẩn hoặc gỡ (trường *hiddenAt*/*removedAt* của C1), và tác giả bị người xem tắt tiếng (B8).
6. **Hạ hạng an toàn**: bài có từ 3 báo cáo đang mở từ 3 người khác nhau, hoặc được đánh dấu nhạy cảm (B5) mà người xem chưa bật "hiện nội dung nhạy cảm", bị

nhân điểm 0,3. Bài có từ 10 báo cáo đang mở thì loại khỏi bảng tin của người khác (vẫn hiện trên trang cá nhân) cho tới khi người duyệt xử lý trong hàng đợi C1.

7. **Tính điểm** từng bài theo công thức ở mục e, lưu lại điểm từng phần để giải thích.
8. **Trộn đa dạng**: không quá 2 bài liền nhau của cùng một tác giả; không quá 3 video liền nhau; một bài và lượt đăng lại của chính bài đó chỉ hiện một lần (giữ mục có điểm cao hơn, ghi "X đã đăng lại").
9. Lưu thứ tự vào *FeedSnapshot*, cắt 10 bài đầu, trả kèm *reason* cho từng bài và con trỏ trang sau.
10. App hiện bài như hiện nay. Menu ba chấm của mỗi bài có thêm "Vì sao tôi thấy bài này".

Luồng 2: Ghi nhận tương tác và dùng lại

1. Reels: giữ nguyên cách gom sự kiện hiện có. Bảng tin: thêm cùng bộ gom cho *surface = "feed"*, chỉ ghi *VIEW* khi bài hiện trên màn hình ít nhất 1 giây (đề xuất) và các thao tác thích, bình luận, lưu, chia sẻ, ẩn.
2. App gửi lô *POST /interactions* (tối đa 50 sự kiện). Lỗi mạng thì giữ lại và gửi kèm lô sau, như hiện nay.
3. Máy chủ bổ sung kiểm tra: bài phải còn xem được với người gửi (dùng *visiblePostWhere*), không chỉ "còn tồn tại". Sự kiện trùng *eventId* không ghi lần hai.
4. Khi ghi xong, máy chủ cộng, trừ điểm sở thích ngay theo bảng ở mục e: điểm theo chủ đề (*UserInterest*, theo kế hoạch Reels) và điểm theo tác giả (*AuthorAffinity*, mới). Điểm giảm dần theo thời gian bằng cách nhân hệ số lúc đọc, không cần tác vụ chạy định kỳ.
5. "Không quan tâm" vừa ẩn bài (như hiện nay) vừa trừ điểm tác giả và chủ đề, nên các bài tương tự của tác giả đó cũng chìm xuống trong 30 ngày.
6. Lần xếp hạng sau (bảng tin hoặc Reels) đọc các điểm này.

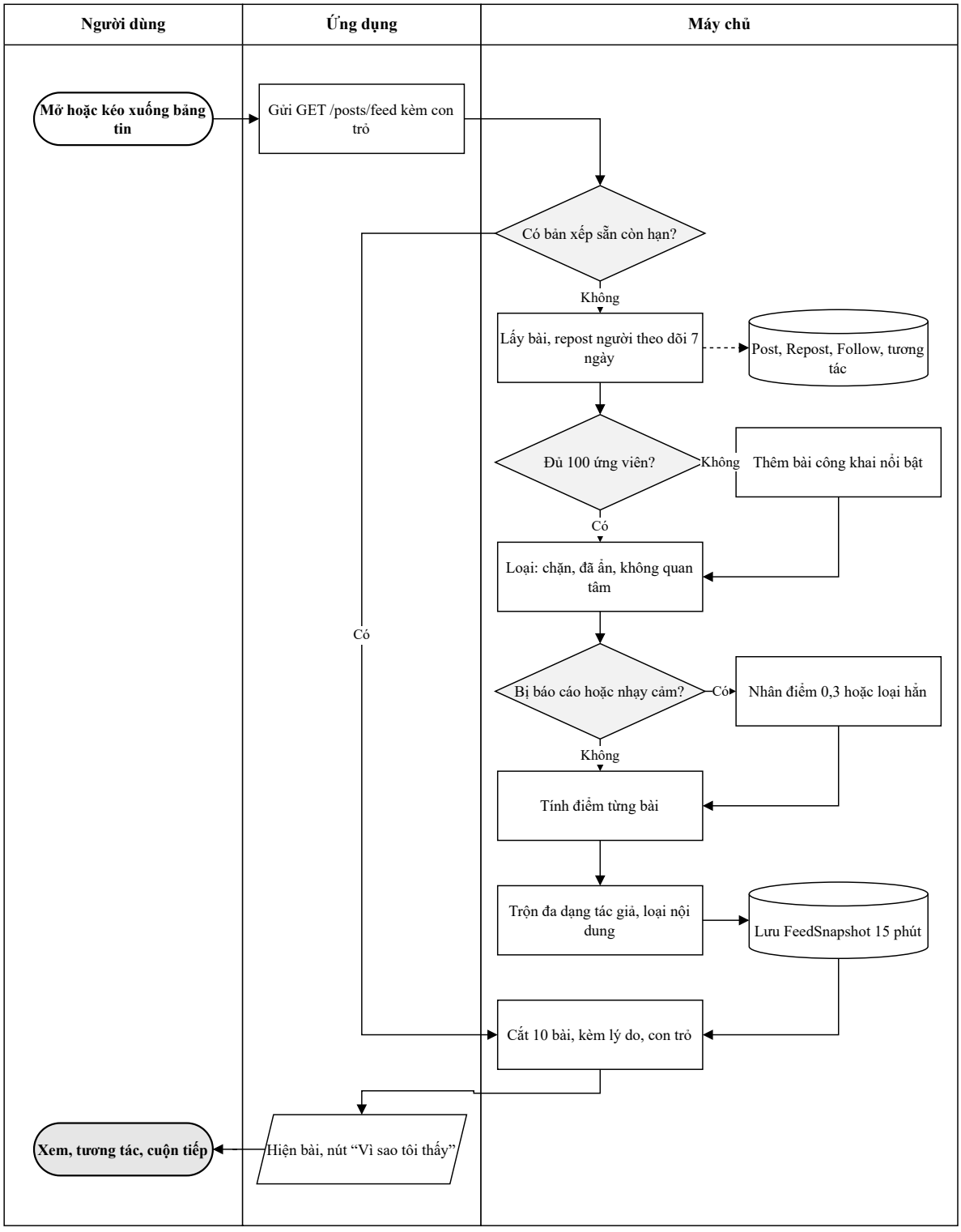
Luồng 3: "Vì sao tôi thấy bài này"

1. Người dùng bấm "Vì sao tôi thấy bài này" trong menu bài viết (bảng tin) hoặc menu Reels.
2. App hiện ngay lý do chính đã nhận từ máy chủ (không cần gọi thêm), ví dụ: "Bạn theo dõi Lan", "Bạn hay tương tác với bài của Lan", "Minh đã đăng lại", "Bài mới đăng", "Đang được nhiều người quan tâm", "Gợi ý: bài công khai về chủ đề bạn hay xem".
3. Bên dưới là các nút điều chỉnh: "Không quan tâm" (ẩn bài, hạ điểm tác giả), "Tắt tiếng [tên]" (B8), "Bỏ theo dõi". Bấm xong app báo "Bạn sẽ thấy ít bài như thế này

hơn".

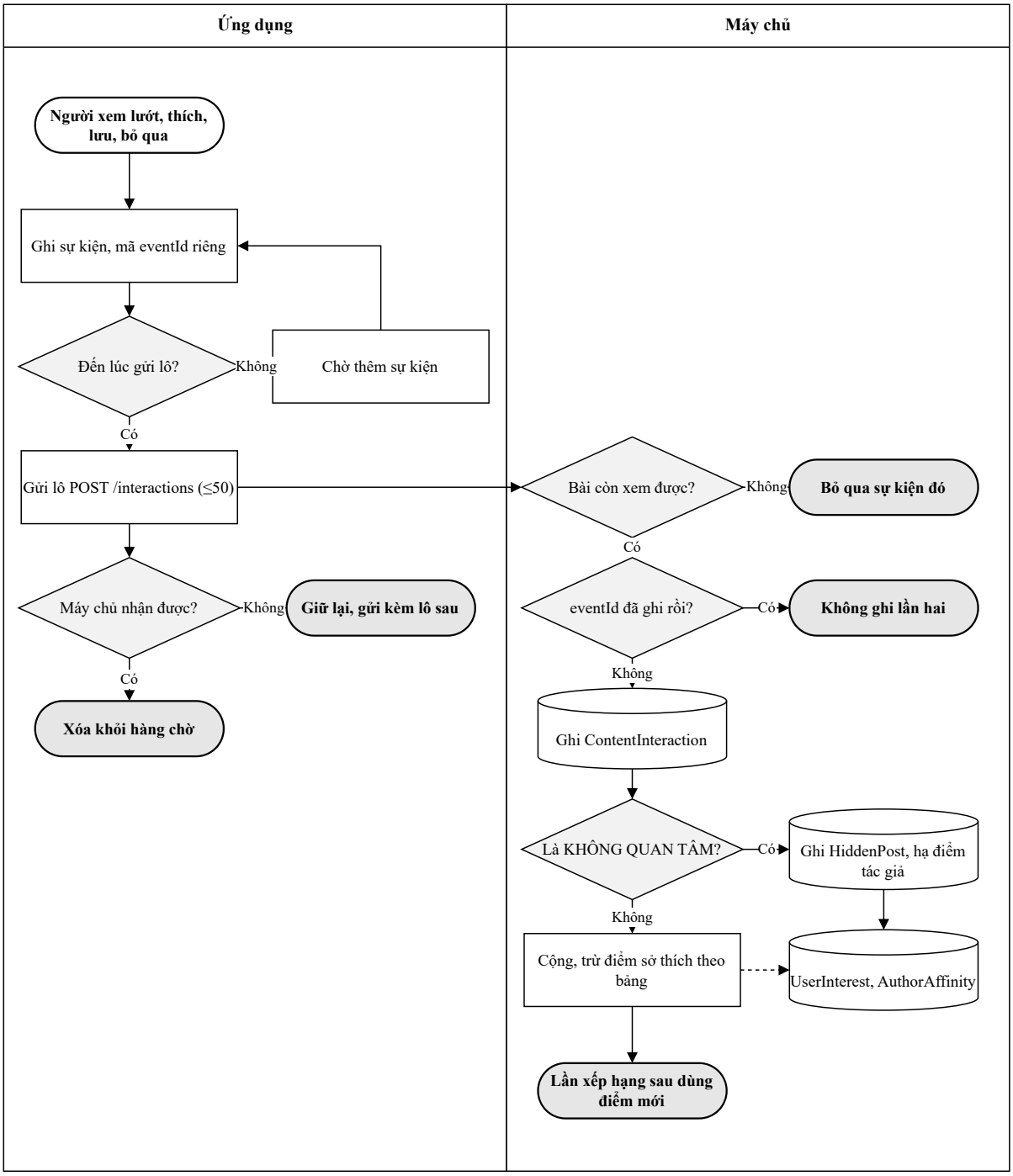
d) Flowchart

Sơ đồ 1 mô tả cách máy chủ dựng một trang bảng tin, có bộ đệm và các bước lọc an toàn.



Hình 56. Dựng một trang bảng tin có xếp hạng

Sơ đồ 2 mô tả cách app ghi và gửi tương tác, và cách máy chủ biến chúng thành điểm sở thích.



Hình 57. Ghi nhận tương tác và dùng lại khi xếp hạng

e) Quy tắc, giới hạn và trường hợp đặc biệt

Công thức bảng tin (mọi trọng số là đề xuất, đặt trong một file cấu hình để chỉnh mà không sửa code):

Thành phần	Cách tính	Trọng số

Độ mới	0,5 mũ (số giờ tuổi / 12): bài 12 giờ còn 50%, 24 giờ còn 25%	4
Quan hệ với tác giả	Điểm *AuthorAffinity* 30 ngày, đưa về 0–1: thích 1, lưu 2, bình luận 3, đăng lại 4, xem hết video 1, có nhắn tin 1-1 trong 30 ngày +5	3
Mức quan tâm của bài	log(1 + thích + 2×bình luận + 3×đăng lại + 2×lưu), tối đa 1,5 (giống Reels hiện nay, thêm lưu)	1
Thưởng	+0,5 nếu theo dõi hai chiều; +2 bài của chính mình trong 1 giờ đầu (để thấy ngay bài vừa đăng)	—
Phạt	−2 nếu bài đã hiện trên màn hình của người này trong 3 ngày; −50% phần "quan hệ" nếu người xem bấm "Không quan tâm" bài của tác giả này trong 30 ngày	—
Hệ số an toàn	× 0,3 nếu ≥ 3 báo cáo mở hoặc nhạy cảm (người xem chưa bật xem); loại nếu ≥ 10 báo cáo mở, bị kiểm duyệt ẩn/gỡ, hoặc tác giả bị khóa	—

Reels dùng công thức đã chốt trong *REEL_FINAL_SPEC_AND_PLAN.md*: 0,30 × chủ đề + 0,25 × chất lượng (tỷ lệ xem hết, làm mượt cho video ít lượt xem) + 0,25 × quan hệ + 0,20 × độ mới (0,5 mũ giờ/48), cộng hệ số an toàn như trên. Bảng cộng, trừ điểm sở thích giữ như tài liệu đó: xem hết +3, phát lại +4, thích +4, bình luận +5, lưu +5, theo dõi +8, lướt qua dưới 2 giây −2, Không quan tâm −10.

- **Giải thích được**: *reason* lấy từ thành phần đóng góp nhiều điểm nhất. Máy chủ không trả con số điểm cho app (tránh người dùng dò công thức để câu tương tác), nhưng lưu điểm từng phần vào *RecommendationLog* để dev và admin xem lại.
- **Tài khoản mới** chưa theo dõi ai: bảng tin trống như hiện nay (có nút sang Tìm kiếm), hoặc có bài gợi ý nếu chủ dự án bật.
- **Bộ đệm**: *FeedSnapshot* sống 15 phút, tối đa 300 mục. Bị xóa khi người dùng đăng bài, theo dõi/bỏ theo dõi, chặn ai đó hoặc kéo để làm mới. Khi cắt trang từ bản đệm, máy chủ vẫn lọc lại quyền xem (bài có thể bị xóa hoặc chặn trong 15 phút đó); bài bị lọc thì bỏ qua, không hiện chỗ trống.
- **Ổn định khi cuộn**: trang sau lấy từ cùng một bản xếp hạng, nên không lặp hoặc sót bài khi điểm thay đổi giữa hai lần cuộn.
- **Lỗi khi tính điểm** (ví dụ bảng điểm sở thích lỗi): máy chủ trả bảng tin theo thời gian như hiện nay, không trả lỗi cho người dùng. Ghi log để dev xem.
- **Chống lạm dụng**: *POST /interactions* tối đa 50 sự kiện mỗi lô, đề xuất tối đa 600 sự kiện mỗi người mỗi giờ; vượt thì bỏ phần thừa (trả 204 như thường). Thích/bỏ thích liên tục cùng một bài chỉ tính một lần mỗi ngày. Báo cáo dùng để hạ hạng chỉ tính từ tài khoản ≥ 7 ngày tuổi, đã xác minh email, để một nhóm tài khoản mới không đè được bài của người khác.

- **Người bị chặn**: không bao giờ vào ứng viên (đã có trong *visiblePostWhere*). Chặn ai đó thì xóa bộ đệm ngay.
- **Quyền riêng tư dữ liệu**: *ContentInteraction* là dữ liệu cá nhân; giữ 90 ngày (đề xuất) rồi xóa; đưa vào gói "Tải xuống dữ liệu của bạn" (E1) và xóa cùng tài khoản (đã có *onDelete: Cascade*).

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và được Dev B duyệt trước khi code. Mọi thay đổi bảng là migration mới, chỉ thêm (không *db push*).

Bảng / trường	**Nội dung**
AuthorAffinity (mới)	*userId*, *authorId*, *score* (Float), *updatedAt*; khóa chính (*userId*, *authorId*). Giảm dần khi đọc: nhân 0,5 mũ (số ngày từ *updatedAt* / 14).
Topic, *PostTopic*, *UserInterest*, *PostStats*, *RecommendationLog*	Đúng như *REEL_FINAL_SPEC_AND_PLAN.md* mục 4. *RecommendationLog* lưu điểm từng phần; giữ 30 ngày.
FeedSnapshot (mới)	*id*, *userId* (duy nhất), *items* (Json: danh sách *{ type, id, reason }*), *createdAt*, *expiresAt*. Dùng PostgreSQL sẵn có, không cần Redis.
ContentInteraction.eventType	Thêm giá trị *COMMENT*, *SHARE*, *HIDE*; *surface* thêm *"feed"*. Thêm chỉ mục (*userId*, *postId*).

Endpoint	**Thay đổi**
GET /posts/feed? cursor=&limit=&refresh=	Thêm *cursor* và *refresh*; vẫn nhận *page* trong một bản phát hành để app cũ chạy được. Mỗi mục có thêm *reason: { code, text }*. *meta* có *nextCursor* (null khi hết).
GET /reels/feed	Giữ nguyên hình dạng; *reason.code* thêm *TOPIC*, *CLOSE_INTERACTION*.
POST /interactions	Giữ nguyên; thêm kiểm tra quyền xem và giới hạn mỗi giờ.
POST /posts/:id/not-interested	Giữ nguyên kết quả; thêm việc trừ điểm tác giả và chủ đề.

Mã lý do đề xuất: *OWN*, *FOLLOWING*, *CLOSE_INTERACTION*, *REPOSTED_BY*, *TRENDING*, *FRESH*, *TOPIC*, *SUGGESTED*.

g) Android, iOS và web

- Phần lớn việc ở máy chủ; app chỉ thêm bộ gom sự kiện cho bảng tin (dùng lại *useReelViewTracker*), hiện *reason* và thêm mục menu. Không cần quyền thiết bị, không thêm thư viện.

- Đo "bài hiện trên màn hình ≥ 1 giây" dùng *onViewableItemsChanged* của *FlatList*, có trên cả Android và iOS. Khi app vào nền thì gửi lô ngay (đã có với *AppState*); iOS có thể dừng app nhanh hơn Android nên lô cuối có thể mất, chấp nhận được.
- Bảng "Vì sao tôi thấy" dùng *ActionSheet* sẵn có của app, không dùng *ActionSheetIOS*.
- Trang quản trị web: thêm ô xem *RecommendationLog* của một bài (vì sao bài lên cao) để xử lý khiếu nại.
- Chi phí: không có dịch vụ ngoài. Tải cơ sở dữ liệu tăng do ghi sự kiện bảng tin; ước tính 50–100 dòng mỗi người dùng hoạt động mỗi ngày.

h) Tiêu chí hoàn thành

- Bảng tin xếp theo công thức: test tự động với dữ liệu mẫu chứng minh bài của người hay tương tác đứng trên bài mới hơn của người ít tương tác; bài 2 ngày tuổi không đứng trên bài 1 giờ tuổi cùng tác giả khi tương tác ngang nhau.
- Không có hai bài liền nhau của cùng tác giả quá 2 lần; bài và lượt đăng lại của nó không cùng hiện.
- Bài có ≥ 3 báo cáo mở bị hạ; bài ≥ 10 báo cáo mở không hiện cho người khác; tác giả bị khóa không còn bài trong bảng tin, Reels, tìm kiếm.
- Cuộn 5 trang liên tiếp không lặp bài; kéo làm mới cho thứ tự mới.
- "Không quan tâm" làm bài đó biến mất và bài khác của tác giả đó tụt hạng ở lần làm mới sau (test tự động).
- "Vì sao tôi thấy bài này" hiện đúng lý do ở bảng tin và Reels.
- Gửi lại một lô sự kiện không tạo dòng trùng; sự kiện của bài không có quyền xem bị bỏ.
- Chạy trên máy Android và iPhone thật: cuộn bảng tin, Reels, menu "Vì sao". Báo cáo ghi rõ đã chạy trên nền tảng nào.
- Bảng tin trả trang đầu dưới 500 ms với 1.000 người theo dõi và 10.000 bài trong 7 ngày (đo trên máy chủ thử).

i) Ước lượng và phụ thuộc

- Backend 6 ngày (ứng viên, lọc, điểm, đa dạng, bộ đệm, cập nhật điểm sở thích, test), mobile 3 ngày (gom sự kiện bảng tin, lý do, menu, cursor), kiểm thử 2 ngày.
- Phụ thuộc: B5 (cờ nhạy cảm của bài), C1 (trạng thái ẩn/gỡ do kiểm duyệt, hàng đợi khi bị báo cáo nhiều), B8 (tắt tiếng). Có thể làm trước với hệ số an toàn chỉ dựa trên số báo cáo, rồi nối B5/C1 khi có.
- Phần chủ đề (*Topic*, *UserInterest*) là Phase 4–5 của kế hoạch Reels; nếu chưa làm thì công thức bảng tin vẫn chạy được không có chủ đề.

- Rủi ro: ít dữ liệu tương tác khi số người dùng còn nhỏ, nên công thức gần như theo thời gian; trọng số cần chỉnh sau khi có số liệu thật. Đổi phân trang sang cursor phải giữ tương thích với app đang cài.

D6. Bài viết nâng cao: trích dẫn bài, bình chọn, gắn thẻ người, lịch sử chỉnh sửa, ghim bài

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ3 · Ước lượng: 18–20 ngày công

a) Mục đích

Năm tính năng nhỏ giúp bài viết đủ dùng như các mạng xã hội quen thuộc: **trích dẫn bài** (đăng lại kèm lời bình của mình), **bình chọn** (hỏi ý kiến bạn bè), **gắn thẻ người** (ghi "cùng với ai"), **lịch sử chỉnh sửa** (ai cũng xem được bài đã bị sửa gì) và **ghim bài** lên đầu trang cá nhân. Lịch sử chỉnh sửa còn là công cụ an toàn: người quấy rối không thể sửa bài thành vô hại sau khi bị báo cáo để thoát xử lý. Gắn thẻ có bước duyệt để không ai bị gán tên vào bài mình không muốn.

b) Hiện trạng

- **Bài viết** (*apps/api/src/modules/posts*): chữ, tối đa 4 ảnh (mỗi ảnh ≤ 5 MB) hoặc một video ≤ 60 giây; quyền xem *PUBLIC*, *FRIENDS* (theo dõi hai chiều), *PRIVATE*. Xóa là xóa mềm (*deletedAt*).
- **Đăng lại** (*Repost*): chỉ đăng lại nguyên bài, không kèm lời; không đăng lại bài của chính mình; tác giả nhận thông báo *REPOST*. Nếu bài gốc bị xóa hoặc người xem mất quyền xem, thẻ hiện "không khả dụng". Server cho đăng lại cả bài *FRIENDS* miễn người đăng lại xem được (bài vẫn chỉ hiện với người có quyền xem bài gốc). **Chưa có trích dẫn.**
- **Sửa bài** (*PATCH /posts/:id*, *posts.service.ts* hàm *update*): sửa chữ, ảnh, quyền xem; ghi đè trực tiếp, **không lưu bản cũ**. *Post* chỉ có *updatedAt* (đổi cả khi chỉ đổi quyền xem), không có *editedAt* (bình luận thì có *Comment.editedAt*). Sửa bài **không** gửi thông báo cho người mới được nhắc tên.
- **Nhắc tên (@)**: *NotificationsService.notifyMentions* tìm mọi chuỗi *@tên* (3–30 ký tự chữ, số, dấu chấm, gạch dưới) và báo từng người. Bỏ qua bài *PRIVATE* và người bị chặn, nhưng **không** kiểm tra người được nhắc có xem được bài *FRIENDS* hay không (họ nhận thông báo rồi mở ra lỗi 404), và **không giới hạn** số người được nhắc trong một bài.
- **Chưa có**: bình chọn, gắn thẻ người, ghim bài. Trang cá nhân xếp bài theo thời gian (*users.service.ts* hàm *findUserPosts*).
- App: *apps/mobile/src/features/post* (màn tạo bài *CreateScreen*, *EditPostModal*, *PostOptionsModal*), thẻ bài *features/feed/components/PostCard.tsx*.

c) Cách hoạt động

Luồng 1: Trích dẫn bài

1. Ở nút Đăng lại, người dùng chọn "Trích dẫn". App mở màn tạo bài, bài gốc hiện dạng thẻ nhỏ bên dưới ô nhập.
2. Người dùng viết lời bình (bắt buộc; không viết gì thì dùng Đăng lại thường) và chọn quyền xem cho bài của mình.
3. Máy chủ kiểm tra: bài gốc còn và người trích dẫn xem được; bài gốc là *PUBLIC* của tài khoản công khai (bài *FRIENDS*, bài của tài khoản riêng tư không trích dẫn được, để nội dung không lọt ra ngoài nhóm người tác giả đã chọn); hai bên không chặn nhau.
4. Máy chủ tạo bài mới có *quotedPostId*, báo tác giả gốc (thông báo *QUOTE*).
5. Khi hiện, mỗi người xem được kiểm tra lại quyền xem bài gốc. Không có quyền hoặc bài gốc đã xóa: thẻ trích dẫn hiện "Bài viết không còn khả dụng", lời bình vẫn hiện. Trích dẫn của một bài trích dẫn chỉ hiện một tầng.

Luồng 2: Bình chọn

1. Ở màn tạo bài, người dùng bấm "Bình chọn", nhập 2–4 phương án (mỗi phương án ≤ 80 ký tự) và thời hạn (1 giờ, 1 ngày, 3 ngày, 7 ngày; mặc định 1 ngày). Câu hỏi là nội dung bài.
2. Người xem bấm một phương án. App gửi *POST /polls/:id/votes*. Máy chủ kiểm tra: xem được bài, bình chọn chưa đóng, phương án thuộc bình chọn này.
3. Chưa bỏ phiếu thì tạo phiếu; đã bỏ phiếu thì đổi sang phương án mới (được đổi cho tới khi đóng). Mỗi người một phiếu.
4. Máy chủ trả số phiếu và phần trăm. Người chưa bỏ phiếu chỉ thấy các nút chọn; người đã bỏ phiếu, tác giả, và mọi người sau khi đóng thì thấy kết quả.
5. Không ai thấy danh sách ai chọn gì, kể cả tác giả (chỉ thấy con số).
6. Đến giờ đóng, tác vụ chạy mỗi phút ghi *closedAt*, rồi báo tác giả và người đã bỏ phiếu: "Bình chọn đã có kết quả". Tác giả cũng có thể đóng sớm.

Luồng 3: Gắn thẻ người

1. Ở màn tạo hoặc sửa bài, người dùng bấm "Gắn thẻ" và tìm người (dùng chung ô gợi ý của D9). Tối đa 20 người mỗi bài.
2. Máy chủ bỏ qua (không báo ai) người có chặn với người đăng, hoặc người đã chọn "Không ai được gắn thẻ tôi".
3. Người được gắn thẻ phải xem được bài. Bài *PRIVATE* không gắn thẻ được; bài *FRIENDS* chỉ gắn người theo dõi hai chiều. Ai không xem được thì thẻ bị bỏ và app báo người đăng.

4. Cần duyệt khi: người được gắn thẻ bật "Duyệt thẻ trước khi hiện" (mặc định bật với thẻ từ người mình không theo dõi), hoặc người đăng đang bị họ hạn chế (B8). Thẻ ở trạng thái chờ chỉ người đăng thấy (mờ).
5. Người được gắn thẻ nhận thông báo "X muốn gắn thẻ bạn" và chọn Chấp nhận hoặc Từ chối. Từ chối thì thẻ bị xóa, người đăng không được báo. Không trả lời trong 14 ngày thì thẻ tự hủy.
6. Thẻ được chấp nhận hiện "cùng với ..." trên bài, và bài vào tab "Bài viết có bạn" trên trang cá nhân người đó (chỉ với người xem có quyền xem bài).
7. Người được gắn thẻ có thể tự gỡ thẻ bất cứ lúc nào. Chặn nhau thì mọi thẻ giữa hai người bị xóa.

Luồng 4: Sửa bài có lịch sử

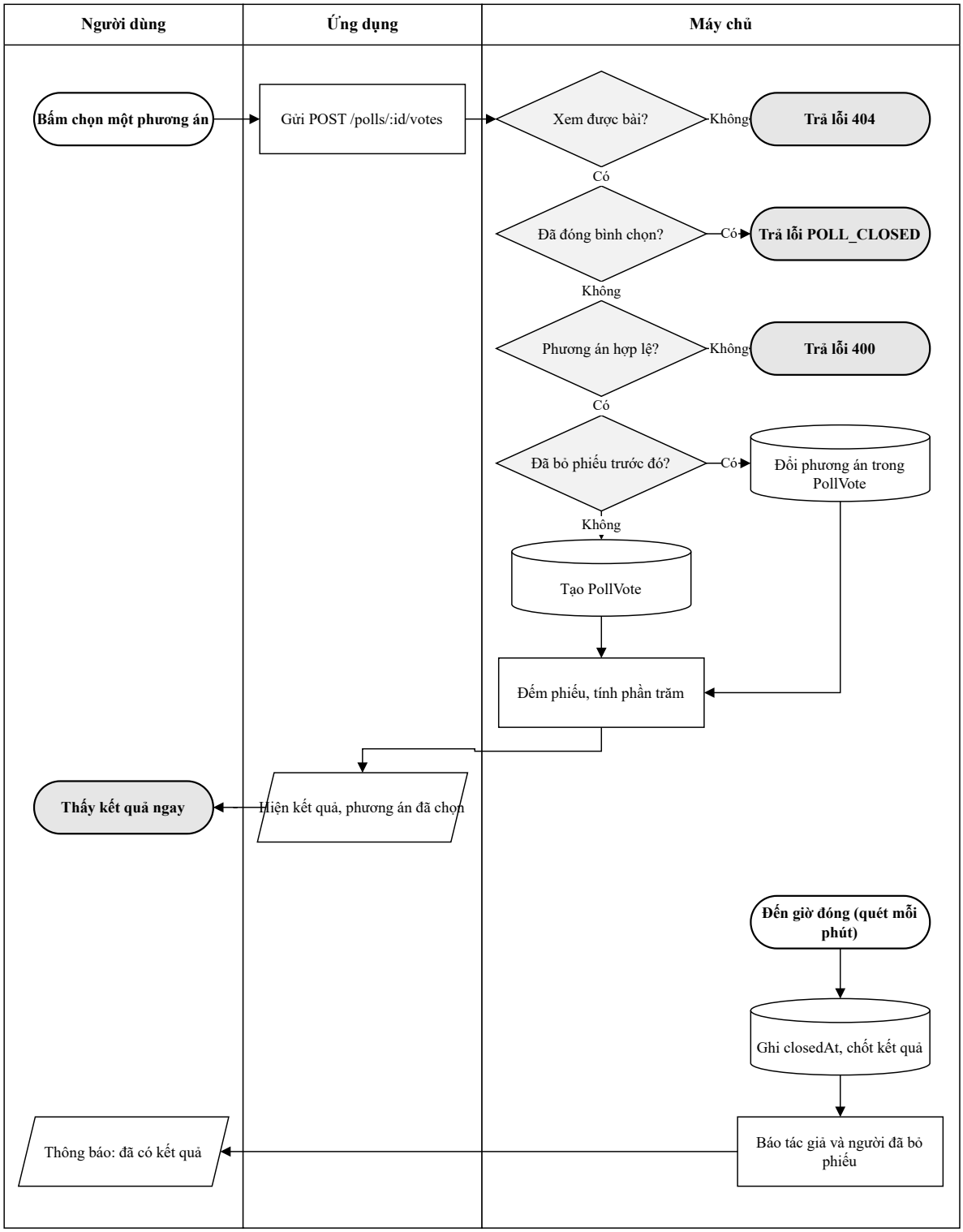
1. Tác giả sửa bài như hiện nay. Máy chủ kiểm tra quyền, rồi xem nội dung chữ hoặc ảnh có đổi không. Chỉ đổi quyền xem thì không tính là chỉnh sửa.
2. Có đổi: lưu bản cũ (chữ, danh sách ảnh) vào *PostRevision*, cập nhật bài, ghi *editedAt*. Tối đa 20 lần sửa mỗi bài (đề xuất).
3. Người mới xuất hiện trong *@tên* sau khi sửa thì nhận thông báo; người đã được báo trước đó thì không báo lại.
4. Bài hiện nhãn "Đã chỉnh sửa". Ai xem được bài thì bấm nhãn để xem các bản trước (mới nhất trước).
5. Ảnh bị gỡ khi sửa vẫn được giữ trong kho tới khi bài bị xóa, để bản cũ xem được và người duyệt có bằng chứng (hiện nay ảnh cũ bị xóa ngay khỏi kho).
6. Bài có bình chọn đã có phiếu: không sửa được phương án và thời hạn.

Luồng 5: Ghim bài

1. Ở menu bài của mình, chọn "Ghim lên trang cá nhân". Tối đa 3 bài ghim (đề xuất); ghim bài thứ tư thì app hỏi bỏ ghim bài cũ nhất.
2. Trang cá nhân hiện bài ghim trên cùng (có biểu tượng ghim), sau đó là các bài khác theo thời gian. Bài ghim vẫn theo quyền xem: người không có quyền thì không thấy.
3. Bỏ ghim từ cùng menu. Xóa bài thì tự bỏ ghim. Không ghim được lượt đăng lại.

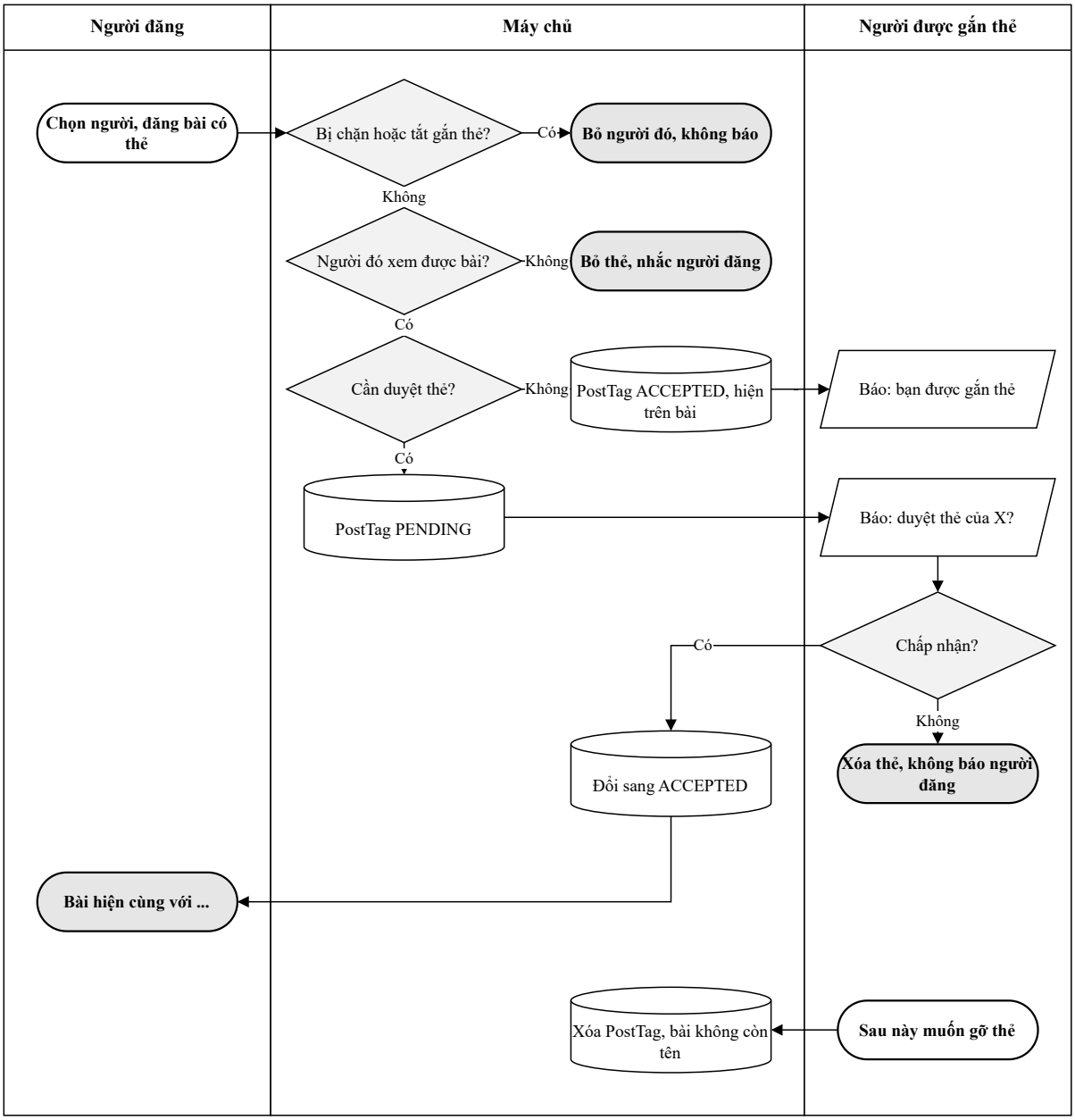
d) Flowchart

Sơ đồ 1: bỏ phiếu và đóng bình chọn.



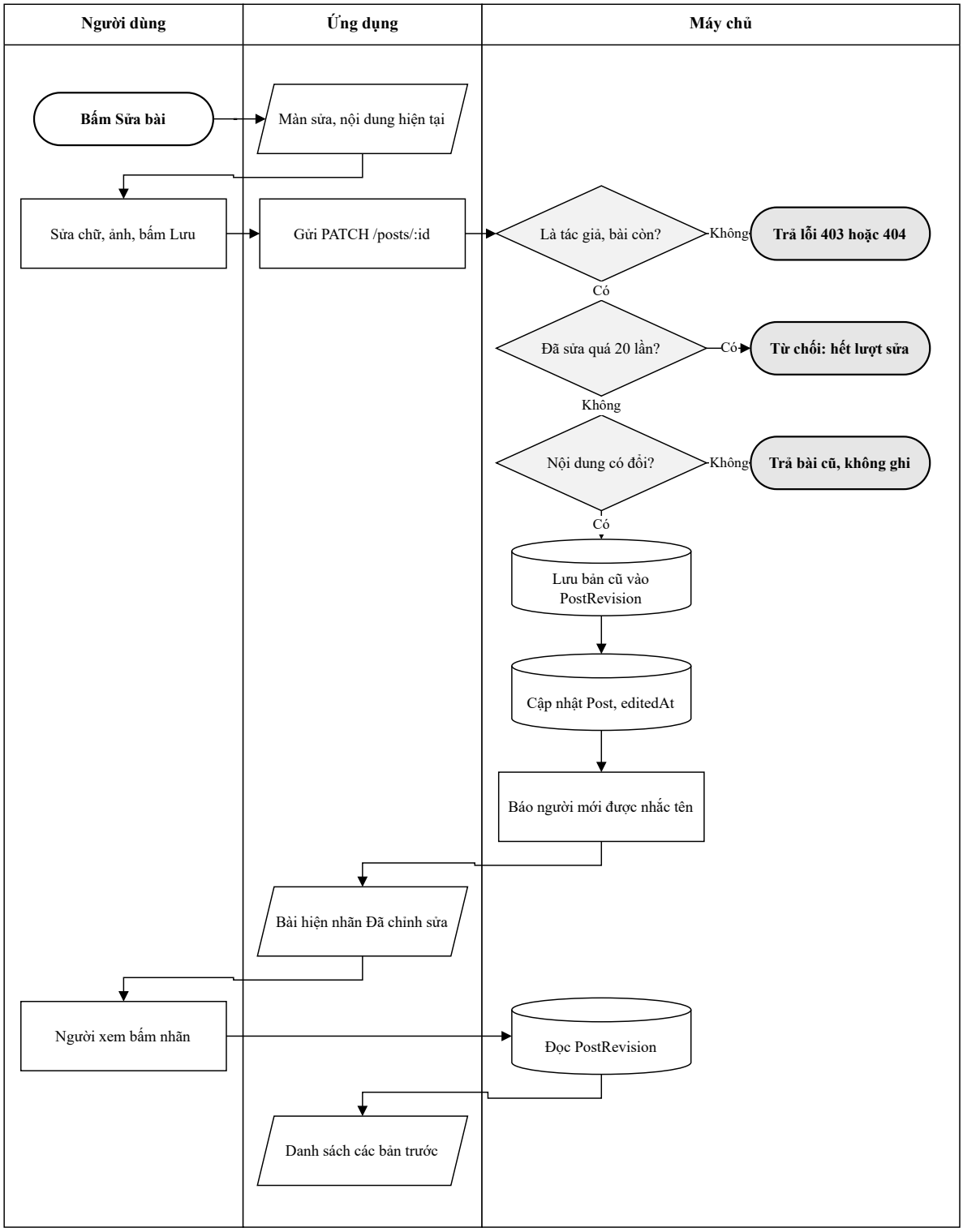
Hình 58. Bình chọn trong bài viết: bỏ phiếu và đóng bình chọn

Sơ đồ 2: gắn thẻ người, có kiểm tra chặn, quyền xem và bước duyệt.



Hình 59. Gắn thẻ người trong bài viết, có duyệt

Sơ đồ 3: sửa bài và xem lịch sử chỉnh sửa.



Hình 60. Sửa bài có lưu lịch sử chỉnh sửa

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Con số đề xuất**: bình chọn 2–4 phương án, ≤ 80 ký tự mỗi phương án, thời hạn 1 giờ đến 7 ngày; gắn thẻ ≤ 20 người mỗi bài; nhắc tên: chỉ báo 10 người đầu tiên mỗi bài hoặc bình luận; ghim ≤ 3 bài; sửa ≤ 20 lần mỗi bài; giữ bản cũ tới khi bài bị xóa hẳn.

- **Bỏ phiếu khi mạng lỗi**: app hiện lựa chọn ngay (lạc quan), lỗi thì trả lại trạng thái cũ và báo "Chưa gửi được phiếu". Bấm nhiều lần liên tiếp chỉ tạo một phiếu (khóa chính là người + bình chọn).
- **Bình chọn và chặn**: người bị chặn không xem được bài nên không bỏ phiếu được; phiếu cũ của họ vẫn được đếm (không lộ ai).
- **Bình chọn trong bài trích dẫn**: thẻ trích dẫn chỉ hiện kết quả, muốn bỏ phiếu phải mở bài gốc.
- **Trích dẫn**: tác giả gốc chặn người trích dẫn thì thẻ trích dẫn thành "không khả dụng" với mọi người. Tác giả gốc đổi bài sang *FRIENDS*/*PRIVATE* sau đó cũng vậy.
- **Gắn thẻ hàng loạt để quấy rối**: mỗi người tối đa 50 thẻ mới mỗi ngày (đề xuất); người bị từ chối thẻ 3 lần liên tiếp bởi cùng một người thì không gắn thẻ người đó được 30 ngày. Thẻ chờ không gửi push lặp lại.
- **Tài khoản bị khóa** (admin hoặc dưới 18 tuổi): không hiện trong danh sách gắn thẻ; thẻ cũ ẩn đi.
- **Lịch sử chỉnh sửa và kiểm duyệt**: báo cáo bài (C1) đính kèm phiên bản đang hiện lúc báo cáo; người duyệt xem được mọi bản cũ.
- **Thông báo mới**: *QUOTE*, *TAG*, *TAG_REQUEST*, *POLL_ENDED*. Người dùng tắt được từng loại trong cài đặt thông báo (D8).
- **Sửa lỗi nhắc tên hiện có**: chỉ báo người xem được bài (dùng *visiblePostWhere*), không chỉ bỏ qua bài *PRIVATE*.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và được Dev B duyệt trước khi code. Migration mới, chỉ thêm.

Bảng / trường	**Nội dung**
Post	Thêm *quotedPostId* (tham chiếu *Post*, có thể trống), *editedAt*, *pinnedAt*. Chỉ mục (*authorId*, *pinnedAt*).
PostRevision	*id*, *postId*, *content*, *media* (Json: url, loại, thứ tự), *createdAt*.
Poll	*id*, *postId* (duy nhất), *closesAt*, *closedAt*.
PollOption	*id*, *pollId*, *text*, *order*.
PollVote	*pollId*, *userId*, *optionId*, *createdAt*; khóa chính (*pollId*, *userId*).
PostTag	*postId*, *userId*, *status* (*PENDING* | *ACCEPTED*), *createdAt*, *respondedAt*; khóa chính (*postId*, *userId*); chỉ mục (*userId*, *status*).

User	Thêm *tagPermission* (*EVERYONE* | *FOLLOWING* | *NOBODY*, mặc định *EVERYONE*), *tagReview* (*ALL* | *NOT_FOLLOWING* | *NONE*, mặc định *NOT_FOLLOWING*), *mentionPermission* (giống *tagPermission*).

Endpoint	**Mục đích**
POST /posts, *POST /posts/media*	Nhận thêm *quotedPostId*, *poll: { options[], durationHours }*, *tagUserIds[]*.
PATCH /posts/:id	Nhận thêm *tagUserIds[]*; lưu *PostRevision* khi chữ/ảnh đổi.
GET /posts/:id/revisions	Danh sách bản cũ (ai xem được bài thì xem được).
POST /polls/:id/votes { optionId }; *POST /polls/:id/close*	Bỏ/đổi phiếu; tác giả đóng sớm. Trả *{ options: [{ id, text, votes, percent }], myOptionId, totalVotes, closedAt }*.
GET /me/tags/pending; *POST /posts/:id/tags/accept*; *DELETE /posts/:id/tags/me*	Thẻ chờ duyệt; chấp nhận; từ chối hoặc tự gỡ.
GET /users/:id/tagged	Tab "Bài viết có bạn" (chỉ thẻ *ACCEPTED*, lọc quyền xem).
POST/DELETE /posts/:id/pin	Ghim, bỏ ghim. *GET /users/:id/posts* trả bài ghim đầu trang 1, có *isPinned*.

Đối tượng *Post* trả về có thêm: *quotedPost* (dạng như *originalPost* của repost), *poll*, *tags*, *editedAt*, *isPinned*.

g) Android, iOS và web

- Không cần quyền thiết bị mới, không cần thư viện mới: các màn dùng thành phần sẵn có của app (*ActionSheet*, *ConfirmModal*, *UserRow*).
- Chọn thời hạn bình chọn bằng danh sách nút cố định thay vì bộ chọn ngày giờ gốc của hệ điều hành (bộ chọn gốc khác nhau giữa Android và iOS).
- Thanh phần trăm của bình chọn vẽ bằng *View* thường, hiển thị giống nhau trên hai nền tảng; có nhãn trợ năng (đọc "Phương án A, 45 phần trăm").
- Màn tạo bài thêm thanh công cụ (Bình chọn, Gắn thẻ) phải nằm trên bàn phím: dùng *KeyboardAvoidingView* với *behavior* theo nền tảng và vùng an toàn (safe area) như các màn hiện có.
- Trang quản trị web: xem lịch sử chỉnh sửa và kết quả bình chọn của bài bị báo cáo.
- Chi phí: không có dịch vụ ngoài. Ảnh cũ giữ lại trong kho làm tăng dung lượng lưu trữ một ít.

h) Tiêu chí hoàn thành

- Trích dẫn: tạo được; bài *FRIENDS* và bài của tài khoản riêng tư bị từ chối; bài gốc bị xóa hoặc chặn thì hiện "không khả dụng" (test tự động).
- Bình chọn: bỏ phiếu, đổi phiếu, không bỏ phiếu được sau khi đóng; tác vụ đóng chạy đúng giờ và gửi thông báo; không lộ danh sách người bỏ phiếu qua API.
- Gắn thẻ: người bị chặn, người tắt gắn thẻ, người không xem được bài đều không bị gắn; thẻ chờ duyệt không hiện với người khác; từ chối không báo người đăng; tự gỡ được.
- Sửa bài: bản cũ lưu đủ chữ và ảnh; đổi quyền xem không tạo bản cũ; nhãn "Đã chỉnh sửa" và danh sách bản cũ hiện đúng; người mới được nhắc nhận thông báo, người cũ không nhận lại.
- Ghim: tối đa 3; bài ghim đứng đầu trang cá nhân; người không có quyền xem không thấy bài ghim.
- Thông báo nhắc tên không gửi cho người không xem được bài (sửa lỗi hiện có).
- Chạy hết các luồng trên máy Android và iPhone thật; báo cáo ghi rõ đã chạy trên nền tảng nào.
- Admin xem được lịch sử chỉnh sửa của bài bị báo cáo.

i) Ước lượng và phụ thuộc

- Backend 8 ngày (trích dẫn 1,5; bình chọn 2,5 gồm tác vụ đóng; gắn thẻ 2; lịch sử 1; ghim 0,5; sửa lỗi nhắc tên 0,5), mobile 8 ngày, kiểm thử 3 ngày.
- Phụ thuộc: D8 (cài đặt thông báo cho loại mới), D9 (ô gợi ý người khi gõ @, dùng lại cho chọn người gắn thẻ), B8 (người bị hạn chế thì thẻ phải duyệt), C1 (người duyệt xem lịch sử chỉnh sửa).
- Dự án chưa có bộ chạy tác vụ định kỳ (không có *@nestjs/schedule*). Đề xuất: một *setInterval* mỗi phút trong service bình chọn; khi chạy nhiều bản API cần khóa (advisory lock của PostgreSQL) để không gửi thông báo trùng. Trạng thái "đã đóng" luôn tính từ *closesAt* khi đọc, nên tác vụ chậm cũng không cho bỏ phiếu muộn.
- Rủi ro: thêm nhiều trường vào đối tượng *Post* có thể làm hỏng *postMapper* ở app cũ; mọi trường mới phải là tùy chọn.

D7. Bạn thân và tin nổi bật (story)

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ3 · Ước lượng: 9–10 ngày công

a) Mục đích

Người dùng muốn chia sẻ một số story chỉ với nhóm nhỏ (gia đình, bạn thân) mà không phải chuyển cả tài khoản sang riêng tư. Danh sách **Bạn thân** cho phép đăng story chỉ những người trong danh sách thấy, nhận ra bằng vòng màu xanh lá. **Lưu trữ** giữ lại story đã hết 24 giờ để chủ xem lại, và **tin nổi bật** cho phép chọn các story đó để ghim thành từng nhóm trên trang cá nhân.

b) Hiện trạng

- **Story** (*apps/api/src/modules/stories*): ảnh hoặc video ≤ 60 giây, tải thẳng lên kho qua *POST /media/upload-url*; hết hạn sau 24 giờ (*expiresAt*), hết hạn chỉ là bị lọc khi đọc.
- **Ai xem được**: story của chính mình và của người mình theo dõi, không chặn nhau (*stories.service.ts*, hàm *feed* và *requireVisible*). Chưa có lựa chọn đối tượng xem: mọi người theo dõi đều thấy mọi story.
- **Khay story** (*apps/mobile/src/features/stories/components/StoriesTray.tsx*): gom theo tác giả; vòng màu nhấn khi còn story chưa xem, vòng xám khi đã xem hết (*StoryView* chỉ dùng để tô vòng, chủ story không xem được ai đã xem).
- **Tương tác**: thả cảm xúc (*StoryReaction*, có thể ẩn danh nếu chủ cho phép), trả lời đi vào tin nhắn (*Message.storyId*), push cảm xúc được gộp 15 phút mỗi story (bộ nhớ một tiến trình).
- **Xóa và dọn**: chủ xóa story thì xóa dòng và tệp. Story hết hạn **không bị dọn**: dòng và tệp vẫn nằm lại (ghi chú *shortcut* trong code). Nghĩa là dữ liệu cho "lưu trữ" đang có sẵn, chỉ chưa có màn xem.
- **Chưa có**: danh sách Bạn thân, story chỉ cho Bạn thân, màn Lưu trữ, tin nổi bật, cài đặt bật/tắt lưu trữ. Chưa báo cáo được story (ghi trong C1).

c) Cách hoạt động

Luồng 1: Quản lý danh sách Bạn thân

1. Vào Cài đặt → Bạn thân. App hiện danh sách người theo dõi mình, có ô tìm và nút "Thêm"/"Bỏ".
2. Máy chủ ghi hoặc xóa *CloseFriend*. Người được thêm hoặc bị bỏ **không** nhận thông báo.

3. Bỏ một người ra khỏi danh sách thì người đó mất quyền xem story Bạn thân ngay, kể cả story đang còn hạn.

Luồng 2: Đăng và xem story Bạn thân

1. Ở màn đăng story, người dùng chọn đối tượng: "Mọi người theo dõi tôi" (mặc định) hoặc "Bạn thân". Lần đầu chọn Bạn thân mà danh sách trống, app mở màn chọn người.
2. Máy chủ lưu story với *audience = CLOSE_FRIENDS*.
3. Khi người xem mở khay story, máy chủ lấy story còn hạn của người họ theo dõi như hiện nay, và bỏ story Bạn thân nếu người xem không có trong danh sách của tác giả. Người không có tên không biết story đó tồn tại.
4. Story Bạn thân hiện vòng xanh lá trong khay và nhãn "Bạn thân" ở góc trình xem.
5. Khi người xem thả cảm xúc hoặc trả lời, máy chủ kiểm tra lại quyền (vẫn có tên, story còn hạn). Câu trả lời vào tin nhắn như hiện nay, kèm nhãn "Đã trả lời story Bạn thân của bạn".

Luồng 3: Lưu trữ story

1. Cài đặt → Story → "Lưu story vào kho lưu trữ" (mặc định bật).
2. Bật: story hết 24 giờ vẫn được giữ, chỉ chủ xem trong màn Lưu trữ (trang cá nhân → menu → Lưu trữ), xếp theo ngày.
3. Tắt: tác vụ dọn hằng giờ xóa tệp và dòng của story đã hết hạn quá 24 giờ, trừ story đang nằm trong tin nổi bật. Tác vụ này cũng giải quyết việc story hết hạn đang nằm lại mãi trong kho.
4. Từ màn Lưu trữ, chủ có thể xóa hẳn từng story, hoặc đăng lại thành story mới.

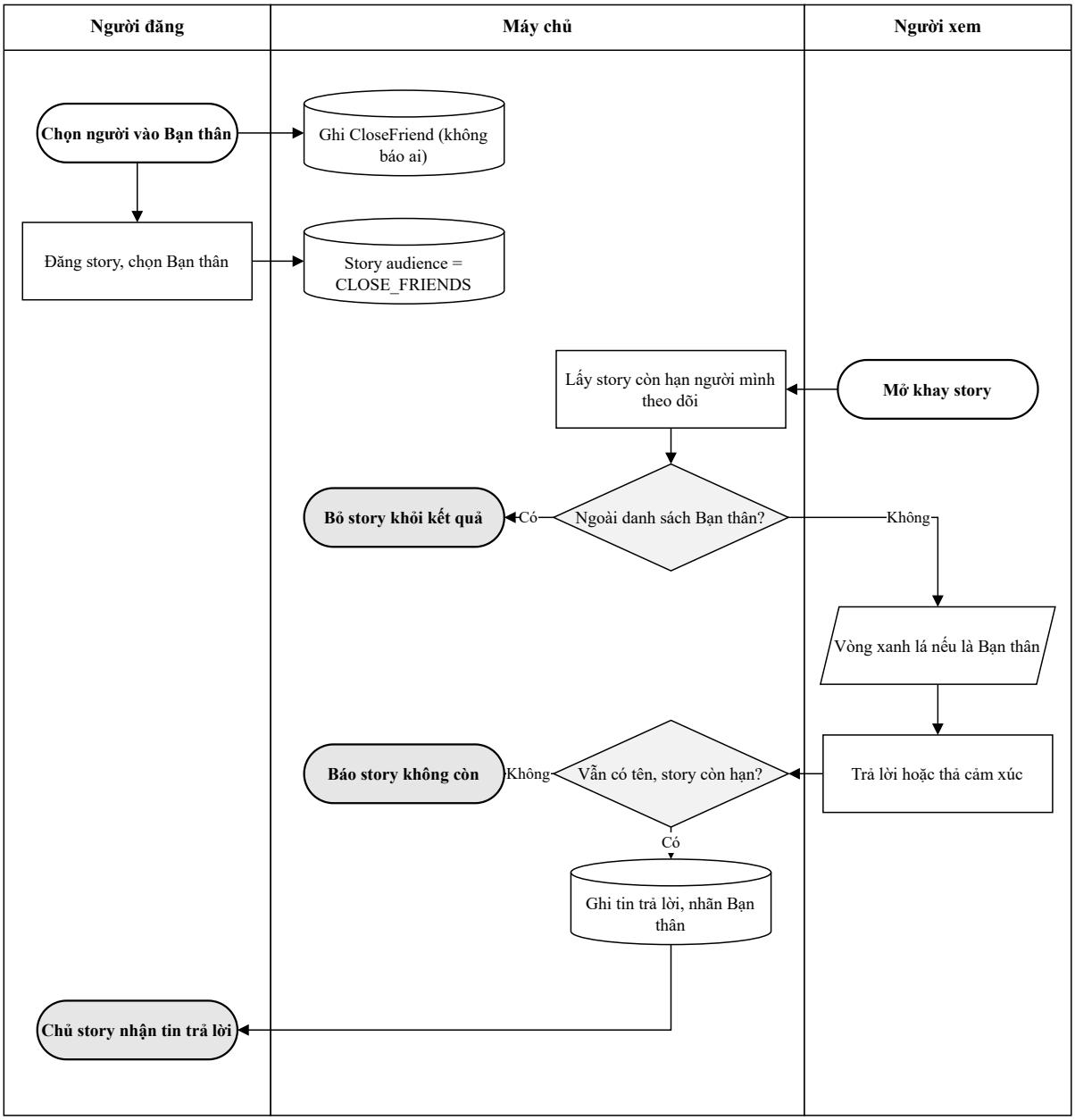
Luồng 4: Tin nổi bật

1. Từ màn Lưu trữ hoặc trình xem story của mình, bấm "Thêm vào tin nổi bật", chọn nhóm có sẵn hoặc tạo nhóm mới (tên ≤ 20 ký tự, ảnh bìa chọn từ một story trong nhóm).
2. Máy chủ kiểm tra story là của mình, nhóm chưa vượt 100 story, chưa vượt 50 nhóm, rồi ghi *Highlight*/*HighlightItem*.
3. Người khác mở trang cá nhân: máy chủ kiểm tra họ được xem trang (không chặn; tài khoản riêng tư thì phải là người theo dõi), rồi trả hàng vòng tin nổi bật. Mục là story Bạn thân thì chỉ trả cho người đang có tên trong danh sách; nhóm không còn mục nào thì ẩn.
4. Bấm vào vòng mở trình xem story sẵn có, chạy lần lượt các mục. Thả cảm xúc và trả lời theo cài đặt của story gốc.

5. Chủ sửa tên, ảnh bìa, thứ tự, bỏ mục hoặc xóa nhóm. Xóa story gốc thì mục đó biến khỏi mọi nhóm.

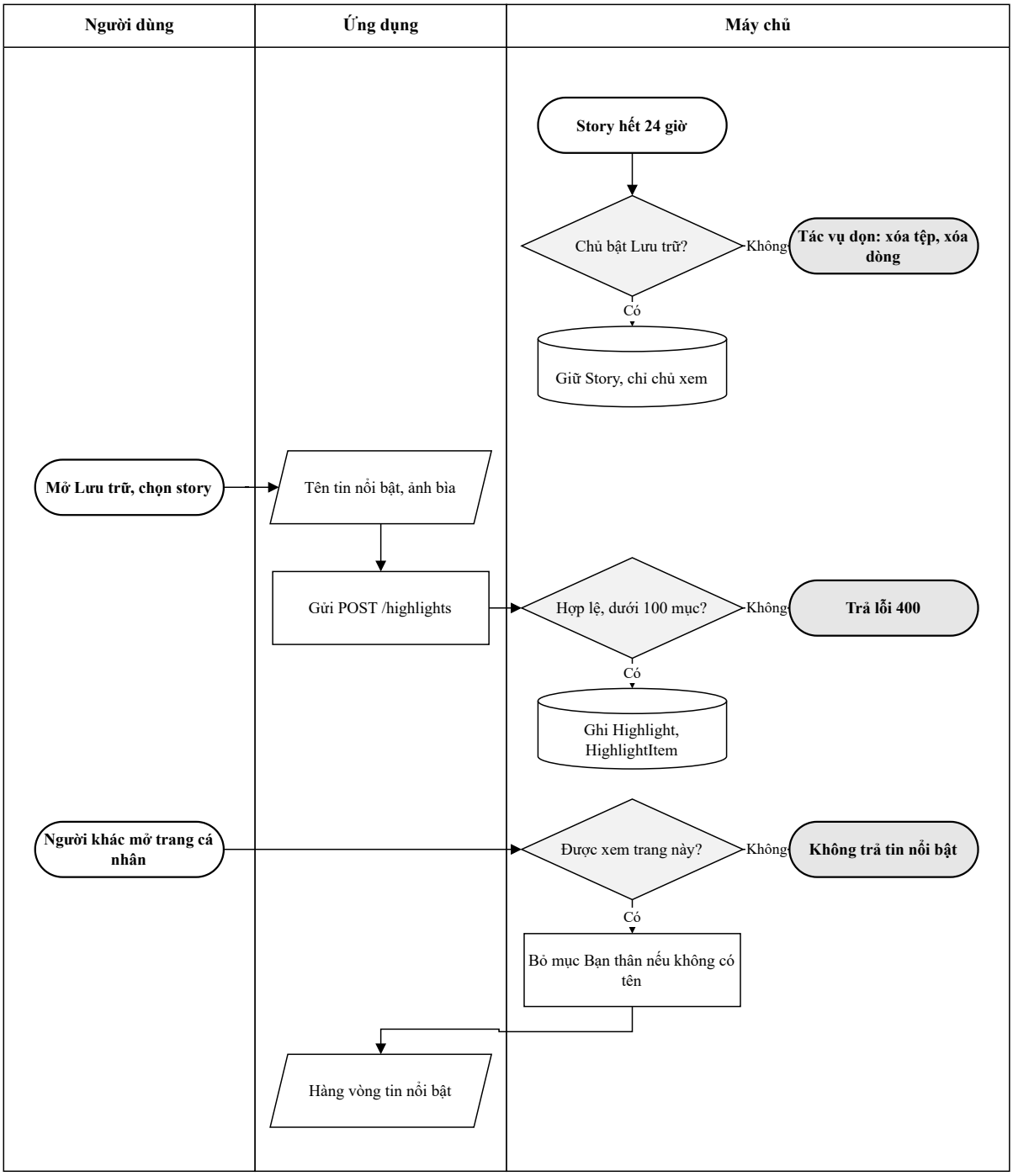
d) Flowchart

Sơ đồ 1: đăng story Bạn thân và kiểm tra quyền khi xem, khi trả lời.



Hình 61. Đăng và xem story chỉ dành cho Bạn thân

Sơ đồ 2: story hết hạn vào kho lưu trữ, tạo tin nổi bật và người khác xem trên trang cá nhân.



Hình 62. Lưu trữ story và tạo tin nổi bật trên hồ sơ

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Con số đề xuất**: Bạn thân tối đa 500 người; 50 nhóm tin nổi bật, mỗi nhóm 100 story; tên nhóm ≤ 20 ký tự; tác vụ dọn chạy mỗi giờ; story hết hạn khi tắt lưu trữ bị xóa sau 24 giờ kể từ lúc hết hạn.
- **Chỉ chọn từ người theo dõi mình**: khay story chỉ hiện story của người mình theo dõi, nên Bạn thân không theo dõi mình thì cũng không thấy. Người đó bỏ theo dõi

thì vẫn giữ trong danh sách nhưng không thấy story cho tới khi theo dõi lại.

- **Chặn**: chặn nhau thì xóa luôn khỏi danh sách Bạn thân hai phía; người bị chặn không thấy story, tin nổi bật.
- **Đổi tài khoản sang riêng tư**: tin nổi bật chỉ còn hiện cho người theo dõi.
- **Không lộ danh sách**: API không bao giờ trả danh sách Bạn thân của người khác, không trả cờ "bạn có trong danh sách của X" ngoài story cụ thể. Nhãn "Bạn thân" chỉ cho biết story đó dành cho nhóm nhỏ.
- **Chụp màn hình**: không chặn hay báo được một cách tin cậy trên cả hai nền tảng; app không hứa điều này. Ghi rõ trong màn chọn đối tượng: "Người xem vẫn có thể chụp màn hình".
- **Ẩn danh**: cảm xúc, trả lời ẩn danh theo cài đặt của từng story như hiện nay; story Bạn thân dùng cùng quy tắc.
- **Nội dung vi phạm**: story trong tin nổi bật sống lâu hơn 24 giờ, nên phải báo cáo được (bổ sung trong C1) và đi qua làm mờ nhạy cảm (B5) như story thường.
- **Lỗi mạng khi thêm vào nhóm**: app chỉ cập nhật khi máy chủ xác nhận; gửi lại cùng story vào cùng nhóm không tạo mục trùng (khóa chính).
- **Xóa tài khoản** (E2): xóa luôn story lưu trữ, tin nổi bật và tệp; danh sách Bạn thân xóa theo (*onDelete: Cascade*).

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và được Dev B duyệt trước khi code. Migration mới, chỉ thêm.

Bảng / trường	**Nội dung**
CloseFriend	*ownerId*, *friendId*, *createdAt*; khóa chính (*ownerId*, *friendId*); chỉ mục *friendId*.
Story	Thêm *audience* (*FOLLOWERS* | *CLOSE_FRIENDS*, mặc định *FOLLOWERS*).
User	Thêm *storyArchive* (Boolean, mặc định true).
Highlight	*id*, *ownerId*, *title*, *coverStoryId* (có thể trống), *order*, *createdAt*.
HighlightItem	*highlightId*, *storyId*, *order*, *addedAt*; khóa chính (*highlightId*, *storyId*); xóa theo story.

Endpoint	**Mục đích**

GET /me/close-friends; *PUT /me/close-friends/:userId*; *DELETE /me/close-friends/:userId*	Xem, thêm, bỏ Bạn thân.
POST /stories	Nhận thêm *audience*. Mỗi story trong *GET /stories/feed* có thêm *audience*; nhóm tác giả có thêm *hasCloseFriends* để tô vòng xanh.
GET /stories/archive?cursor=	Story đã hết hạn của mình, mới nhất trước.
GET /users/:id/highlights; *GET /highlights/:id*	Hàng vòng trên trang cá nhân; danh sách mục để mở trình xem.
POST /highlights; *PATCH /highlights/:id*; *DELETE /highlights/:id*; *POST/DELETE /highlights/:id/items/:storyId*	Tạo, sửa (tên, bìa, thứ tự), xóa nhóm; thêm, bỏ mục.
PATCH /users/me	Nhận thêm *storyArchive*.

Các hàm *react*, *reply*, *markViewed* chuyển sang kiểm tra quyền chung: story còn hạn **hoặc** nằm trong tin nổi bật mà người xem được xem, cộng điều kiện Bạn thân.

g) Android, iOS và web

- Không cần quyền thiết bị mới (ảnh, video story đã dùng quyền thư viện ảnh khai báo trong *app.json*). Không cần thư viện mới.
- Vòng xanh lá vẽ bằng viền *View* như vòng hiện có; màu xanh phải đủ tương phản trên nền sáng của app, và có nhãn trợ năng ("Story Bạn thân") vì người mù màu không phân biệt được vòng.
- Hàng tin nổi bật cuộn ngang trên trang cá nhân dùng *FlatList* ngang, chạy giống nhau trên hai nền tảng.
- Tác vụ dọn story chạy trên máy chủ, không phụ thuộc nền tảng. Dự án chưa có bộ chạy định kỳ: dùng *setInterval* mỗi giờ với khóa PostgreSQL (giống đề xuất ở D6).
- Chi phí: lưu trữ tăng vì story không còn bị bỏ đi (thực tế hiện nay cũng chưa bị xóa). Ước tính 1–3 MB mỗi story; cần theo dõi dung lượng kho S3/MinIO.

h) Tiêu chí hoàn thành

- Story Bạn thân chỉ hiện với người có tên; người không có tên không thấy qua mọi API (khay, xem, cảm xúc, trả lời, tin nổi bật) — test tự động cho từng API.
- Bỏ một người khỏi danh sách thì họ mất quyền ngay với story đang còn hạn.

- Vòng xanh lá và nhãn "Bạn thân" hiện đúng; người được thêm/bỏ không nhận thông báo.
- Story hết hạn vào Lưu trữ khi bật; tắt lưu trữ thì tác vụ dọn xóa tệp và dòng, trừ mục trong tin nổi bật.
- Tạo, sửa, xóa tin nổi bật; người bị chặn và người không theo dõi tài khoản riêng tư không thấy.
- Chạy trên máy Android và iPhone thật: đăng story Bạn thân, xem bằng tài khoản có và không có tên, mở tin nổi bật. Báo cáo ghi rõ đã chạy trên nền tảng nào.

i) Ước lượng và phụ thuộc

- Backend 3 ngày (Bạn thân 1, lưu trữ và tác vụ dọn 0,5, tin nổi bật 1,5), mobile 5 ngày (màn Bạn thân, chọn đối tượng, vòng xanh, màn Lưu trữ, tạo/sửa tin nổi bật, hàng vòng trên hồ sơ), kiểm thử 2 ngày.
- Phụ thuộc: C1 (báo cáo story), B5 (làm mờ story nhạy cảm), E2 (xóa dữ liệu khi xóa tài khoản), E1 (đưa Lưu trữ vào gói tải dữ liệu).
- Rủi ro: quên áp điều kiện Bạn thân ở một API là lộ story; nên gom về một hàm kiểm tra quyền duy nhất như *visiblePostWhere* của bài viết.

D8. Thông báo đẩy hoàn chỉnh và cài đặt thông báo theo loại, giờ yên lặng

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ1 · Ước lượng: 12–14 ngày công

a) Mục đích

Thông báo đẩy (push, tức thông báo hiện trên màn hình khóa khi app đang tắt) là cách chính để người dùng quay lại app: có tin nhắn, có bình luận, có người theo dõi. Hiện code gửi push đã có nhưng **chưa từng chạy thử**. Tính năng này làm cho push chạy thật trên Android và iPhone, cho người dùng tắt từng loại thông báo và đặt giờ yên lặng, gộp thông báo trùng để không bị làm phiền, bấm vào thông báo mở đúng màn hình, hiện số chưa đọc trên biểu tượng app (badge), và tự dọn các thiết bị không còn dùng. Phần che tên người gửi ẩn danh phải giữ nguyên trong mọi trường hợp.

b) Hiện trạng

- **Máy chủ** (*apps/api/src/modules/notifications/notifications.service.ts*): mọi thông báo đi qua *notify()*: bỏ nếu tự gửi cho mình hoặc hai bên chặn nhau, lưu bảng *Notification*, đẩy qua Socket.IO (*notifications.gateway.ts*, phòng *user:<id>*), rồi gửi push. Tám loại có lưu: *LIKE*, *COMMENT*, *REPLY*, *FOLLOW*, *REPOST*, *MENTION*, *FOLLOW_REQUEST*, *FOLLOW_ACCEPT*.
- **Push** (*pushToUser*): gọi thẳng *https://exp.host/--/api/v2/push/send* (dịch vụ push của Expo, chuyển tiếp sang FCM của Google cho Android và APNs của Apple cho iOS), gửi mọi thiết bị của người nhận trong một lần, không có mã truy cập Expo, không đọc kết quả. Tiêu đề cố định "MobileSocialMedia". Lỗi bị nuốt để không làm hỏng thao tác chính.
- **Push không lưu thông báo**: tin nhắn mới (*messages.service.ts*) và cảm xúc story (*stories.service.ts*) gọi *pushToUser* trực tiếp. Tin nhắn ẩn danh đã che tên ("Người ẩn danh"), tin chờ có tiền tố "[Tin nhắn chờ]", ảnh không bao giờ hiện trong push. Cảm xúc story được gộp tối đa một push mỗi 15 phút mỗi story, không nêu tên (bộ nhớ một tiến trình).
- **Thiết bị**: bảng *DeviceToken* (*token*, *userId*, *platform*, *updatedAt*); *POST /notifications/devices* ghi hoặc chuyển token sang tài khoản đang đăng nhập; *DELETE /notifications/devices?token=* khi đăng xuất. **Không dọn** token hỏng (ghi chú *shortcut* trong code và DEC-020).
- **App** (*apps/mobile/src/features/notifications/services/pushService.ts*): *expo-notifications ~57.0.22* đã cài. Sau khi đăng nhập, app xin quyền ngay (không có màn giải thích trước), lấy token Expo, gửi lên máy chủ; bỏ qua trong Expo Go và chế độ dữ liệu giả. Bấm thông báo: *FOLLOW* mở trang cá nhân, có *postId* thì mở chi tiết bài; **tin nhắn, yêu cầu theo dõi, cảm xúc story không mở gì**. Không xử

lý trường hợp bấm thông báo khi app đang tắt hẳn (không đọc thông báo đã bấm lúc khởi động). Không đặt badge (*shouldSetBadge: false*). Không tạo kênh thông báo Android.

- **Cấu hình còn thiếu** (*apps/mobile/app.json*): chưa có plugin *expo-notifications*, chưa có *extra.eas.projectId* (mã dự án EAS), chưa có *eas.json*, chưa có *google-services.json* (Firebase cho Android), chưa có khóa APNs. *getExpoPushTokenAsync()* được gọi không truyền *projectId*.
- **Danh sách thông báo** trong app: có đánh dấu đã đọc từng cái và tất cả, số chưa đọc ở biểu tượng chuông; chưa tải thêm khi cuộn (báo cáo tính năng, mục V).
- **Chưa có**: cài đặt theo loại, giờ yên lặng, gộp thông báo (trừ cảm xúc story), badge, dọn token, chia lô 100 thông báo mỗi yêu cầu (giới hạn của Expo).

c) Cách hoạt động

Luồng 0: Chuẩn bị một lần (dev, không phải code)

1. Tạo dự án EAS (*eas init*), ghi *projectId* vào *app.json*; thêm plugin *expo-notifications* (biểu tượng, màu thông báo Android).
2. Android: tạo dự án Firebase, tải *google-services.json*, khai báo *android.googleServicesFile*; tải khóa tài khoản dịch vụ FCM V1 lên EAS (*eas credentials*).
3. iOS: tài khoản Apple Developer, tạo khóa APNs (.p8) và tải lên EAS; quyền push (aps-environment) được plugin tự thêm.
4. Build bản phát triển (development build) cho cả hai: *eas build --profile development*. Expo Go không nhận được push thật.
5. Máy chủ: thêm biến môi trường *EXPO_ACCESS_TOKEN* và bật "push an toàn" trong tài khoản Expo, để chỉ máy chủ của mình gửi được push tới các token.

Luồng 1: Đăng ký thiết bị

1. Sau khi đăng nhập hoặc mở app, nếu bản build hỗ trợ push và người dùng chưa từng được hỏi, app hiện màn giải thích ngắn ("Nhận thông báo khi có tin nhắn, bình luận...") với nút "Bật thông báo" và "Để sau".
2. Bấm "Bật": app tạo kênh thông báo Android (bắt buộc từ Android 8; Android 13 chỉ hiện hộp xin quyền sau khi có kênh), rồi gọi hộp xin quyền của hệ điều hành. "Để sau" thì nhắc lại sau 7 ngày, và luôn bật được trong Cài đặt.
3. Được phép: app lấy token Expo (truyền *projectId*), gửi *POST /notifications/devices* kèm nền tảng.

4. Máy chủ: nếu token đang gắn với tài khoản khác (đổi tài khoản trên cùng máy) thì chuyển sang tài khoản mới, để người cũ không nhận push trên máy này. Ghi *lastSeenAt*.
5. Mỗi lần mở app, app gửi lại token (token có thể đổi) và đặt badge theo số chưa đọc.
6. Đăng xuất: xóa token trên máy chủ, xóa badge, gỡ bộ nghe. Phiên bị đăng xuất từ xa (A2) thì máy chủ xóa token của phiên đó.

Luồng 2: Gửi một thông báo qua mọi bước kiểm tra

1. Một sự kiện xảy ra (thích, bình luận, tin nhắn, gắn thẻ...). Mọi loại, kể cả tin nhắn và cảm xúc story, đi qua **một** hàm gửi, thay vì gọi *pushToUser* rải rác.
2. Bỏ nếu tự gửi cho mình, hai bên chặn nhau, người gửi đang bị người nhận tắt tiếng (B8), hoặc người nhận không còn xem được nội dung (ví dụ bị nhắc tên trong bài *FRIENDS* không xem được).
3. Lưu *Notification* (trừ tin nhắn, vốn đã có số chưa đọc riêng) và gửi socket nếu app đang mở.
4. Người nhận tắt push loại này, hoặc đang "Tạm dừng tất cả": chỉ giữ trong danh sách, không push.
5. Đang trong giờ yên lặng: vẫn gửi nhưng không âm thanh, không rung (iOS: mức ngắt "passive"; Android: kênh "Yên lặng" mức thấp). Thông báo bảo mật (đăng nhập lạ A3, đổi mật khẩu) luôn có âm thanh.
6. Gộp: cùng loại, cùng bài, đã có push trong 15 phút qua thì không gửi thêm; lần kế tiếp sau 15 phút gửi một push gộp "Lan và 3 người khác đã thích bài viết của bạn". Tin nhắn không gộp theo thời gian, nhưng cùng hội thoại dùng chung khóa nhóm để hệ điều hành xếp chồng.
7. Che thông tin: người gửi ẩn danh luôn là "Người ẩn danh"; tin chờ và tin ẩn danh **không** hiện nội dung trên màn hình khóa ("Bạn có một tin nhắn chờ mới"); người dùng tắt "Hiện nội dung tin nhắn" thì mọi tin chỉ hiện "Tin nhắn mới".
8. Tính badge = số thông báo chưa đọc + số hội thoại chưa đọc; gắn dữ liệu mở màn hình (*type*, *postId*, *commentId*, *conversationId*, *storyId*, *actorId*, *recipientId*).
9. Gửi tới Expo theo lô ≤ 100, lưu mã biên nhận (ticket). Expo chuyển sang FCM hoặc APNs.
10. Khoảng 15 phút sau, tác vụ đọc biên nhận (*getReceipts*). Lỗi *DeviceNotRegistered* (app đã gỡ hoặc token hết hạn) thì xóa token đó. Token không được gửi lại quá 60 ngày cũng bị xóa.

Luồng 3: Bấm vào thông báo

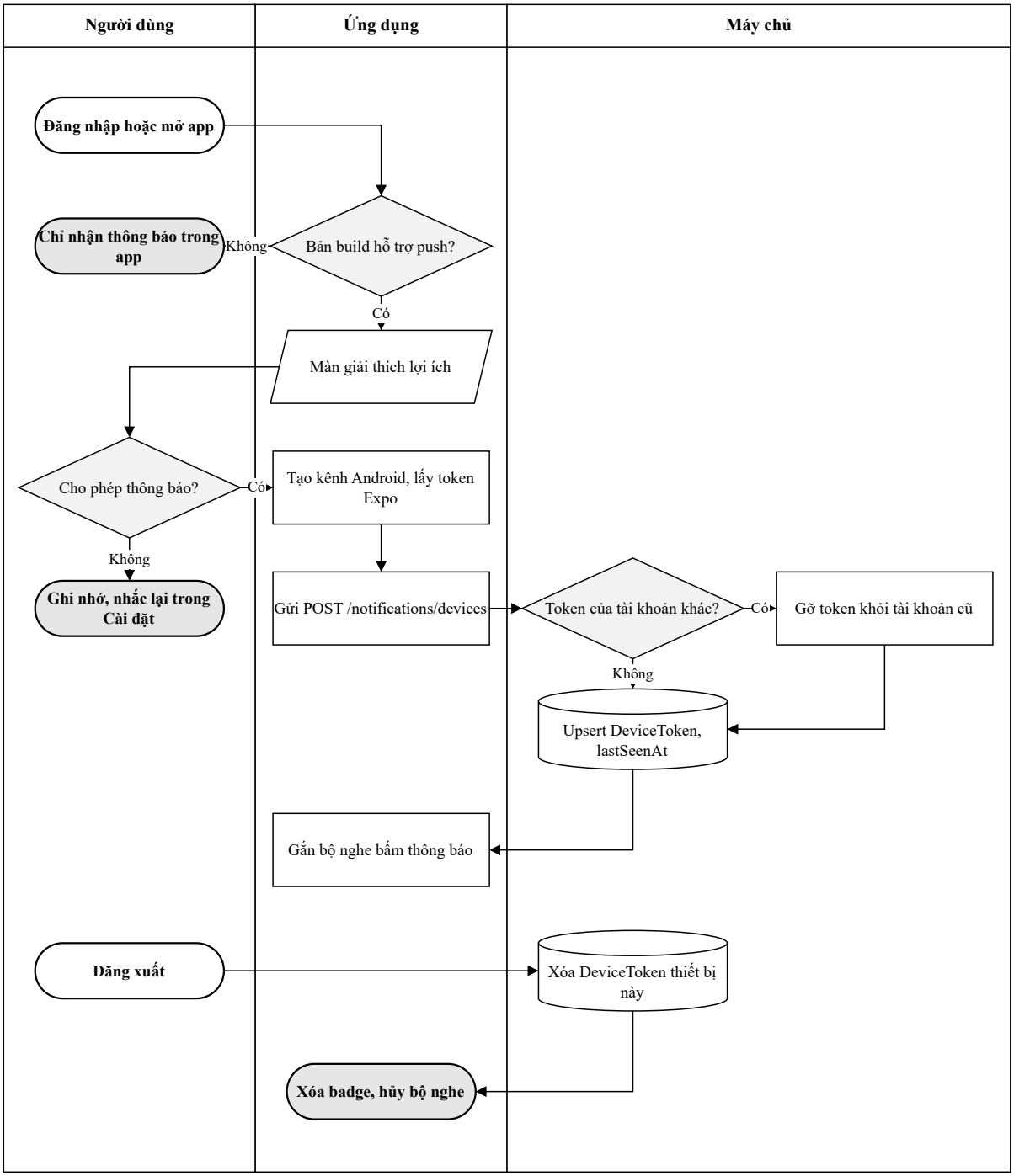
1. App đọc dữ liệu của thông báo đã bấm, cả khi app đang chạy nền và khi app vừa được mở từ trạng thái tắt hẳn (đọc thông báo đã bấm lúc khởi động, chờ đăng nhập xong rồi mới chuyển màn).
2. *recipientId* khác tài khoản đang đăng nhập: mở danh sách Thông báo, không mở nội dung (tránh lộ nội dung của tài khoản khác trên cùng máy).
3. Tin nhắn mở đúng hội thoại; bài, bình luận mở chi tiết bài và cuộn tới bình luận; theo dõi, yêu cầu theo dõi mở trang cá nhân hoặc màn Yêu cầu theo dõi; cảm xúc story mở danh sách cảm xúc; gắn thẻ mở màn duyệt thẻ (D6).
4. Màn đích tải dữ liệu như bình thường; nội dung đã xóa hoặc mất quyền xem thì hiện "Nội dung không còn".
5. Máy chủ đánh dấu thông báo đó đã đọc, app đặt lại badge.

Luồng 4: Cài đặt thông báo

1. Cài đặt → Thông báo: công tắc theo nhóm: Thích và cảm xúc; Bình luận và trả lời; Nhắc tên và gắn thẻ; Người theo dõi mới và yêu cầu; Tin nhắn; Tin nhắn chờ; Story; Bình chọn. Nhóm Bảo mật luôn bật, không tắt được.
2. "Hiện nội dung tin nhắn" (mặc định bật); "Tạm dừng tất cả" 1 giờ, 8 giờ, 24 giờ; "Giờ yên lặng" có giờ bắt đầu, kết thúc (mặc định tắt; gợi ý 22:00–07:00), dùng múi giờ của máy.
3. Hệ điều hành đang tắt quyền thông báo thì màn hiện dòng "Thông báo đang tắt trong cài đặt máy" và nút mở cài đặt máy.

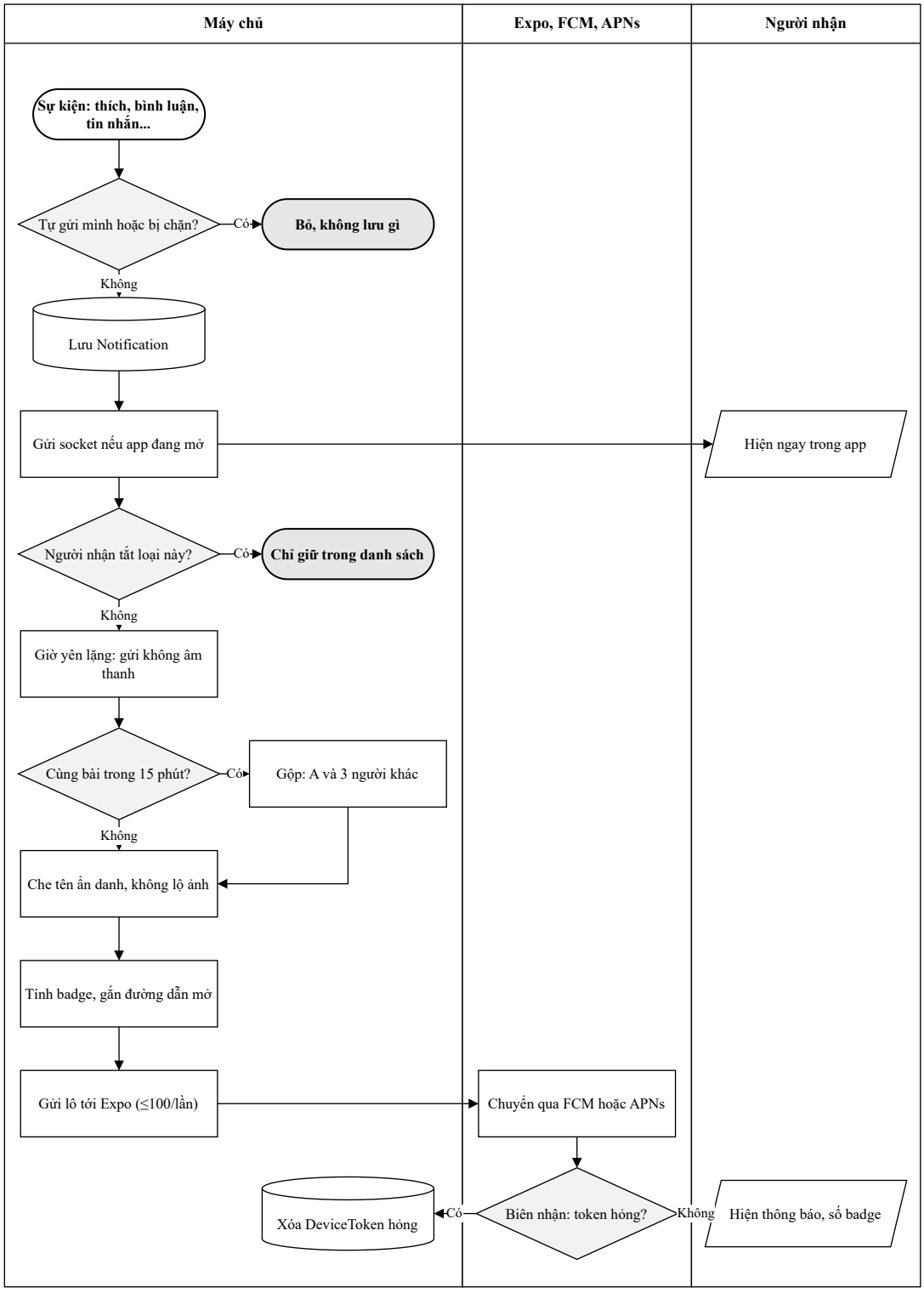
d) Flowchart

Sơ đồ 1: đăng ký thiết bị và hủy khi đăng xuất.



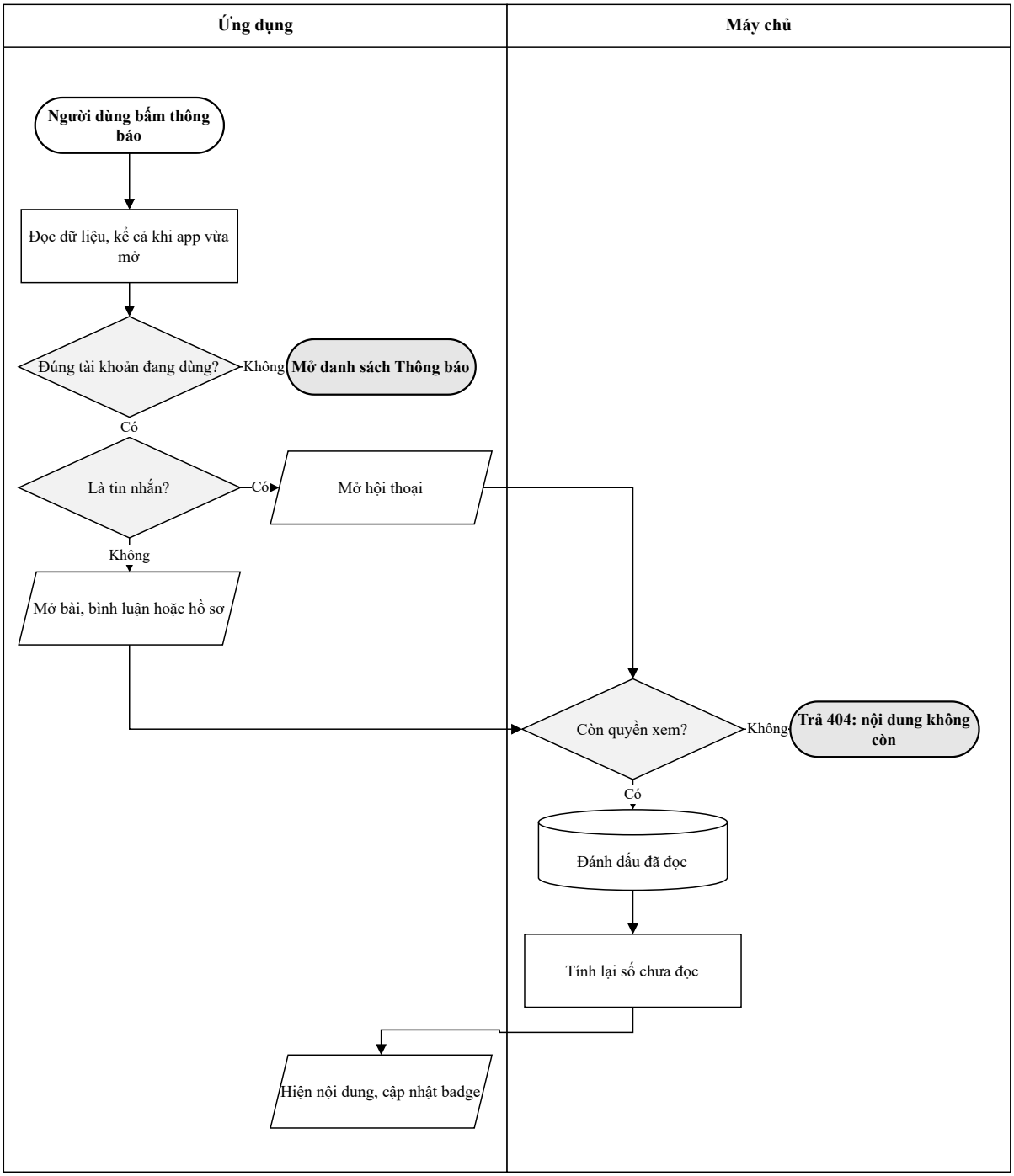
Hình 63. Đăng ký thiết bị nhận thông báo đẩy

Sơ đồ 2: gửi một thông báo qua mọi bước kiểm tra, tới khi dọn token hỏng.



Hình 64. Gửi một thông báo qua mọi bước kiểm tra

Sơ đồ 3: bấm vào thông báo và mở đúng màn hình.



Hình 65. Bấm vào thông báo: mở đúng màn hình

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Con số đề xuất**: gộp trong 15 phút; tối đa 30 push mỗi người nhận mỗi giờ (trừ tin nhắn và bảo mật), vượt thì chỉ lưu vào danh sách; lô gửi ≤ 100 (giới hạn Expo); đọc biên nhận sau 15 phút; xóa token không dùng sau 60 ngày; nhắc bật thông báo lại sau 7 ngày, tối đa 3 lần.
- **Lỗi mạng tới Expo**: thử lại 3 lần, cách 1, 5, 30 giây; vẫn lỗi thì bỏ push (thông báo vẫn có trong danh sách). Không bao giờ làm hỏng thao tác chính (giữ nguyên

nguyên tắc hiện có).

- **Expo trả lỗi giới hạn tốc độ** (429): chờ và gửi lại phần còn lại; ghi log để dev biết.
- **Nhiều máy chủ API cùng chạy**: bộ đếm gộp và giới hạn hiện nằm trong bộ nhớ một tiến trình (như cảm xúc story). Đề xuất lưu khóa gộp vào bảng *PushThrottle* trong PostgreSQL để nhiều tiến trình dùng chung; không thêm Redis chỉ vì việc này.
- **Người bị chặn, bị khóa**: không gửi. Tài khoản người nhận bị khóa (admin hoặc dưới 18 tuổi) thì không gửi push nào, và xóa token khi khóa.
- **Ẩn danh**: tên người gửi chỉ lấy từ hàm che tên chung của hội thoại (*ANONYMOUS_PEER*); test tự động bắt buộc: không push nào chứa tên, ảnh đại diện hay id của người gửi ẩn danh.
- **Đổi tài khoản trên cùng máy**: token chỉ thuộc một tài khoản tại một thời điểm (đã có); thông báo cũ của tài khoản trước vẫn nằm trong khay hệ thống, nên bước kiểm tra *recipientId* khi bấm là bắt buộc.
- **Badge**: Android chỉ hiện chấm hoặc số tùy trình khởi chạy của hãng máy; không hứa con số chính xác trên Android.
- **Quyền bị thu hồi** trong cài đặt máy: token vẫn còn nhưng thông báo không hiện; app kiểm tra quyền khi mở và hiện nhắc ở màn Cài đặt thông báo.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và được Dev B duyệt trước khi code. Migration mới, chỉ thêm.

Bảng / trường	**Nội dung**
DeviceToken	Thêm *lastSeenAt*, *sessionId* (có thể trống, nối với phiên của A2), *createdAt*.
NotificationSettings (mới, một dòng mỗi người)	*userId* (khóa chính), *mutedTypes* (mảng chuỗi), *showMessagePreview* (mặc định true), *quietStart*, *quietEnd* (phút trong ngày, có thể trống), *timeZone*, *pausedUntil*, *pushPromptedAt*.
PushTicket (mới)	*id* (mã biên nhận Expo), *token*, *createdAt*; xóa sau khi đọc biên nhận.
PushThrottle (mới)	*key* (người nhận + loại + bài), *lastSentAt*, *pendingCount*.
Notification.type	Thêm các loại mới của D6 (*QUOTE*, *TAG*, *TAG_REQUEST*, *POLL_ENDED*) và *STORY_REACTION* nếu muốn hiện trong danh sách.

Endpoint	Mục đích
GET /notifications/settings; *PATCH /notifications/settings*	Đọc, sửa cài đặt.
GET /notifications/badge	*{ notifications, messages, total }* để app đặt badge khi mở.
POST /notifications/devices	Giữ nguyên hình dạng; máy chủ cập nhật *lastSeenAt*.
GET /notifications?cursor=	Thêm phân trang con trỏ để app tải thêm khi cuộn.

Dữ liệu trong mỗi push (cố định, app dựa vào để mở màn): *{ type, recipientId, postId?, commentId?, conversationId?, storyId?, actorId? }*. Với người gửi ẩn danh, *actorId* luôn là *"anonymous"*.

g) Android, iOS và web

- **Cần cả hai phía**: FCM (Android) và APNs (iOS), cùng đi qua dịch vụ Expo. Nếu tạm thời chỉ thiết lập được một phía, phía còn lại ghi là việc chưa xong, không bỏ qua.
- **Quyền**: Android 13+ cần quyền *POST_NOTIFICATIONS* (plugin *expo-notifications* tự khai báo); iOS không cần chuỗi mô tả trong *Info.plist* cho thông báo nhưng cần quyền push (aps-environment), plugin tự thêm. Cả hai đều phải thêm plugin vào *app.json* trong cùng thay đổi.
- **Kênh Android**: "Mặc định" (có âm thanh), "Tin nhắn" (có âm thanh, mức cao), "Yên lặng" (mức thấp). iOS không có kênh; dùng *sound* và mức ngắt (*interruptionLevel*) trong push. Khả năng xếp chồng theo hội thoại trên iOS (*threadId*/category qua Expo) cần kiểm tra.
- **Badge**: iOS hiện số chính xác; Android tùy hãng máy.
- **Thư viện**: dùng *expo-notifications* đã cài (đúng Expo SDK 57); không cần thêm. Máy chủ gọi API Expo bằng *fetch* như hiện nay, không bắt buộc thêm *expo-server-sdk*.
- **Web quản trị**: không gửi push từ trang quản trị trong phạm vi này; có thể thêm sau ô "Gửi thông báo thử tới tài khoản" để dev kiểm tra.
- **Chi phí**: Expo push, FCM miễn phí. APNs cần tài khoản Apple Developer (99 USD/năm, vốn cần để lên App Store). EAS Build gói miễn phí giới hạn số lượt build mỗi tháng (con số cụ thể cần kiểm tra trên trang Expo).
- **Yêu cầu cửa hàng**: Apple không cho bắt buộc bật thông báo để dùng app, và không dùng push để quảng cáo nếu người dùng chưa đồng ý; màn giải thích phải

có nút "Để sau".

h) Tiêu chí hoàn thành

- Trên máy Android thật và iPhone thật (bản development build): nhận push cho từng loại (thích, bình luận, trả lời, nhắc tên, theo dõi, yêu cầu theo dõi, chấp nhận, đăng lại, tin nhắn, tin chờ, tin ẩn danh, cảm xúc story) khi app chạy nền và khi app tắt hẳn.
- Bấm từng loại mở đúng màn hình, cả khi app tắt hẳn; thông báo của tài khoản khác không mở nội dung.
- Tắt một loại thì không nhận push loại đó nhưng vẫn thấy trong danh sách; giờ yên lặng làm push im lặng; tạm dừng hoạt động đúng thời gian.
- 10 lượt thích trong 15 phút cho ra tối đa 2 push.
- Push tin ẩn danh và tin chờ không chứa tên hay nội dung (test tự động trên nội dung gửi tới Expo).
- Gỡ app trên một máy: sau khi đọc biên nhận, token của máy đó bị xóa.
- Badge đúng số chưa đọc trên iPhone; đọc hết thì về 0.
- Báo cáo ghi rõ đã chạy trên Android, trên iPhone, và phiên bản hệ điều hành.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (gom về một hàm gửi, cài đặt, giờ yên lặng, gộp, che, badge, chia lô, biên nhận và dọn token), mobile 4 ngày (cấu hình *app.json*/EAS, kênh Android, màn giải thích, mở màn khi bấm kể cả khởi động lạnh, badge, màn cài đặt), kiểm thử 3 ngày, cộng 1 ngày thiết lập tài khoản Firebase, Apple, EAS.
- Phụ thuộc: A2 (phiên và thiết bị, để xóa token khi đăng xuất từ xa), A3 (thông báo bảo mật), B8 (tắt tiếng), D6 (các loại thông báo mới). Cần tài khoản Apple Developer và quyền truy cập dự án Firebase.
- Rủi ro: thiết lập chứng chỉ thường mất thời gian hơn code; push trên iOS chỉ thử được trên máy thật. Việc giờ yên lặng phụ thuộc múi giờ máy gửi lên, sai múi giờ thì im lặng sai giờ.

D9. Tìm kiếm nâng cao: lịch sử tìm kiếm, gợi ý khi gõ @, tìm trong tin nhắn

Nhóm: Mạng xã hội đầy đủ · Giai đoạn: GĐ3 · Ước lượng: 10–11 ngày công

a) Mục đích

Bốn cải tiến nhỏ cho việc tìm: **lịch sử tìm kiếm** để mở lại nhanh người hoặc từ khóa vừa tìm; **gợi ý tên khi gõ @** để nhắc tên đúng người mà không phải nhớ tên đăng nhập; **tìm trong tin nhắn** để tìm lại địa chỉ, số tài khoản, hẹn giờ đã nhắn; và **tải thêm kết quả tìm người** khi cuộn. Mọi kết quả phải tôn trọng chặn, tài khoản bị khóa và che tên người ẩn danh.

b) Hiện trạng

- **Tìm người** (*apps/api/src/modules/search/search.service.ts*, *GET /users/search?q=&page=&limit=*): tìm chuỗi con không phân biệt hoa thường trong tên đăng nhập và tên hiển thị, bỏ người chặn nhau hai chiều, xếp theo tên đăng nhập A→Z (không theo mức khớp). Có phân trang (tối đa 50 mỗi trang). Cần kiểm tra: không lọc tài khoản bị admin khóa (*bannedAt*) hay bị khóa do dưới 18 tuổi (*ageLockedAt*).
- **App tìm người** (*apps/mobile/src/features/search*): chờ 350 ms sau khi gõ rồi gọi API, **chỉ lấy trang 1** (20 người), không tải thêm khi cuộn. Ô trống thì hiện gợi ý theo dõi và hashtag thịnh hành.
- **Tìm bài viết** (*GET /posts/search*): tìm chuỗi con trong nội dung, có hashtag, theo quyền xem, có tải thêm khi cuộn. Ghi chú *shortcut*: quét toàn bảng, cần chỉ mục *pg_trgm* (chỉ mục tìm chuỗi con của PostgreSQL) khi bài nhiều.
- **Nhắc tên**: máy chủ nhận ra *@tên* khi đăng bài và bình luận để gửi thông báo; app tô màu và bấm được *@tên* (*components/common/RichText.tsx*). **Chưa có gợi ý khi gõ @** (ghi trong báo cáo tính năng, mục V).
- **Lịch sử tìm kiếm**: chưa có. App chưa có thư viện lưu dữ liệu kiểu khóa–giá trị (AsyncStorage); đã có *expo-file-system* và *expo-secure-store*.
- **Tin nhắn** (*apps/api/src/modules/messages*): hội thoại 1-1, tin chữ và ảnh, lưu dạng chữ thường trên máy chủ (không mã hóa đầu cuối). Tải tin theo trang ngược thời gian (*before*), danh sách hội thoại lấy 100 gần nhất. **Chưa có tìm kiếm.** Hội thoại ẩn danh được che tên ở mọi API (*ANONYMOUS_PEER*).

c) Cách hoạt động

Luồng 1: Lịch sử tìm kiếm

1. Khi người dùng bấm vào một người, một hashtag, hoặc gửi từ khóa (từ 2 ký tự), app lưu mục đó lên đầu lịch sử. Trùng thì đưa lên đầu, không thêm dòng.

2. Lưu trên máy, riêng theo tài khoản (một tệp JSON nhỏ bằng *expo-file-system*), tối đa 20 mục. Không gửi lên máy chủ.
3. Ô tìm trống: hiện "Gần đây" trên cùng, mỗi dòng có nút xóa; có nút "Xóa tất cả". Bên dưới vẫn là gợi ý và hashtag thịnh hành như hiện nay.
4. Đăng xuất hoặc xóa tài khoản thì xóa tệp lịch sử của tài khoản đó.
5. Mục là người đã chặn nhau hoặc tài khoản không còn: bấm vào thì trang cá nhân báo không tìm thấy và app tự bỏ mục đó.

Luồng 2: Tải thêm kết quả tìm người

1. App dùng lại cách tải thêm của danh sách bài (*usePostList*): cuộn gần cuối thì xin trang kế tiếp tới khi hết.
2. Máy chủ xếp theo mức khớp: trùng hẳn tên đăng nhập, rồi bắt đầu bằng từ khóa, rồi chứa từ khóa; trong cùng mức thì người mình theo dõi trước. Bỏ tài khoản bị khóa.

Luồng 3: Gợi ý tên khi gõ @

1. Trong ô viết bài, sửa bài, bình luận, khi người dùng gõ @ ở đầu dòng hoặc sau dấu cách, app nhận ra cụm đang gõ (chữ, số, dấu chấm, gạch dưới).
2. Chỉ có @: hiện tối đa 8 người hay tương tác (lấy từ lần gọi gần nhất). Có chữ: chờ 250 ms, xem bộ đệm trong bộ nhớ (60 giây), không có thì gọi *GET /users/mention-suggest?q=*.
3. Máy chủ tìm theo tên đăng nhập và tên hiển thị, ưu tiên: người theo dõi hai chiều, người mình theo dõi, người mình nhắn tin trong 30 ngày, rồi người khác. Bỏ: chặn hai chiều, tài khoản bị khóa, người đặt "Không ai được nhắc tên tôi" (cài đặt ở D6). Với bình luận dưới bài *FRIENDS*, chỉ gợi ý người xem được bài.
4. App hiện danh sách ngay trên bàn phím. Người dùng bấm một người: app thay cụm đang gõ bằng *@tên* . Gõ tiếp hoặc thêm dấu cách thì danh sách đóng.
5. Khi đăng, máy chủ gửi thông báo nhắc tên như hiện nay, cộng thêm kiểm tra quyền xem và giới hạn 10 người (D6).

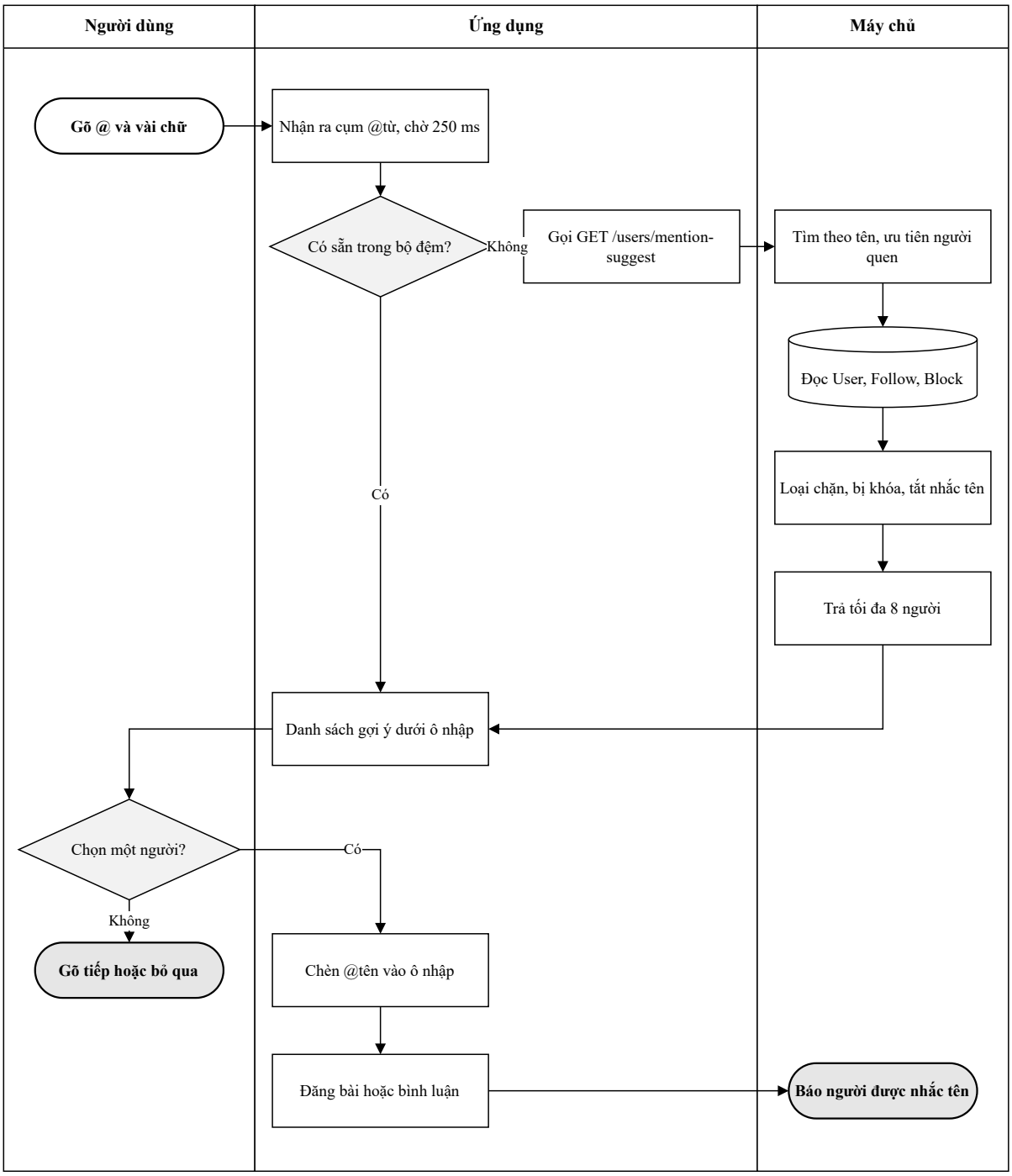
Luồng 4: Tìm trong tin nhắn

1. Ở tab Tin nhắn có ô tìm. Gõ từ khóa: app lọc ngay tên trong danh sách hội thoại đang có, đồng thời sau 350 ms gọi *GET /messages/search?q=*.
2. Máy chủ chỉ tìm trong hội thoại mà người hỏi là thành viên và đang hiện trong hộp thư (cùng điều kiện *inboxWhere*); bỏ tin đã thu hồi (D2), bỏ hội thoại người hỏi đã xóa phía mình (nếu D2 thêm), chỉ tìm tin chữ.

3. Kết quả trong hội thoại ẩn danh chưa tiết lộ: phía người nhận hiện "Người ẩn danh", không lộ tên.
4. Trả 20 kết quả mỗi trang, mới nhất trước, kèm đoạn trích quanh từ khóa và con trỏ trang sau.
5. Bấm một kết quả: app mở hội thoại tại tin đó (máy chủ trả 20 tin trước và 20 tin sau), cuộn tới và tô sáng tin trong 2 giây. Cuộn lên, xuống thì tải tiếp như bình thường.

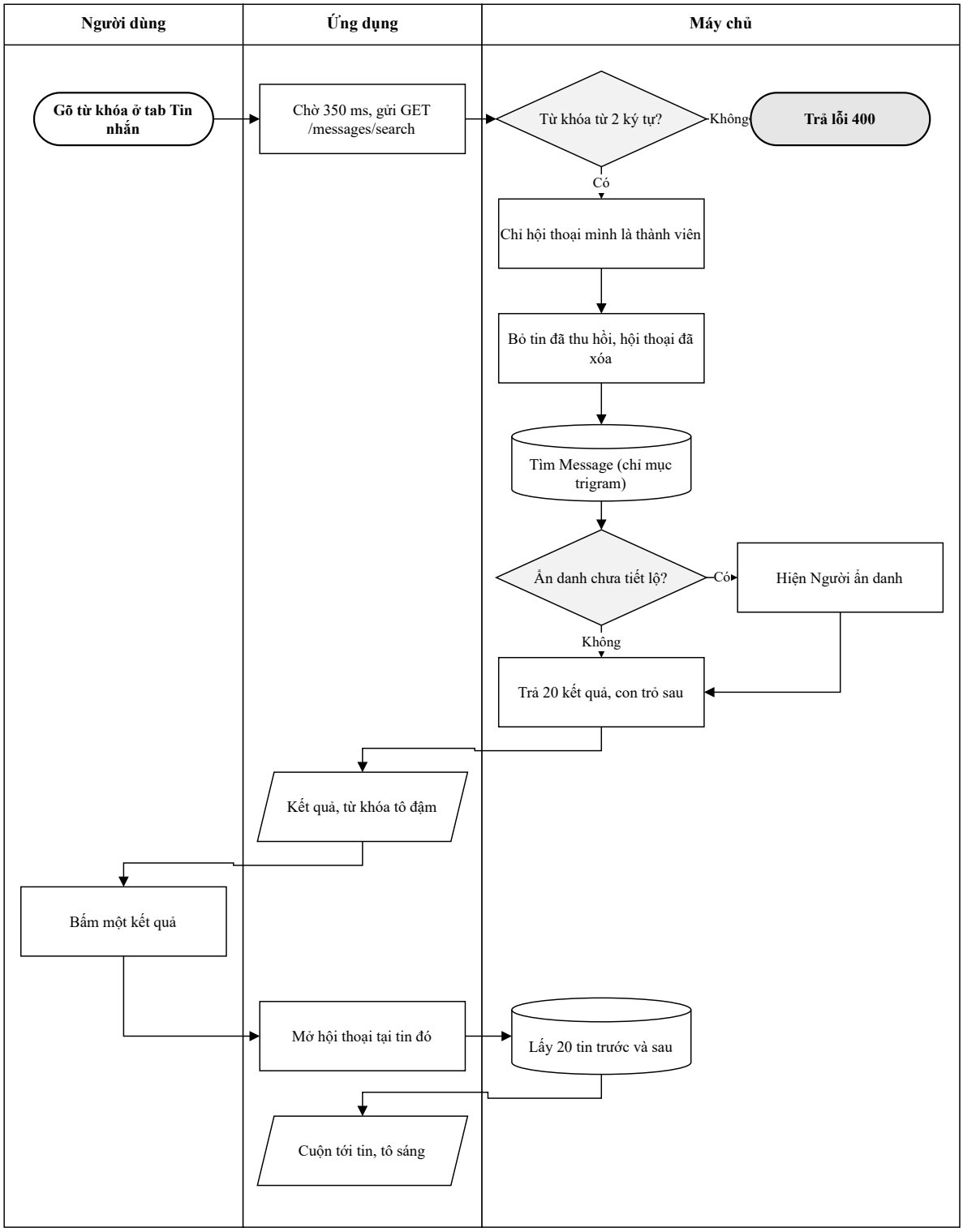
d) Flowchart

Sơ đồ 1: gợi ý tên khi gõ @.



Hình 66. Gợi ý tên khi gõ @ trong bài viết, bình luận

Sơ đồ 2: tìm trong tin nhắn và mở đúng tin.



Hình 67. Tìm kiếm trong tin nhắn

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Con số đề xuất**: lịch sử 20 mục; gợi ý @ tối đa 8 người, chờ 250 ms, bộ đệm 60 giây; tìm tin nhắn từ 2 ký tự, 20 kết quả mỗi trang, tối đa 30 lần tìm mỗi phút mỗi người; tìm người tối đa 50 mỗi trang (giữ như hiện có).

- **Chống dò danh sách người dùng**: gợi ý @ và tìm người dùng chung giới hạn tốc độ (đề xuất 60 yêu cầu mỗi phút mỗi người), ngoài giới hạn 300 yêu cầu/phút/IP hiện có.
- **Tài khoản riêng tư** vẫn hiện trong tìm người và gợi ý @ (giống hiện nay), vì chỉ lộ tên và ảnh đại diện.
- **Tiếng Việt không dấu**: gõ "nguyen" chưa ra "Nguyễn". Có thể thêm phần mở rộng *unaccent* của PostgreSQL (Supabase có sẵn) cho tìm người và tìm tin nhắn; đề xuất làm cùng đợt, nhưng cần Dev B đồng ý vì phải thêm phần mở rộng vào cơ sở dữ liệu.
- **Mạng lỗi**: gợi ý @ lỗi thì đóng danh sách, không báo lỗi (người dùng vẫn gõ tay được). Tìm tin nhắn lỗi thì hiện "Không tải được kết quả" và nút thử lại.
- **Người bị chặn**: không hiện ở mọi kết quả. Tìm tin nhắn dùng cùng điều kiện với hộp thư hiện nay (*inboxWhere* trong *messages.service.ts*, đã bỏ hội thoại với người chặn nhau), nên tin trong hội thoại đó cũng không ra, cho tới khi bỏ chặn.
- **Ảnh nhạy cảm** trong tin nhắn không được tìm (không có chữ). Nếu sau này có mã hóa đầu cuối, tìm tin nhắn phải chuyển xuống máy và bỏ API này.
- **Nhóm chat** (D1): phạm vi tìm mở rộng sang các nhóm người hỏi đang là thành viên; tin trước lúc vào nhóm không trả.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và được Dev B duyệt trước khi code.

Thay đổi dữ liệu	**Nội dung**
Chỉ mục *pg_trgm*	Trên *User.username*, *User.displayName*, *Message.content* (và *Post.content* đang có ghi chú). Migration mới, cần bật phần mở rộng *pg_trgm*.
Lịch sử tìm kiếm	Không có bảng mới: lưu trên máy.

Endpoint	**Mục đích**
GET /users/search	Giữ nguyên tham số; đổi thứ tự theo mức khớp, bỏ tài khoản bị khóa; mỗi người có thêm *isFollowing*.
GET /users/mention-suggest?q=&postId=	Tối đa 8 người *{ id, username, displayName, avatarUrl }*. *postId* (tùy chọn) để chỉ gợi ý người xem được bài đó. Đặt trước route */users/:id* (xem DEC-018).

GET /messages/search?q=&cursor=	*{ data: [{ messageId, conversationId, peer, snippet, createdAt }], meta: { nextCursor } }*. *peer* đã được che nếu ẩn danh.
GET /conversations/:id/messages?around=<messageId>	Thêm tham số *around*: trả 20 tin trước và 20 tin sau tin đó, để mở đúng chỗ.

g) Android, iOS và web

- Không cần quyền thiết bị, không thêm thư viện: lịch sử dùng *expo-file-system* đã cài (lưu trong thư mục tài liệu của app, bị xóa khi gỡ app trên cả hai nền tảng). Không dùng *expo-secure-store* cho việc này, vì trên iOS dữ liệu trong Keychain có thể còn lại sau khi gỡ app.
- Danh sách gợi ý @ phải nằm trên bàn phím: dùng *KeyboardAvoidingView* với *behavior* khác nhau theo nền tảng như các màn hiện có; kiểm tra trên iPhone có tai thỏ và Android có thanh điều hướng.
- Nhận vị trí con trỏ trong ô nhập bằng *onSelectionChange* của *TextInput*; hành vi có khác nhau nhỏ giữa Android và iOS khi gõ tiếng Việt bằng bộ gõ Telex (chữ đang ghép dấu), cần thử trên cả hai với bàn phím tiếng Việt.
- Chi phí: không có dịch vụ ngoài. Chỉ mục *pg_trgm* tăng dung lượng cơ sở dữ liệu một ít.

h) Tiêu chí hoàn thành

- Lịch sử: lưu, đưa lên đầu khi trùng, xóa từng mục, xóa tất cả, tách theo tài khoản, xóa khi đăng xuất.
- Tìm người: cuộn tải thêm tới hết; trùng hẳn tên đăng nhập đứng đầu; tài khoản bị khóa và người chặn nhau không xuất hiện (test tự động).
- Gợi ý @: hiện trong ô bài viết, sửa bài, bình luận; chèn đúng *@tên*; không gợi ý người chặn nhau, người tắt nhắc tên, và (với bài *FRIENDS*) người không xem được bài.
- Tìm tin nhắn: chỉ trả tin trong hội thoại của mình (test tự động với tài khoản thứ ba); hội thoại ẩn danh không lộ tên; bấm kết quả mở đúng tin và tô sáng.
- Gõ tiếng Việt có dấu bằng Telex trong ô có gợi ý @ không làm mất chữ, trên cả Android và iPhone.
- Báo cáo ghi rõ đã chạy trên Android, trên iPhone.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (gợi ý @ 1, xếp hạng và lọc tìm người 1, tìm tin nhắn và *around* 1,5, chỉ mục 0,5), mobile 5 ngày (lịch sử 1, tải thêm 0,5, ô nhập có gợi ý @ dùng chung cho 3 chỗ 2, màn tìm tin nhắn 1,5), kiểm thử 2 ngày.

- Phụ thuộc: D6 (cài đặt "ai được nhắc tên tôi" và giới hạn 10 người), D2 (tin đã thu hồi), D1 (tìm trong nhóm). Có thể làm trước và thêm điều kiện khi các mã kia xong.
- Rủi ro: tìm chuỗi con trong bảng tin nhắn lớn sẽ chậm nếu thiếu chỉ mục *pg_trgm*; ô nhập có gợi ý dễ lỗi với bộ gõ tiếng Việt.

NHÓM E. QUYỀN RIÊNG TƯ VÀ TUÂN THỦ

E1. Tải xuống dữ liệu của bạn

Nhóm: Quyền dữ liệu cá nhân · Giai đoạn: GĐ3 · Ước lượng: 8–9 ngày công

a) Mục đích

Người dùng xin được một bản sao toàn bộ dữ liệu của mình (hồ sơ, bài viết, bình luận, tin nhắn, ảnh, video, cảm xúc, danh sách theo dõi) dưới dạng một tệp ZIP. Đây là quyền của chủ thể dữ liệu theo luật bảo vệ dữ liệu cá nhân của Việt Nam và của nhiều nước khác. Tính năng cũng giúp người dùng lưu lại kỷ niệm trước khi xóa tài khoản (E2), và cho thấy sản phẩm minh bạch về dữ liệu.

Về pháp lý: Nghị định 13/2023/NĐ-CP và Luật Bảo vệ dữ liệu cá nhân (có hiệu lực từ 01/01/2026) cho người dùng quyền được biết, được truy cập và nhận bản sao dữ liệu cá nhân của mình, và đặt thời hạn phản hồi yêu cầu. **Thời hạn cụ thể, dạng tệp bắt buộc và cách xử lý dữ liệu liên quan tới người khác phải do luật sư xác nhận**; các con số trong mục này là đề xuất kỹ thuật, không phải tư vấn pháp lý. Nếu app có người dùng ở EU thì GDPR (quy định bảo vệ dữ liệu của EU) cũng áp dụng, thường với thời hạn 30 ngày.

b) Hiện trạng

- **Chưa có tính năng xuất dữ liệu.** Không có endpoint, màn hình hay bảng nào cho việc này. Trang Chính sách quyền riêng tư (*apps/mobile/src/features/settings/screens/LegalScreen.tsx*) là bản nháp, chưa nhắc tới quyền nhận bản sao dữ liệu.
- **Có sẵn để dùng lại:**
  - Bucket riêng tư (kho tệp không đọc công khai) và URL có chữ ký (link tải có thời hạn): *apps/api/src/modules/storage/storage.service.ts*, *media-url.ts*. Hiện chỉ ảnh tin nhắn nằm ở đây (giá trị lưu dạng *s3p:<key>*, link ký hết hạn sau 1 giờ).
  - Gửi email: *apps/api/src/modules/mail/mail.service.ts* (nodemailer qua SMTP), hiện chỉ có email mã OTP xác minh và đặt lại mật khẩu.
  - Thông báo đẩy: *NotificationsService.pushToUser* gửi qua dịch vụ push của Expo (Expo chuyển tiếp sang FCM cho Android và APNs cho iOS).
  - Xác nhận lại danh tính trước thao tác nguy hiểm: *UsersService.deleteAccount* đã làm mẫu (tài khoản có mật khẩu nhập mật khẩu; tài khoản chỉ đăng nhập

Google gõ lại username). Sai thì trả 400, không trả 401, vì app tự đăng xuất khi gặp 401.

    - Giới hạn tần suất theo IP: *@nestjs/throttler* (300 yêu cầu/phút chung, các route đăng nhập chặt hơn) trong *app.module.ts*, *auth.controller.ts*.

- **Thiếu:** hàng đợi việc nền và lịch chạy định kỳ (backend chưa có *@nestjs/schedule*, BullMQ hay Redis), thư viện tạo ZIP, bảng lưu yêu cầu xuất, email "tệp đã sẵn sàng".
- **Dữ liệu có trong cơ sở dữ liệu** (*apps/api/prisma/schema.prisma*): User, Post + PostMedia, Comment, Like (6 loại cảm xúc), CommentLike, Repost, Save, HiddenPost, Follow, FollowRequest, Block, Report, Conversation + Message, Story + StoryView + StoryReaction, Notification, ContentInteraction (lịch sử xem Reels), DeviceToken, AuthToken.
- **Dữ liệu ẩn danh cần che:** hội thoại ẩn danh (*Conversation.kind* = ANON_A/ANON_B, che danh tính tới khi *revealedAt*), cảm xúc story ẩn danh (*StoryReaction.isAnonymous*). MessagesService đang che ở mọi chỗ trả dữ liệu; bản xuất phải che y như vậy.

c) Cách hoạt động

Luồng 1: Yêu cầu tệp dữ liệu

1. Người dùng vào *Cài đặt > Quyền riêng tư > Tải xuống dữ liệu của bạn*. App hiện danh sách nội dung có trong tệp, những gì không có, thời gian chuẩn bị (thường vài phút, tối đa 48 giờ, đề xuất) và trạng thái yêu cầu gần nhất.
2. Người dùng chọn phạm vi: *Toàn bộ* (có ảnh, video) hoặc *Chỉ chữ* (nhẹ, không có tệp ảnh, video). Bấm *Yêu cầu tệp*.
3. App hỏi lại mật khẩu. Tài khoản chỉ đăng nhập Google thì đăng nhập Google lại để lấy token mới (không dùng cách gõ username như màn xóa tài khoản, vì bản xuất chứa toàn bộ tin nhắn). Khi đã có 2FA (A1) thì hỏi thêm mã 6 số.
4. Máy chủ kiểm tra: xác nhận đúng; tài khoản không bị khóa; chưa có yêu cầu nào trong 24 giờ qua và không có yêu cầu đang chạy. Sai mật khẩu trả 400 và đếm số lần sai (dùng chung bộ đếm của A4). Vượt giới hạn trả 429 kèm thời điểm được yêu cầu lại.
5. Máy chủ tạo một dòng *DataExport* trạng thái PENDING và gửi email: "Có yêu cầu tải dữ liệu từ tài khoản của bạn. Nếu không phải bạn, hãy đổi mật khẩu." Email này giúp phát hiện kẻ chiếm tài khoản đang lấy dữ liệu.
6. App hiện "Đang chuẩn bị tệp. Chúng tôi sẽ báo khi xong." Người dùng có thể rời màn hình.

Luồng 2: Tạo tệp (việc nền)

1. Việc nền chạy mỗi phút, nhận một yêu cầu PENDING bằng cách đổi trạng thái sang PROCESSING có điều kiện (chỉ một tiến trình nhận được, kể cả khi chạy nhiều bản API).
2. Đọc dữ liệu theo từng phần (mỗi lần 500 dòng) để không tốn bộ nhớ. Ghi mỗi loại dữ liệu ra một tệp JSON, kèm một trang *index.html* dễ đọc bằng trình duyệt.
3. Với phạm vi *Toàn bộ*: chép ảnh, video từ kho vào thư mục *media/* trong ZIP. Tệp ZIP được ghi thẳng lên bucket riêng tư theo dòng chảy (không giữ cả tệp trong RAM).
4. Lỗi (mất kết nối kho, hết thời gian): thử lại tối đa 3 lần, cách nhau 5 phút. Hỏng cả 3 lần thì đánh dấu FAILED, gửi email và push "Chưa tạo được tệp, vui lòng thử lại". Yêu cầu FAILED không tính vào giới hạn 24 giờ.
5. Thành công: lưu khóa tệp, kích thước, đặt trạng thái READY, hạn tải 7 ngày. Gửi email và push "Tệp dữ liệu của bạn đã sẵn sàng". Email **không** chứa link tải trực tiếp, chỉ hướng dẫn mở app.

Luồng 3: Tải tệp

1. Người dùng mở thông báo hoặc vào lại màn *Tải xuống dữ liệu*, bấm *Tải xuống*.
2. App hỏi lại mật khẩu (như bước 3 của luồng 1).
3. Máy chủ kiểm tra: xác nhận đúng, tệp thuộc về người này, còn hạn, chưa quá 10 lượt tải. Đúng thì tạo URL có chữ ký sống 15 phút (đề xuất), kèm tên tệp gợi ý *du-lieu-<username>-<ngày>.zip*, và ghi một lượt tải.
4. App mở URL bằng trình duyệt của hệ điều hành. Trình duyệt tải tệp về máy (Android: thư mục Tải xuống; iPhone: ứng dụng Tệp).
5. Hết 7 ngày, việc dọn dẹp xóa tệp khỏi kho, đặt trạng thái EXPIRED; dòng DataExport giữ lại làm nhật ký.

Nội dung tệp (đề xuất)

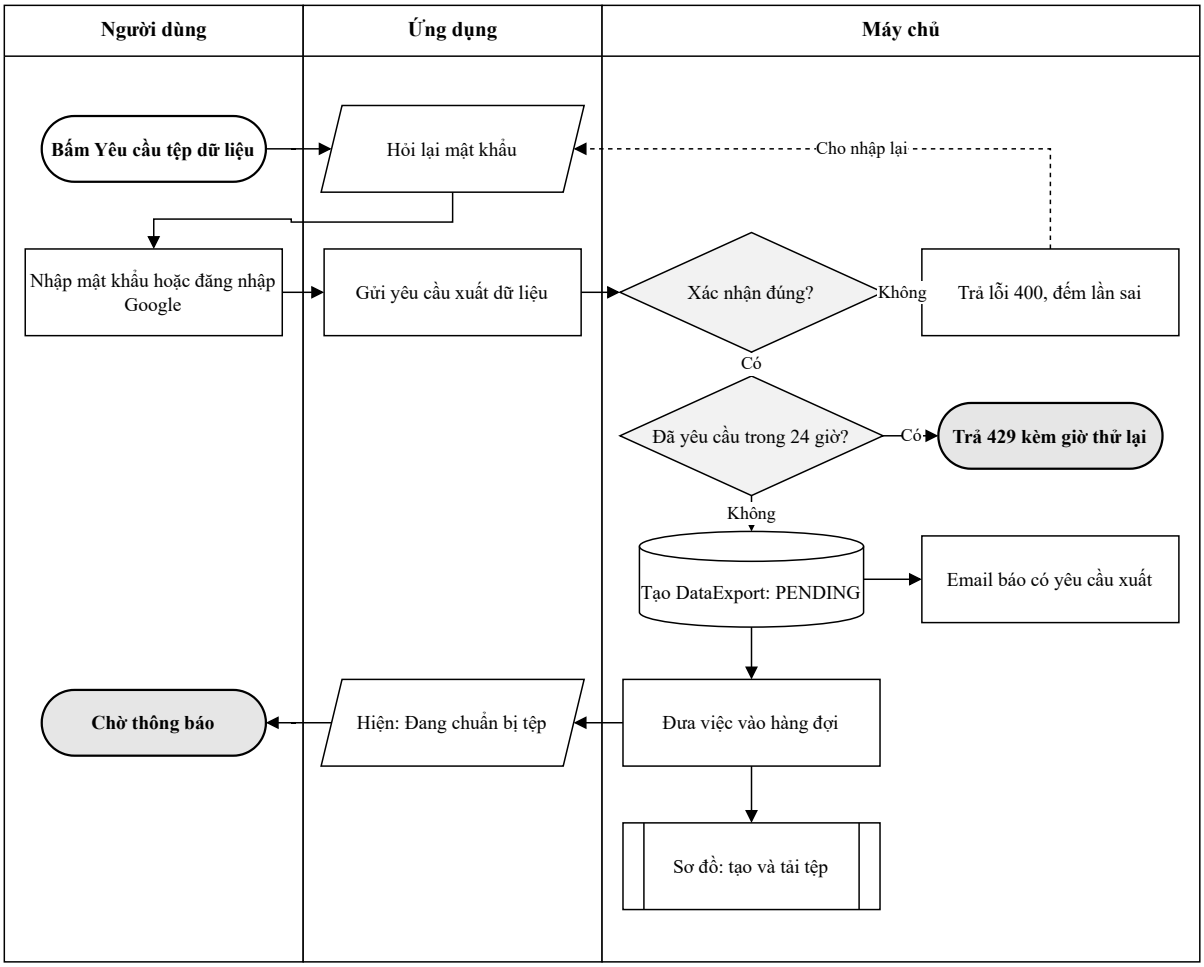
Thư mục / tệp	Có gì
profile.json	username, email, tên hiển thị, tiểu sử, ngày sinh, ngày tạo, tài khoản riêng tư hay không, cài đặt nhận tin ẩn danh. Không có mật khẩu băm.
posts.json	Bài viết của mình (cả bài đã xóa mềm còn trong cơ sở dữ liệu, ghi rõ "đã xóa"), quyền xem, số cảm xúc, số bình luận, tên tệp ảnh/video tương ứng.
comments.json	Bình luận mình viết, kèm id bài và câu trả lời mình viết. Không chép bình luận của người khác.

reactions.json	Cảm xúc mình thả cho bài viết, thích bình luận, cảm xúc story.
followers.json, following.json, blocked.json	Username của người theo dõi mình, người mình theo dõi, người mình chặn, yêu cầu theo dõi đang chờ.
messages/<id hội thoại>.json	Mọi tin nhắn trong hội thoại mình tham gia (cả tin của người kia, vì mình đã nhận được). Ảnh tin nhắn trong *media/messages/*. Người gửi ẩn danh chưa tiết lộ ghi là "Người ẩn danh".
stories.json	Story mình đăng còn trong cơ sở dữ liệu. Không có danh sách người xem.
saved.json, reposts.json, hidden.json	Bài đã lưu, đã đăng lại, đã ẩn (chỉ id và link, không chép nội dung bài của người khác).
reports.json	Báo cáo mình đã gửi: loại đối tượng, lý do, ghi chú, trạng thái.
activity.json	Lịch sử xem Reels (ContentInteraction), danh sách thiết bị nhận thông báo (chỉ loại máy, không có token).
media/	Ảnh đại diện, ảnh bìa, ảnh và video bài viết, story, ảnh tin nhắn mình gửi.
index.html	Trang tóm tắt, mở bằng trình duyệt, có link tới từng tệp.

Không có trong tệp: mật khẩu băm, token đăng nhập, mã OTP, token thiết bị; danh tính người gửi ẩn danh chưa tự tiết lộ (trong tin nhắn và cảm xúc story); báo cáo người khác gửi về mình (lộ người báo cáo); ghi chú và quyết định nội bộ của quản trị viên; bình luận, bài viết của người khác; ai đã xem story của mình (đề xuất, chủ dự án quyết).

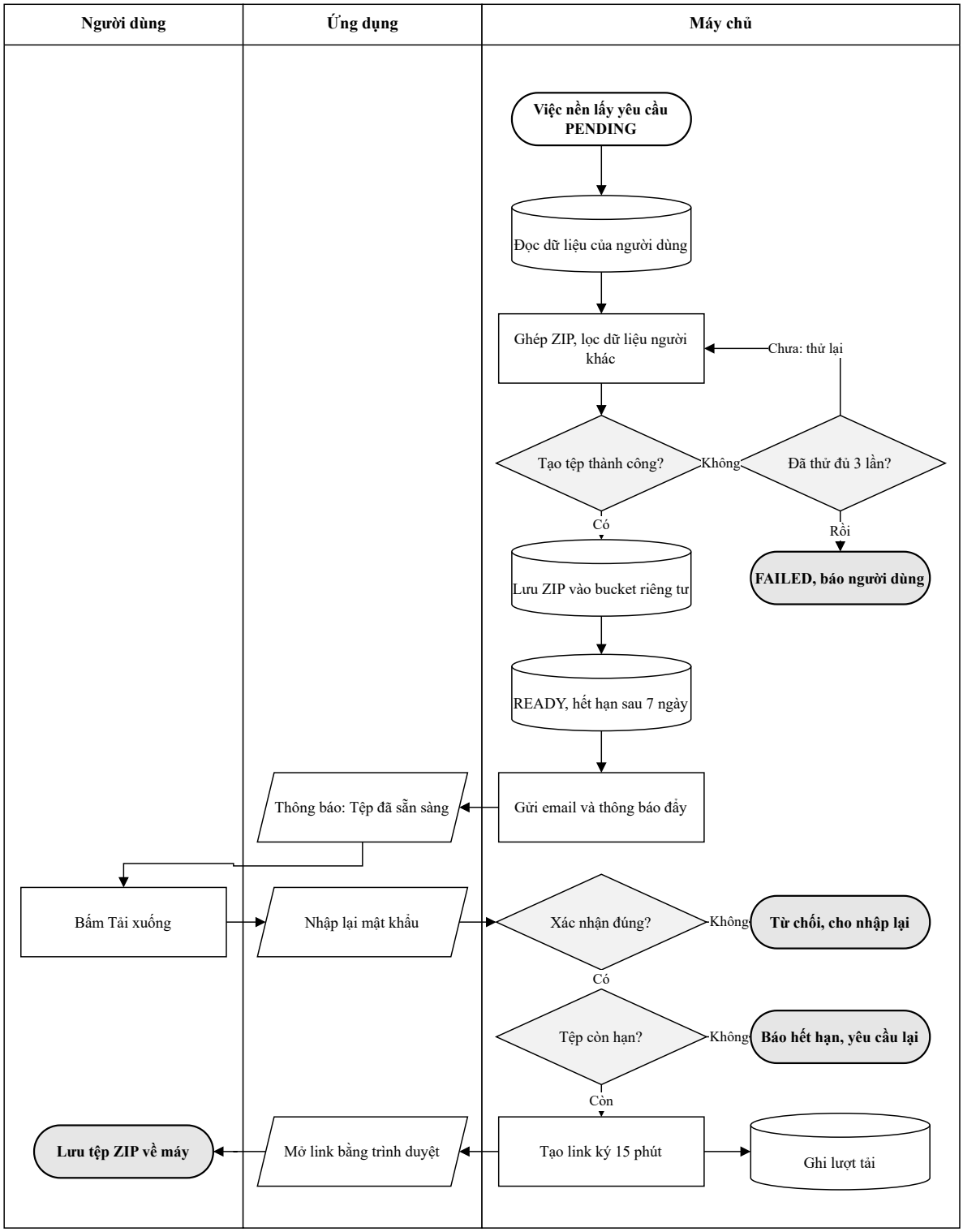
d) Flowchart

Sơ đồ 1: người dùng yêu cầu tệp, xác nhận lại danh tính, máy chủ kiểm tra giới hạn và xếp việc.



Hình 68. Yêu cầu tải xuống dữ liệu của bạn

Sơ đồ 2: việc nền tạo tệp ZIP (có thử lại), báo cho người dùng, tải bằng link có hạn sau khi xác nhận lại.



Hình 69. Tạo tệp ZIP và tải xuống bằng link có hạn

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Giới hạn (đề xuất):** 1 yêu cầu mỗi 24 giờ mỗi tài khoản; không tạo yêu cầu mới khi đang có yêu cầu PENDING/PROCESSING; tối đa 10 lượt tải mỗi tệp; thêm *@Throttle* 5 lần/giờ theo IP cho route yêu cầu và route tải (chống dò mật khẩu).

- **Thời hạn:** tệp sống 7 ngày; link ký sống 15 phút; việc tạo tệp phải xong trong 48 giờ (đề xuất, luật sư xác nhận thời hạn phản hồi theo luật).
- **Kích thước:** tài khoản nhiều video có thể ra tệp vài GB. Đề xuất trần 4 GB một tệp; vượt thì chia thành nhiều phần (*part-1.zip*, *part-2.zip*). Phạm vi *Chỉ chữ* luôn nhỏ.
- **Tệp ảnh bị thiếu trong kho** (ví dụ tệp chỉ có trên máy dev khác, xem *docs/decisions.md* mục lưu trữ cục bộ): bỏ qua, ghi tên tệp vào *missing-files.txt* trong ZIP, không làm hỏng cả bản xuất.
- **Ảnh cũ là URL tuyệt đối** (Supabase, ảnh Google): ghi link vào JSON, không tải về.
- **Tài khoản bị khóa** (bannedAt) không đăng nhập được nên không tự yêu cầu được; nếu luật yêu cầu vẫn phải cung cấp, quản trị viên tạo yêu cầu thay từ trang quản trị (đề xuất, luật sư xác nhận). Tài khoản khóa vì dưới 18 tuổi (ageLockedAt): cùng cách.
- **Tài khoản đang chờ xóa (E2):** khi người dùng yêu cầu xóa, hủy các yêu cầu xuất đang chờ và xóa tệp đã tạo. Màn xóa tài khoản gợi ý tải dữ liệu trước.
- **Người bị chặn:** hội thoại với người mình đã chặn vẫn có trong tệp (dữ liệu của mình). Không thêm gì về người đã chặn mình ngoài những gì mình từng thấy.
- **Lỗi mạng khi tải:** link còn hạn thì bấm tải lại không cần nhập lại mật khẩu trong 15 phút; hết hạn thì xác nhận lại để lấy link mới.
- **Lạm dụng:** kẻ chiếm tài khoản muốn lấy dữ liệu sẽ bị chặn bởi việc nhập lại mật khẩu và 2FA, và chủ tài khoản nhận email ngay khi có yêu cầu.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và ghi quyết định vào *docs/decisions.md* trước khi code.

Bảng / trường mới	**Ý nghĩa**
DataExport.id, userId (Cascade theo User)	Một yêu cầu xuất.
scope: FULL | TEXT_ONLY	Phạm vi.
status: PENDING | PROCESSING | READY | FAILED | EXPIRED | CANCELLED	Trạng thái.
attempts Int, error String?	Số lần thử, lỗi gần nhất (không hiện cho người dùng).
fileKeys String[], sizeBytes BigInt?	Khóa tệp trong bucket riêng tư (nhiều phần nếu chia).

createdAt, startedAt, readyAt, expiresAt, downloadCount	Mốc thời gian và số lượt tải. Chỉ mục (userId, createdAt).

Endpoint	**Mô tả**
GET /users/me/data-exports	Yêu cầu gần nhất và trạng thái; thời điểm được yêu cầu lại.
POST /users/me/data-exports { scope, password? | googleIdToken?, totp? }	Tạo yêu cầu. Lỗi: 400 sai xác nhận, 409 đang có yêu cầu chạy, 429 code *EXPORT_RATE_LIMITED* kèm *retryAt*.
POST /users/me/data-exports/:id/download { password? | googleIdToken?, totp? }	Trả *{ urls: [...], expiresAt }*. Lỗi: 400 sai xác nhận, 404 không thuộc mình, 410 hết hạn.
POST /admin/users/:id/data-export	(Tùy chọn) quản trị viên tạo bản xuất cho tài khoản bị khóa; ghi nhật ký (C3).

Backend cần thêm: *StorageService* hàm tải lên theo dòng chảy và hàm ký URL tải có *ResponseContentDisposition* (tên tệp); *MailService* 3 mẫu email (có yêu cầu, sẵn sàng, thất bại). Thư viện mới (chỉ backend, cần ghi vào *docs/decisions.md*): *archiver* (tạo ZIP theo dòng chảy), *@aws-sdk/lib-storage* (tải lên nhiều phần), *@nestjs/schedule* (việc chạy định kỳ; dùng chung với E2, E3, E4). Không cần Redis ở giai đoạn này: hàng đợi chính là bảng DataExport.

g) Android, iOS và web

- **Tải tệp:** dùng *Linking.openURL* có sẵn trong React Native để mở link ký bằng trình duyệt hệ thống. Không cần thư viện mới, không cần quyền thiết bị trên cả hai nền tảng. Android: Chrome lưu vào Tải xuống. iOS: Safari hiện hỏi tải, tệp vào ứng dụng Tệp (Files).
- **Đăng nhập Google lại:** dùng *@react-native-google-signin/google-signin* đã cài (có cấu hình cả hai nền tảng). Khi có Đăng nhập bằng Apple (A6), tài khoản Apple xác nhận lại bằng Apple.
- **Thông báo:** push qua Expo (FCM + APNs) đã có; người tắt quyền thông báo vẫn nhận email và thấy trạng thái trong màn hình.
- **Bàn phím:** ô nhập mật khẩu dùng *KeyboardAvoidingView* như *DeleteAccountScreen* (padding trên iOS).
- **Mạng:** link ký phải là HTTPS ở bản phát hành (iOS chặn HTTP thường); *S3_PUBLIC_URL* / *S3_ENDPOINT* production phải là tên miền HTTPS.
- **Chi phí:** dung lượng kho cho tệp ZIP (sống 7 ngày, xóa tự động) và băng thông tải xuống. Email qua SMTP hiện có; khi lượng người dùng lớn cần dịch vụ email giao

dịch (có phí theo số email).

- **Cửa hàng:** App Store và Google Play không bắt buộc tính năng này, nhưng mục "An toàn dữ liệu" của Google Play và nhãn quyền riêng tư của Apple nên mô tả đúng.

h) Tiêu chí hoàn thành

- Yêu cầu tệp, nhận email "có yêu cầu", nhận push và email "đã sẵn sàng", tải về và giải nén được, *index.html* mở được.
- Sai mật khẩu trả 400 và không đăng xuất app; yêu cầu lần 2 trong 24 giờ bị từ chối với giờ được thử lại.
- Tệp không chứa mật khẩu băm, token, danh tính người gửi ẩn danh chưa tiết lộ, báo cáo người khác gửi về mình (có test tự động kiểm tra từng điều).
- Link ký hết hạn sau 15 phút; tệp bị xóa khỏi kho sau 7 ngày; lỗi kho được thử lại 3 lần rồi báo FAILED.
- Hai bản API chạy cùng lúc không xử lý trùng một yêu cầu.
- Tải về được trên Android (máy thật hoặc giả lập) và trên iPhone; báo cáo ghi rõ đã chạy trên nền tảng nào.
- Chính sách quyền riêng tư cập nhật mục "Quyền của bạn" (luật sư duyệt câu chữ).

i) Ước lượng và phụ thuộc

- Backend 5 ngày (bảng, 3 endpoint, việc nền, ZIP theo dòng chảy, che dữ liệu ẩn danh, email, dọn dẹp); mobile 2 ngày (màn trạng thái, xác nhận lại, mở link); kiểm thử 1,5 ngày.
- Phụ thuộc: không bắt buộc. Dùng chung hạ tầng việc nền với E2. Nên có A1 (2FA) và A4 (chống dò mật khẩu) để xác nhận lại chặt hơn; A6 nếu có tài khoản Apple.
- Rủi ro: tệp rất lớn làm việc nền chạy lâu và tốn băng thông; bỏ sót một bảng mới thêm sau này (cần quy ước: thêm bảng chứa dữ liệu người dùng thì cập nhật bản xuất); lộ danh tính ẩn danh nếu che sai (phải có test).

E2. Xóa tài khoản có thời gian chờ 30 ngày và trang web yêu cầu xóa

Nhóm: Quyền dữ liệu cá nhân · Giai đoạn: GĐ1 · Ước lượng: 11–12 ngày công

a) Mục đích

Hôm nay bấm xóa là mất ngay mọi thứ, không cứu được nếu bấm nhầm hoặc bị người khác chiếm tài khoản rồi xóa. Thời gian chờ 30 ngày cho người dùng cơ hội đổi ý (chỉ cần đăng nhập lại). Google Play bắt buộc có một **trang web** để yêu cầu xóa tài khoản mà không cần cài app; thiếu trang này app có thể bị từ chối khi đăng lên cửa hàng. Tính năng cũng làm rõ dữ liệu nào bị xóa, dữ liệu nào phải giữ lại vì lý do pháp lý (báo cáo vi phạm, nhật ký).

b) Hiện trạng

- **Xóa ngay, trong app:** *DELETE /users/me* (*apps/api/src/modules/users/users.controller.ts → UsersService.deleteAccount*). Tài khoản có mật khẩu phải nhập mật khẩu (so bằng bcrypt); tài khoản chỉ có Google gõ lại username. Sai trả 400.
- **Thứ tự xóa hiện tại:** (1) gom đường dẫn tệp: ảnh, video và ảnh thu nhỏ của mọi bài viết (kể cả bài đã xóa mềm), tệp story, ảnh trong **mọi** hội thoại của người này (cả ảnh do người kia gửi), ảnh bìa, ảnh đại diện; (2) *prisma.user.delete*, các bảng liên quan bị xóa theo nhờ *onDelete: Cascade*; (3) *StorageService.removeByUrls* xóa tệp ở cả bucket công khai và riêng tư, bỏ qua URL ngoài kho (ảnh Google, ảnh cũ Supabase), **nuốt mọi lỗi** (Promise.allSettled), không thử lại, nên tệp có thể còn sót lại mà không ai biết.
- **Hệ quả của Cascade** (*apps/api/prisma/schema.prisma*):
  - Bài viết, bình luận, cảm xúc, bài đăng lại, lưu, theo dõi, chặn, story, thông báo, token thiết bị, lịch sử xem Reels bị xóa.
  - Bình luận người khác viết dưới bài của người này, và câu trả lời của người khác dưới bình luận của người này, cũng mất (Cascade theo Post và Comment cha).
  - **Hội thoại** (Conversation.userA/userB Cascade): người kia mất **toàn bộ** cuộc trò chuyện, kể cả tin họ gửi.
  - **Báo cáo người này đã gửi** (Report.reporter Cascade) bị xóa, kể cả báo cáo đang mở.
  - **Báo cáo về người này** còn lại (targetId là chuỗi, không có khóa ngoại) nhưng trỏ tới tài khoản không còn. Báo cáo hội thoại giữ bản chụp tin nhắn (*Report.snapshot*) nhưng ảnh trong bản chụp là khóa *s3p:* đã bị xóa khỏi kho

ở bước (3), nên quản trị viên mất bằng chứng ảnh. Trang quản trị hiển thị báo cáo có đối tượng đã mất thế nào: cần kiểm tra.

- **Phiên đăng nhập:** JWT sống 30 ngày (*auth.module.ts*), không có danh sách phiên. *JwtStrategy* chỉ chặn token theo danh sách trong bộ nhớ (*ban-list.ts*: bị khóa, dưới 18 tuổi); không có trạng thái "chờ xóa".
- **Ẩn nội dung:** chưa có cơ chế ẩn nội dung của một tài khoản. Tài khoản bị khóa (bannedAt) vẫn hiện bài viết; quy tắc xem bài chung nằm ở *visiblePostWhere* (*apps/api/src/modules/posts/post-view.ts*).
- **App:** *DeleteAccountScreen.tsx* ghi "Không thể khôi phục", hộp xác nhận "Toàn bộ dữ liệu của bạn sẽ bị xoá ngay". *LegalScreen.tsx* ghi "việc xoá có hiệu lực ngay". Cả hai phải sửa khi đổi sang chờ 30 ngày.
- **Trang web:** chưa có (báo cáo tính năng đã ghi là còn thiếu). Dự án chưa có tên miền web (*docs/decisions.md*). API đã có mẫu phục vụ một trang HTML tĩnh: *AdminPageController* trả *admin.html* ở *GET /admin*; trang xóa tài khoản làm cùng cách được.
- **Nhật ký thao tác:** chưa có bảng nhật ký (thuộc C3).

c) Cách hoạt động

Luồng 1: Yêu cầu xóa trong app

1. Người dùng vào *Cài đặt* > *Xóa tài khoản*. App hiện: tài khoản sẽ bị ẩn ngay và xóa vĩnh viễn sau 30 ngày; trong 30 ngày đăng nhập lại là hủy; những gì bị xóa, những gì được giữ lại; nút *Tải dữ liệu trước* (E1).
2. Người dùng nhập mật khẩu (hoặc gõ username với tài khoản chỉ có Google, như hiện nay; khi có 2FA thì thêm mã 6 số), bấm *Xóa tài khoản*, xác nhận lần nữa trong hộp thoại.
3. Máy chủ kiểm tra xác nhận. Đúng thì ghi *deletionRequestedAt* = bây giờ, *deletionScheduledAt* = bây giờ + 30 ngày, nguồn APP.
4. Máy chủ ẩn tài khoản: hồ sơ trả 404 với người khác, bài viết, bình luận, story không hiện, không xuất hiện trong tìm kiếm và gợi ý. Thu hồi mọi phiên (thêm vào danh sách chặn token như *bannedUserIds*, hoặc xóa phiên khi đã có A2), xóa token thiết bị để không nhận push. Hủy yêu cầu xuất dữ liệu đang chờ.
5. Máy chủ gửi email: ngày sẽ xóa, cách hủy (đăng nhập lại), link "Không phải tôi" dẫn tới đổi mật khẩu.
6. App đăng xuất và hiện màn "Tài khoản sẽ bị xóa vào ngày …".

Luồng 2: Hủy bằng cách đăng nhập lại

1. Trong 30 ngày, người dùng đăng nhập (mật khẩu, Google, hoặc đặt lại mật khẩu nếu quên).
2. Máy chủ thấy tài khoản đang chờ xóa: không cấp phiên ngay, trả mã *ACCOUNT_PENDING_DELETION* kèm ngày xóa và một mã khôi phục dùng một lần (sống 10 phút).
3. App hỏi: "Tài khoản đang chờ xóa vào ngày …. Hủy xóa và tiếp tục dùng?"
4. Chọn *Hủy xóa*: app gửi mã khôi phục; máy chủ xóa hai mốc ngày, hiện lại nội dung, cấp phiên, gửi email "Đã hủy yêu cầu xóa". Chọn *Không*: giữ lịch xóa, quay về màn đăng nhập.

Luồng 3: Yêu cầu xóa qua trang web (không cần app)

1. Người dùng mở trang *https://<tên miền>/xoa-tai-khoan* (link này khai trong Google Play Console và trong Chính sách quyền riêng tư). Trang nói rõ dữ liệu bị xóa, dữ liệu giữ lại và thời gian giữ.
2. Nhập email đăng ký, bấm *Gửi*. Máy chủ giới hạn 3 lần/giờ mỗi IP và mỗi email.
3. Máy chủ **luôn trả cùng một câu** "Nếu email này có tài khoản, chúng tôi đã gửi link xác nhận" để không lộ email nào có tài khoản. Chỉ khi email có tài khoản mới tạo mã (lưu dạng băm, sống 30 phút, dùng một lần) và gửi email có link.
4. Người dùng bấm link trong email. Trang kiểm tra mã: hết hạn hoặc đã dùng thì báo và cho gửi lại.
5. Mã hợp lệ: trang hiện hậu quả và nút *Xác nhận xóa*. Bấm thì máy chủ làm giống bước 3–5 của luồng 1 (nguồn WEB), email có thêm link *Hủy yêu cầu* (sống tới ngày xóa) cho người không còn app.

Luồng 4: Xóa vĩnh viễn sau 30 ngày

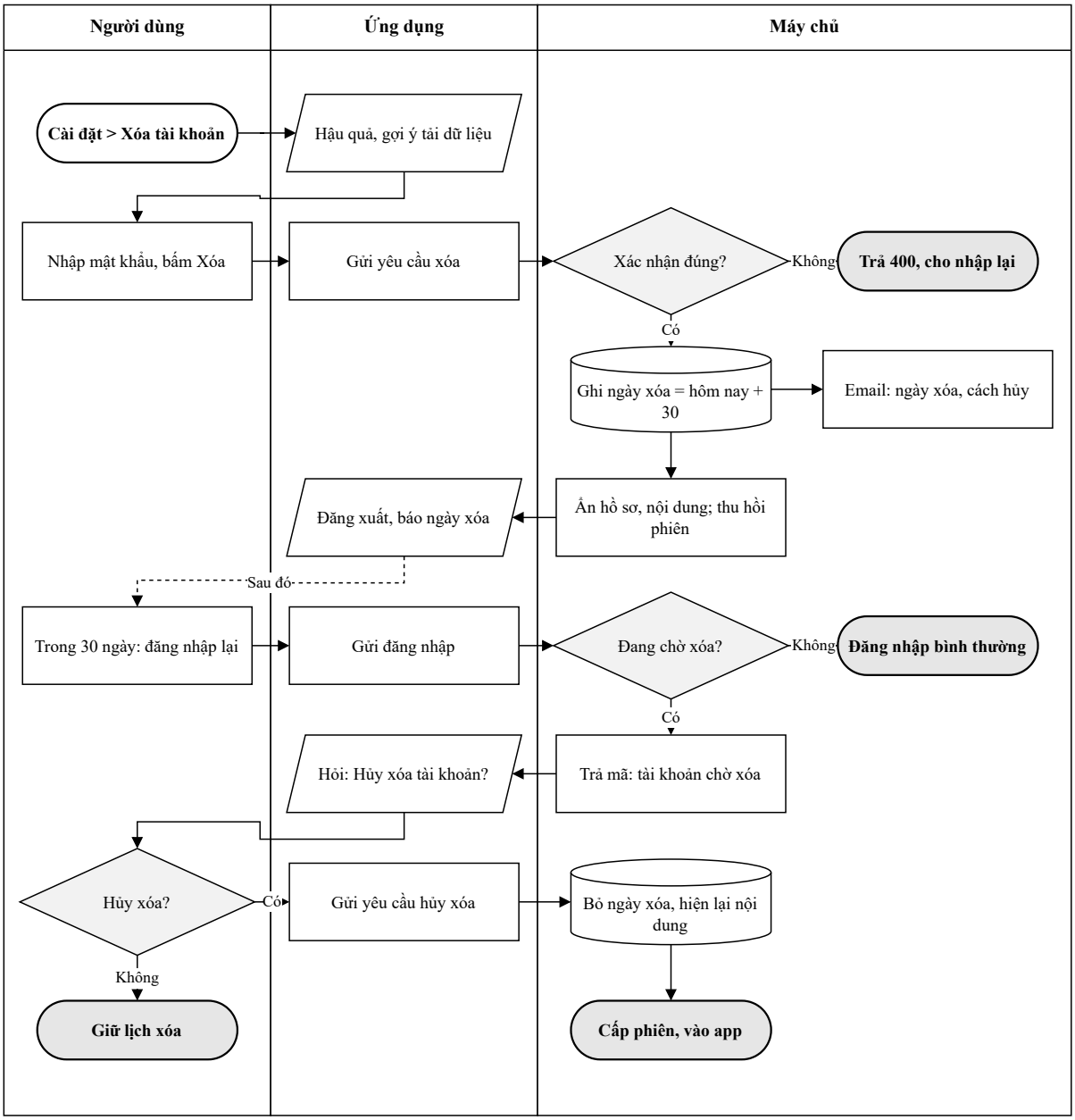
1. Việc nền chạy mỗi ngày (đề xuất 02:00), lấy từng tài khoản có *deletionScheduledAt* đã qua.
2. Tài khoản đang bị giữ (*legalHoldAt*: đang điều tra, cơ quan chức năng yêu cầu) thì hoãn, ghi lý do, hiện trong danh sách của quản trị viên.
3. Gom đường dẫn mọi tệp của người này (như code hiện tại, thêm tệp xuất dữ liệu E1, giấy tờ xác minh E4).
4. Giữ lại báo cáo liên quan (xem quy tắc ở mục e): chép ảnh bằng chứng trong bản chụp báo cáo sang thư mục *evidence/* của bucket riêng tư trước khi xóa tệp.
5. Xử lý tin nhắn theo phương án chủ dự án chọn (mục e).
6. Xóa dữ liệu của người dùng trong một giao dịch, rồi biến dòng User thành "bia mộ": username *deleted_<id>*, email *<id>@deleted.invalid*, xóa mật khẩu, Google

id, tên, tiểu sử, ngày sinh, ảnh; đặt *deletedAt*. Giữ dòng để khóa ngoại của báo cáo và tin nhắn còn hợp lệ.

7. Xóa tệp trong kho. Tệp xóa lỗi được ghi vào hàng đợi xóa lại (thử lại mỗi ngày, tối đa 7 lần, sau đó báo quản trị viên), thay vì nuốt lỗi như hiện nay.
8. Ghi nhật ký "tài khoản <id> đã xóa lúc …, nguồn APP/WEB" (không lưu email, tên). Gửi email cuối "Tài khoản của bạn đã bị xóa" tới email đã đọc ra trước bước 6.

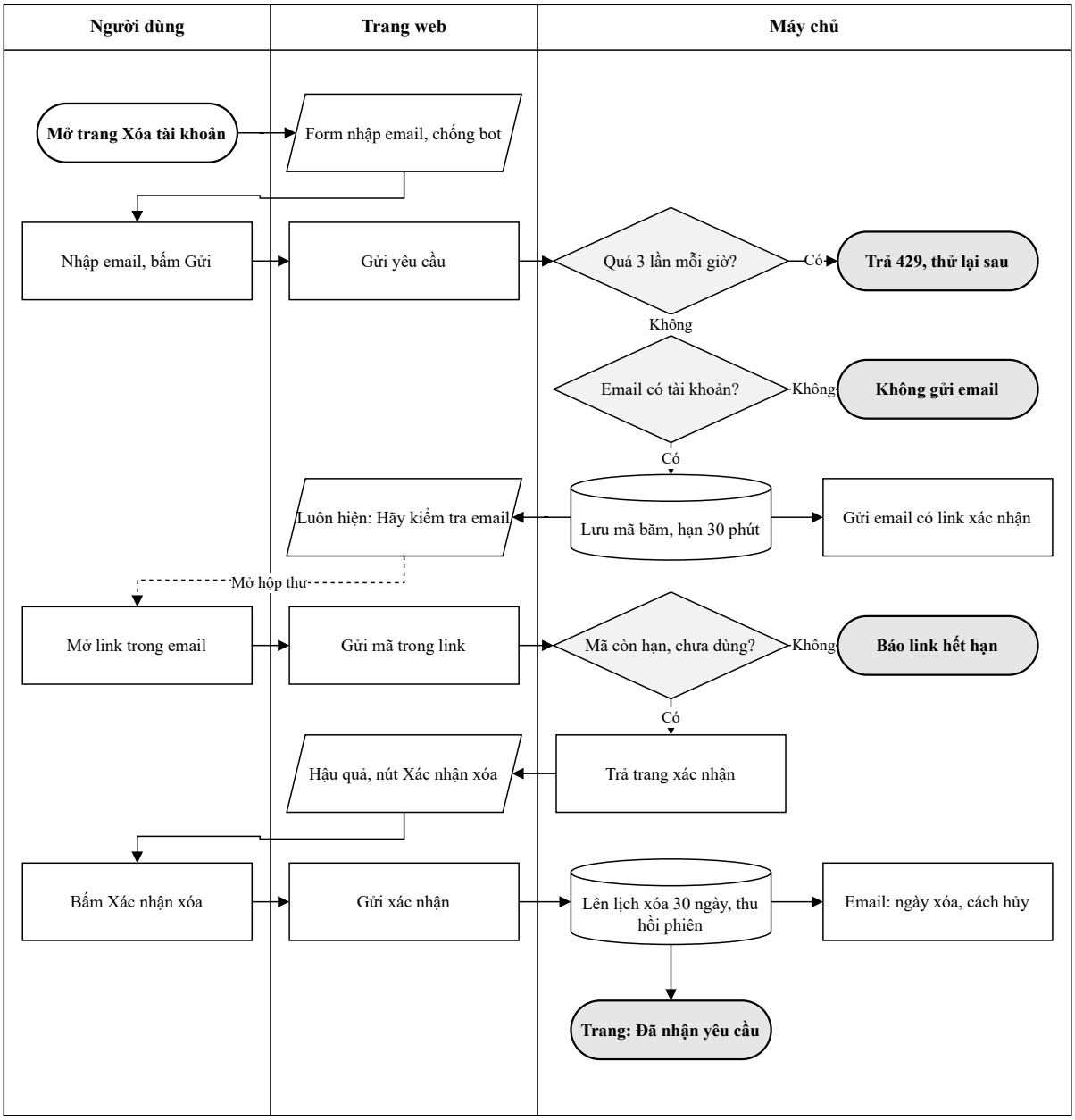
d) Flowchart

Sơ đồ 1: yêu cầu xóa trong app, ẩn tài khoản, và hủy bằng cách đăng nhập lại.



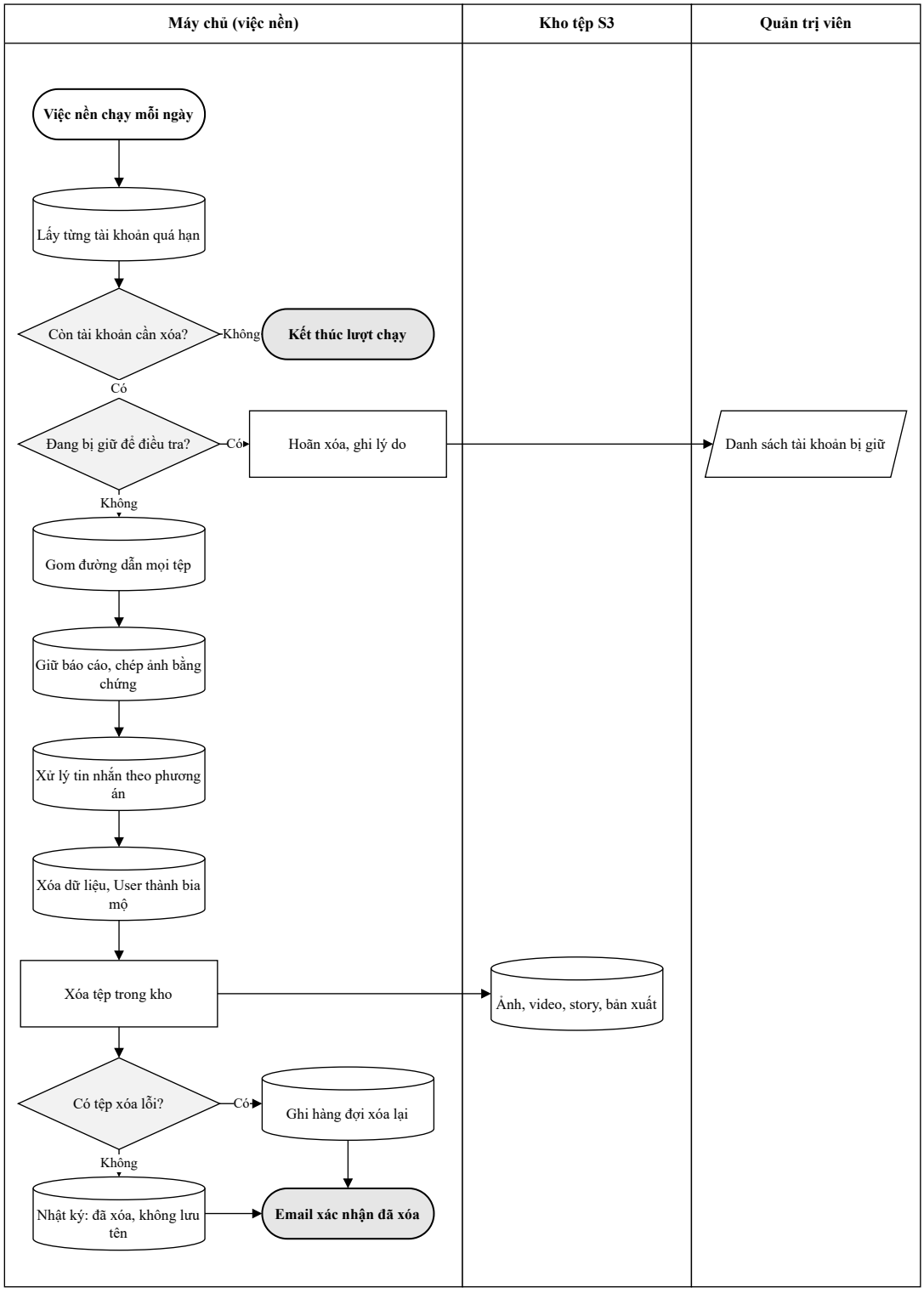
Hình 70. Yêu cầu xóa tài khoản trong app và hủy bằng cách đăng nhập lại

Sơ đồ 2: trang web yêu cầu xóa, xác minh bằng email, không lộ email nào có tài khoản.



Hình 71. Yêu cầu xóa tài khoản qua trang web (không cần app)

Sơ đồ 3: việc nền xóa vĩnh viễn sau 30 ngày, có nhánh giữ để điều tra và xóa tệp lỗi.



Hình 72. Xóa vĩnh viễn khi hết 30 ngày chờ

e) Quy tắc, giới hạn và trường hợp đặc biệt

Dữ liệu	**Đề xuất khi xóa vĩnh viễn**
Hồ sơ, ảnh đại diện, ảnh bìa, ngày sinh	Xóa. Dòng User thành bia mộ, không còn thông tin nhận dạng.

Bài viết, ảnh, video, story, cảm xúc, lưu, đăng lại, theo dõi, chặn	Xóa (như hiện nay).
Bình luận của người này	Xóa. Câu trả lời của người khác dưới bình luận đó cũng mất (như hiện nay); muốn giữ thì phải đổi Cascade, chủ dự án quyết.
Tin nhắn	**Chủ dự án chọn:** (A) giữ hội thoại cho người kia, người gửi hiện "Tài khoản đã xóa", nội dung giữ nguyên (giống Messenger, Instagram); (B) giữ hội thoại, xóa nội dung và ảnh của người đã xóa, giữ tin của người kia; (C) xóa cả hội thoại với cả hai bên (hiện nay). Đề xuất (B): tôn trọng quyền xóa mà người kia không mất phần của mình.
Hội thoại ẩn danh	Như tin nhắn; người kia vẫn chỉ thấy "Người ẩn danh".
Báo cáo người này đã gửi	Giữ (người báo cáo là bia mộ) để quản trị viên xử lý tiếp. Hiện nay bị xóa theo Cascade.
Báo cáo về người này, bản chụp hội thoại, ảnh bằng chứng	Giữ tới khi xử lý xong + 12 tháng (đề xuất), rồi xóa. Luật sư xác nhận thời gian.
Nhật ký thao tác quản trị (C3), nhật ký xóa	Giữ, không chứa email, tên. Thời gian giữ theo luật sư.
Bản sao lưu cơ sở dữ liệu	Dữ liệu còn trong bản sao lưu tới khi bản đó hết hạn (Supabase giữ theo gói). Phải nói rõ trong chính sách.

- **Vì sao giữ một phần:** Nghị định 147/2024/NĐ-CP đặt nghĩa vụ cho mạng xã hội về lưu thông tin và cung cấp cho cơ quan chức năng khi có yêu cầu; Luật Bảo vệ dữ liệu cá nhân cho phép không xóa trong một số trường hợp luật định. **Danh sách dữ liệu được giữ và thời hạn phải do luật sư xác nhận**; bảng trên là đề xuất kỹ thuật.
- **Né lệnh khóa:** tài khoản đang bị khóa (bannedAt) vẫn được yêu cầu xóa (Google Play yêu cầu). Đề xuất giữ bản băm email trong danh sách cấm đăng ký lại trong 12 tháng để không lách lệnh khóa; cần luật sư xác nhận.
- **Username:** giữ trong 30 ngày chờ (vẫn thuộc người dùng). Sau khi xóa, username được giải phóng; nếu là tài khoản có dấu tick (E4), khóa username đó thêm 90 ngày để chống mạo danh (đề xuất).
- **Quản trị viên:** không cho tài khoản ADMIN cuối cùng tự xóa.

- **Thời gian chờ:** 30 ngày (đề xuất, giống Instagram, Facebook). Quản trị viên có thể xóa ngay theo yêu cầu đặc biệt, ghi nhật ký.
- **Trang web, chống lạm dụng:** 3 yêu cầu/giờ mỗi IP và mỗi email; luôn trả cùng một câu; mã trong link lưu dạng băm, sống 30 phút, dùng một lần; có thể thêm captcha (Cloudflare Turnstile, miễn phí) nếu bị spam.
- **Email bị chiếm:** kẻ chiếm email có thể yêu cầu xóa qua web. Giảm rủi ro bằng 30 ngày chờ và email báo mỗi bước; chủ tài khoản đăng nhập lại là hủy.
- **Lỗi mạng khi bấm xóa trong app:** máy chủ xử lý một lần (gọi lại khi đã chờ xóa thì trả kết quả cũ), app hiện lỗi và cho thử lại.
- **Đang có yêu cầu xuất dữ liệu (E1):** hủy, xóa tệp đã tạo.
- **Đăng nhập bằng Apple (A6):** khi xóa vĩnh viễn phải gọi API thu hồi token của Apple (App Store yêu cầu).

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và ghi quyết định (bia mộ thay vì Cascade, phương án tin nhắn, thời hạn giữ) vào *docs/decisions.md* trước khi code.

Bảng / trường	**Ý nghĩa**
User.deletionRequestedAt, deletionScheduledAt DateTime?	Đang chờ xóa và ngày xóa. Chỉ mục trên deletionScheduledAt.
User.deletionSource String? (APP | WEB | ADMIN)	Nguồn yêu cầu.
User.legalHoldAt DateTime?, legalHoldReason String?	Hoãn xóa vì điều tra.
User.deletedAt DateTime?	Đã thành bia mộ.
AuthTokenPurpose thêm ACCOUNT_DELETION, ACCOUNT_RESTORE	Mã trong link web và mã khôi phục khi đăng nhập; dùng lại bảng AuthToken (đã có băm, hạn, đếm lần thử).
Report.reporter: đổi Cascade	Không cần nếu dùng bia mộ (dòng User không bị xóa).
StorageDeletionQueue (key, bucket, attempts, lastError)	Tệp xóa lỗi để thử lại.

Endpoint	**Mô tả**
DELETE /users/me (giữ đường dẫn, đổi nghĩa)	Lên lịch xóa, trả *{ scheduledAt }*. App cũ vẫn gọi được.
POST /auth/login, /auth/google (thêm lỗi)	401 code *ACCOUNT_PENDING_DELETION* kèm *scheduledAt*, *restoreToken*.

POST /auth/restore-account { restoreToken }	Hủy xóa, trả accessToken như đăng nhập.
GET /account-deletion (HTML công khai)	Trang web, phục vụ như *admin.html*.
POST /account-deletion/request { email, captcha? }	Công khai, luôn trả 202 cùng một câu; 429 khi vượt giới hạn.
GET /account-deletion/confirm?token=, POST /account-deletion/confirm { token }	Trang xác nhận và lên lịch xóa.
POST /account-deletion/cancel { token }	Hủy từ link trong email.
GET /admin/deletions, POST /admin/users/:id/legal-hold	Quản trị viên xem tài khoản chờ xóa, đặt hoặc gỡ giữ.

Các chỗ phải lọc tài khoản đang chờ xóa (dev tìm theo *authorSelect* và *visiblePostWhere*): bảng tin, trang cá nhân, bình luận, tìm kiếm, gợi ý, story, danh sách theo dõi, Reels, hộp thư (người kia thấy "Tài khoản không khả dụng"). Việc nền dùng *@nestjs/schedule* chung với E1.

g) Android, iOS và web

- **App:** sửa chữ trong *DeleteAccountScreen* và *LegalScreen*; màn đăng nhập (mật khẩu và Google) xử lý mã *ACCOUNT_PENDING_DELETION* bằng hộp thoại hỏi hủy xóa, giống cách đang xử lý *EMAIL_NOT_VERIFIED*. Không thư viện mới, không quyền thiết bị mới. Chạy được như nhau trên Android và iOS.
- **App Store:** Apple yêu cầu xóa tài khoản ngay trong app (đã có). Có thời gian chờ được chấp nhận nếu nói rõ cho người dùng biết bao lâu. Khi có Đăng nhập bằng Apple (A6) phải thu hồi token Apple lúc xóa.
- **Google Play:** yêu cầu đường dẫn xóa trong app **và** một trang web yêu cầu xóa, khai trong mục An toàn dữ liệu (Data safety) của Play Console, kèm mô tả dữ liệu bị xóa, dữ liệu giữ lại và thời gian giữ.
- **Trang web:** HTML tĩnh do API trả về, không cần dự án web riêng. Cần **tên miền HTTPS** công khai (dự án chưa có): chi phí tên miền khoảng vài trăm nghìn đồng mỗi năm (ước tính) cộng chứng chỉ HTTPS (miễn phí với Let's Encrypt hoặc Cloudflare). Trang phải dùng được trên điện thoại (chữ to, một cột).
- **Email:** SMTP hiện có đủ cho thử nghiệm; khi phát hành nên dùng dịch vụ email giao dịch để email không vào thư rác (có phí theo số email).

h) Tiêu chí hoàn thành

- Xóa trong app: tài khoản bị ẩn ngay với người khác (hồ sơ 404, bài và bình luận không hiện, không tìm thấy), mọi phiên bị đăng xuất, nhận email có ngày xóa.
- Đăng nhập lại trong 30 ngày (mật khẩu, Google, sau khi đặt lại mật khẩu) hiện hộp hủy xóa; hủy thì mọi thứ hiện lại đúng như cũ.
- Trang web: email có tài khoản và không có tài khoản nhận cùng một câu trả lời; link hết hạn sau 30 phút, dùng một lần; vượt 3 lần/giờ bị chặn.
- Việc nền: tài khoản quá hạn bị xóa, tài khoản bị giữ được bỏ qua; báo cáo liên quan và ảnh bằng chứng còn xem được trong trang quản trị; tệp xóa lỗi được thử lại; chạy hai lần không lỗi.
- Test tự động cho: lọc nội dung tài khoản chờ xóa ở mọi endpoint liệt kê, khôi phục, xóa vĩnh viễn, không lộ email trên trang web.
- Chạy luồng app trên Android và trên iPhone; trang web thử trên Chrome Android và Safari iPhone. Báo cáo ghi rõ nền tảng đã chạy.
- Link trang web đã khai trong Google Play Console; Chính sách quyền riêng tư cập nhật (luật sư duyệt).

i) Ước lượng và phụ thuộc

- Backend 7 ngày (trường mới, lên lịch, lọc ở nhiều endpoint, khôi phục khi đăng nhập, trang web và email, việc nền xóa kiểu bia mộ, hàng đợi xóa tệp, giữ bằng chứng); mobile 2 ngày; kiểm thử 2,5 ngày.
- Phụ thuộc: nên làm sau hoặc cùng A2 (thu hồi phiên thật thay vì danh sách trong bộ nhớ); A6 (thu hồi token Apple) nếu có Apple; C3 (nhật ký thao tác) để ghi việc giữ và xóa; E1 để gợi ý tải dữ liệu trước khi xóa. Cần tên miền cho trang web.
- Rủi ro: bỏ sót một chỗ hiển thị khiến tài khoản "đã xóa" vẫn lộ ra; đổi từ Cascade sang bia mộ chạm nhiều bảng; quy định giữ dữ liệu chưa được luật sư chốt.

E3. Kiểm tra quyền riêng tư

Nhóm: Quyền riêng tư · Giai đoạn: GĐ3 · Ước lượng: 5–6 ngày công

a) Mục đích

Cài đặt quyền riêng tư nằm rải rác, người dùng ít khi vào xem. "Kiểm tra quyền riêng tư" dẫn người dùng đi qua từng nhóm cài đặt, giải thích bằng lời thường mỗi lựa chọn có nghĩa gì, và nhắc lại định kỳ. Người lợi nhiều nhất là người mới và người đang bị làm phiền: họ biết ngay cách đóng tài khoản, chặn tin nhắn lạ, bật xác thực hai lớp. Đây cũng là cách thể hiện điểm khác biệt "an toàn" của sản phẩm.

b) Hiện trạng

- **Cài đặt đã có** (*apps/mobile/src/features/settings/screens/SettingsScreen.tsx*, nhóm "Quyền riêng tư"):
  - **Tài khoản riêng tư**: công tắc, lưu bằng *PATCH /users/me { isPrivate }*. Chuyển về công khai thì máy chủ tự chấp nhận mọi yêu cầu theo dõi đang chờ (*UsersService.updateProfile*). Lưu lỗi thì công tắc tự trả về.
  - **Nhận tin nhắn ẩn danh**: mở màn cảnh báo *AnonymousMessagesScreen* trước khi bật (máy chủ ghi chú: app chỉ gửi *allowAnonymousMessages: true* sau khi người dùng đọc cảnh báo).
  - **Yêu cầu theo dõi** (*FollowRequestsScreen*) và **Người dùng đã chặn** (*BlockedUsersScreen*, *GET /users/me/blocked*).
  - Đổi hoặc đặt mật khẩu (*ChangePasswordScreen*), Xóa tài khoản.
- **Quyền theo từng nội dung:** mỗi bài viết có quyền xem PUBLIC / FRIENDS / PRIVATE (*PostPrivacy*); mỗi story có cờ cho phép cảm xúc và trả lời ẩn danh (*Story.allowAnonymous*). Không có cài đặt mặc định cho các lựa chọn này.
- **Ai nhắn tin được:** chưa có cài đặt. Ai chưa bị chặn đều mở được hội thoại; nếu người nhận không theo dõi người gửi thì hội thoại vào "tin nhắn chờ" (*MessagesService.open*). Nâng cấp thuộc B1.
- **Chưa có:** cài đặt ai được bình luận (B7), ai được nhắc tên hoặc gắn thẻ (*notifyMentions* gửi thông báo khi bị @ mà không có cài đặt; gắn thẻ thuộc D6), xác thực hai lớp (A1), danh sách thiết bị và phiên (A2; JWT sống 30 ngày, không có danh sách phiên), Hạn chế/Tắt tiếng (B8), Tải dữ liệu (E1). Chưa có màn kiểm tra quyền riêng tư và chưa có lời nhắc định kỳ.

c) Cách hoạt động

Luồng 1: Mở kiểm tra

1. Người dùng mở *Cài đặt* > *Quyền riêng tư* > *Kiểm tra quyền riêng tư*, hoặc bấm vào lời nhắc (push hoặc thẻ ở đầu màn Cài đặt).
2. App hiện màn giới thiệu: các bước, khoảng 2 phút, có thể dừng giữa chừng. Máy chủ trả các cài đặt hiện tại.

Luồng 2: Đi qua từng bước

1. Mỗi bước là một màn: tiêu đề, một câu giải thích, các lựa chọn với giá trị hiện tại, và nhãn "Nên bật" ở lựa chọn an toàn hơn. Nút *Tiếp* và *Bỏ qua*.
2. Người dùng đổi một lựa chọn: app lưu ngay bằng endpoint đã có của cài đặt đó (như công tắc trong Cài đặt). Lưu lỗi: trả lựa chọn về giá trị cũ và báo "Không lưu được, thử lại".
3. Lựa chọn cần thêm bước thì mở màn riêng rồi quay lại: bật tin nhắn ẩn danh qua màn cảnh báo hiện có; bật 2FA qua luồng của A1; xem thiết bị qua màn của A2.
4. Hết bước: màn tóm tắt liệt kê những gì đã đổi và những gì còn "Nên xem lại". Máy chủ ghi ngày hoàn thành và hẹn lần nhắc sau.

Các bước (đề xuất). Bước nào mà tính năng chưa có thì ẩn đi; bước nào không còn lựa chọn thì bỏ qua.

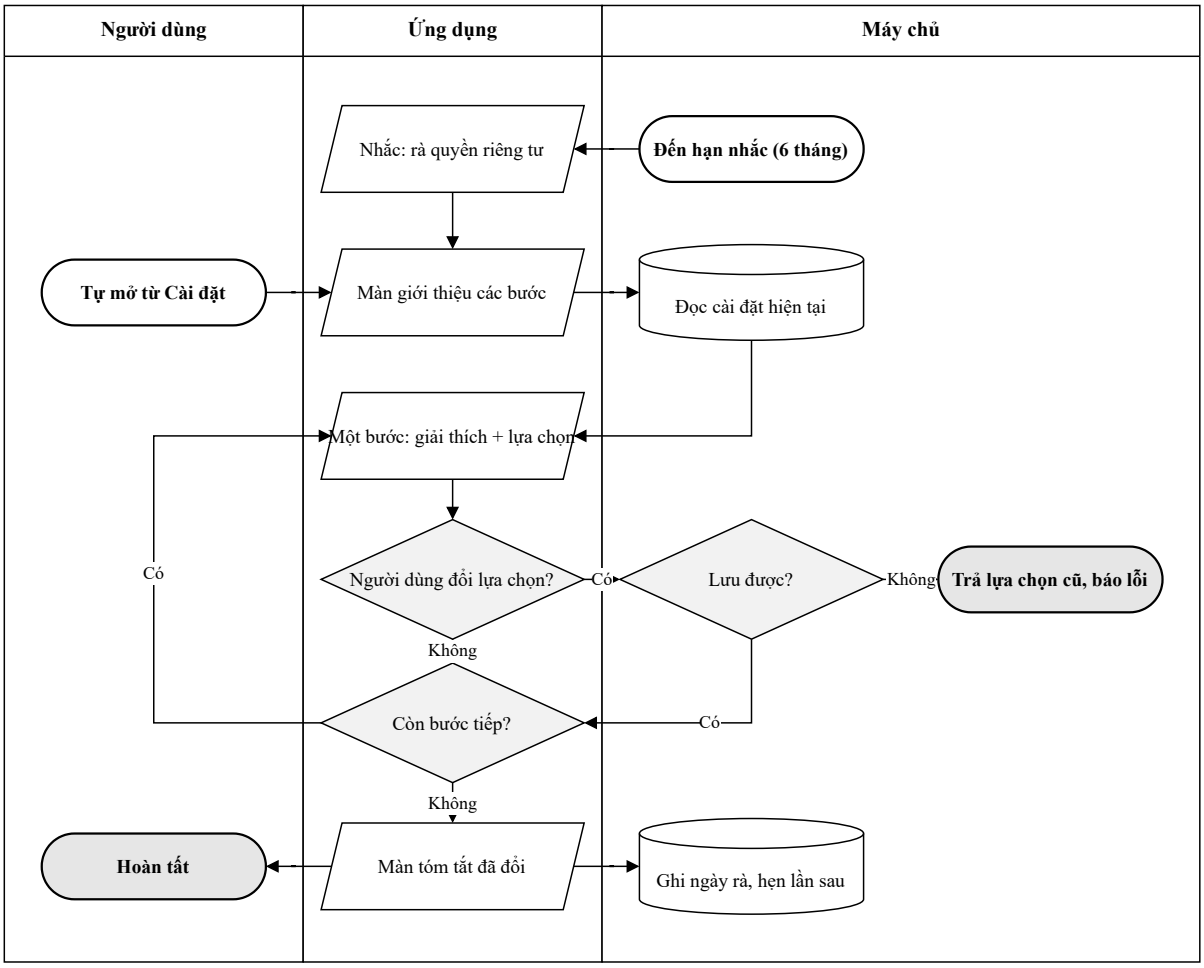
Bước	**Nội dung**	**Có sẵn hôm nay?**
1. Ai thấy nội dung của bạn	Tài khoản riêng tư; quyền xem mặc định khi đăng bài (giải thích PUBLIC / FRIENDS / PRIVATE).	Tài khoản riêng tư: có. Mặc định khi đăng: chưa (thêm trường mới).
2. Ai liên hệ được với bạn	Ai được nhắn tin (B1), nhận tin nhắn ẩn danh, ai được bình luận (B7), ai được nhắc tên hoặc gắn thẻ (D6), yêu cầu theo dõi đang chờ.	Tin ẩn danh và yêu cầu theo dõi: có. Còn lại: chờ B1, B7, D6.
3. Bảo vệ đăng nhập	Đặt mật khẩu (tài khoản chỉ có Google), đổi mật khẩu, bật xác thực hai lớp.	Mật khẩu: có. 2FA: chờ A1.
4. Thiết bị đang đăng nhập	Danh sách thiết bị, đăng xuất thiết bị lạ.	Chờ A2.
5. Người bạn đã chặn, hạn chế, tắt tiếng	Xem lại và bỏ chặn nếu muốn.	Chặn: có. Hạn chế, tắt tiếng: chờ B8.
6. Dữ liệu của bạn	Tải dữ liệu (E1), xóa tài khoản (E2); chỉ là link, không hỏi gì.	Xóa tài khoản: có. Tải dữ liệu: chờ E1.

Luồng 3: Lời nhắc định kỳ

1. Việc nền chạy mỗi ngày, tìm người dùng đến hạn: 7 ngày sau khi tạo tài khoản lần đầu, sau đó 180 ngày sau lần hoàn thành gần nhất (đề xuất).
2. Gửi push "Dành 2 phút rà lại quyền riêng tư của bạn" và đặt thẻ nhắc ở đầu màn Cài đặt. Ghi ngày đã nhắc.
3. Bỏ qua lời nhắc: nhắc lại sau 30 ngày, tối đa 2 lần mỗi chu kỳ. Người dùng tắt được lời nhắc trong màn tóm tắt.

d) Flowchart

Sơ đồ: mở kiểm tra (từ lời nhắc hoặc từ Cài đặt), đi qua từng bước, lưu từng thay đổi, tóm tắt và hẹn lần nhắc sau.



Hình 73. Kiểm tra quyền riêng tư theo từng bước

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Không tự đổi thay người dùng.** Kiểm tra chỉ gợi ý; mọi thay đổi do người dùng bấm. Không dùng màu hay chữ gây áp lực, không giấu nút *Bỏ qua*.
- **Lưu từng thay đổi ngay**, không đợi cuối luồng: người dùng thoát giữa chừng thì phần đã đổi vẫn còn. Mở lại thì bắt đầu từ bước chưa xong (lưu bước trên máy).

- **Bật tin nhắn ẩn danh** luôn đi qua màn cảnh báo hiện có, không bật thẳng bằng công tắc trong kiểm tra. Tắt thì tắt ngay.
- **Chuyển tài khoản sang công khai** trong kiểm tra phải báo rõ "Các yêu cầu theo dõi đang chờ sẽ được chấp nhận" (máy chủ làm việc này).
- **Lỗi mạng:** trả lựa chọn về cũ, báo lỗi, cho thử lại; không chuyển bước khi đang lưu.
- **Lời nhắc:** không quá 1 push mỗi 30 ngày cho tính năng này; không gửi cho tài khoản bị khóa, dưới 18 tuổi bị khóa, đang chờ xóa (E2). Tôn trọng giờ yên lặng và cài đặt thông báo theo loại (D8).
- **Sự kiện bảo mật** (đề xuất, cần A3): khi có đăng nhập lạ, thẻ nhắc mở thẳng bước 3–4 thay vì cả luồng.
- **Tài khoản bị quấy rối** (B4): thẻ nhắc có thể mở thẳng bước 2.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* trước khi code.

Trường mới trên User	**Ý nghĩa**
privacyCheckCompletedAt DateTime?	Lần hoàn thành gần nhất.
privacyCheckRemindedAt DateTime?, privacyCheckReminderCount Int	Lần nhắc gần nhất, số lần nhắc trong chu kỳ.
privacyCheckRemindersEnabled Boolean @default(true)	Người dùng tắt lời nhắc.
defaultPostPrivacy PostPrivacy @default(PUBLIC)	(Tùy chọn) quyền xem mặc định khi đăng bài; app soạn bài đọc giá trị này.

Endpoint	**Mô tả**
GET /users/me/privacy-summary	Một lần gọi trả mọi giá trị cần cho các bước: isPrivate, allowAnonymousMessages, hasPassword, số người đã chặn, số yêu cầu theo dõi đang chờ, và (khi có) trạng thái 2FA, số thiết bị, quyền nhắn tin, quyền bình luận, quyền gắn thẻ; kèm *nextReminderAt*.
POST /users/me/privacy-check/complete { changed: string[] }	Ghi ngày hoàn thành, đặt lại bộ đếm nhắc.
PATCH /users/me { privacyCheckRemindersEnabled, defaultPostPrivacy }	Thêm 2 trường vào *UpdateProfileDto*.

Lưu từng cài đặt dùng endpoint sẵn có của nó (*PATCH /users/me*, các endpoint của A1, A2, B1, B7, B8, D6). Việc nhắc dùng chung lịch chạy *@nestjs/schedule* với E1, E2 và hàm *pushToUser* đã có.

g) Android, iOS và web

- Toàn bộ là màn hình React Native thường, không thư viện mới, không quyền thiết bị mới. Dùng lại các thành phần Cài đặt hiện có; giữ vùng an toàn (safe area) và nút *Tiếp* không bị thanh điều hướng Android hay vạch Home của iPhone che.
- Push qua Expo (FCM + APNs) đã có. Người dùng từ chối quyền thông báo (iOS hỏi lần đầu; Android 13 trở lên cũng hỏi) vẫn thấy thẻ nhắc trong Cài đặt.
- Không có chi phí dịch vụ ngoài.

h) Tiêu chí hoàn thành

- Đi hết các bước đang có; mỗi thay đổi lưu ngay và đúng với màn Cài đặt; thoát giữa chừng rồi mở lại tiếp tục đúng bước.
- Lưu lỗi (tắt mạng) thì lựa chọn trả về cũ và có báo lỗi.
- Bật tin nhắn ẩn danh từ kiểm tra luôn qua màn cảnh báo.
- Lời nhắc: tài khoản 7 ngày tuổi nhận push; hoàn thành thì 180 ngày sau mới nhắc lại; tắt lời nhắc thì không nhận nữa; tài khoản khóa hoặc chờ xóa không nhận (có test tự động cho việc chọn người cần nhắc).
- Bước của tính năng chưa có (2FA, thiết bị…) bị ẩn, không có nút chết.
- Chạy trên Android và trên iPhone; báo cáo ghi rõ nền tảng đã chạy.

i) Ước lượng và phụ thuộc

- Backend 1,5 ngày (trường mới, privacy-summary, complete, việc nhắc); mobile 3 ngày (6 màn bước + giới thiệu + tóm tắt + thẻ nhắc); kiểm thử 1 ngày. Mỗi khi một tính năng phụ thuộc ra mắt, thêm bước tương ứng khoảng 0,5 ngày.
- Phụ thuộc (mềm, làm được bản đầu khi chưa có): A1, A2, B1, B7, B8, D6, E1, D8 (giờ yên lặng cho lời nhắc). Nên làm sau khi ít nhất A1 và B1 xong, nếu không kiểm tra chỉ có 2–3 lựa chọn.
- Rủi ro: lời nhắc gây phiền nếu dày; chữ giải thích phải được duyệt để không hứa quá mức (ví dụ "riêng tư" không có nghĩa là quản trị viên không xem được khi có báo cáo).

E4. Xác minh tài khoản (dấu tick)

Nhóm: Tin cậy và chống mạo danh · Giai đoạn: GĐ4 · Ước lượng: khoảng 8 ngày công

a) Mục đích

Dấu tick cho người dùng biết tài khoản này đúng là của người nổi tiếng, nhãn hàng hay tổ chức mà nó tự nhận. Nó giảm lừa đảo kiểu "giả fanpage, giả người nổi tiếng nhắn xin chuyển tiền", vốn là chiêu phổ biến ở Việt Nam. Dấu tick chỉ có giá trị khi khó giả và bị gỡ khi tài khoản đổi danh tính hoặc vi phạm; vì vậy tính năng gồm cả quy trình duyệt, quy tắc mất tick và chống mạo danh.

b) Hiện trạng

- **Chưa có xác minh.** Bảng User (*apps/api/prisma/schema.prisma*) không có trường xác minh; chỉ có *emailVerifiedAt* (xác minh email, khác dấu tick) và *role* USER/ADMIN.
- **Hiển thị tác giả:** mọi nơi trả thông tin người đăng dùng chung *authorSelect* (id, username, displayName, avatarUrl) trong *apps/api/src/modules/posts/post-view.ts*. Thêm một trường ở đây là đi theo được bảng tin, bình luận, tìm kiếm, gợi ý, tin nhắn. App hiện tên ở *ProfileHeader.tsx* và các thẻ bài viết, bình luận.
- **Đổi tên:** *PATCH /users/me* cho đổi displayName (1–50 ký tự) và username (3–30 ký tự, chữ, số, dấu chấm, gạch dưới) bất cứ lúc nào, không giới hạn số lần (*UpdateProfileDto*). displayName không lọc ký tự giống dấu tick (✓, ✔, ☑, ✅).
- **Báo cáo:** lý do hiện có là SPAM, HARASSMENT, SENSITIVE, MISINFORMATION, SCAM, OTHER (*CreateReportDto*); chưa có "Mạo danh". Trang quản trị (*admin.html*, *AdminService*) có báo cáo, danh sách người dùng, khóa/mở khóa; chưa có hàng đợi xác minh, chưa có nhật ký thao tác (C3).
- **Tải ảnh riêng tư:** đã có bucket riêng tư và URL ký 1 giờ (*storage.service.ts*, *media-url.ts*) dùng được cho ảnh giấy tờ. App đã có *expo-image-picker* với quyền thư viện ảnh khai trong *app.json* (chưa khai quyền camera).
- **Biểu tượng:** app dùng Lucide qua *ClayIcon.tsx*; biểu tượng *badge-check* có sẵn trong gói, chỉ cần thêm một dòng import.

c) Cách hoạt động

Ai đủ điều kiện (đề xuất)

- **Cá nhân là người của công chúng:** nghệ sĩ, vận động viên, nhà báo, người sáng tạo nội dung, chính khách. Phải là người thật và được nhiều nguồn tin độc lập nhắc tới (báo chí, không tính bài quảng cáo trả tiền).

- **Nhãn hàng, doanh nghiệp, tổ chức, cơ quan:** có đăng ký hợp pháp (giấy chứng nhận đăng ký doanh nghiệp, quyết định thành lập) hoặc nhãn hiệu đã đăng ký.
- **Điều kiện cơ bản máy chủ tự kiểm tra:** email đã xác minh; tài khoản ít nhất 30 ngày tuổi; đã bật 2FA (A1); có ảnh đại diện, tên hiển thị, tiểu sử và ít nhất 1 bài viết; không bị xử lý vi phạm trong 90 ngày (C2); không bị khóa; không có đơn đang chờ; không bị từ chối trong 30 ngày.
- Mỗi người hoặc tổ chức chỉ một tài khoản có tick (trừ tài khoản theo ngôn ngữ khác, quản trị viên quyết).

Luồng 1: Nộp đơn

1. Người dùng vào *Cài đặt* > *Tài khoản* > *Yêu cầu xác minh*. App hỏi máy chủ điều kiện cơ bản; thiếu điều kiện nào thì hiện danh sách điều còn thiếu và cách làm, không cho mở mẫu đơn.
2. Đủ điều kiện: mẫu đơn gồm loại (Cá nhân / Tổ chức), lĩnh vực, tên pháp lý, ảnh giấy tờ (cá nhân: căn cước; tổ chức: giấy đăng ký), 1–5 link bài báo hoặc trang chính thức nhắc tới mình, ghi chú.
3. Người dùng chọn ảnh giấy tờ từ thư viện ảnh. App gửi đơn; máy chủ lưu ảnh vào bucket riêng tư (giá trị *s3p:*), tạo đơn trạng thái PENDING.
4. App hiện "Đơn đang được xem xét, thường trong 7 ngày (đề xuất)".

Luồng 2: Quản trị viên duyệt

1. Đơn vào tab *Xác minh* của trang quản trị, cũ nhất lên trước. Ảnh giấy tờ mở bằng link ký sống 1 giờ; mỗi lần mở ghi nhật ký (C3).
2. Quản trị viên kiểm tra: tên trên giấy tờ khớp tên pháp lý; link báo chí có thật và độc lập; không trùng một tài khoản đã có tick của cùng người.
3. **Duyệt:** máy chủ ghi *verifiedAt*, loại, người duyệt; gửi push và thông báo "Tài khoản của bạn đã được xác minh". Dấu tick hiện ngay ở mọi nơi.
4. **Từ chối hoặc thiếu giấy tờ:** ghi lý do (chọn từ danh sách: giấy tờ không rõ, chưa đủ nổi bật, tên không khớp, khác); báo người dùng kèm lý do; được nộp lại sau 30 ngày.
5. 30 ngày sau khi có quyết định, việc nền xóa ảnh giấy tờ khỏi kho; chỉ giữ quyết định, lý do, người duyệt.

Luồng 3: Mất dấu tick

1. **Đổi username hoặc tên hiển thị:** app cảnh báo "Đổi tên sẽ làm mất dấu xác minh". Người dùng xác nhận thì máy chủ lưu tên mới và gỡ tick ngay trong cùng thao tác. Đổi ảnh đại diện, tiểu sử không mất tick.

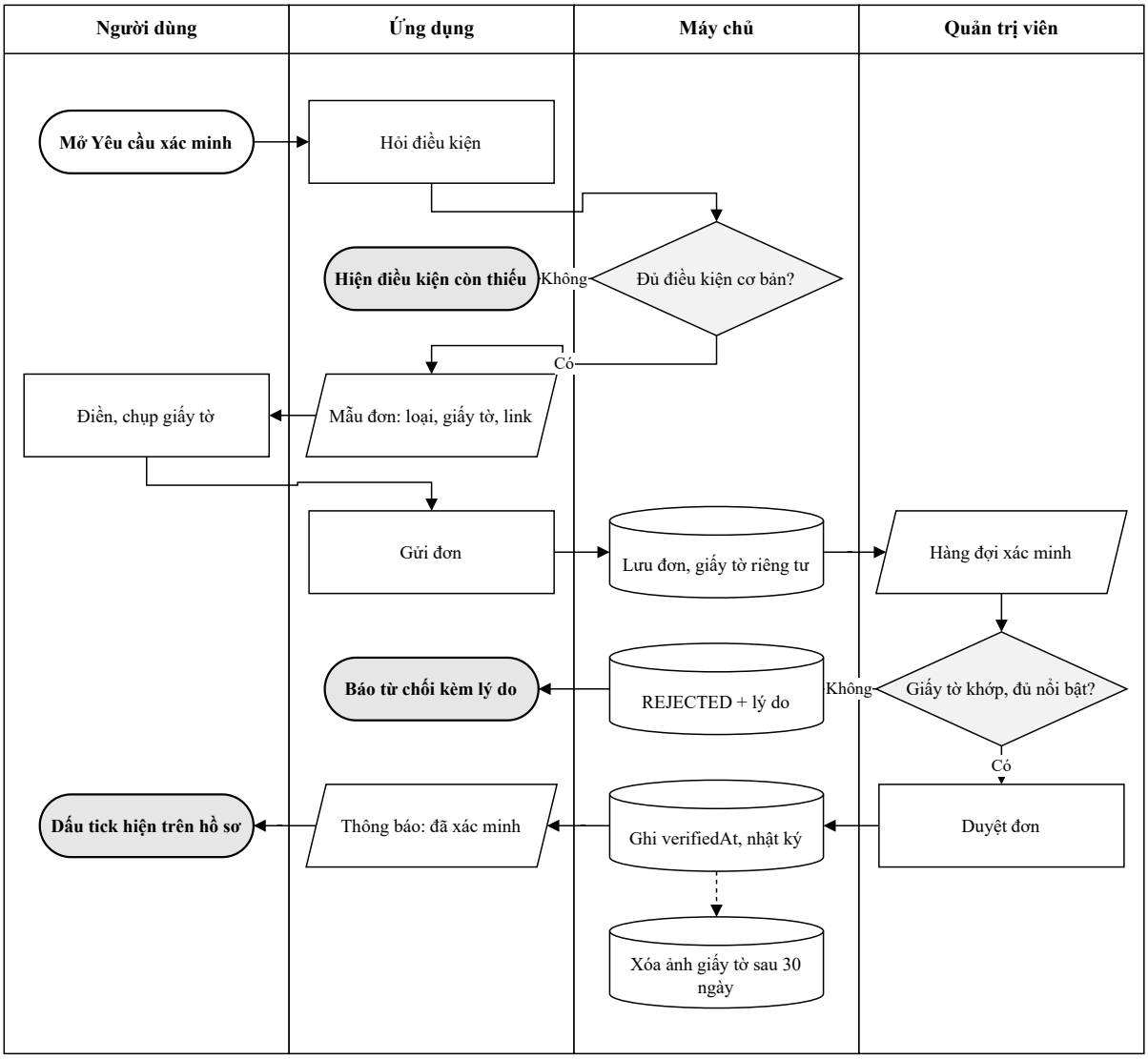
2. **Vi phạm:** khi quản trị viên khóa tài khoản hoặc áp bậc xử phạt từ mức đề xuất (C2), tick bị gỡ, ghi lý do.
3. **Chuyển nhượng, bán tài khoản, đổi chủ** (phát hiện qua báo cáo): gỡ tick, có thể khóa.
4. Người dùng nhận thông báo kèm lý do; được nộp lại sau 30 ngày (với vi phạm: sau 90 ngày, đề xuất).

Luồng 4: Chống mạo danh

1. **Chặn khi đặt tên:** khi bất kỳ ai đăng ký hoặc đổi username, máy chủ chuẩn hóa (chữ thường, bỏ dấu, bỏ dấu chấm và gạch dưới, đổi ký tự dễ nhầm như 0→o, 1→l) và so với username của tài khoản có tick. Trùng thì từ chối "Tên này đã được một tài khoản xác minh dùng".
2. **Gắn cờ tên hiển thị:** tên hiển thị chuẩn hóa trùng tên của tài khoản có tick không bị chặn (nhiều người trùng tên thật) nhưng được đưa vào hàng đợi để quản trị viên xem.
3. **Cấm ký tự giống dấu tick** trong tên hiển thị (✓ ✓ ☑ ✅ và các ký tự tương tự).
4. **Báo cáo mạo danh:** thêm lý do IMPERSONATION với câu hỏi "Ai đang bị mạo danh?" (tôi / người tôi biết / người nổi tiếng hoặc nhãn hàng). Báo cáo này vào hàng đợi ưu tiên. Quản trị viên xác nhận thì khóa tài khoản giả và báo người báo cáo; không phải thì bác bỏ và báo lại.
5. Trên trang cá nhân của tài khoản có tick, mục "Giới thiệu" hiện ngày xác minh và loại tài khoản; người khác bấm vào dấu tick thấy giải thích ngắn.

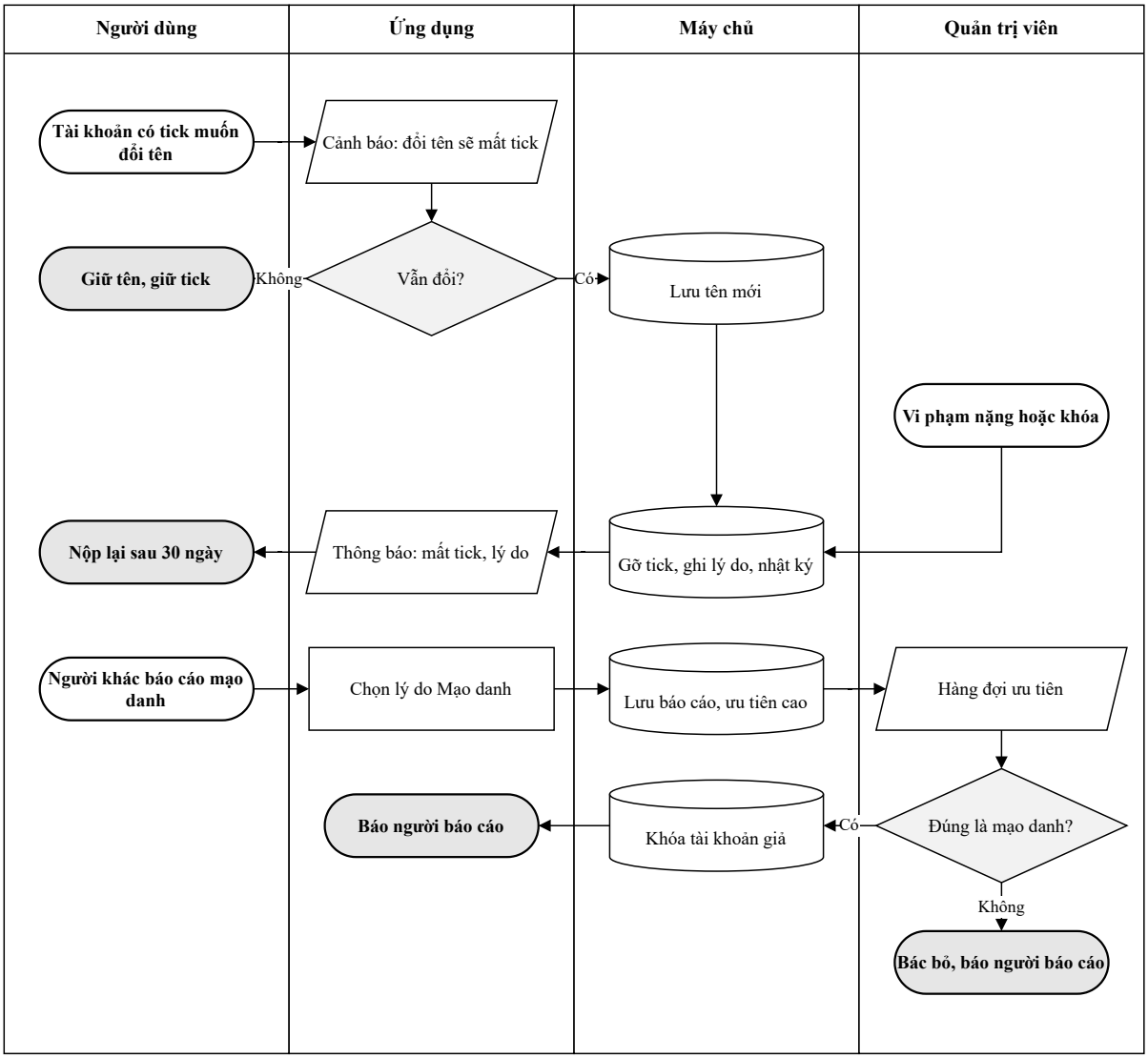
d) Flowchart

Sơ đồ 1: nộp đơn và quản trị viên duyệt.



Hình 74. Nộp đơn và duyệt xác minh tài khoản

Sơ đồ 2: mất dấu tick khi đổi tên hoặc vi phạm, và xử lý báo cáo mạo danh.



Hình 75. Mất dấu tick và xử lý báo cáo mạo danh

e) Quy tắc, giới hạn và trường hợp đặc biệt

- **Số liệu đề xuất:** 1 đơn đang chờ mỗi tài khoản; nộp lại sau 30 ngày khi bị từ chối hoặc mất tick do đổi tên, 90 ngày khi mất do vi phạm; ảnh giấy tờ tối đa 3 ảnh, mỗi ảnh ≤ 5 MB, JPEG/PNG/WebP (cùng quy tắc với ảnh đại diện); duyệt trong 7 ngày.
- **Không bán tick.** Dấu tick không trả phí; nếu sau này có gói trả phí thì phải là biểu tượng khác để không lẫn nghĩa (chủ dự án quyết).
- **Giấy tờ tùy thân là dữ liệu nhạy cảm:** chỉ lưu ở bucket riêng tư, chỉ quản trị viên được quyền xem, mỗi lần xem ghi nhật ký, xóa sau 30 ngày. Không đưa vào bản xuất dữ liệu (E1) ngoài trạng thái đơn. Cách thu thập, căn cứ xử lý và thời gian giữ giấy tờ phải được luật sư xác nhận theo luật bảo vệ dữ liệu cá nhân.

- **Tài khoản có tick bị chiếm:** 2FA là điều kiện bắt buộc để giảm rủi ro. Khi có cảnh báo đăng nhập lạ (A3) trên tài khoản có tick, đề xuất tạm ẩn tick tới khi chủ xác nhận.
- **Tài khoản có tick bị xóa (E2):** username được giữ thêm 90 ngày sau khi xóa để không ai lấy ngay.
- **Tài khoản riêng tư** vẫn được tick (cá nhân), nhưng tổ chức nên công khai (đề xuất).
- **Lỗi mạng khi gửi đơn:** ảnh và đơn gửi trong một yêu cầu; lỗi thì app giữ dữ liệu đã điền và cho gửi lại; máy chủ không tạo đơn trùng khi đã có đơn PENDING.
- **Lạm dụng báo cáo mạo danh** (báo cáo hàng loạt để hạ tài khoản thật): báo cáo không tự gỡ tick; chỉ quản trị viên quyết.

f) Dữ liệu và API (đề xuất)

Đây là đề xuất, cần đưa vào *docs/api-contract.md* và ghi vào *docs/decisions.md* (thêm trường vào *authorSelect* ảnh hưởng mọi màn) trước khi code.

Bảng / trường	**Ý nghĩa**
User.verifiedAt DateTime?, verifiedType String? (PERSON | ORGANIZATION)	Có tick hay không; *authorSelect* thêm hai trường này, DTO trả *isVerified*.
VerificationRequest: id, userId, type, category, legalName, links String[], note, documentKeys String[], status (PENDING | APPROVED | REJECTED | CANCELLED), rejectReason, reviewedById, reviewedAt, documentsPurgedAt, createdAt	Đơn xác minh. Chỉ mục (status, createdAt), (userId, createdAt).
VerificationEvent: userId, action (GRANTED | REVOKED), reason, actorId, createdAt	Lịch sử cấp và gỡ tick (hoặc dùng bảng nhật ký của C3).
CreateReportDto.reason thêm IMPERSONATION; Report thêm impersonatedKind String?	Báo cáo mạo danh.
Notification.actorId (đang bắt buộc)	Thông báo hệ thống ("đã được xác minh", "mất tick") không có người gây ra. Đề xuất cho actorId được để trống và app hiện biểu tượng hệ thống; nếu chưa đổi thì chỉ gửi push qua *pushToUser*, không tạo dòng Notification.

Endpoint	**Mô tả**

GET /users/me/verification	Điều kiện còn thiếu, đơn gần nhất, ngày được nộp lại.
POST /users/me/verification (multipart: các trường + documents[])	Tạo đơn. Lỗi: 403 code *VERIFICATION_NOT_ELIGIBLE* kèm danh sách thiếu; 409 đã có đơn; 429 chưa đủ 30 ngày.
DELETE /users/me/verification	Rút đơn đang chờ.
GET /admin/verifications?status=	Hàng đợi; ảnh giấy tờ trả bằng link ký 1 giờ.
POST /admin/verifications/:id/approve, /reject { reason }	Duyệt, từ chối.
DELETE /admin/users/:id/verification { reason }	Gỡ tick thủ công.
PATCH /users/me (đổi hành vi)	Tài khoản có tick đổi username/displayName: gỡ tick; cần thêm *confirmLoseVerification: true*, thiếu thì trả 409 code *VERIFICATION_WILL_BE_LOST* để app hiện cảnh báo.

g) Android, iOS và web

- **Chọn ảnh giấy tờ:** dùng *expo-image-picker* đã cài, chọn từ thư viện ảnh; quyền thư viện ảnh đã khai trong *app.json* cho cả hai nền tảng. Nếu muốn cho chụp trực tiếp bằng camera thì phải thêm *cameraPermission* vào cấu hình plugin (iOS: NSCameraUsageDescription; Android: CAMERA) trong cùng thay đổi, rồi build lại bản native.
- **Dấu tick:** biểu tượng Lucide *badge-check* (đã có gói *lucide-react-native*), đặt cạnh tên trong một thành phần dùng chung; có nhãn trợ năng "Tài khoản đã xác minh" cho VoiceOver (iOS) và TalkBack (Android). Kích thước theo cỡ chữ để không lệch dòng trên cả hai nền tảng.
- **Trang quản trị:** thêm tab trong *admin.html* (web), không cần app.
- **Chi phí:** không có dịch vụ ngoài; tốn thời gian người duyệt. Không dùng dịch vụ eKYC (xác minh danh tính tự động) ở giai đoạn này; nếu lượng đơn lớn có thể cân nhắc, có phí theo lượt.
- **Cửa hàng:** không có yêu cầu riêng; mục An toàn dữ liệu (Google Play) và nhãn quyền riêng tư (Apple) phải khai việc thu thập giấy tờ tùy thân.

h) Tiêu chí hoàn thành

- Tài khoản thiếu điều kiện thấy đúng danh sách điều còn thiếu; tài khoản đủ điều kiện nộp được đơn kèm ảnh.

- Quản trị viên xem ảnh bằng link có hạn, duyệt và từ chối được; mỗi thao tác được ghi lại.
- Duyệt xong, dấu tick hiện ở trang cá nhân, bảng tin, bình luận, tìm kiếm, tin nhắn.
- Đổi username hoặc tên hiển thị trên tài khoản có tick thì có cảnh báo và mất tick; đổi ảnh, tiểu sử thì không.
- Đặt username trùng (sau chuẩn hóa) với tài khoản có tick bị từ chối; tên hiển thị có ký tự ✓ bị từ chối (có test tự động).
- Báo cáo mạo danh vào hàng đợi ưu tiên; xử lý xong người báo cáo nhận kết quả.
- Ảnh giấy tờ bị xóa khỏi kho 30 ngày sau quyết định.
- Chạy luồng nộp đơn và hiển thị tick trên Android và trên iPhone; báo cáo ghi rõ nền tảng đã chạy.

i) Ước lượng và phụ thuộc

- Backend 4 ngày (trường, bảng đơn, endpoint, kiểm tra tên khi đăng ký/đổi tên, báo cáo mạo danh, tab quản trị, việc xóa ảnh); mobile 2,5 ngày (màn điều kiện và mẫu đơn, trạng thái, dấu tick ở mọi nơi hiện tên, cảnh báo đổi tên); kiểm thử 1,5 ngày.
- Phụ thuộc: A1 (2FA là điều kiện), C2 (bậc xử phạt để gỡ tick), C3 (phân quyền người duyệt, nhật ký xem giấy tờ). Có thể làm bản đầu chỉ với vai trò ADMIN hiện có nếu C3 chưa xong.
- Rủi ro: duyệt sai (cấp tick cho tài khoản giả) làm mất uy tín cả hệ thống; giữ giấy tờ tùy thân là trách nhiệm pháp lý; quy tắc chuẩn hóa tên quá chặt sẽ chặn nhầm người dùng thật.

VI. RỦI RO, PHÁP LÝ VÀ CHI PHÍ

1. Pháp lý (cần luật sư xác nhận trước khi chốt)

Phần này chỉ nêu những chỗ cần hỏi, không phải ý kiến pháp lý.

- **Nghị định 147/2024/NĐ-CP về quản lý dịch vụ Internet và thông tin trên mạng.** Theo hiểu biết của nhóm, nghị định yêu cầu mạng xã hội xác thực tài khoản bằng số điện thoại Việt Nam (hoặc số định danh), có thủ tục đăng ký hoặc cấp phép, và phải gỡ nội dung vi phạm trong thời hạn ngắn khi có yêu cầu. Câu trả lời quyết định A5 thuộc GĐ1 hay GĐ4, và nhắn ẩn danh (B2) được thiết kế tới đâu.
- **Bảo vệ dữ liệu cá nhân.** Sản phẩm lưu ngày sinh, tin nhắn, ảnh, thiết bị và địa chỉ IP. Cần xác nhận nghĩa vụ về đồng ý, quyền tải và xóa dữ liệu (E1, E2), thời gian lưu nhật ký (C3), và việc lưu dữ liệu ở máy chủ nước ngoài (Supabase, kho tệp đặt tại Singapore).
- **Nhắn ẩn danh và nội dung người dùng tạo ra.** Khi có yêu cầu của cơ quan chức năng, sản phẩm phải biết danh tính thật của người gửi ẩn danh; thiết kế hiện tại đã lưu danh tính thật (chỉ che với người nhận), cần luật sư xác nhận cách lưu và cách cung cấp.

2. Yêu cầu của App Store và Google Play

- App có nội dung người dùng tạo ra phải có báo cáo, chặn, lọc nội dung và xử lý báo cáo kịp thời (đã có một phần; C1, C2, B7 làm đầy đủ).
- Có đăng nhập bằng bên thứ ba (Google) trên iOS thì phải có Đăng nhập bằng Apple (A6).
- Phải xóa được tài khoản trong app, và Google Play yêu cầu thêm một trang web để yêu cầu xóa mà không cần cài app (E2).
- Phải có đường dẫn công khai tới chính sách quyền riêng tư, khai báo dữ liệu thu thập (Data Safety, App Privacy) và phân loại độ tuổi 18+.
- Gọi thoại và video (D4) trên iOS cần CallKit và VoIP push; Apple kiểm tra chặt việc dùng VoIP push đúng mục đích.

3. Lỗi đang có trong code, phát hiện khi lập kế hoạch

Khi đọc code để viết mục "Hiện trạng", nhóm lập kế hoạch thấy một số lỗi **đang tồn tại**, không phụ thuộc tính năng mới. Các lỗi này nên sửa trước GĐ1, vì vài lỗi trong số

đó làm lộ nội dung hoặc làm mất dữ liệu của người khác. Tất cả đều mới được thấy khi đọc code, chưa được chạy lại để xác nhận.

#	**Lỗi**	**Mục liên quan**
1	Thông báo đẩy của tin nhắn chờ hiện cả nội dung tin ("[Tin nhắn chờ] …"), nên tin lừa đảo hiện ngay trên màn hình khóa, dù hộp thư cố ý ẩn nội dung đó.	B1, D8
2	Người nhận đã bấm "Xóa" tin nhắn chờ, nhưng người gửi nhắn tiếp thì người nhận vẫn nhận thông báo đẩy và sự kiện thời gian thực.	B1
3	Tắt "Nhận tin nhắn ẩn danh" không chặn tin mới trong các cuộc trò chuyện ẩn danh đã mở từ trước, cũng không chặn trả lời story ẩn danh.	B2
4	Bài viết của tài khoản bị khóa vẫn hiện trên bảng tin, Reels và kết quả tìm kiếm. Tài khoản bị khóa vì chưa đủ tuổi vẫn hiện khi tìm người.	B6, C2, D5
5	Người được nhắc tên trong bài chỉ dành cho bạn bè vẫn nhận thông báo, dù không xem được bài (bấm vào thì báo lỗi không tìm thấy).	D6
6	Trang quản trị trả về danh tính thật của người nhắn ẩn danh và bản chụp cuộc trò chuyện mà không ghi lại ai đã xem.	C1, C3
7	Xóa tài khoản làm người kia mất luôn cả cuộc trò chuyện, xóa các báo cáo mà người đó đã gửi, và xóa ảnh bằng chứng trong báo cáo về người đó.	E2
8	Gỡ bình luận vi phạm là xóa hẳn, nên không khôi phục được nếu người viết kháng nghị thành công.	C1, C2
9	Ghi nhận tương tác Reels không kiểm tra người gửi có được xem bài đó không.	D5
10	Tin nhắn đang chờ gửi chỉ nằm trong bộ nhớ của màn hình chat: rời màn hình hoặc tắt app là mất.	D2
11	Đổi hoặc đặt lại mật khẩu không đăng xuất các thiết bị khác và không gửi email báo; đăng xuất không có tác dụng gì ở máy chủ (phiên vẫn dùng được tới hết 30 ngày).	A2
12	Khi đăng nhập bằng email chưa đăng ký, máy chủ trả lời nhanh hơn hẳn, nên người ngoài đo thời gian là biết email nào đã có tài khoản.	A4

4. Quyết định kỹ thuật dùng chung

Nhiều tính năng cùng cần một số nền tảng mà hiện chưa có. Mỗi điểm dưới đây nên được quyết một lần, ghi vào *docs/decisions.md* và thống nhất với người phụ trách backend, thay vì để từng tính năng tự làm một kiểu.

1. **Việc nền chạy định kỳ.** Đóng bình chọn, dọn story và tin thu hồi, xóa tài khoản sau 30 ngày, tạo tệp tải dữ liệu, gửi lời nhắc đều cần một bộ chạy việc theo lịch. Đề xuất: dùng thư viện *@nestjs/schedule*, kèm khóa trong PostgreSQL để chỉ một tiến trình chạy mỗi việc. Không để mỗi tính năng tự dùng *setInterval* riêng.
2. **Chạy một hay nhiều bản API.** Danh sách tài khoản bị khóa, giới hạn tần suất, kết nối Socket.IO, việc gộp thông báo và bộ quét nội dung hiện đều nằm trong bộ nhớ của một tiến trình. Kế hoạch giả định **chỉ chạy một bản API**; khi cần nhiều bản thì phải thêm Redis cho tất cả các phần này cùng lúc.
3. **Hội thoại nhiều người.** Bảng hội thoại hiện chỉ chứa đúng hai người. Nhắn tin nhóm (D1) cần thêm bảng thành viên và sửa lại toàn bộ luồng 1-1 hiện có. Đây là thay đổi lớn nhất về dữ liệu trong kế hoạch.
4. **Xóa tài khoản kiểu "bia mộ".** Thay vì xóa dây chuyền mọi thứ liên quan, giữ lại một bản ghi người dùng đã xóa hết thông tin cá nhân, để tin nhắn trong nhóm, báo cáo và nhật ký vẫn còn nguyên (E2, D1, C1).
5. **Thông báo do hệ thống gửi.** Hiện mỗi thông báo bắt buộc phải có một người gây ra, nên không gửi được các thông báo như "tệp dữ liệu đã sẵn sàng" hay "bạn bị cảnh cáo". Cần cho phép thông báo không có người gây ra.
6. **Một hàm duy nhất quyết định ai được xem gì.** Bài riêng tư, bạn thân, nhóm kín, tài khoản bị khóa, người bị chặn, hạn chế và tắt tiếng phải được kiểm tra ở cùng một chỗ, dùng chung cho bảng tin, Reels, tìm kiếm, thông báo và socket. Lỗi số 4, 5 và 9 ở trên đều do kiểm tra rải rác ở nhiều nơi.
7. **Bản development thay cho Expo Go.** Thông báo đẩy, Đăng nhập bằng Apple, ghi âm, gọi điện và chụp ảnh giấy tờ đều cần bản build riêng (EAS Build) và khai báo quyền trong *app.json*; Expo Go không đủ. Nên chuyển sang bản development ngay từ GĐ1.
8. **Thư viện mới.** Kế hoạch đề xuất thêm một số thư viện: *@nestjs/schedule*, *archiver*, *@aws-sdk/lib-storage*, ffmpeg ở máy chủ, *expo-audio*, thư viện WebRTC và CallKit cho gọi điện, và thư viện cho Đăng nhập bằng Apple. Mỗi thư viện phải được kiểm tra hỗ trợ Android, iOS và Expo SDK 57 trước khi cài, và được ghi vào *docs/decisions.md*.

5. Rủi ro kỹ thuật và vận hành theo tính năng

Rủi ro riêng của từng tính năng, do người viết đặc tả nêu ra; chi tiết và cách giảm rủi ro nằm ở phần i) của tính năng đó.

Mã	Rủi ro chính

A1	Khôi phục qua hỗ trợ dễ bị lừa nếu quy trình xác minh lỏng; Mã email dự phòng làm yếu 2FA khi email bị chiếm; App cũ không hiểu phản hồi twoFactorRequired.
A2	Lỗi làm mới token đăng xuất hàng loạt người dùng; Chuyển đổi từ token 30 ngày của app cũ; Phải cập nhật quyết định DEC-008.
A3	Vị trí theo IP sai gây cảnh báo nhầm; Email cảnh báo vào thư rác nếu thiếu SPF/DKIM; Notification.actorId đang bắt buộc.
A4	Ngưỡng theo IP chặn oan người dùng chung mạng (CGNAT); IP lấy sai nếu cấu hình proxy khác trust proxy = 1; Throttler hiện lưu trong bộ nhớ, sai khi chạy nhiều bản API.
A5	GĐ1 chỉ khi luật sư xác nhận Nghị định 147/2024 bắt buộc, nếu không thì GĐ4; Chi phí SMS và lạm dụng gửi SMS; Đăng ký brandname mất 1-4 tuần; Giảm tỉ lệ đăng ký.
A6	Không có iPhone thật để thử; Người dùng ẩn email không nhận được OTP nếu chưa đăng ký tên miền gửi thư với Apple; Không có đăng nhập Apple gốc trên Android.
B1	Lọc nhầm tin thật vào thư mục Đã lọc; Đổi mặc định quyền nhắn tin làm khó kết bạn mới; Sửa lỗi đẩy thông báo cho tin chờ đã xóa và lộ nội dung tin chờ trên màn hình khóa.
B2	Hạn mức quá chặt hoặc quá lỏng; App Review hỏi kỹ ứng dụng có nhắn ẩn danh; Nghĩa vụ xác thực tài khoản theo Nghị định 147/2024 cần luật sư xác nhận; Mục tự tạo trong hàng chờ cần tài khoản hệ thống nếu C1 chưa có.
B3	Cảnh báo nhầm với người bán hàng online; Kẻ gian đổi cách viết để lách danh sách cụm từ; Link gửi sang Google phải ghi trong chính sách quyền riêng tư.
B4	Ngưỡng đột biến tuyệt đối không hợp tài khoản rất lớn; Truy vấn đếm sau mỗi bình luận cần kiểm tra hiệu năng; Phải thống nhất cờ ẩn bình luận với B7 và B8.
B5	Mô hình làm mờ nhầm ảnh hở da; giữ nhầm bài ở ngưỡng 0,9 cần đo trước; CPU máy chủ tăng (0,5–0,7 giây mỗi ảnh, 3–5 khung mỗi video); Mô hình chỉ nhận diện khỏa thân/gợi dục, không nhận diện bạo lực hay xâm hại trẻ em; Khác đề xuất C1 về quét trước/sau khi hiện và khi thiếu mô hình: cần chủ dự án chọn.
B6	Lưu ảnh giấy tờ tùy thân và dữ liệu sinh trắc (Nghị định 13/2023, Luật BVDLCN); Báo cáo sai để quấy rối; Người dưới 18 dùng giấy tờ người khác; Thời hạn xóa tài khoản và giữ dữ liệu cần luật sư xác nhận.
B7	Chặn nhầm vì tiếng Việt bỏ dấu dễ trùng từ; Người dùng lách bằng cách viết khác; danh sách từ cần cập nhật thường xuyên; Danh sách từ nặng/nhẹ phải do người soạn và duyệt trước khi kiểm thử.
B8	Lộ việc bị hạn chế qua chi tiết nhỏ trong phản hồi API (số đếm, đã xem); Hộp thư xếp theo từng người xem làm truy vấn phức tạp hơn; Cần thống nhất với B1 (tin nhắn chờ) và D8 (cài đặt thông báo).

C1	Ẩn nhầm do nhiều người hùa nhau báo cáo (giảm bằng điều kiện tài khoản báo cáo); Mô hình ảnh chặt tay làm hàng đợi P2 đông; Cần người trực để giữ SLA P0 1 giờ ngoài giờ hành chính; Tiến trình quét chạy trong một tiến trình API; nhiều bản API cần khóa hàng hoặc Redis (quyết định kiến trúc); Quy trình xử lý nội dung xâm hại trẻ em và thời hạn gỡ theo Nghị định 147/2024 cần luật sư xác nhận.
C2	Danh sách điều khoản và số điểm là quyết định chính sách của chủ dự án; Đội nhỏ khó bảo đảm người duyệt kháng nghị khác người ra quyết định; Danh sách khóa trong bộ nhớ một tiến trình phải thêm ngày hết hạn; nhiều bản API cần Redis hoặc kiểm tra database; Thời hạn lưu lịch sử vi phạm cần luật sư xác nhận.
C3	C3 ở GĐ3 nhưng C1 ở GĐ1 đã mở rộng việc xem danh tính thật; đề xuất làm sớm nhật ký và bước xem kèm lý do; Bỏ quyền UPDATE/DELETE trên bảng nhật ký là thay đổi cấu hình database Supabase, phải phối hợp backend; Thời hạn lưu nhật ký cần luật sư xác nhận.
D1	Conversation hiện chỉ cho 2 người (userAId/userBId): cần migration thêm bảng ConversationMember và sửa lại toàn bộ luồng 1-1 (đọc, chưa đọc, socket, báo cáo); Message.sender onDelete Cascade: xóa tài khoản sẽ xóa tin của người đó trong nhóm; ChatScreen đã 990 dòng, cần tách thành phần trước khi thêm nhóm.
D2	Sửa tin phải chạy lại luật chặn link/số điện thoại, nếu không người lạ lách được luật tin nhắn chờ; Video và tin thoại không được quét nội dung (chỉ quét ảnh bìa video); Định dạng âm thanh ghi trên Android và iOS có thể khác MIME, cần thử chéo sớm; Chi phí kho tệp tăng theo video 30 MB/tin.
D3	Lộ bài nhóm kín nếu có truy vấn bài viết không đi qua visiblePostWhere; Khối lượng kiểm duyệt tăng mạnh; Quản trị nhóm là người dùng thường, có thể lạm quyền.
D4	Thư viện native cộng đồng (WebRTC, CallKeep, PushKit) cần kiểm tra tương thích React Native 0.86, Expo SDK 57, kiến trúc mới; iOS ngừng gửi push VoIP nếu app không báo CallKit ngay; FCM bị chặn trên điện thoại Android tiết kiệm pin mạnh; Google Play yêu cầu khai báo thông báo toàn màn hình và dịch vụ nền; Chi phí TURN tăng theo số giờ gọi video.
D5	Ít dữ liệu tương tác khi còn ít người dùng, trọng số phải chỉnh sau khi có số liệu thật; Đổi phân trang page sang cursor phải giữ tương thích app cũ; Bật bài gợi ý ngoài người theo dõi là thay đổi quyết định DEC-023, cần chủ dự án duyệt.
D6	Chưa có bộ chạy tác vụ định kỳ: đóng bình chọn dùng setInterval + khóa PostgreSQL; Thêm trường vào Post có thể làm hỏng postMapper của app cũ nếu không để tùy chọn; Gắn thẻ có thể bị dùng để quấy rối nếu thiếu giới hạn và bước duyệt.
D7	Quên áp điều kiện Bạn thân ở một API là lộ story; phải gom về một hàm kiểm tra quyền; Dung lượng kho tăng vì story được lưu trữ.
D8	Push chưa từng chạy thử; thiết lập chứng chỉ thường mất thời gian hơn code; iOS chỉ thử được trên máy thật với development build; Gộp và giới hạn trong bộ nhớ một tiến trình sẽ sai khi chạy nhiều bản API.

D9	Tìm chuỗi con trong bảng tin nhắn chậm nếu thiếu chỉ mục pg_trgm; Ô nhập có gợi ý @ dễ lỗi với bộ gõ tiếng Việt Telex; Nếu sau này mã hóa đầu cuối thì tìm tin nhắn phải chuyển xuống máy.
E1	Tệp rất lớn làm việc nền lâu, tốn băng thông; Che sai làm lộ danh tính người gửi ẩn danh; Bảng mới thêm sau này bị bỏ sót khỏi bản xuất; Thời hạn phản hồi theo luật chưa được luật sư xác nhận.
E2	Bỏ sót chỗ hiển thị khiến tài khoản chờ xóa vẫn lộ ra; Đổi từ Cascade sang bia mộ chạm nhiều bảng; Danh sách dữ liệu giữ lại và thời hạn chưa được luật sư chốt; Google Play từ chối nếu thiếu trang web.
E3	Ít giá trị nếu làm trước A1 và B1 (chỉ 2–3 lựa chọn); Lời nhắc dày gây phiền.
E4	Cấp tick nhầm cho tài khoản giả; Lưu giấy tờ tùy thân là trách nhiệm pháp lý; Chuẩn hóa tên quá chặt chặn nhầm người thật.

6. Dịch vụ bên ngoài và chi phí phát sinh

Chi phí chạy hằng tháng của bản thật (máy chủ, cơ sở dữ liệu, kho tệp, email) đã được ước lượng riêng ở mức khoảng 30–50 USD mỗi tháng lúc đầu. Bảng dưới chỉ liệt kê những gì **kế hoạch này thêm vào**; giá là tham khảo, cần kiểm tra lại khi chọn nhà cung cấp.

Dịch vụ	**Dùng cho**	**Chi phí tham khảo (cần kiểm tra lại)**
Apple Developer Program	A6, D4, D8, phát hành iOS	99 USD mỗi năm. Bắt buộc để có khóa thông báo đẩy APNs và Đăng nhập bằng Apple.
Firebase Cloud Messaging	D8, D4	Miễn phí. Cần một dự án Firebase và tệp *google-services.json*.
Expo EAS (Build, thông báo đẩy)	D8, D4, phát hành	Có gói miễn phí giới hạn số lượt build mỗi tháng; cần kiểm tra giới hạn hiện tại.
Nhà cung cấp SMS OTP	A5	Tính theo tin nhắn, cộng thủ tục đăng ký tên thương hiệu với nhà mạng (1–4 tuần). Cần báo giá thật.
Google Web Risk (kiểm tra đường link)	B3	Trả phí sau hạn mức miễn phí mỗi tháng; chưa kiểm tra giá. Bản Safe Browsing miễn phí chỉ dùng cho mục đích phi thương mại.
Cơ sở dữ liệu vị trí theo IP (GeoIP)	A3	Có bản miễn phí cần đăng ký và cập nhật định kỳ.
Dịch vụ xác minh tuổi hoặc danh tính (eKYC)	B6, E4 (tùy chọn)	Tính theo lượt xác minh; chỉ cần khi chọn cách xác minh tự động.

Máy chủ TURN	D4	Tính theo dung lượng gọi video chuyển qua: khoảng 0,05 USD/GB (Cloudflare) đến 0,40 USD/GB (Twilio), hoặc tự chạy coturn.
Dịch vụ gọi có sẵn (Stream, Agora, LiveKit)	D4 (thay cho tự làm)	Tính theo phút gọi; rút ngắn công sức D4 còn khoảng 15–18 ngày.
Cloudflare Turnstile (chống bot)	E2	Miễn phí.
Dung lượng kho tệp tăng thêm	D2, D7, E1	Video và tin thoại trong tin nhắn, story được lưu trữ, tệp tải dữ liệu giữ 7 ngày. Tính theo GB lưu trữ.

7. Rủi ro về nguồn lực

- **Kiểm duyệt cần người thật.** Hàng đợi kiểm duyệt (C1) chỉ có ích khi có người duyệt hằng ngày. Cần quyết định ai trực, trong giờ nào, và thời hạn xử lý mục tiêu trước khi mở đăng ký công khai.
- **Khối lượng lớn so với nhóm nhỏ.** Tổng ngày công ở mục IV là cho một người đã quen code. Nên khóa phạm vi từng giai đoạn và không thêm tính năng giữa chừng.
- **Chưa từng chạy trên iPhone.** Mọi tính năng hiện có mới chạy trên Android. Cần có máy iPhone (hoặc máy Mac để chạy giả lập iOS) ngay từ GĐ1, vì các phần native (thông báo đẩy, Đăng nhập bằng Apple, gọi điện) chỉ kiểm tra được trên thiết bị thật.

VII. CÂU HỎI CẦN CHỦ DỰ ÁN QUYẾT

Các câu hỏi dưới đây được gộp từ phần đặc tả của từng tính năng. Mỗi câu có sẵn một đề xuất, để chủ dự án chỉ cần đồng ý hoặc chọn cách khác. Quyết định nào ảnh hưởng tới người khác thì ghi vào *docs/decisions.md* trước khi bắt đầu giai đoạn có tính năng đó.

1. Cần quyết trước khi bắt đầu GĐ1

#	Câu hỏi	Đề xuất	Mục
1	Sửa 12 lỗi đang có (mục VI.3) ngay hay đợi làm cùng tính năng?	Sửa ngay, trước GĐ1; ưu tiên lỗi 1, 2, 3, 6 và 7 vì làm lộ nội dung hoặc mất dữ liệu của người khác.	VI.3
2	Nhật ký thao tác và bước "xem danh tính thật phải ghi lý do" đang nằm ở C3 (GĐ3), trong khi C1 (GĐ1) đã cho người duyệt xem danh tính thật.	Chuyển phần này lên làm cùng C1 (thêm khoảng 2 ngày).	C1, C3

3	Có làm Đăng nhập bằng Apple, hay ẩn nút Google trên iOS để khỏi bắt buộc?	Làm Đăng nhập bằng Apple; người dùng Apple đặt mật khẩu để đăng nhập trên Android.	A6
4	Thông báo đẩy của tin nhắn chờ và tin ẩn danh có hiện nội dung không?	Không. Chỉ hiện "Bạn có tin nhắn chờ mới".	B1, D8
5	Quét ảnh và video trước hay sau khi hiện cho người khác? Khi mô hình nhận diện ảnh hỏng thì làm gì?	Ảnh quét trước khi lưu (chậm thêm khoảng 3 giây); video và story ẩn với người khác cho tới khi quét xong. Mô hình hỏng thì xếp hàng quét lại, chỉ nội dung bị báo cáo mới vào hàng đợi người duyệt.	B5, C1
6	Xóa tài khoản: tin nhắn của người đã xóa xử lý thế nào? Phương án hiện tại xóa luôn cả cuộc trò chuyện của người kia.	Giữ cuộc trò chuyện, xóa chữ và ảnh của người đã xóa, hiện "Người dùng đã xóa". Áp dụng cả cho nhóm chat.	E2, D1
7	Ai trực kiểm duyệt, trong giờ nào, và thời hạn xử lý mục tiêu là bao lâu?	Đề xuất thời hạn 1 giờ / 4 giờ / 24 giờ / 72 giờ theo bốn mức nghiêm trọng; cần chỉ định người trực trước khi mở đăng ký công khai.	C1
8	Ai giữ tài khoản Apple Developer, dự án Firebase, dự án EAS và tên miền? Có máy iPhone để thử không?	Một người chịu trách nhiệm tất cả các tài khoản này; cần ít nhất một iPhone thật từ GĐ1.	A6, D8, E2
9	Năm quyết định kỹ thuật dùng chung ở mục VI.4 (việc nền, một bản API, xóa kiểu bia mộ, thông báo hệ thống, hàm quyền xem dùng chung).	Đồng ý cả năm, ghi vào *docs/decisions.md* và thống nhất với người phụ trách backend.	VI.4

2. Cần luật sư trả lời

#	**Câu hỏi**	**Ảnh hưởng tới**	**Mục**
10	Nghị định 147/2024 có áp dụng cho sản phẩm không: bắt buộc xác thực số điện thoại, giấy phép mạng xã hội, thời hạn gỡ nội dung, tài khoản cũ được bao lâu để bổ sung, người dùng nước ngoài?	A5 thuộc GĐ1 hay GĐ4; nhắn ẩn danh được làm tới đâu; thời hạn xử lý trong hàng đợi.	A5, B2, C1
11	Thời hạn lưu báo cáo, bằng chứng, nhật ký thao tác và lịch sử vi phạm. Đề xuất hiện tại: 12 tháng sau khi xử lý xong, nhật ký 2 năm.	Thiết kế xóa dữ liệu, dung lượng lưu trữ.	C1, C2, C3, E2

12	Có được thu và lưu ảnh giấy tờ tùy thân, dữ liệu khuôn mặt để xác minh tuổi và cấp dấu tick không; lưu bao lâu (đề xuất xóa sau 30 ngày)?	Cách xác minh tuổi khi kháng nghị và cách duyệt dấu tick.	B6, E4
13	Quy trình khi phát hiện nội dung xâm hại trẻ em: báo cơ quan nào, giữ hay xóa tệp, có cần công cụ đối chiếu như PhotoDNA không?	Hàng đợi kiểm duyệt mức nghiêm trọng nhất.	C1
14	Thời hạn phản hồi yêu cầu tải và xóa dữ liệu cá nhân theo quy định bảo vệ dữ liệu cá nhân hiện hành.	Thời gian chờ của E1 và E2.	E1, E2

3. Các con số cần duyệt

Tất cả là đề xuất; nên duyệt một lần trước GĐ tương ứng, rồi chỉnh theo số liệu thật sau khi có người dùng.

Mảng	**Con số đề xuất**	**Mục**
Phiên đăng nhập	Mã truy cập sống 15 phút; phiên hết hạn sau 60 ngày không dùng, tối đa 1 năm; phiên mới dưới 24 giờ không được đăng xuất phiên cũ nếu không nhập mật khẩu.	A2
Chống dò mật khẩu	Chờ tăng dần từ lần sai thứ 5, khóa 15 phút ở lần thứ 10; tối đa 50 lần sai mỗi giờ cho một địa chỉ IP.	A4
Tin nhắn chờ và ẩn danh	20 cuộc trò chuyện mới mỗi ngày (5 với tài khoản mới); 30 tin ẩn danh mỗi ngày; ngưỡng điểm lạm dụng 30 và 60.	B1, B2
Giới hạn tạm thời	Gợi ý bật khi có 20 bình luận từ 10 người lạ trong 60 phút.	B4
Làm mờ ảnh	Điểm 0,7 trở lên thì làm mờ, 0,9 trở lên thì giữ chờ duyệt. Cần đo trên một bộ ảnh mẫu trước khi chốt.	B5
Hàng đợi kiểm duyệt	Tự ẩn sau 1 báo cáo về an toàn trẻ em, 3 người khác nhau báo lừa đảo hoặc bạo lực, 5 người với lý do khác.	C1
Xử phạt	Điểm vi phạm 1 / 2 / 3 theo mức độ, hết hạn sau 90 ngày; cảnh cáo → hạn chế 7 ngày → khóa 7 ngày → khóa 30 ngày → khóa vĩnh viễn; kháng nghị trong 30 ngày.	C2
Tin nhắn nâng cao	Thu hồi trong 24 giờ; sửa trong 15 phút, tối đa 5 lần; giữ tin đã thu hồi 30 ngày để phục vụ báo cáo.	D2
Bảng tin	Độ mới ×4, mức thân với tác giả ×3, lượt tương tác ×1; bị đẩy xuống khi có 3 báo cáo đang mở, ẩn với người khác khi có 10.	D5
Bài viết và story	Tối đa 20 lần sửa, 20 người được gắn thẻ, 3 bài ghim; 500 bạn thân, 50 nhóm tin nổi bật mỗi nhóm 100 story.	D6, D7

Thông báo	Gộp các thông báo cùng một bài trong 15 phút.	D8

4. Lựa chọn sản phẩm (quyết trước giai đoạn tương ứng)

#	Câu hỏi	Đề xuất	Mục
15	Mã qua email có được dùng làm cách dự phòng cho 2FA không? Khi mất cả điện thoại lẫn mã dự phòng thì khôi phục thế nào?	Cho dùng nhưng cảnh báo là kém an toàn hơn; khôi phục qua quản trị viên xác minh, có thời gian chờ 7 ngày.	A1
16	Mặc định "Ai được nhắn tin cho tôi"; ai được gửi tin ẩn danh cho tôi?	Mặc định "Mọi người" (người lạ vào tin nhắn chờ); tin ẩn danh chỉ từ người đã theo dõi mình ít nhất 3 ngày.	B1, B2
17	Người gửi ẩn danh đã tự tiết lộ danh tính thì có được gửi ảnh không?	Có, vì cuộc trò chuyện lúc đó không còn ẩn danh.	B2
18	Có trả phí dịch vụ kiểm tra đường link (Google Web Risk) không?	Có, khi lên store; trước đó dùng danh sách tự soạn.	B3
19	Lấy khung hình video để quét: ở máy chủ bằng ffmpeg hay trên điện thoại?	Ở máy chủ bằng ffmpeg, vì điện thoại có thể bị làm giả kết quả.	B5
20	Cách xác minh tuổi khi người dùng kháng nghị bị khóa vì nghi dưới 18.	Chọn sau khi luật sư trả lời câu 12; tài liệu đã liệt kê năm cách và đánh đổi của từng cách.	B6
21	Người viết bình luận có được biết bình luận của mình đã bị ẩn không? Ai soạn danh sách từ cấm?	Không báo (giống Instagram). Danh sách từ do chủ dự án hoặc kiểm duyệt viên soạn và duyệt trước khi thử.	B7
22	Cách chuyển dữ liệu hội thoại sang nhiều người.	Thêm bảng thành viên dùng chung cho cả hội thoại 1-1 và nhóm.	D1
23	Bài trong nhóm cộng đồng có hiện trên bảng tin chính không? Có cho đăng ẩn danh trong nhóm không?	Bản đầu: không hiện trên bảng tin chính, không cho ẩn danh.	D3
24	Gọi điện: tự làm, dùng dịch vụ có sẵn, hay thử trước?	Thử gọi thoại giữa Android và iPhone trong 2–3 ngày, rồi mới chọn.	D4
25	Bảng tin có gợi ý bài công khai của người mình chưa theo dõi không? (đổi quyết định DEC-023)	Có công tắc, mặc định tắt.	D5
26	Có được trích dẫn bài chỉ dành cho bạn bè không? Gắn thẻ từ người lạ có cần duyệt không? Chủ bình chọn có thấy ai chọn gì không?	Chỉ trích dẫn bài công khai của tài khoản công khai; gắn thẻ từ người mình không theo dõi phải duyệt; bình chọn chỉ hiện số lượng.	D6

27	Lưu trữ story có bật mặc định không?	Có, chỉ chủ story xem được.	D7
28	Lịch sử tìm kiếm lưu ở đâu? Có thêm tiện ích PostgreSQL *unaccent* và *pg_trgm* (tìm không dấu, tìm nhanh) không?	Lưu trên máy; thêm cả hai tiện ích, cần người phụ trách backend đồng ý.	D9
29	Dấu tick có miễn phí không? Giấy tờ chụp bằng camera hay chọn từ thư viện ảnh?	Miễn phí; bản đầu chỉ chọn từ thư viện ảnh (khỏi xin thêm quyền camera).	E4
30	Tài khoản bị khóa có được yêu cầu tải dữ liệu của mình không?	Có, qua trang web với xác minh email, giống trang yêu cầu xóa.	E1